Bundesamt
für Sicherheit in der
Informationstechnik

Deutschland
Digital•Sicher•BSI•

Cloud Computing Compliance Criteria Catalogue (C5:2026)

Kriterienkatalog Cloud Computing
Version 1.1.0
Bundesamt für Sicherheit in der Informationstechnik (BSI)

Änderungshistorie

Version	*Datum*	*Beschreibung*
1.0.0	07.04.2026	Erstveröffentlichung
1.1.0	11.08.2026	Korrekturen und redakt. Anpassung

Tabelle 1 Änderungshistorie

Bundesamt für Sicherheit in der Informationstechnik
Postfach 20 03 63
53133 Bonn
Tel.: +49 22899 9582-0
E-Mail: cloudsecurity@bsi.bund.de
Internet: https://www.bsi.bund.de
© Bundesamt für Sicherheit in der Informationstechnik 2026

Dieses Werk ist unter der Creative Commons Attribution-NoDerivatives 4.0 International (CC BY-ND 4.0) lizensiert. Um eine Kopie der Lizenz einzusehen, besuchen Sie https://creativecommons.org/licenses/by-nd/4.0/deed.de .

Inhalt

1 Einführung 10
1.1 Vorbemerkungen 10
1.2 Definitionen 11
1.2.1 Begriffe im Zusammenhang mit Cloud-Sicherheit 11
1.2.2 Begriffe im Zusammenhang mit Prüfungen 16
2 Aufbau und inhaltliche Gliederung der Kriterien 21
2.1 Aufbau 21
2.2 Inhatliche Gliederung der C5-Kriterien 22
2.3 Zugrundeliegende Standards und Publikationen 22
3 Nachweis der Konformität durch unabhängige Prüfungen 26
3.1 Einleitung 26
3.2 Anzuwendende Prüfungsstandards 26
3.3 Verhältnis zu anderen Prüfungen 27
3.4 Ergänzende Anforderungen des BSI 28
3.4.1 Attestierungsauftrag (Assurance Engagement) 28
3.4.2 Qualifikation des Prüfers 28
3.4.3 Anzuwendende Kriterien 29
3.4.4 Prüfungsgegenstand und Ziel der Prüfung 30
3.4.5 Anforderungen an die Systembeschreibung und die Erklärung der gesetzlichen Vertreter 32
3.4.6 Berücksichtigung von Dienstleistungsunternehmen (Service-Organisationen) 34
3.4.7 Erlangung von Prüfevidenzen hinsichtlich der Systembeschreibung 35
3.4.8 Beurteilung der Erfüllung der C5-Kriterien 36
3.4.9 Erlangung von Prüfevidenzen hinsichtlich der Ausgestaltung von Kontrollen 36
3.4.10 Erlangung von Prüfevidenzen hinsichtlich der Wirksamkeit von Kontrollen 37
3.4.11 Erwägungen für Erstaufträge 37
3.4.12 Umgang mit Abweichungen 37
3.4.13 Berichterstattung 38
3.5 Umgang mit Überarbeitungen dieses Kriterienkatalogs 42
4 Angaben zu den Rahmenbedingungen des Cloud-Dienstes 44
GC-01 Angaben zu anwendbarem Recht, Gerichtsbarkeit, Länder, Partitionen, Regionen, Zonen und Standorte 44
GC-02 Angaben zu Verfügbarkeit und Störungsbeseitigung im Regelbetrieb 45
GC-03 Angaben zu Wiederanlaufparametern im Notbetrieb 45
GC-04 Angaben zum Ansatz zur Sicherstellung der Dienstverfügbarkeit 46
GC-05 Angaben zum Umgang mit Untersuchungsanfragen von staatlichen Stellen 47
GC-06 Angaben zu Zertifizierungen oder Bescheinigungen 48
5 Basiskriterien, Zusatzkriterien, Ergänzende Informationen 49

5.1 Organisation der Informationssicherheit (OIS) 49
OIS-01 Informationssicherheitsmanagementsystem (ISMS) 49
OIS-02 Informationssicherheitsrichtlinie 50
OIS-03 Schnittstellen und Abhängigkeiten 51
OIS-04 Aufgabentrennung 52
OIS-05 Threat Intelligence 53
OIS-06 Kontakt zu relevanten Behörden und Interessengruppen 55
OIS-07 Richtlinie für Risikomanagement 55
OIS-08 Anwendung der Richtlinie für Risikomanagement - Risikobeurteilung 56
OIS-09 Anwendung der Richtlinie für Risikomanagement - Risikobehandlung 59
OIS-10 Informationssicherheit im Projektmanagement 60
5.2 Sicherheitsrichtlinien und Arbeitsanweisungen (SP) 61
SP-01 Dokumentation, Kommunikation und Bereitstellung von Richtlinien und Verfahren 61
SP-02 Überprüfung und Freigabe von Richtlinien und Verfahren 63
SP-03 Ausnahmen von bestehenden Richtlinien und Verfahren 64
5.3 Personal (HR) 66
HR-01 Überprüfung der Qualifikation und Vertrauenswürdigkeit 66
HR-02 Beschäftigungs- und Vertragsbedingungen 68
HR-03 Programm zur Sicherheitsausbildung und Sensibilisierung 69
HR-04 Maßregelungsprozess 71
HR-05 Verantwortlichkeiten bei Beendigung oder Änderung der Beschäftigung 72
HR-06 Vertraulichkeitsvereinbarungen 72
HR-07 Remote-Arbeit - Richtlinie 73
HR-08 Remote-Arbeit - Umsetzung 74
5.4 Asset Management (AM) 75
AM-01 Rahmenwerk für Asset Management 75
AM-02 Asset-Inventar 76
AM-03 Hardware-Asset-Inventar 77
AM-04 Software-Asset-Inventar 78
AM-05 Richtlinie für die ordnungsgemäße und sichere Nutzung von Assets 79
AM-06 Inbetriebnahme von Hardware 80
AM-07 Außerbetriebnahme von Hardware 80
AM-08 Verpflichtung zur ordnungsgemäßen Nutzung, sicheren Handhabung und Rückgabe von Assets 82
AM-09 Klassifizierung und Kennzeichnung von Assets 82
AM-10 Schutz von vorübergehend nicht genutzter Hardware 84
AM-11 Transfer von Hardware 85
AM-12 Wechselmedien und Endgeräte 85

5.5 Physische Sicherheit (PS) 87
PS-01 Sicherheitsanforderungen für Gebäude und Räumlichkeiten 87
PS-02 Redundanzmodell 89
PS-03 Perimeterschutz 91
PS-04 Physische Zutrittskontrolle 92
PS-05 Schutz vor Bedrohungen von Außen und aus der Umgebung 93
PS-06 Schutz vor Unterbrechungen durch Stromausfälle und ähnliche Risiken für Versorgungseinrichtungen 95
PS-07 Überwachung der Betriebs- und Umgebungsparameter 97
PS-08 Anforderungen an die Sicherheit von Arbeitsplätzen 97
5.6 Regelbetrieb (OPS) 98
OPS-01 Kapazitätsmanagement - Planung 98
OPS-02 Kapazitätsmanagement - Überwachung 99
OPS-03 Kapazitätsmanagement - Steuerung von Ressourcen 100
OPS-04 Schutz vor Malware - Richtlinien und Verfahren 101
OPS-05 Schutz vor Malware - Umsetzung 101
OPS-06 Datensicherung und -wiederherstellung - Richtlinien und Verfahren 103
OPS-07 Datensicherung und -wiederherstellung - Überwachung 104
OPS-08 Datensicherung und -wiederherstellung - Regelmäßige Tests 105
OPS-09 Datensicherung und -wiederherstellung - Aufbewahrung 106
OPS-10 Protokollierung und Überwachung - Richtlinien und Verfahren 107
OPS-11 Protokollierung und Überwachung - Richtlinien und Verfahren für den Umgang mit abgeleiteten Cloud-Dienstdaten und Kontodaten 108
OPS-12 Protokollierung und Überwachung - Zugriff, Aufbewahrungsfristen und Löschung 110
OPS-13 Protokollierung und Überwachung - Sicherheitsinformations- und Ereignismanagement 110
OPS-14 OPS-14 Protokollierung und Überwachung - Aufbewahrung der Protokolldaten 111
OPS-15 Protokollierung und Überwachung - Zurechenbarkeit 112
OPS-16 Protokollierung und Überwachung - Konfiguration 113
OPS-17 Protokollierung und Überwachung - Verfügbarkeit der Überwachungssoftware 113
OPS-18 Umgang mit Schwachstellen - Richtlinien und Verfahren 114
OPS-19 Umgang mit Vorfällen und Abstürzen - Richtlinien und Verfahren 116
OPS-20 Umgang mit Vorfällen - Umsetzung 117
OPS-21 Umgang mit Abstürzen - Implementierung 118
OPS-22 Umgang mit Schwachstellen, Vorfällen und Abstürzen - Penetrationstests 118
OPS-23 Umgang mit Schwachstellen, Vorfällen und Abstürzen - Messungen, Analysen und Bewertungen von Abläufen 121
OPS-24 Einbindung des Cloud-Kunden bei Vorfällen 122
OPS-25 Umgang mit Schwachstellen, Vorfällen und Abstürzen - Schwachstellenscans 123
OPS-26 Umgang mit Schwachstellen, Vorfällen und Abstürzen - Systemhärtung 124

OPS-27 Umgang mit Schwachstellen - Richtlinien und Verfahren zum Patch-Management 125
OPS-28 Umgang mit Schwachstellen - Implementierung des Patch-Managements 127
OPS-29 Umgang mit Schwachstellen, Vorfällen und Abstürzen - extern bezogene Komponenten 127
OPS-30 Trennung von Datensätzen - Richtlinien und Verfahren 128
OPS-31 Trennung von Datensätzen - Implementierung 129
OPS-32 Confidential Computing - Richtlinien und Verfahren 130
OPS-33 Confidential Computing - Remote-Attestierung 131
OPS-34 Container-Management - Richtlinien und Verfahren 133
OPS-35 Containermanagement - Implementierung 134
5.7 Identitäts- und Berechtigungsmanagement (IAM) 134
IAM-01 Richtlinie für Identitäten und Zugriffsberechtigungen 134
IAM-02 Vergabe und Änderung von Identitäten und Zugriffsberechtigungen 137
IAM-03 Risikobasiertes Verfahren zur Sperrung und zum Entzug von Identitäten 137
IAM-04 Entzug oder Anpassung von Zugriffsberechtigungen bei Veränderungen des Aufgabengebiets 139
IAM-05 Regelmäßige Überprüfung von Zugriffsberechtigungen 140
IAM-06 Privilegierte Zugriffsberechtigungen 141
IAM-07 Zugriff auf Cloud-Kundendaten 143
IAM-08 Authentisierungsmechanismen 146
IAM-09 Vertraulichkeit von Authentisierungsinformationen 147
5.8 Kryptographie und Schlüsselmanagement (CRY) 149
CRY-01 Richtlinie für die Verwendung kryptographischer Mechanismen 149
CRY-02 Kryptographisches Änderungsmanagement 151
CRY-03 Überprüfung kryptographischer Verfahren 152
CRY-04 Schutz von Daten bei der Übertragung 153
CRY-05 Verschlüsselung von sensiblen Daten bei der Speicherung 154
CRY-06 Sichere Schlüsselerzeugung 155
CRY-07 Rotation kryptographischer Schlüssel 155
CRY-08 Ausstellung von Public-Key-Zertifikaten 156
CRY-09 Sichere Schlüsselbereitstellung 157
CRY-10 Sichere Speicherung von Schlüsseln 157
CRY-11 Archivierung kryptographischer Schlüssel 158
CRY-12 Management von Statusänderungen kryptographischer Schlüssel 158
CRY-13 Umgang mit kompromittierten Schlüsseln 159
CRY-14 Sichere Deaktivierung kryptographischer Schlüssel 159
CRY-15 Anforderungen an Pre-Shared Keys 160
CRY-16 Betriebliche Kontinuität für das Schlüsselmanagement 160
CRY-17 Management des Lebenszyklus kryptographischer Schlüssel 161

CRY-18 Nutzung externer Schlüsselmanagementsysteme ... 162
CRY-19 Sicherer Umgang mit kundenseitig verwalteten Schlüsseln ... 163
5.9 Kommunikationssicherheit (COS) ... 163
COS-01 Technische Schutzmaßnahmen ... 163
COS-02 Sicherheitsanforderungen an Verbindungen im Netz des Cloud-Anbieters ... 165
COS-03 Überwachung von Verbindungen im Netz des Cloud-Anbieters ... 165
COS-04 Netzübergreifender Zugriff ... 166
COS-05 Netze für die Administration ... 167
COS-06 Trennung des Datenverkehrs in gemeinsam genutzten Netzumgebungen ... 168
COS-07 Dokumentation der Netztopologie ... 169
COS-08 Richtlinien für die Datenübertragung ... 170
5.10 Portabilität und Interoperabilität (PI) ... 171
PI-01 Sicherheit von Eingabe- und Ausgabeschnittstellen ... 171
PI-02 Vertragliche Vereinbarungen zur Bereitstellung von Cloud-Kundendaten ... 172
PI-03 Sichere Datenlöschung ... 174
5.11 Beschaffung, Entwicklung und Änderung von Informationssystemen (DEV) ... 175
DEV-01 Richtlinien für die Entwicklung/Beschaffung von Systemkomponenten ... 175
DEV-02 Auslagerung der Entwicklung ... 177
DEV-03 Richtlinien für Änderungen an Systemkomponenten ... 178
DEV-04 Programm für Sicherheitsschulungen und Sensibilisierung in Bezug auf kontinuierliche Software-Bereitstellung und zugehörige Systeme, Komponenten oder Werkzeuge ... 180
DEV-05 Designdokumentation für Sicherheitsfunktionen ... 181
DEV-06 Risikobeurteilung, Kategorisierung und Priorisierung von Änderungen ... 181
DEV-07 Testen von Änderungen ... 182
DEV-08 Protokollierung von Änderungen ... 183
DEV-09 Versionskontrolle ... 184
DEV-10 Freigaben für die Bereitstellung in der Produktionsumgebung ... 185
DEV-11 Schutz von Entwicklungs- und Testumgebungen ... 185
DEV-12 Trennung der Umgebungen ... 186
DEV-13 Transparenz über Softwarekomponenten ... 187
DEV-14 Sichere Nutzung von Hardware und Software Dritter ... 188
DEV-15 Ausnahmen vom Änderungsmanagementprozess ... 188
5.12 Steuerung und Überwachung von Service-Organisationen und Lieferanten (SSO) ... 189
SSO-01 Richtlinien und Verfahren zur Steuerung und Überwachung von Service-Organisationen ... 189
SSO-02 Risikobeurteilung von Service-Organisationen ... 190
SSO-03 Datenverarbeitung von Service-Organisationen ... 191
SSO-04 Verzeichnis von Service-Organisationen ... 192
SSO-05 Überwachung der Einhaltung von Anforderungen ... 193

SSO-06 Strategie zur Vertragsbeendigung für Service-Organisationen ... 196
SSO-07 Sicherstellung von Transparenz innerhalb von Service-Organisationen ... 197
SSO-08 Steuerung des Austauschs mit Lieferanten funktionaler Komponenten ... 198
5.13 Umgang mit Sicherheitsvorfällen (SIM) ... 199
SIM-01 Richtlinie für den Umgang mit Sicherheitsvorfällen ... 199
SIM-02 Pläne zur Reaktion auf Sicherheitsvorfälle ... 199
SIM-03 Bearbeitung von Sicherheitsvorfällen ... 200
SIM-04 Dokumentation und Berichterstattung über Sicherheitsvorfälle ... 201
SIM-05 Verpflichtung des Personals zur Meldung von Sicherheitsvorfällen an eine zentrale Stelle ... 202
SIM-06 Auswertung und Lernprozess ... 203
5.14 Kontinuität des Geschäftsbetriebs und Notfallmanagement (BCM) ... 204
BCM-01 Business Continuity- und Notfallmanagementsystem ... 204
BCM-02 Business Impact Analyse ... 205
BCM-03 Pläne zur betrieblichen Kontinuität ... 206
BCM-04 Testen der betrieblichen Kontinuität ... 207
5.15 Compliance (COM) ... 209
COM-01 Identifizierung anwendbarer gesetzlicher, regulatorischer, selbst auferlegter oder vertraglicher Anforderungen ... 209
COM-02 Richtlinie für die Planung und Durchführung von Audits ... 209
COM-03 Interne Audits des Informationssicherheitsmanagementsystems ... 211
COM-04 Informationen über die Informationssicherheitsleistung und Managementbewertung des ISMS ... 212
5.16 Umgang mit behördlichen Auskunfts- und Herausgabeverlangen (INQ) ... 213
INQ-01 Juristische Bewertung von behördlichen Auskunfts- und Herausgabeverlangen ... 213
INQ-02 Information der Cloud-Kunden über behördliche Auskunfts- und Herausgabeverlangen ... 214
INQ-03 Begrenzung des Zugriffs auf oder der Offenlegung von Daten bei behördlichen Auskunfts- und Herausgabeverlangen ... 215
INQ-04 Kommunikation technischer Verfahren zur Datenoffenlegung bei behördlichen Auskunfts- und Herausgabeverlangen ... 216
5.17 Produktsicherheit (PSS) ... 217
PSS-01 Leitlinien und Empfehlungen für Cloud-Kunden ... 217
PSS-02 Identifikation von Schwachstellen des Cloud-Dienstes ... 219
PSS-03 Information der Cloud-Kunden über bekannte Schwachstellen ... 220
PSS-04 Fehlerbehandlungs- und Protokollierungsmechanismen ... 222
PSS-05 Authentisierungsmechanismen ... 223
PSS-06 Session Management ... 224
PSS-07 Vertraulichkeit von Authentisierungsinformationen ... 225
PSS-08 Rahmenwerk für Rollen und Berechtigungen ... 226
PSS-09 Autorisierungsmechanismen ... 227

PSS-10 Software-defined Networking 228
PSS-11 Images für virtuelle Maschinen und Container 228
PSS-12 Region der Datenverarbeitung und -speicherung 229

1 Einführung

1.1 Vorbemerkungen

Cybersicherheit ist eine gesamtgesellschaftliche Aufgabe, die nur gemeinschaftlich bewältigt werden kann. Das BSI nimmt seine Verantwortung als integraler Bestandteil der deutschen, europäischen und globalen Cybersicherheitsarchitektur wahr und arbeitet in offener, kollaborativer Zusammenarbeit auf Augenhöhe mit allen Beteiligten an der Vision der Cybernation Deutschland. Informationssicherheit ist eine Voraussetzung für eine erfolgreiche Digitalisierung, denn diese kann nur gelingen, wenn Nutzerinnen und Nutzer Vertrauen in (neue) Technologien entwickeln und sie sicher zu ihrem Nutzen einsetzen können.

Cloud Computing ist die Grundlage moderner industrialisierter IT und damit essenziell für die Digitalisierung von Wirtschaft, Verwaltung und Gesellschaft. Um das Potenzial dieser Entwicklung jedoch sicher zu nutzen und die Vision Cybernation Deutschland umzusetzen, sind industriekompatible Sicherheitsstandards erforderlich: Sie machen Cloud-Dienste vergleichbar, schaffen Vertrauen und unterstützen damit den Gleichklang von Cybersicherheit und Digitalisierung.

Souveräne Entscheidungen über den Einsatz von Cloud-Diensten erfordern Wahlmöglichkeiten und die Fähigkeit, diese auf belastbarer Grundlage zu bewerten. Dies setzt ein fundiertes Verständnis der verfügbaren Angebote und ihrer Sicherheitseigenschaften voraus – um ihre Wirksamkeit zu beurteilen, Risiken für die Informationssicherheit zu bewerten, erreichbare Resilienz einzuschätzen, komplexe Lieferketten und zugehörige Abhängigkeiten zu analysieren und aus diesen Erkenntnissen klare und verbindliche Anforderungen abzuleiten. Der Cloud Computing Compliance Criteria Catalogue (C5) leistet hierzu einen entscheidenden Beitrag: Als technischer und prozeduraler Standard von hoher fachlicher Qualität schafft er die Transparenz über die Sicherheitseigenschaften von Cloud-Diensten, die notwendig ist, damit strategische Entscheidungen auf technisch fundierter und belastbarer Grundlage getroffen werden können.

Seit 2016 stellt das BSI mit dem C5 eine etablierte Säule für die Sicherheit des Cloud Computings bereit. Der C5 trägt unmittelbar zur Erreichung der strategischen Ziele der Cybernation Deutschland bei: Er setzt Cybersicherheit als verbindlichen Standard auf die Agenda von Cloud-Anbietern und ihren Cloud-Kunden, erhöht die Cyberresilienz von Unternehmen und Institutionen substanziell, fördert eine konsistente Digitalisierung durch verlässliche Sicherheitsanforderungen und stärkt den deutschen, europäischen und globalen Cybermarkt als Grundlage für ein vertrauenswürdiges Cloud-Ökosystem. Mit dem C5:2026 legt das BSI nun die zweite inhaltliche Überarbeitung dieses Kriterienkatalogs vor. Der C5:2026 baut auf dem Fundament des C5:2020 auf und führt dessen bewährte Kriterien fort, ergänzt sie jedoch um wesentliche neue Anforderungen, um der Vielzahl technologischer und regulatorischer Entwicklungen der letzten Jahre Rechnung zu tragen.

Eine bedeutende Entwicklung in diesem Zusammenhang ist die Arbeit der ENISA am europäischen Cloud-Zertifizierungsschema EUCS. Der C5:2020, ein weit verbreiteter und weltweit etablierter Standard für Cloud-Sicherheit, diente als Grundlage für die Entwicklung der Sicherheitsanforderungen der geplanten EUCS-Stufe Substantial. Die in diesem Prozess sowie durch das Europäische Komitee für Normung und das Europäische Komitee für elektrotechnische Normung (CEN/CENELEC) entwickelten Anforderungen bilden die inhaltliche Grundlage des C5:2026. Das BSI reagiert damit auf das Tempo des technologischen Wandels und gewährleistet zugleich die Kompatibilität mit EUCS Substantial.

Zusätzlich zum EUCS wurden bei der Entwicklung des C5:2026 die aktuellen Fassungen weiterer relevanter Dokumente berücksichtigt, darunter Version 4 der CSA Cloud Controls Matrix, die Ausgabe 2022 der Norm ISO/IEC 27001 sowie die NIS2-Richtlinie. Darüber hinaus sind praktische Erfahrungen von Cloud-Anbietern, Prüferinnen und Prüfern sowie Beraterinnen und Beratern in diese aktuelle Überarbeitung eingeflossen.

Die folgenden Aspekte stellen die wesentlichen Änderungen gegenüber der vorherigen Version dieses Kriterienkatalogs dar:

- Aufnahme neuer Kriterien zu aktuellen technischen Entwicklungen und Fortschritten, insbesondere im Hinblick auf Container-Management, Supply-Chain-Management, Post-Quanten-Kryptographie und Confidential Computing;
- Detailliertere Berücksichtigung von Mandantenfähigkeit und der technischen Umsetzung von Souveränität, um Nutzern eine fundierte Grundlage für souveräne Entscheidungen über den Einsatz von Cloud-Diensten zu geben;
- Auf Basis häufig eingegangener Rückmeldungen zum C5:2020: Präzisere Abgrenzung, auf welche Datentypen einzelne Kriterien Anwendung finden;
- Strukturelle Überarbeitung der Kriterien im Einklang mit EUCS: C5-Kriterien bestehen nun aus Unterkriterien, die inhaltlich klar voneinander abgegrenzt sind und so eine präzisere Zuordnung zu Kontrollen innerhalb der Kontrollsysteme von Cloud-Anbietern sowie mehr Klarheit in der Prüfung ermöglichen; und
- Explizite Klassifizierung der Zusatzkriterien danach, ob sie die bestehenden Basiskriterien durch strengere Anforderungen schärfen ('verschärfende Zusatzkriterien') oder sie durch neue Anforderungen erweitern ('erweiternde Zusatzkriterien').

Struktur und Inhalt dieses Kriterienkatalogs werden in Abschnitt 2 dargestellt. Hinweise zum Nachweis der Konformität mit diesem Kriterienkatalog finden sich in Abschnitt 3. Die Kriterien für unabhängige Prüfungen sind in den Abschnitten 4 und 5 enthalten.

1.2 Definitionen

1.2.1 Begriffe im Zusammenhang mit Cloud-Sicherheit

Für die Zwecke dieses Kriterienkatalogs gelten die folgenden Definitionen. Sie leiten sich aus dem IT-Grundschutz-Kompendium des BSI und der internationalen Norm ISO/IEC 22123:2023 (Information Technology - Cloud Computing - Part 1: Vocabulary) bzw. der vorläufigen deutschen Fassung prEN ISO IEC 22123-1:2025 ab und wurden durch eigene Arbeiten ergänzt:

Abgeleitete Cloud-Dienstdaten

Klasse von Datenobjekten unter der Kontrolle des Cloud-Anbieters, die als Ergebnis der Interaktion des Cloud-Kunden mit dem Cloud-Dienst entstehen. Abgeleitete Cloud-Dienstdaten umfassen den Teil von Protokolldaten, der Aufzeichnungen darüber enthält, wer den Cloud-Dienst genutzt hat, zu welchen Zeiten, welche Funktionen, welche Datentypen betroffen waren und so weiter. Sie können außerdem Informationen über die Anzahl autorisierter Cloud-Nutzer und deren Identitäten enthalten. Ebenso können sie Konfigurations- oder Anpassungsdaten umfassen, sofern der Cloud-Dienst solche Konfigurations- und Anpassungsfunktionen bereitstellt.

Assets

In diesem Kriterienkatalog wird dieser Begriff synonym mit dem Begriff ''Systemkomponenten'' (vgl. unten) verwendet.

Authentizität

Die Eigenschaft von Informationen, dass Änderungen eindeutig einem Verursacher zugeordnet werden können.

Cloud-Anbieter

Synonym zu Cloud-Dienstleister (vgl. ISO 22123-1:2025 3.3.3). Natürliche oder juristische Person, die einen Cloud-Dienst bereitstellt.

Cloud-Anbieterdaten

Synonym zu Cloud-Dienstleisterdaten (vgl. ISO 22123-1:2025 3.9.3). Klasse von Datenobjekten, die spezifisch für den Betrieb des Cloud-Dienstes sind und unter der Kontrolle des Cloud-Anbieters stehen. Cloud-Anbieterdaten umfassen unter anderem Konfigurations- und Nutzungsinformationen von Systemkomponenten, Zuweisungen von Speicher- und Netzressourcen, Ausfallraten physischer und virtueller Ressourcen, Betriebskosten und Ähnliches.

Cloud Computing

Paradigma, einen netzbasierten Zugang auf ein skalierbares und elastisches Reservoir gemeinsam nutzbarer physischer oder virtueller Ressourcen nach dem ''Selbstbedienungsprinzip'' (engl. Self-Service) und bedarfsgerechter Administration zu ermöglichen. Beispiele für Ressourcen sind Server, Betriebssysteme, Netzwerke, Software, Anwendungen und Speichersysteme. Das Selbstbedienungsprinzip bezieht sich auf die Bereitstellung von Ressourcen für Cloud-Dienste, die von Cloud-Kunden mit Hilfe automatisierter Mittel vorgenommen werden.

Cloud-Dienst

Informationstechnischer Dienst, der mittels Cloud Computing über definierter Schnittstellen angeboten wird. Dies umfasst Infrastruktur (z. B. Rechenleistung, Speicherplatz), Plattformen und Software.

Cloud-Kunde

Kurzform für Cloud-Dienstleistungskunde (vgl. ISO 22123-1:2025 3.3.2). Natürliche oder juristische Person, die zum Zweck der Nutzung des Cloud-Dienstes in einer Geschäftsbeziehung mit dem Cloud-Anbieter steht.

Cloud-Kundendaten

Klasse von Datenobjekten, die aus rechtlichen oder anderen Gründen der Kontrolle des Cloud-Kunden unterliegen und direkt in den Cloud-Dienst eingegeben wurden (einschließlich Zugangsdaten zur Steuerung des Zugriffs auf Informationen oder andere Ressourcen) oder die aus der Nutzung der Funktionen des Cloud-Dienstes durch oder im Namen des Cloud-Kunden über die veröffentlichte Schnittstelle des Cloud-Dienstes resultieren.

Cloud-Nutzer

Kurzform von Cloud-Dienstleistungsnutzer (vgl. ISO 22123-1:2025 3.3.4). Natürliche Person oder eine in ihrem Namen handelnde Stelle, die einem Cloud-Kunden zugeordnet ist und Cloud-Dienste nutzt.

Cloud-Vermittler

Kurzform für Cloud-Dienstleistungsvermittler (vgl. ISO 22123-1:2025 3.3.7). Ein Cloud-Vermittler ist eine natürliche oder juristische Person oder eine Gruppe aus solchen (unabhängig davon, ob sie rechtsfähig ist oder nicht), die eine festgelegte Menge an unterstützenden oder ergänzenden Aufgaben für den Cloud-Anbieter, einen oder mehrere Cloud-Kunden oder beide ausführt – mit der spezifischen Funktion, Beziehungen zwischen Cloud-Kunden und Cloud-Anbietern auszuhandeln.

Cybersicherheitsrisiko

Cybersicherheitsrisiken sind Auswirkungen von Unsicherheit im Zusammenhang mit Information und Technik. Cybersicherheitsrisiken beziehen sich auf den Verlust von Vertraulichkeit, Authentizität, Integrität (vgl. unten) oder Verfügbarkeit von Informationen, Daten oder Informationssystemen. Sie spiegeln potenzielle nachteilige Auswirkungen auf organisatorische Abläufe (d. h. Auftrag, Funktionen, Bild oder Ruf)

und Vermögenswerte wider, insbesondere in Bezug auf die Sicherheit von Netz- und Informationssystemen.

Funktionale Komponente

Funktionaler Baustein, der für die Ausführung einer Tätigkeit benötigt wird und durch eine Implementierung gestützt ist.

Hardware-Komponenten

Systemkomponenten (vgl. unten), die als Hardware klassifiziert sind.

Hardware-Objekte

Physische und virtuelle Infrastrukturessourcen (z. B. Server, Speichersysteme, Netzkomponenten) sowie Endgeräte, sofern der Cloud-Anbieter in einer Risikobewertung festgestellt hat, dass diese im Falle von Verlust oder unbefugtem Zugriff die Informationssicherheit des Cloud-Dienstes gefährden könnten (z. B. mobile Geräte, die als Sicherheitstoken zur Authentisierung verwendet werden).

IKT-Dienst

Dienst eines Informations- und Kommunikationstechnologiesystems, der vollständig oder überwiegend in der Übertragung, Speicherung, dem Abruf oder der Verarbeitung von Informationen mittels Netz- und Informationssystemen besteht.

Informationssicherheit

Informationssicherheit bezeichnet die Praktiken und Grundsätze, die dazu bestimmt sind, Informationen vor unbefugtem Zugriff, unbefugter Nutzung, Offenlegung, Störung, Veränderung oder Zerstörung zu schützen. Im Kontext dieses Katalogs gewährleistet sie die Vertraulichkeit, Integrität, Authentizität und Verfügbarkeit von Cloud-Kundendaten, Cloud-Anbieterdaten, abgeleitete Cloud-Dienstdaten und Kontodaten.

Integrität

Die Eigenschaft, dass Informationen vollständig, korrekt (richtig, unbeschädigt) und vor Manipulation sowie unbeabsichtigter oder fehlerhafter Veränderung geschützt sind.

Kontodaten

Klasse von Datenobjekten, die für jeden Cloud-Kunden (vgl. unten) spezifisch und zur Verwaltung des Cloud-Dienstes (vgl. unten) erforderlich sind. Kontodaten (z. B. Zahlungsinformationen, Kontaktdaten usw.) entstehen typischerweise beim Erwerb eines Cloud-Dienstes und stehen unter der Kontrolle des Cloud-Anbieters (vgl. unten).

Leitlinie

Eine Leitlinie gibt Empfehlungen, Orientierung und Good Practice zu einem bestimmten Thema. Leitlinien sind weniger formal als Richtlinien oder Verfahren (beide vgl. unten) und enthalten im Allgemeinen keine Anforderungen. Sie dienen häufig als Erläuterung zu Richtlinien und helfen bei der Festlegung von Verfahren.

Maximal Tolerierbare Ausfallzeit (engl. Maximum Tolerable Period of Disruption; MTPD)

Zeitliche Obergrenze bis zu der ein Geschäftsprozess maximal ausfallen darf, bevor nicht tolerierbare Auswirkungen für eine Institution auftreten. Die Obergrenze wird anhand einer Schadensbewertung des betreffenden Geschäftsprozesses ermittelt.

Maximal zulässiger Datenverlust (engl. Recovery Point Objective (RPO))

Wert für das Alter, das verfügbare Daten maximal haben dürfen, um zeitkritische Geschäftsprozesse nach einer Unterbrechung sinnvoll betreiben zu können. Der maximal zulässige Datenverlust wird in der Regel als geforderter Datensicherungszyklus je Anwendung, IT-System oder Geschäftsprozess angegeben.

Notbetriebsniveau (engl. Minimum Business Continuity Objective; MBCO)

Die erforderliche Leistungsfähigkeit im Notfall, um einen angemessenen Geschäftsbetrieb gewährleisten zu können. Das Notbetriebsniveau oder MBCO wird je Geschäftsprozess oder Ressource individuell festgelegt.

Partition

Eine Partition ist eine Gruppe von einer oder mehreren Regionen (vgl. unten), die ein gemeinsames Identitäts- und Berechtigungsmanagement-System (engl. Identity and Access Management; IAM) sowohl für den Cloud-Anbieter als auch für Cloud-Kunden nutzen. Jede Region ist ausschließlich Teil einer Partition, und zwischen Partitionen besteht eine strikte Trennung ohne gemeinsam genutzte Infrastruktur.

Penetrationstest

Autorisierter, simulierter Angriff unter realen Bedingungen auf Systemkomponenten zur Identifikation von Möglichkeiten, Schwachstellen auszunutzen, um Sicherheitsmerkmale des Cloud-Dienstes zu umgehen oder zu überwinden.

Protokolldaten

Daten, die verwendet werden, um ausgewählte Elemente, die bei der Ausführung eines Prozesses oder einer Tätigkeit identifiziert wurden, aufzuzeichnen und zu beschreiben oder zu kennzeichnen. Protokolldaten enthalten sowohl abgeleitete Cloud-Dienstdaten als auch Cloud-Anbieterdaten.

Rahmenwerk

Ein Rahmenwerk ist eine strukturierte Menge aus Richtlinien, Verfahren, Leitlinien und begleitenden Dokumenten, das einen organisierten Ansatz zur Erreichung bestimmter Ziele bereitstellt.

Recovery Time Objective (RTO)

Der Zeitraum nach einem Vorfall, innerhalb dessen ein Produkt, ein Dienst oder eine Tätigkeit wieder aufgenommen oder Ressourcen auf ein vordefiniertes Niveau wiederhergestellt werden müssen, um die Auswirkungen der Unterbrechung auf ein akzeptables Maß zu begrenzen.

Redundanz

Verfügbarkeit alternativer Komponenten, Systeme oder Prozesse, die nach dem Ausfall einer oder mehrerer Komponenten die beabsichtigte Funktion übernehmen, um das erforderliche Serviceniveau aufrechtzuerhalten.

Region

Eine Region umfasst eine oder mehrere Zonen (vgl. unten), die sämtlich innerhalb eines einzigen Ballungsraums (Metropole) gelegen sind. Cloud-Anbieter können für eine Region beliebige Bezeichnungen verwenden, etwa „EU-south-west“, jedoch muss die Infrastruktur der Region auf einen Ballungsraum beschränkt sein und darf niemals über ein ganzes Land oder einen ganzen Kontinent gestreut sein. Hinweis: In Fällen, in denen eine Region nur aus einer Zone besteht (häufig bei kleineren Anbietern), kann der praktische Unterschied zwischen Region und Zone gering sein; die konzeptionelle Unterscheidung bleibt jedoch bestehen: Eine Region beschreibt den Managementbereich des Ballungsraums, und eine Zone bildet eine Verfügbarkeitsgruppierung innerhalb dieses Bereichs.

Resilienz

Fähigkeit, potenziell störenden Ereignissen oder Bedingungen – ob natürlich oder menschengemacht – zu widerstehen, sich an sie anzupassen oder sich schnell davon zu erholen, um den vorgesehenen Dienst aufrechtzuerhalten oder wiederherzustellen.

Richtlinie

Absichten und Ausrichtungen einer Organisation, die von ihrer obersten Leitung formell in Kraft gesetzt werden.

Risikoinhaber

Person oder Stelle, die für die Steuerung eines Risikos verantwortlich ist und die entsprechende Befugnis besitzt.

Schutzbedarf

Hinreichendes und angemessenes Maß an Informationssicherheit für die Cloud-Kunden in Bezug auf die im Cloud-Dienst verarbeiteten, gespeicherten oder übertragenen Informationen. Der Schutzbedarf von Systemkomponenten und Daten leitet sich vom Schutzbedarf des Cloud-Dienstes ab. Der Cloud-Kunde muss selbst entscheiden, ob das Maß an Informationssicherheit für Cloud-Kundendaten, abgeleitete Cloud-Dienstdaten und Kontodaten entsprechend seinem eigenen Schutzbedarf ausreicht.

Schwachstellenscan

Einsatz automatisierter Werkzeuge in Kombination mit manueller Verifizierung identifizierter Befunde zur Identifikation und Bewertung von sowie Beriht über Schwachstellen, die bei Ausnutzung zu einer beabsichtigten oder unbeabsichtigten Beeinträchtigung des Cloud-Dienstes und seiner Daten führen können.

Sicherheitsvorfall

Ereignis, das die Verfügbarkeit, Authentizität, Integrität oder Vertraulichkeit gespeicherter, übertragener oder verarbeiteter Daten oder der von Systemkomponenten des Cloud-Dienstes angebotenen oder über diese zugänglichen Dienste beeinträchtigt. Ein Vorfall ist ein materialisiertes Cybersicherheitsrisiko. Sicherheitsvorfälle sind eine Untermenge von Vorfällen.

Software-Komponenten

Systemkomponenten (vgl. unten), die als Software klassifiziert sind.

Standort

Ein Standort ist ein einzelnes Gelände, das eine oder mehrere Datenhallen umfasst, jeweils mit eigener Stromversorgung, Netzwerkanbindung und Brandschutz. Jeder Standort ist physisch von allen anderen Standorten getrennt und exklusiv einer einzelnen Zone (vgl. unten) zugeordnet.

Systemkomponenten

Elemente von Informations- und Kommunikationstechnologiesystemen, die für die Informationssicherheit des Cloud-Dienstes während der Erstellung, Verarbeitung, Speicherung, Übertragung, Löschung oder Vernichtung von Informationen im Verantwortungsbereich des Cloud-Anbieters erforderlich sind und in die folgenden fünf Kategorien eingeteilt werden können: Infrastruktur, Software, Personen, Verfahren und Daten.

Verfahren

Ein Verfahren ist häufig mit einer Richtlinie verbunden und beschreibt, wie eine Richtlinie, ein Prozess oder eine Aufgabe konkret umgesetzt wird; es operationalisiert also die Absichten und Ausrichtungen, die Richtlinien festlegen.

Verfügbarkeit

Die Eigenschaft, dass Informationen, Dienste und Funktionen von IT-Systemen, IT-Anwendungen oder IT-Netzen auf Anforderung durch eine autorisierte Stelle zugänglich und nutzbar sind.

Vertraulichkeit

Die Eigenschaft, dass Informationen nicht unbefugten Individuen, Stellen oder Prozessen zugänglich gemacht oder offengelegt werden.

Vorfall

Ungeplante Unterbrechung des Cloud-Dienstes, eine Verringerung der Qualität des Cloud-Dienstes oder ein Ereignis, das sich gegenüber dem Cloud-Kunden noch nicht auf den Cloud-Dienst ausgewirkt hat.

Wesentliche Änderung

Hinzufügung, Änderung oder Entfernung von Systemkomponenten (vgl. unten), von der vernünftigerweise erwartet werden kann, dass sie Cybersicherheitsrisiken, die Wirksamkeit von Kontrollen oder vertragliche Verpflichtungen des Cloud-Anbieters wesentlich beeinflusst. Beispielhafte Ereignisse, die eine wesentliche Änderung darstellen können, sind in den ergänzenden Informationen zum Kriterium OPS-22 aufgeführt.

Zeitnah

Hinreichend früh durchgeführt oder eintretend, ohne unangemessene Verzögerung, unter Berücksichtigung der Art der Angelegenheit und des potenziellen Schadens, den sie verursachen könnte, einschließlich der Fähigkeit des Cloud-Anbieters, die C5-Kriterien zu erfüllen.

Zone

Kurzform von Verfügbarkeitszone (vgl. ISO 22123-1:2025 3.14.1). Eine Zone ist eine logische Gruppe aus mindestens zwei Standorten in räumlicher Nähe. Zonen sind physisch voneinander getrennt und verfügen über separate Stromversorgung, Kühlung, Netzanbindung und Umwelt-Risikoprofile, etwa separate Brandabschnitte. Hierdurch wird das Risiko minimiert, dass Störungen in einer Zone die Verfügbarkeit anderer Zonen innerhalb einer Region beeinträchtigen.

1.2.2 Begriffe im Zusammenhang mit Prüfungen

Darüber hinaus gelten die folgenden Definitionen, basierend auf dem International Standard on Assurance Engagements (ISAE) 3000 (Revised) „Assurance Engagements Other than Audits or Reviews of Historical Financial Information“ und ISAE 3402 „Assurance Reports on Controls at a Service Organization“, herausgegeben von der International Federation of Accountants (IFAC), ISO/IEC 17029:2019 „Conformity assessment — General principles and requirements for validation and verification bodies“, herausgegeben von der International Organization for Standardization (ISO), sowie der Veröffentlichung „Internal Control - Integrated Framework“, herausgegeben vom Committee of Sponsoring Organizations of the Treadway Commission (COSO).

Abweichung

Begriff um falsche Darstellungen zu benennen, die daher rühren, dass eine Kontrolle in einem spezifischen Fall nicht funktioniert hat. Eine Abweichung kann einzeln oder in Kombination mit anderen Abweichungen zu einem Mangel führen.

Attestierungsauftrag

Ein Attestierungsauftrag eines Cloud-Anbieters an eine andere Partei (Prüfer/Auditor; vgl. unten), um den zugrunde liegenden Prüfungsgegenstand anhand der Kriterien zu messen oder zu bewerten. Der Prüfer stellt häufig auch die daraus resultierenden Informationen über den Prüfungsgegenstand in einem Bericht oder einer Erklärung dar und zieht die Schlussfolgerung, ob diese Informationen frei von wesentlichen Mängeln sind (vgl. unten). Bitte beachten: Im allgemeinen Sprachgebrauch werden Attestierungsaufträge als Audits bezeichnet, während Wirtschaftsprüferinnen und Wirtschaftsprüfer den Begriff Audit ausschließlich für Abschlussprüfungen verwenden. Um das Verständnis zu erleichtern, verwenden wir in der Beschreibung den Begriff Prüfung im Sinne des allgemeinen Sprachgebrauchs: dabei handelt es sich nachfolgend um einen Attestierungsauftrag, keine Abschlussprüfung.

Behauptung

Vom Cloud-Anbieter erklärte Information.

Carve-out Methode

Methode zum Umgang mit einer Leistung von einer Subservice-Organisation (vgl. unten), bei der die Komponenten des internen Kontrollsystems (vgl. unten) der Subservice-Organisation, die zur Erbringung der Leistungen für den Cloud-Anbieter genutzt werden, aus der Beschreibung des für die Entwicklung und den Betrieb des Cloud-Dienstes relevanten internen Kontrollsystems des Cloud-Anbieters sowie aus dem Umfang der Prüfung ausgeschlossen werden. Folglich werden in der Prüfung keine Angaben über die Subservice-Organisation berücksichtigt, welche über die Informationen hinausgehen, die dem Cloud-Anbieter für den Betrieb seiner Kontrollen zur Erfüllung der Kriterien der SSO-Domäne vorliegen. Die Beschreibung des internen Kontrollsystems benennt jedoch (a) die Art der von der Subservice-Organisation erbrachten Leistungen; (b) die Arten von Kontrollen, die bei der Subservice-Organisation erwartet werden und die in Kombination mit Kontrollen beim Cloud-Anbieter erforderlich sind, um hinreichende Sicherheit darüber zu verschaffen, dass die anwendbaren C5-Kriterien erreicht wurden; und (c) die beim Cloud-Anbieter eingesetzten Kontrollen zur Überwachung der Wirksamkeit der Kontrollen der Subservice-Organisation.

C5-Kriterien

Die in diesem Katalog definierten Kriterien, die zur Beurteilung der Informationssicherheit des Cloud-Dienstes angewendet werden.

Direkte Prüfung (engl. Direct Engagement)

Ein Attestierungsauftrag, bei dem der Prüfer den Cloud-Dienst als zugrunde liegenden Prüfungsgegenstand anhand der C5-Kriterien prüft und das resultierende Prüfungsergebnis zusammen mit dem Prüfungsgegenstand in die daraus resultierenden Informationen über den Prüfungsgegenstand als Teil seiner Berichterstattung darstellt.

Inclusive Methode

Methode zum Umgang mit einer Leistung von einer Subservice-Organisation (vgl. unten), bei der die Beschreibung des für die Entwicklung und den Betrieb des Cloud-Dienstes relevanten internen Kontrollsystems (vgl. unten) des Cloud-Anbieters eine Beschreibung enthält von (a) der Art der von der Subservice-Organisation erbrachten Leistungen; (b) den Komponenten des internen Kontrollsystems der Subservice-Organisation, die zur Erbringung von Leistungen für den Cloud-Anbieter genutzt werden, einschließlich der Kontrollen der Subservice-Organisation, die in Kombination mit Kontrollen beim Cloud-Anbieter erforderlich sind, um hinreichende Sicherheit darüber zu verschaffen, dass die anwendbaren C5-Kriterien erreicht wurden; und (c) den beim Cloud-Anbieter eingesetzten Kontrollen zur Überwachung der Wirksamkeit der Kontrollen der Subservice-Organisation. (Bei Anwendung der Inclusive Methode unterliegen die Kontrollen bei der Subservice-Organisation den Prüfungshandlungen des Prüfers. Da die

Systemkomponenten der Subservice-Organisation in die Beschreibung einbezogen sind, gehören diese Komponenten zum Umfang der Prüfung.)

Information und Kommunikation

Information ist erforderlich, damit die Organisation ihre internen Kontrollverantwortlichkeiten zur Unterstützung der Zielerreichung wahrnehmen kann. Kommunikation erfolgt sowohl intern als auch extern und stellt der Organisation die Informationen bereit, die sie zur Durchführung der täglichen Kontrollen benötigt.

Internes Kontrollsystem

Die von den gesetzlichen Vertretern (Management) des Cloud-Anbieters angewandten Grundsätze, Verfahren und Maßnahmen zur organisatorischen und technischen Umsetzung von Managemententscheidungen, um die Wirksamkeit und Effizienz der Geschäftstätigkeiten, die Informationssicherheit des Cloud-Dienstes sowie die Einhaltung der für den Cloud-Anbieter geltenden gesetzlichen und sonstigen Regelungen sicherzustellen. Dieser Katalog beschreibt Kriterien für das Kontrollumfeld, die Risikobewertung, die Kontrollaktivitäten, Information und Kommunikation sowie die Überwachungsaktivitäten des Cloud-Anbieters, die für die Entwicklung und den Betrieb des Cloud-Dienstes relevant sind.

Kontrollaktivitäten

Maßnahmen, die durch Richtlinien und Verfahren festgelegt werden, um sicherzustellen, dass Managementvorgaben zur Minderung von Risiken für die Zielerreichung umgesetzt werden.

Kontrolle

Richtlinie oder Verfahren zur Verringerung der Eintrittswahrscheinlichkeit von Ereignissen oder zur Aufdeckung eingetretener Ereignisse, um die Informationssicherheit des Cloud-Dienstes aufrechtzuerhalten. Kontrollen existieren in jeder der fünf Komponenten des internen Kontrollsystems des Cloud-Anbieters (Kontrollumfeld, Risikobewertung, Kontrollaktivitäten, Information und Kommunikation sowie Überwachungsaktivitäten). Eine Kontrolle ist entweder präventiv (darauf ausgelegt, ein unbeabsichtigtes Ereignis oder Ergebnis zum Zeitpunkt des erstmaligen Auftretens zu verhindern) oder detektierend (darauf ausgelegt, ein unbeabsichtigtes Ereignis oder Ergebnis nach dem ersten Verarbeitungsschritt, aber vor dem endgültigen Abschluss des angestrebten Ziels zu entdecken und Maßnahmen zu ergreifen, um ein unbeabsichtigtes Ereignis oder Ergebnis zu korrigieren oder zu vermeiden).

Kontrollumfeld

Gesamtheit von Standards, Prozessen und Strukturen, die die Grundlage für die Durchführung interner Kontrollen in der gesamten Organisation bilden.

Korrespondierende Kontrollen der Cloud-Kunden (engl. Complementary User Entity Controls; CUEC)

Kontrollen (vgl. unten), von denen der Cloud-Anbieter bei der Gestaltung seines für die Entwicklung und den Betrieb des Cloud-Dienstes relevanten internen Kontrollsystems (vgl. unten) ausgegangen ist, dass sie von Cloud-Kunden umgesetzt werden. Die umgesetzten korrespondierenden Kontrollen der Cloud-Kunden sind zusammen mit den internen Kontrollen des Cloud-Anbieters erforderlich, um hinreichende Sicherheit zu verschaffen, dass die anwendbaren C5-Kriterien erfüllt werden.

Korrespondierende Kontrollen der Subservice-Organisation (engl. Complementary Subservice Organisation Controls; CSOC)

Kontrollen (vgl. unten), von denen der Cloud-Anbieter bei der Gestaltung seines für die Entwicklung und den Betrieb des Cloud-Dienstes relevanten internen Kontrollsystems (vgl. unten) ausgegangen ist, dass sie von der Subservice-Organisation (vgl. unten) umgesetzt werden. Die korrespondierenden Kontrollen der

Subservice-Organisation sind zusammen mit den internen Kontrollen des Cloud-Anbieters erforderlich, um hinreichende Sicherheit zu verschaffen, dass die anwendbaren C5-Kriterien erfüllt werden.

Mangel

Begriff um falsche Darstellungen zu benennen, die daher rühren, dass Kontrollen nicht angemessen ausgestaltet oder wirksam umgesetzt waren.

Prüfer (engl. Practitioner)/Auditor

Die Person oder Personen, die die Prüfung durchführen.

Prüfung einer Erklärung

Ein Attestierungsauftrag, bei dem der Prüfer prüft, ob die Erklärung der gesetzlichen Vertreter zum Cloud-Dienst frei von wesentlichen Fehlern ist.

Risikobewertung

Prozess zur Identifikation und Analyse von Risiken für die Erreichung der Ziele einer Organisation.

Schriftliche Erklärung

Aussagen zur Beschreibung des internen Kontrollsystems des Cloud-Anbieters sowie zur Angemessenheit der Gestaltung und, sofern relevant, zur Wirksamkeit des Betriebs der Kontrollen zur Erfüllung der C5-Kriterien, erstellt von den gesetzlichen Vertretern (Management) des Cloud-Anbieters.

Service-Organisation

Synonym zu Dienstleistungsunternehmen. Partner, Anbieter oder andere Dritte, die dem Cloud-Anbieter im Zusammenhang mit der Entwicklung oder dem Betrieb des Cloud-Dienstes Leistungen erbringen.

Subservice-Organisation

Service-Organisationen, für die die folgenden Merkmale in Kombination gelten:

1. Die von der Service-Organisation erbrachten Leistungen sind wahrscheinlich relevant für das Verständnis der Cloud-Kunden hinsichtlich der anwendbaren C5-Kriterien. Eine Leistung ist wahrscheinlich relevant, wenn die Service-Organisation Zugriff auf Systemkomponenten des Cloud-Dienstes hat und vertrauliche Informationen einsehen oder Informationen zwischen sich selbst und dem Cloud-Dienst übertragen kann.
2. Korrespondierende Kontrollen der Subservice-Organisation (CSOC) bei der Service-Organisation sind in Kombination mit den Kontrollen des Cloud-Anbieters erforderlich, um die anwendbaren C5-Kriterien mit hinreichender Sicherheit zu erfüllen.

Überwachungsaktivitäten

Laufende Beurteilungen, separate Beurteilungen oder eine Kombination daraus, um festzustellen, ob jede der fünf Komponenten interner Kontrollen vorhanden ist und funktioniert.

Validierung

Die Bestätigung einer Behauptung durch den Cloud-Anbieter selbst durch Bereitstellung objektiver Nachweise, dass die Anforderungen für eine bestimmte beabsichtigte zukünftige Verwendung oder Anwendung erfüllt wurden.

Verifizierung

Die Bestätigung einer Behauptung durch den Cloud-Anbieter selbst durch Bereitstellung objektiver Nachweise, dass festgelegte Anforderungen erfüllt wurden.

Wesentlicher Mangel/wesentliche falsche Darstellung

Mängel in der Erklärung, z. B.:

1. Informationen weisen darauf hin, dass Kontrollen nicht angemessen ausgestaltet, nicht oder nicht wirksam umgesetzt waren, um die C5-Kriterien mit hinreichender Sicherheit zu erfüllen;
2. Informationen sind falsch oder fehlen, obwohl sie einzeln oder insgesamt für die Cloud-Kunden des Cloud-Anbieters relevant sein können, um die Informationssicherheit des Cloud-Dienstes zu beurteilen; oder
3. Informationen enthalten unangemessene Verallgemeinerungen oder unausgewogene und verzerrende Darstellungen, die die Cloud-Kunden des Cloud-Anbieters in die Irre führen können.

2 Aufbau und inhaltliche Gliederung der Kriterien

2.1 Aufbau

Dieser Kriterienkatalog enthält sogenannte „Rahmenbedingungen“ (vgl. Abschnitt 4) und Kriterien zur Informationssicherheit von Cloud-Diensten (vgl. Abschnitt 5).

Die sogenannten „Rahmenbedingungen“ (vgl. Abschnitt 4) definieren einen besonderen Satz von Kriterien, die für mehr Transparenz über die Rahmenbedingungen des Cloud-Dienstes sowie über die Anforderungen an die Systembeschreibung und die schriftliche Erklärung sorgen sollen (vgl. Abschnitt 3.4.4.2; dieser Abschnitt enthält auch Hinweise zur Erlangung von Nachweisen über die Rahmenbedingungen in einer direkten Prüfung). Diese weiteren Kriterien dienen dazu, Cloud-Kunden über die Informationssicherheit des Cloud-Dienstes zu informieren und sie bei der Bewertung seiner Eignung für ihren individuellen Anwendungsfall zu unterstützen. Diese weiteren Kriterien dienen außerdem der Sicherstellung der Vergleichbarkeit der Berichterstattung, um Cloud-Kunden den Vergleich mehrerer Cloud-Anbieter oder Cloud-Dienste, für die ein C5-Bericht vorliegt, zu erleichtern.

Abschnitt 5 enthält 17 Zielsetzungen hinsichtlich der Informationssicherheit von Cloud-Diensten. Jedes Ziel hat einen eigenen Unterabschnitt, in dem die jeweiligen Kriterien zu finden sind, die zur Erreichung des Ziels erforderlich sind.

Die Kriterien selbst sind in Basiskriterien und Zusatzkriterien (C5-Kriterien) unterteilt. Behandeln die Kriterien mehrere Aspekte zur Erreichung des Ziels, werden sie in Unterkriterien aufgeteilt. Dies geschieht

1. zur Erleichterung der Zuordnung von Kontrollen zu
    1. den Kontrollen des internen Kontrollsystems des Cloud-Anbieters,
    2. korrespondierenden Kontrollen des Cloud-Kunden zu den Kontrollen des Cloud-Anbieters; und
2. zur Erleichterung der Dokumentation von Prüfungshandlungen für Prüferinnen und Prüfer.

Die Gesamtheit aller Basis-Unterkriterien eines Kriteriums (z. B. OIS-01.01B, OIS-01.02B und OIS-01-03B) wird daher als Basiskriterium bezeichnet (in diesem Fall OIS-01). Definitionen und Kontext sind über das gesamte Kriterium hinweg zu verstehen; das heißt, die zu demselben Kriterium gehörenden Unterkriterien sind nicht isoliert, sondern in ihrer Kombination zu betrachten.

Die Zusatz-Unterkriterien werden weiter in schärfende und erweiternde zusätzliche Unterkriterien unterteilt (auch als „verschärfende Zusatz-Unterkriterien“ und „erweiternde Zusatz-Unterkriterien“ bezeichnet). Die Gesamtheit aller zusätzlichen schärfenden und erweiternden Unterkriterien eines Kriteriums wird als Zusatzkriterium bezeichnet (z. B. bezieht sich der Ausdruck „Zusatzkriterium von OIS-01“ auf die Menge aus OIS-01.01AS und OIS-01.01AC). Ein verschärfendes Zusatz-Unterkriterium schärft immer ein bestimmtes Basis-Unterkriterium. Hierzu adressiert es denselben Aspekt zur Erreichung der Zielsetzung des Kriteriums wie das Basis-Unterkriterium, jedoch mit schärferen Sicherheitsanforderungen. Ein verschärfendes Zusatz-Unterkriterium wirkt somit als strengerer Ersatz des Basis-Unterkriteriums, das es schärft. Ein erweiterndes Zusatz-Unterkriterium hingegen erweitert das Basiskriterium, indem es neue Aspekte zur Erreichung des Ziels des Kriteriums einführt, die bislang von keinem der Basis-Unterkriterien behandelt wurden. Ein erweiterndes Zusatz-Unterkriterium wirkt somit als Erweiterung der gesamten Menge der Basis-Unterkriterien seines Kriteriums. Die Definitionen und der Kontext des Basiskriteriums erstrecken sich auch auf das Zusatzkriterium.

Die Basiskriterien spiegeln aus Sicht des BSI das Niveau an Informationssicherheit wider, das ein Cloud-Dienst mindestens bieten muss, wenn Cloud-Kunden mit diesem Informationen verarbeiten, die einen normalen Schutzbedarf haben. Die Basiskriterien bilden den Mindestumfang einer Prüfung nach diesem Kriterienkatalog ab. Nichtsdestotrotz obliegt es den Cloud-Kunden, für ihren individuellen Anwendungsfall

zu bewerten, inwiefern die Basiskriterien den Schutzbedarf ihrer Informationen angemessen reflektieren. Für Cloud-Kunden, deren Informationen einen höheren Schutzbedarf haben, können die Zusatzkriterien einen Ausgangs- bzw. Ansatzpunkt darstellen, um diesen Schutzbedarf gemeinsam mit einer soliden Architektur ihres Cloud-Workloads zu adressieren. Die Identifikation der konkret erforderlichen Zusatzkriterien zur Erfüllung dieses Schutzbedarfs ist ein mögliches Ergebnis der durch den Cloud-Kunden vorgenommenen Bewertung. Cloud-Anbieter können die Zusatzkriterien zusätzlich zu den Basiskriterien in eine Prüfung aufnehmen, um Kunden mit einem höheren Schutzbedarf anzusprechen.

Zusätzlich zu den Basiskriterien, Zusatzkriterien und ergänzenden Informationen enthält der Kriterienkatalog auch korrespondierende Kundenkriterien: Zusätzlich zu den Basiskriterien, Zusatzkriterien und ergänzenden Informationen enthält der Kriterienkatalog auch korrespondierende Kundenkriterien: Die Aufrechterhaltung der Informationssicherheit eines Cloud-Dienstes obliegt nicht alleine dem Cloud-Anbieter. Auch die Kunden müssen den Mitwirkungspflichten in ihrem Verantwortungsbereich nachkommen. Bei Cloud-Diensten für Infrastruktur sind Kunden typischerweise selbst dafür verantwortlich, z. B. Sicherheitsaktualisierungen für das von Ihnen genutzte Betriebssystem einzuspielen, wohingegen diese Verantwortung bei der Nutzung eines Cloud-Dienstes für eine Software typischerweise beim Cloud-Anbieter liegt.

Für ausgewählte C5-Kriterien sind korrespondierende Kriterien für Kunden angegeben, die aufzeigen sollen, wo potentiell Mitwirkungspflichten bestehen. Es handelt sich dabei allerdings um keine abschließende und für alle Cloud-Dienste allgemein gültige Aufstellung. Vielmehr werden folgende Ziele verfolgt:

1. Cloud-Anbieter soll dies beim Erstellen der Systembeschreibung unterstützen, jene C5-Kriterien zu identifizieren, bei denen typischerweise korrespondierende Kontrollen der Cloud-Kunden (CUEC) vorausgesetzt werden, die zusammen mit den Kontrollen des Cloud-Anbieters eingerichtet sein müssen, um die C5-Kriterien zu erfüllen (vgl. Abschnitt 3.4.4.1);
2. Prüferinnen und Prüfer soll dies bei der Prüfung der Systembeschreibung dabei unterstützen, die Angemessenheit der Angaben zu den CUEC zu beurteilen; und
3. Cloud-Kunden soll dies unterstützen die Angaben zu den CUEC in der Systembeschreibung besser zu verstehen und entsprechende Kontrollen einzurichten.

Vertrauen in die Informationssicherheit eines Cloud-Dienstes kann durch detaillierte Angaben über die beim Cloud-Anbieter eingerichteten Kontrollen hergestellt werden. Neben Transparenz hinsichtlich der C5-Kriterien (vgl. Abschnitt 2.3), sind auch die Angaben zu den Rahmenbedingungen des Cloud-Dienstes zu beachten (z. B. Gerichtsstandort des Cloud-Anbieters oder vertragliche Vereinbarungen zur Verfügbarkeit und Störungsbeseitigung). Diese müssen aus Sicht des BSI den potentiellen Kunden eines Cloud-Dienstes bekannt sein, um dessen Eignung für ihren jeweiligen Anwendungsfall beurteilen zu können.

2.2 Inhatliche Gliederung der C5-Kriterien

Die C5-Kriterien gliedern sich in 17 Bereiche, die sich an der Darstellung der Maßnahmenziele aus ISO/IEC 27001:2013 Anhang A orientieren (vgl. Tabelle 2.1).

2.3 Zugrundeliegende Standards und Publikationen

Die C5-Kriterien leiten sich aus Anforderungen ab, die aus national und international etablierten Standards und Publikationen entnommen wurden. Der Detaillierungsgrad geht dabei meist über diese Standards und Publikationen hinaus, um ein hohes Niveau an Transparenz über die Grundsätze, Verfahren und Maßnahmen der Cloud-Anbieter zu erreichen.

Nr.	*Bereich (Kennung)*	*Zielsetzung*
1	Organisation der Informationssicherheit (OIS)	Planung, Umsetzung, Aufrechterhaltung und kontinuierlich Verbesserung eines Rahmenwerks zur Informationssicherheit innerhalb der Organisation.
2	Sicherheitsrichtlinien und Arbeitsanweisungen (SP)	Bereitstellen von Richtlinien und Verfahren bzgl. des Sicherheitsanspruchs und zur Unterstützung der geschäftlichen Anforderungen.
3	Personal (HR)	Sicherstellen, dass Mitarbeiter ihre Aufgaben verstehen, sich ihrer Verantwortung in Bezug auf Informationssicherheit bewusst sind und die Assets der Organisation bei Änderung der Aufgaben oder Beendigung geschützt werden.
4	Asset Management (AM)	Identifizieren der organisationseigenen Assets gewährleisten und ein angemessenes Schutzniveau über deren gesamten Lebenszyklus sicherstellen.
5	Physische Sicherheit (PS)	Verhindern von unberechtigtem physischem Zutritt und Schutz vor Diebstahl, Schaden, Verlust und Ausfall des Betriebs.
6	Regelbetrieb (OPS)	Sicherstellen eines ordnungsgemäßen Regelbetriebs einschließlich angemessener Maßnahmen für Planung und Überwachung der Kapazität, Schutz vor Schadprogrammen, Protokollierung und Überwachung von Ereignissen sowie den Umgang mit Schwachstellen, Störungen und Fehlern.
7	Identitäts- und Berechtigungs-management (IAM)	Absichern der Autorisierung und Authentifizierung von Benutzern des Cloud-Anbieters (in der Regel privilegierte Benutzer) zur Verhinderung von unberechtigten Zugriffen
8	Kryptographie und Schlüsselmanagement (CRY)	Sicherstellen eines angemessenen und wirksamen Gebrauchs von Kryptographie zum Schutz der Vertraulichkeit, Authentizität oder Integrität von Information.
9	Kommunikations-sicherheit (COS)	Sicherstellen des Schutzes von Informationen in Netzen und den entsprechenden informationsverarbeitenden Systemen.
10	Portabilität und Interoperabilität (PI)	Ermöglichen der Eigenschaft, den Cloud-Dienst über andere Cloud-Dienste oder IT-Systemen der Cloud-Kunden ansprechen zu können, die gespeicherten Cloud-Kundendaten bei Beendigung des Auftragsverhältnisses zu beziehen und beim Cloud-Anbieter sicher zu löschen.
11	Beschaffung, Entwicklung und Änderung von Informationssystemen (DEV)	Sicherstellen der Informationssicherheit im Entwicklungszyklus von Systemkomponenten des Cloud-Dienstes.
12	Steuerung und Überwachung von Service-Organisationen und Lieferanten (SSO)	Sicherstellen des Schutzes von Informationen auf die Dienstleister bzw. Lieferanten des Cloud-Anbieters (Service-Organisationen) zugreifen können, sowie Überwachung der vereinbarten Leistungen und Sicherheitsanforderungen.
13	Umgang mit Sicherheitsvorfällen (SIM)	Gewährleisten eines konsistenten und umfassenden Vorgehens zur Erfassung, Bewertung, Kommunikation und Behandlung von Sicherheitsvorfällen.
14	Kontinuität des Geschäftsbetriebs und Notfallmanagement (BCM)	Planen, Implementieren, Aufrechterhalten und Testen von Verfahren und Maßnahmen zur Kontinuität des Geschäftsbetriebs und für das Notfallmanagement

Nr.	*Bereich (Kennung)*	*Zielsetzung*
15	Compliance (COM)	Vermeiden von Verstößen gegen anwendbare gesetzliche, regulatorische, selbstauferlegte oder vertragliche Anforderungen zur Informationssicherheit und Überprüfen der Einhaltung.
16	Umgang mit behördlichen Auskunfts- und Herausgabeverlangen (INQ)	Gewährleisten eines angemessenen Umgangs mit behördlichen Auskunfts- und Herausgabeverlangen hinsichtlich juristischer Überprüfung, Information der Cloud-Kunden und Begrenzung des Zugriffs auf oder der Offenlegung von Cloud-Kundendaten oder abgeleiteten Cloud-Dienstdaten.
17	Produktsicherheit (PSS)	bereitstellen aktueller Informationen zur sicheren Konfiguration und über bekannte Schwachstellen des Cloud-Dienstes für Cloud-Kunden, geeigneter Mechanismen zur Fehlerbehandlung und Protokollierung sowie zur Authentisierung und Autorisierung von Cloud-Nutzern der Cloud-Kunden.

Tabelle 2 Bereiche des Kriterienkatalogs mit zugewiesenen Zielsetzungen

Bei der Entwicklung dieses Kriterienkatalogs wurden Anforderungen aus den folgenden Normen und Veröffentlichungen berücksichtigt:

1. ISO/IEC 27001:2022 - Information security, cybersecurity and privacy protection - Information security management systems - Requirements
2. ISO/IEC 27002:2022 - Information security, cybersecurity and privacy protection - Information security controls
3. ISO/IEC 27017:2015 - Information technology - Security techniques - Code of practice for information security controls based on ISO/IEC 27002 for cloud services
4. BSI - IT-Grundschutz-Kompendium, 2023
5. CSA (Cloud Security Alliance, eine Non-Profit-Organisation zur Verbreitung von Sicherheitsstandards im Cloud Computing) - Cloud Controls Matrix 4.0.12 (CSA CCM)
6. AICPA (American Institute of Certified Public Accountants) - TSP Section 100 - 2027 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy (Aktualisierungen März 2020)
7. ANSSI (Agence nationale de la sécurité des systèmes d'information, Nationale Cybersicherheitsbehörde Frankreichs) - Providers of cloud computing services v. 3.2 (SecNumCloud)
8. IDW (Institut der Wirtschaftsprüfer) RS FAIT 5 - „Grundsätze ordnungsmäßiger Buchführung bei Auslagerung von rechnungslegungsrelevanten Dienstleistungen einschließlich Cloud Computing", Stand 4. November 2015
9. ANHANG „Technical and methodological requirements", C(2024)7151, Durchführungsverordnung zur NIS2-Richtlinie (2022/2555)
10. CEN/TS 18026:2024, „Three-level approach for a set of cybersecurity requirements for cloud services", 2024
11. AC/322-D(2021)0032-REV1, „Technical and Implementation Directive for the Protection of NATO Information within Public Cloud-Based Communication and Information Systems", 2024.

Cloud-Anbietern, die sich bei der Gestaltung ihrer Grundsätze, Verfahren und Maßnahmen bereits an einem oder mehreren dieser Standards und Publikationen orientieren, können diese den C5-Kriterien zuordnen, um die Erfüllung zu beurteilen.

Hinweis: CEN/TS 18026:2024 ist die technische Spezifikation ist, die für das europäische Zertifizierungsschema für Cloud-Dienste (EUCS) erstellt wurde, für welches der C5:2020 die Grundlage für das Niveau „Substantial“ war und die einen wichtigen Zwischenschritt für den vorliegenden C5 darstellte.

Die Zuordnung wird durch Kreuzreferenztabellen unterstützt, die das BSI auf seiner Webseite bereitstellt (https://www.bsi.bund.de/C5). Die Kreuzreferenztabellen sind als Hilfsmittel zu verstehen. Unabhängig von den darin enthaltenen Angaben ist stets im Einzelfall zu beurteilen, ob die eingerichteten Grundsätze, Verfahren und Maßnahmen geeignet sind, die C5-Kriterien zu erfüllen (vgl. Abschnitt 3.4.8).

3 Nachweis der Konformität durch unabhängige Prüfungen

3.1 Einleitung

Das BSI empfiehlt Cloud-Anbietern und Cloud-Kunden die in diesem Kriterienkatalog festgelegten C5-Kriterien zu nutzen. Während Cloud-Anbieter ihre Grundsätze, Verfahren und Maßnahmen an den C5-Kriterien ausrichten können, verfolgen Cloud-Kunden das Ziel zu überprüfen, ob der Cloud-Anbieter diese Kriterien erfüllt. Eine Selbstbewertung für jeden einzelnen Cloud-Kunden wäre für Cloud-Anbieter jedoch nicht effizient und würde den Cloud-Kunden keine ausreichende Sicherheit bieten. Zudem stünde, wenn ein Cloud-Kunde diese Informationen von mehreren Cloud-Anbietern anfordert, kein standardisierter Informationssatz zur Verfügung, was den Vergleich der von den unterschiedlichen Cloud-Anbietern bereitgestellten Informationen erschweren würde. Eine Prüfung durch eine unabhängige dritte Partei, die für den Cloud-Anbieter einen Bericht nach internationalen Prüfungsstandards erstellt, der bestehenden und potenziellen Cloud-Kunden zugänglich gemacht wird, ist eine geeignete und wirtschaftliche Lösung. Aus diesem Grund legt das BSI im Folgenden seine Auffassung zu den Anforderungen an solche Prüfungen dar.

Der Cloud-Kunde sollte die Einhaltung der in diesem Kriterienkatalog festgelegten Kriterien als integralen Bestandteil der Beauftragung eines Cloud-Anbieters betrachten. Das BSI hat eine Excel-basierte Bewertungshilfe veröffentlicht, um Cloud-Kunden bei einer strukturierten Bewertung von C5-Berichten zu unterstützen. Darüber hinaus sollte der Cloud-Kunde dies vertraglich mit dem Cloud-Anbieter vereinbaren. Dies gilt insbesondere dann, wenn der Cloud-Anbieter die Zusatzkriterien erfüllen muss. Für Cloud-Kunden auf Bundesebene der deutschen öffentlichen Verwaltung gilt der „Mindeststandard des BSI zur Nutzung externer Cloud-Dienste“.

Darüber hinaus sollte ein potenzieller Cloud-Kunde seine Entscheidung nicht allein auf eine bestehende, aktuelle Berichterstattung (unabhängig davon, ob sie sich auf die Basiskriterien oder die Zusatzkriterien bezieht) nach diesem Kriterienkatalog stützen, sondern den Prüfbericht regelmäßig anfordern und für den individuellen Anwendungsfall bewerten.

Das BSI ist an keinem Teil der Prüfung oder Berichterstattung beteiligt. Der Prüfer führt die Prüfung unabhängig von Weisungen des BSI durch und wird in der Regel vom Cloud-Anbieter und nicht vom Cloud-Kunden beauftragt.

3.2 Anzuwendende Prüfungsstandards

National und international etablierte Standards bilden die Grundlage für die Ausgestaltung der C5-Kriterien und die Anforderungen an den Nachweis der Konformität. Dies sind:

1. der International Standard on Assurance Engagements (ISAE) 3000 (Revised) „Assurance Engagements Other than Audits or Reviews of Historical Financial Information“,
2. der Deutsche Prüfungsstandard (PS) 860 „IT-Prüfung außerhalb der Abschlussprüfung“ des Instituts der Wirtschaftsprüfer (IDW), der mit ISAE 3000 (Revised) im Einklang steht,
3. oder andere nationale Entsprechungen zu ISAE 3000 (Revised).

Prüfer haben einen dieser Standards oder nationale Entsprechungen als Grundlage für Prüfungsplanung, -durchführung und -berichterstattung heranzuziehen. Prüfer sollten für einzelne Fragestellungen der Prüfungsdurchführung und Berichterstattung sinngemäß weitere Prüfungsstandards berücksichtigen. Hierzu gehören:

1. ISAE 3402 „Assurance Reports on Controls at a Service Organization“,

2. der deutsche IDW PS 951 n.F. „Die Prüfung des internen Kontrollsystems bei Dienstleistungsunternehmen“, der mit ISAE 3402 im Einklang steht,
3. oder andere nationale Entsprechungen zu ISAE 3402.

Der Umfang von Prüfungen nach diesen Standards umfasst die vom Dienstleistungsunternehmen (hier: dem Cloud-Anbieter) konzipierten und implementierten Grundsätze, Verfahren und Maßnahmen, um Cloud-Kunden seine Dienstleistungen bereitzustellen. Sie verlangen vom Dienstleistungsunternehmen zunächst Kontrollziele zu bestimmen und hierzu dann Kontrollen zur Erreichung dieser Kontrollziele zu definieren. Im Kontext von C5 werden die Kontrollziele durch die anzuwendenden C5-Kriterien bestimmt. Im weiteren Kontext des C5 umfassen Kontrollen Aspekte der Kontrollumgebung des Cloud-Anbieters, der Risikobewertung, der Kontrollaktivitäten, der Information und Kommunikation sowie der Überwachungsaktivitäten, die für die Entwicklung und den Betrieb des Cloud-Dienstes entsprechend den Kriterien dieses Katalogs relevant sind. Die Kombination der vorgenannten Aspekte wird auch als „internes Kontrollsystem“ bezeichnet, wie es vom Committee of Sponsoring Organizations of the Treadway Commission (COSO) in seiner Veröffentlichung „Internal Control - Integrated Framework“ beschrieben wird.

3.3 Verhältnis zu anderen Prüfungen

National und international etablierte Standards bilden die Grundlage für die Ausgestaltung der C5-Kriterien (vgl. Abschnitt 2.3). Nutzt der Cloud-Anbieter die Verweise auf etablierte Standards und Veröffentlichungen, hat der Cloud-Anbieter die entsprechenden Grundsätze, Verfahren und Maßnahmen bereits in seinem Betrieb berücksichtigt.

Diese Grundsätze, Verfahren und Maßnahmen bilden typischerweise auch die Grundlage für weitere Prüfungen, für die der Cloud-Anbieter möglicherweise bereits unabhängige Prüfer beauftragt hat. In diesem Zusammenhang sind insbesondere Prüfungen nach ISAE 3402/SOC 1 oder SOC 2 zu nennen. In diesen Fällen ist es effizienter, diese Prüfungen organisatorisch und zeitlich mit einer Prüfung nach diesem Kriterienkatalog abzustimmen. Dies ermöglicht Prüfern und Cloud-Anbietern, Nachweise gleichzeitig für die Berichterstattung nach unterschiedlichen Standards zu nutzen. Im Falle des Erwerbs von Zertifikaten durch den Cloud-Anbieter (z. B. ISO/IEC 27001, ISO 22301) ist es ebenfalls möglich, die entsprechenden Prüfungen in gewissem Umfang zu kombinieren. Zu diesem Zweck kann eine Kreuzreferenztabelle des BSI verwendet werden. Hierfür kann eine Kreuzreferenztabelle des BSI verwendet werden, welche auf dessen Webseite bereitgestellt wird (https://www.bsi.bund.de/C5).

Bei der Beurteilung der Abdeckung von C5-Kriterien durch Ergebnisse aus anderen Prüfungen ist insbesondere die Prüfungsmethodik zu berücksichtigen und mit der für einen Attestierungsauftrag oder einer direkten Prüfung erforderlichen hinreichenden Sicherheit („reasonable assurance“) zu vergleichen (vgl. Abschnitt 3.4.4). So sind beispielsweise Ergebnisse aus ISO-Zertifizierungsaudits anders zu bewerten als solche aus einer ISAE-3000-Prüfung.

In den Kreuzreferenztabellen sind die C5-Kriterien den in anderen Standards definierten Kriterien zugeordnet. Hierbei ist zu berücksichtigen, dass eine Zuordnung zunächst nur die thematische Verwandtschaft der Kriterien widerspiegelt. Zudem ist angegeben, inwiefern die C5-Kriterien aus Sicht des BSI das von den zugeordneten, anderen Kriterien artikulierte Niveau an Informationssicherheit abbilden.

Die Tabellen sind lediglich als Hilfsmittel anzusehen, um in einer ersten Annäherung zu verstehen, inwiefern sich die C5-Kriterien mit den in anderen Standards definierten Kriterien überschneiden. Von den in den Kreuzreferenztabellen angegebenen Zuordnungen kann jedoch nicht vollständig auf die tatsächliche Abdeckung der C5-Kriterien durch bei einem Cloud-Anbieter eingerichtete Grundsätze, Verfahren und Maßnahmen geschlossen werden. Dies gilt auch dann, wenn diese eingerichteten Grundsätze, Verfahren und Maßnahmen bereits einer Prüfung gemäß eines oder mehrerer in den Kreuzreferenztabellen enthaltener Standards unterzogen wurden. Aus Sicht des BSI ist stets individuell und spezifisch zu

ermitteln, inwiefern die von einem Cloud-Anbieter eingerichteten Grundsätze, Verfahren und Maßnahmen die C5-Kriterien tatsächlich abdecken. Der bloße Verweis auf die in anderen Standards definierten Kriterien, denen die C5-Kriterien in den Kreuzreferenztabellen zugeordnet sind, ist daher nicht ausreichend.

Der bloße Verweis auf die in anderen Standards definierten Kriterien, denen die C5-Kriterien in der Kreuzreferenztabelle zugeordnet sind, ist nicht ausreichend.

Die sonstigen Möglichkeiten des Prüfers, im Rahmen seiner Eigenverantwortlichkeit ggf. auch Ergebnisse Dritter zu verwenden, bleiben hiervon unberührt.

3.4 Ergänzende Anforderungen des BSI

Die folgenden Abschnitte skizzieren die ergänzenden Anforderungen des BSI an Konformitätsbewertungen nach diesem Kriterienkatalog. Diese Anforderungen ergänzen und präzisieren die allgemeinen Anforderungen des ISAE 3000 und sinngemäß des ISAE 3402 und sind von Cloud-Anbietern und Prüfern bei der Durchführung von Konformitätsbewertungen auf Grundlage dieses Kriterienkatalogs einzuhalten. Darüber hinaus wurden die Prüfungsstandards AT-C Section 105 „Concepts Common to All Attestation Engagements“ und AT-C Section 205 „Examination Engagements“ des AICPA, des American Institute of Certified Public Accountants, berücksichtigt. Diese Standards ergänzen ISAE 3402 und IDW PS 951 insbesondere um Anforderungen an die Berücksichtigung von Subservice-Organisationen.

3.4.1 Attestierungsauftrag (Assurance Engagement)

Konformitätsbewertungen sind stets in Übereinstimmung mit ISAE 3000 (Revised) oder anderen nationalen Entsprechungen zu ISAE 3000 (Revised), z. B. dem Deutschen Prüfungsstandard (PS) 860, zu erbringen.

ISAE 3000 (Revised) unterscheidet zwischen Attestierungsaufträgen mit „hinreichender Sicherheit“ (reasonable assurance) und Attestierungsaufträgen mit „begrenzter Sicherheit“ (limited assurance). Prüfer haben Attestierungsaufträge (und direkte Prüfungen) mit hinreichender Sicherheit durchzuführen, um die Konformität mit diesem Kriterienkatalog zu bewerten.

Ferner wird zwischen „Prüfung einer Erklärung“ (engl. Attestation Engagements) und „Direkter Prüfung“ (engl. Direct Engagements) unterschieden. Beide Varianten sind geeignet, die Konformität mit diesem Kriterienkatalog zu bewerten. Darüber hinaus können Prüfungen hinsichtlich der Angemessenheit der Ausgestaltung oder der Wirksamkeit von Kontrollen durchgeführt werden. Die Wirksamkeit ist zu bewerten, um ein Urteil zu den Kontrollen des Cloud-Anbieters zur Erfüllung der C5-Kriterien über einen festgelegten Zeitraum hinweg abgeben zu können. Attestierungsaufträge zur Angemessenheit der Ausgestaltung von Kontrollen beschränken sich auf die Ausgestaltung zu einem bestimmten Stichtag. Solche Aufträge dürfen nur im Falle eines Erstauftrags für einen oder mehrere Cloud-Dienste durchgeführt werden, wenn noch keine ausreichenden Nachweise vorliegen, um ein Urteil über die Wirksamkeit über einen festgelegten Zeitraum hinweg abzugeben (z. B. wenn ein neuer Cloud-Dienst für Cloud-Kunden bereitgestellt werden soll). Dementsprechend dürfen Attestierungsaufträge, die sich nur auf die Angemessenheit der Ausgestaltung beziehen, nicht regelmäßig wiederkehrend durchgeführt werden.

3.4.2 Qualifikation des Prüfers

Nach ISAE 3000 (Revised) hat der Prüfer vor Annahme eines Auftrags sicherzustellen, dass die beruflichen Pflichten (für Prüfer in Deutschland § 43 WPO, Wirtschaftsprüferordnung), einschließlich der Unabhängigkeitspflicht, eingehalten werden. Auf Grundlage seiner Kenntnisse des Prüfungsgegenstands hat der Prüfer zu beurteilen, ob die mit dem Auftrag betrauten Mitglieder des Prüfungsteams über die erforderliche Kompetenz und das Verständnis der Branche sowie die Fertigkeit zur Durchführung der Prüfung verfügen und ob ausreichende Erfahrung mit den einschlägigen formalen Anforderungen vorhanden ist oder erlangt werden kann.

Prüfungen auf Grundlage dieses Kriterienkatalogs stellen besondere Anforderungen an die Qualifikation des Prüfers und der Mitglieder des Prüfungsteams. Daher sind die folgenden Aspekte von jenen Mitgliedern des Prüfungsteams zu erfüllen, die nach dem International Standard on Quality Management (ISQM) 1 „Quality Management for Firms that Perform Audits or Reviews of Financial Statements, or Other Assurance or Related Services Engagements“ oder dem deutschen IDW-Qualitätsmanagementstandard „Anforderungen an das Qualitätsmanagement in der Wirtschaftsprüferpraxis“ (IDW QMS 1 (09.2022)) oder anderen nationalen Entsprechungen von ISQM 1 die Durchführung der Prüfung überwachen und die Ergebnisse des Auftrags überprüfen (einschließlich Bewertung der durchgeführten Arbeiten, Durchsicht der Dokumentation und der geplanten Berichterstattung):

1. Mindestens 3 Jahre einschlägige Berufserfahrung mit IT-Prüfungen nach den einschlägigen ISAE-Standards

oder eine der folgenden Berufsprüfungen/Zertifizierungen:

1. Information Systems Audit and Control Association (ISACA) – Certified Information Systems Auditor (CISA), Certified Information Security Manager (CISM) oder Certified in Risk and Information Systems Control (CRISC)
2. ISO/IEC 27001 Lead Auditor oder BSI-zertifizierter ISO-27001-Auditor für Prüfungen auf Basis des BSI IT-Grundschutzes
3. Cloud Security Alliance (CSA) – Certificate of Cloud Security Knowledge (CCSK)
4. (ISC)² – Certified Cloud Security Professional (CCSP)
5. (ISC)² – Certified Information Systems Security Professional (CISSP)

Auf Wunsch des Auftraggebers hat der Prüfer geeignete Nachweise dafür bereitzustellen, dass das Prüfungsteam die Qualifikationsanforderungen erfüllt.

Die Einhaltung der Qualifikationsanforderungen ist im Abschnitt „Unabhängigkeit und Qualitätsmanagement“ des Prüfberichts zu bestätigen.

3.4.3 Anzuwendende Kriterien

Die Basiskriterien spiegeln aus Sicht des BSI das Niveau an Informationssicherheit wider, das ein Cloud-Dienst mindestens bieten muss, wenn Cloud-Kunden mit diesem Informationen verarbeiten, die einen normalen Schutzbedarf haben. Die Basiskriterien bilden den Mindestumfang einer Prüfung nach diesem Kriterienkatalog ab. Nichtsdestotrotz obliegt es den Cloud-Kunden, für ihren individuellen Anwendungsfall zu bewerten, inwiefern die Basiskriterien den Schutzbedarf ihrer Informationen angemessen reflektieren. Für Cloud-Kunden, deren Informationen einen höheren Schutzbedarf haben, können die Zusatzkriterien einen Ausgangs- bzw. Ansatzpunkt darstellen, um diesen Schutzbedarf gemeinsam mit einer soliden Architektur ihres Cloud-Workloads zu adressieren. Die Identifikation der konkret erforderlichen Zusatzkriterien zur Erfüllung dieses Schutzbedarfs ist ein mögliches Ergebnis der durch den Cloud-Kunden vorgenommenen Bewertung.

Cloud-Anbieter können die Zusatzkriterien zusätzlich zu den Basiskriterien in eine Prüfung aufnehmen. Der Cloud-Anbieter ist frei in der Auswahl, welche der Zusatzkriterien in den Umfang einer Prüfung aufgenommen werden. Der Cloud-Anbieter kann auch einzelne zusätzliche Unterkriterien eines Kriteriums in den Prüfungsumfang aufnehmen, ohne den gesamten Satz der zusätzlichen Unterkriterien des Kriteriums einbeziehen zu müssen. Die Auswahl sollte sich jedoch an den vertraglichen Anforderungen mit den Cloud-Kunden orientieren. Wenn die Konformität mit bestimmten vertraglichen Anforderungen durch die Aufnahme zusätzlicher Kriterien oder Unterkriterien in den Umfang nachgewiesen werden könnte, sollten diese Kriterien oder Unterkriterien einbezogen werden. Bezieht der Cloud-Anbieter nur bestimmte Zusatzkriterien oder Unterkriterien ein, ist die Begründung für die Auswahl in der Systembeschreibung darzulegen.

Der Cloud-Anbieter hat die anwendbaren C5-Kriterien in der Systembeschreibung seines internen Kontrollsystems für den Cloud-Dienst darzustellen. Sind einzelne (Unter-)Kriterien nicht anwendbar, muss die Darstellung Begründungen für den Ausschluss enthalten. Begründungen für Ausschlüsse dürfen sich nur auf die Art und Ausgestaltung des Cloud-Dienstes oder auf die Grundsätze, Verfahren und Maßnahmen des Cloud-Anbieters beziehen (z. B. C5-Kriterien, die nur für IaaS gelten, wenn der Cloud-Dienst als SaaS ausgelegt ist). Auf Grundlage der vom Cloud-Anbieter bereitgestellten Informationen hat der Prüfer die sachgerechte Darstellung der Begründungen zu beurteilen. Kriterien dürfen nicht ausgeschlossen werden, weil die Kontrollen des Cloud-Anbieters nicht angemessen ausgestaltet oder nicht wirksam durchgeführt wurden, um diese Kriterien zu erfüllen, oder weil der Cloud-Anbieter nicht willens oder nicht in der Lage ist, die Konformität nachzuweisen.

Wenn ein zusätzlich schärfendes Unterkriterium in die Prüfung aufgenommen und in der Systembeschreibung des internen Kontrollsystems des Cloud-Anbieters für den Cloud-Dienst dargestellt wird, wird das Basis-Unterkriterium, das dadurch geschärft wird, in der Systembeschreibung nicht dargestellt, sondern nur das zusätzlich schärfende Unterkriterium. Das Basis-Unterkriterium wird durch das zusätzlich schärfende Unterkriterium ersetzt. Wenn ein erweiterndes Zusatz-Unterkriterium in die Prüfung aufgenommen wird, werden die Unterkriterien des Basiskriteriums, das dadurch erweitert wird, in der Systembeschreibung in Kombination mit dem erweiternden Zusatz-Unterkriterium dargestellt.

Wenn ein Kriterium einen risikobasierten Ansatz verlangt und die Risikobewertung des Cloud-Anbieters zu dem Ergebnis gekommen ist, dass keine zu mindernden Risiken bestehen, hat der Cloud-Anbieter dies bei der Darstellung der Anwendbarkeit des Kriteriums darzulegen.

3.4.4 Prüfungsgegenstand und Ziel der Prüfung

3.4.4.1 Prüfung einer Erklärung (engl. Attestation Engagement)

Gegenstand der Prüfung sind die Systembeschreibung des internen Kontrollsystems des Cloud-Anbieters, das für die Entwicklung und den Betrieb des Cloud-Dienstes entsprechend den Kriterien dieses Katalogs relevant ist (nachfolgend die „Beschreibung“) und die darin beschriebenen Kontrollen. Die Prüfung basiert auf einer schriftlichen Erklärung der Unternehmensleitung des Cloud-Anbieters (die Erklärung der gesetzlichen Vertreter) über die Angemessenheit der Systembeschreibung und über die Angemessenheit der Ausgestaltung der in der Systembeschreibung dargestellten Kontrollen zur Erfüllung der anwendbaren C5-Kriterien zu einem bestimmten Stichtag (Typ-1-Bericht) oder über die Angemessenheit der Ausgestaltung und die Wirksamkeit der Kontrollen über einen festgelegten Zeitraum hinweg (Typ-2-Bericht). Ziel der Prüfung ist es, dem Prüfer ein Urteil mit hinreichender Sicherheit darüber zu ermöglichen, ob:

1. die Systembeschreibung des internen Kontrollsystems des Cloud-Anbieters, das für die Entwicklung und den Betrieb des Cloud-Dienstes relevant ist und zu dem festgelegten Stichtag (Typ-1-Bericht) oder während des festgelegten Zeitraums (Typ-2-Bericht) konzipiert und implementiert war, entsprechend den in Abschnitt 3.4.13 dieses Katalogs festgelegten Kriterien an die Systembeschreibung sachgerecht darstellt;
2. die in der Systembeschreibung genannten Kontrollen angemessen ausgestaltet waren, um mit hinreichender Sicherheit zu gewährleisten, dass die anwendbaren Kriterien zum festgelegten Stichtag (Typ-1-Bericht) oder (sofern beauftragt) während des festgelegten Zeitraums (Typ-2-Bericht) erfüllt würden, sofern diese Kontrollen zu diesem Stichtag (Typ-1-Bericht) oder während dieses Zeitraums (Typ-2-Bericht) wirksam durchgeführt wurden; und
3. sofern beauftragt (Typ-2-Bericht), die in der Systembeschreibung genannten Kontrollen wirksam durchgeführt wurden, um mit hinreichender Sicherheit zu gewährleisten, dass die anwendbaren Kriterien während des festgelegten Zeitraums erfüllt wurden.

Typ-1-Berichte sind auf den Erstauftrag zu beschränken und dürfen nicht für aufeinanderfolgende Aufträge beauftragt werden. Ist ein Typ-2-Bericht beauftragt, sollte der Mindestzeitraum mindestens drei Monate

umfassen. Bei kürzeren Zeiträumen kann der Prüfer keine ausreichenden Nachweise zur Wirksamkeit der Kontrollen erlangen. Der Höchstzeitraum sollte zwölf Monate nicht überschreiten. In Ausnahmefällen kann der festgelegte Zeitraum über zwölf Monate hinaus verlängert werden, beispielsweise zur besseren Abstimmung mit anderen Prüfungen. Generell wird Konsistenz beim festgelegten Zeitraum empfohlen.

Es kann vorkommen, dass sich das Urteil des Prüfers zur Ausgestaltung und Wirksamkeit der Kontrollen des Cloud-Anbieters auch auf korrespondierende Kontrollen bei Subservice-Organisationen oder bei den Anwenderorganisationen (Cloud-Kunden) bezieht. In diesen Fällen geht der Cloud-Anbieter bei der Ausgestaltung seiner eigenen Kontrollen zur Erfüllung der Kriterien von der wirksamen Durchführung der korrespondierenden Kontrollen bei den Subservice-Organisationen oder den Cloud-Kunden aus. Aufgrund der für Cloud Computing typischen geteilten Zuständigkeiten zwischen dem Cloud-Anbieter, Subservice-Organisationen (z. B. Rechenzentrumsbetreibern; SaaS-Dienst auf einer IaaS-Plattform) und Cloud-Kunden (z. B. Identitäts- und Zugriffsmanagement für Personal, das zur Cloud-Kundenorganisation gehört) ist es wahrscheinlich, dass solche korrespondierenden Kontrollen neben den Kontrollen des Cloud-Anbieters erforderlich sind, um einzelne Kriterien zu erfüllen. Die Prüfungshandlungen des Prüfers erstrecken sich jedoch explizit nicht auf die bei Subservice-Organisationen oder Anwenderorganisationen eingerichteten korrespondierenden Kontrollen, sondern beschränken sich auf deren sachgerechte Darstellung in der Systembeschreibung des Cloud-Anbieters. Zur Berücksichtigung von Kontrollen bei Subservice-Organisationen siehe auch Abschnitt 3.4.6.

Cloud-Anbieter, die bereits eine Systembeschreibung ihres internen Kontrollsystems erstellt haben, können diese in Prüfungen nach diesem Kriterienkatalog wiederverwenden. Eine bestehende Systembeschreibung, die zur Erfüllung der Anforderungen eines anderen Standards erstellt wurde, ist jedoch erforderlichenfalls an die Kriterien an die Systembeschreibung (vgl. Abschnitt 3.4.5.1 „Kriterien an die Systembeschreibung“) dieses Katalogs anzupassen.

3.4.4.2 Direkte Prüfung

Bei einer direkten Prüfung stellt der Cloud-Anbieter, im Gegensatz zur Prüfung einer Erklärung, keine Systembeschreibung bereit. Vielmehr nimmt der Prüfer die vom Cloud-Anbieter für den Cloud-Dienst angewandten Grundsätze, Verfahren und Maßnahmen selbst auf. Das Identifizieren der relevanten Aspekte des internen Kontrollsystems für die Entwicklung und den Betrieb des Cloud-Dienstes erfolgt während der Durchführung des Auftrags. Dies erfordert typischerweise, dass der Prüfer Fachpersonal des Cloud-Anbieters befragt und einschlägige Nachweise und Dokumente einsieht.

Ziel der Prüfung ist es, dem Prüfer zu ermöglichen, mit hinreichender Sicherheit ein Urteil dazu abzugeben, ob

1. die vom Cloud-Anbieter angewandten Grundsätze, Verfahren und Maßnahmen angemessen ausgestaltet waren, um mit hinreichender Sicherheit zu gewährleisten, dass die anwendbaren Kriterien zum festgelegten Stichtag (Typ-1-Bericht) oder (sofern beauftragt) während des festgelegten Zeitraums (Typ-2-Bericht) erfüllt würden, sofern diese Grundsätze, Verfahren und Maßnahmen zu diesem Stichtag (Typ-1-Bericht) oder während dieses Zeitraums (Typ-2-Bericht) wirksam durchgeführt wurden; und
2. sofern beauftragt (Typ-2-Bericht), die vom Cloud-Anbieter angewandten Grundsätze, Verfahren und Maßnahmen wirksam durchgeführt wurden, um mit hinreichender Sicherheit zu gewährleisten, dass die anwendbaren Kriterien während des festgelegten Zeitraums erfüllt wurden.

Typ-1-Berichte sind nur für Erstaufträge vorzuschreiben. Nachfolgende Aufträge erfordern einen Typ-2-Bericht. Ist ein Typ-2-Bericht beauftragt, sollte der Mindestzeitraum mindestens drei Monate umfassen. Bei kürzeren Zeiträumen kann der Prüfer keine ausreichenden Nachweise zur Wirksamkeit der Kontrollen erlangen. Der Höchstzeitraum sollte zwölf Monate nicht überschreiten. In Ausnahmefällen kann der festgelegte Zeitraum über zwölf Monate hinaus verlängert werden, beispielsweise zur besseren Abstimmung mit anderen Prüfungen. Generell wird Konsistenz beim festgelegten Zeitraum empfohlen.

Die direkte Prüfung eignet sich insbesondere für Cloud-Anbieter, die ihr internes Kontrollsystem für die Entwicklung und den Betrieb des Cloud-Dienstes noch nicht hinreichend in einer Systembeschreibung dokumentiert haben. Es ist zu beachten, dass im Falle einer direkten Prüfung der Prüfer auch dafür verantwortlich ist, die im Abschnitt „Informationen zu den Allgemeinen Bedingungen des Cloud-Dienstes“ (vgl. Abschnitt 4) aufgeführten Informationen darzustellen.

3.4.5 Anforderungen an die Systembeschreibung und die Erklärung der gesetzlichen Vertreter

3.4.5.1 Kriterien an die Systembeschreibung

Bei einer Prüfung einer Erklärung ist die Systembeschreibung des internen Kontrollsystems des Cloud-Anbieters, das für die Entwicklung und den Betrieb des Cloud-Dienstes relevant ist (das „System“), in Übereinstimmung mit den folgenden Kriterien an die Systembeschreibung zu erstellen.

1.) Sachgerechte Darstellung des Systems, das zu dem festgelegten Stichtag (Typ-1-Bericht) oder während des festgelegten Zeitraums (Typ-2-Bericht) konzipiert und implementiert war, mit folgendem Mindestinhalt, um Cloud-Kunden ausreichende Transparenz über die Informationssicherheit der im Umfang befindlichen Cloud-Dienste zu geben:

1. Name, Typ und Umfang der bereitgestellten Cloud-Dienste;
2. Beschreibung der Systemkomponenten zur Bereitstellung des Cloud-Dienstes;
3. Informationen zu den allgemeinen Rahmenbedingungen des Cloud-Dienstes gemäß den Kriterien in Abschnitt 4 dieses Kriterienkatalogs, die potenziellen Cloud-Kunden die Beurteilung seiner Eignung für ihren Anwendungsfall ermöglichen;
4. Die anwendbaren C5-Kriterien, einschließlich Begründungen, falls einzelne Kriterien entsprechend den im Abschnitt „Anzuwendende Kriterien“ dargelegten Anforderungen nicht anwendbar sind;
5. Kontrollumgebung, Risikobewertung, Kontrollaktivitäten, Information und Kommunikation sowie Überwachungsaktivitäten, die für die Entwicklung und den Betrieb des Cloud-Dienstes gemäß den anwendbaren Kriterien relevant sind;
6. Umgang mit wesentlichen Ereignissen und Bedingungen, die Ausnahmen vom Normalbetrieb darstellen, wie Sicherheitsvorfälle oder der Ausfall von Systemkomponenten;
7. Korrespondierende Kundenkontrollen (auch als Complementary User Entity Controls (CUEC) bezeichnet), die bei der Ausgestaltung der Kontrollen des Cloud-Anbieters vorausgesetzt werden; und
8. Funktionen und Dienstleistungen in Bezug auf die anwendbaren C5-Kriterien, die von Subservice-Organisationen erbracht werden, einschließlich
    1. Art der von der Subservice-Organisation erbrachten Dienstleistungen, einschließlich (1) des Namens des Unternehmens, mit dem ein Vertragsverhältnis für die erbrachten Dienstleistungen besteht, (2) des Ortes der Verarbeitung und Speicherung von Daten, (3) der Bewertung der Komplexität und Einzigartigkeit der erbrachten Dienstleistungen sowie der daraus resultierenden Abhängigkeit des Cloud-Anbieters von der Subservice-Organisation und (4) der Verfügbarkeit von Prüfberichten nach den Kriterien dieses Katalogs;
    2. der Arten von Kontrollen, die bei der Subservice-Organisation erwartet werden und die in Kombination mit Kontrollen beim Cloud-Anbieter erforderlich sind, um mit hinreichender Sicherheit zu gewährleisten, dass die anwendbaren C5-Kriterien erreicht wurden; und
    3. der Kontrollen beim Cloud-Anbieter, die verwendet werden, um die Wirksamkeit der Kontrollen der Subservice-Organisation gemäß Kriterium SSO-05 zu überwachen.

Im Falle eines Typ-2-Berichts sind außerdem die folgenden Inhalte aufzunehmen:

1. Angaben zu wesentlichen Änderungen des für die C5-Kriterien relevanten internen Kontrollsystems des Cloud-Anbieters, die während des festgelegten Zeitraums implementiert wurden;
2. Angaben zu wesentlichen Ereignissen und Bedingungen, die Ausnahmen vom Normalbetrieb darstellen, die während des festgelegten Zeitraums eingetreten sind und dazu geführt haben, dass:
    1. vertragliche Vereinbarungen über die Verfügbarkeit des Cloud-Dienstes nicht erfüllt wurden, oder
    2. unbefugte Dritte Zugang zu Daten von Cloud-Kunden erhalten haben, oder
    3. die Integrität der Daten der Cloud-Kunden beeinträchtigt wurde oder die eingerichteten Schutzmaßnahmen (z. B. Datensicherung) nicht wirksam waren,
3. sowie die vom Cloud-Anbieter eingeleiteten Maßnahmen, um solche Ereignisse und Bedingungen künftig zu verhindern.

Ereignisse und Bedingungen sind typischerweise wesentlich, wenn sie mehrere Cloud-Kunden betreffen und der Cloud-Anbieter die betroffenen Parteien oder die Öffentlichkeit informiert. Die Informationen über die Ereignisse und Bedingungen sowie die eingerichteten Schutzmaßnahmen sollten so transparent wie möglich sein, ohne Schwachstellen oder potenzielle Angriffspunkte offenzulegen. Darüber hinaus dürfen die in der Systembeschreibung dargestellten Einzelheiten die Informationssicherheit einzelner Cloud-Kunden nicht gefährden und sollten daher keine detaillierte Beschreibung einzelner Ereignisse und Konditionen enthalten.

2.) Die Systembeschreibung darf keine für die Erfüllung der anwendbaren C5-Kriterien relevanten Informationen auslassen oder verfälschen, wobei anzuerkennen ist, dass die Systembeschreibung erstellt wird, um den gemeinsamen Bedürfnissen eines breiten Kreises von Cloud-Kunden (vorgesehene Nutzer des Berichts) zu entsprechen und daher möglicherweise nicht jeden Aspekt des Systems enthält, den jede einzelne Person innerhalb dieser Cloud-Kunden für ihre eigenen spezifischen Bedürfnisse als wichtig ansehen könnte.

Im Falle einer direkten Prüfung hat der Prüfer das System des Cloud-Anbieters in allen wesentlichen Aspekten als Teil des Prüfberichts darzustellen, damit die vorgesehenen Nutzer des Berichts ein angemessenes Verständnis der Informationssicherheit des Cloud-Dienstes erlangen können.

3.4.5.2 Erklärung der gesetzlichen Vertreter (engl. Management Statement)

Die Unternehmensleitung des Cloud-Anbieters hat eine schriftliche Erklärung abzugeben, mit der sie nach bestem Wissen und Gewissen bestätigt, dass:

1. die Beschreibung das System des Cloud-Anbieters, das zu dem festgelegten Stichtag (Typ-1-Bericht) oder während des festgelegten Zeitraums (Typ-2-Bericht) konzipiert und implementiert war, entsprechend den im Abschnitt „Kriterien an die Systembeschreibung“ dieses Katalogs festgelegten Kriterien an die Systembeschreibung sachgerecht darstellt;
2. die in der Systembeschreibung genannten Kontrollen angemessen ausgestaltet waren, um mit hinreichender Sicherheit zu gewährleisten, dass die anwendbaren Kriterien zum festgelegten Stichtag (Typ-1-Bericht) oder (sofern beauftragt) während des festgelegten Zeitraums (Typ-2-Bericht) erfüllt würden, sofern diese Kontrollen zu diesem Stichtag (Typ-1-Bericht) oder während dieses Zeitraums (Typ-2-Bericht) wirksam durchgeführt wurden.

Die Erklärung der gesetzlichen Vertreter soll auf der Grundlage der folgenden Kriterien abgegeben werden:

1. Die Risiken, die die Erfüllung der anwendbaren Kriterien gefährden, wurden identifiziert;

2. Die in der Systembeschreibung identifizierten Kontrollen, sofern sie wirksam durchgeführt werden, gewährleisten mit hinreichender Sicherheit, dass diese Risiken die Erfüllung der anwendbaren Kriterien nicht verhindern.
3. Sofern beauftragt (Typ-2-Bericht), wurden die in der Systembeschreibung genannten Kontrollen wirksam durchgeführt, um mit hinreichender Sicherheit zu gewährleisten, dass die anwendbaren Kriterien während des festgelegten Zeitraums erfüllt wurden. Das für diese Erklärung anzuwendende Kriterium ist, dass die Kontrollen wie konzipiert konsequent angewendet wurden, einschließlich der Frage, ob manuelle Kontrollen von Personen mit angemessener Kompetenz und Befugnis ausgeführt wurden.

Deckt die Erklärung der gesetzlichen Vertreter einen Zeitraum von mehr als zwölf Monaten ab, hat die Unternehmensleitung den Grund hierfür anzugeben.

Die Unternehmensleitung des Cloud-Anbieters muss über eine angemessene Grundlage für ihre schriftliche Erklärung verfügen. Im Falle eines Typ-2-Berichts kann diese Erklärung auf den Überwachungsaktivitäten des Cloud-Anbieters zur Wirksamkeit der Kontrollen über den zu prüfenden Zeitraum beruhen. Dies umfasst das Identifizieren und Melden von Mängeln an die zuständigen Personen innerhalb der Organisation des Cloud-Anbieters sowie die Einleitung notwendiger Korrekturmaßnahmen. Der Cloud-Anbieter kann die Überwachung der Kontrollen durch laufende Aktivitäten, spezifische Bewertungen oder einer Kombination aus beidem durchführen. Die Innenrevision oder Mitarbeiter mit ähnlichen Funktionen können zu solchen Aktivitäten beitragen. Dies kann auch die Nutzung von Informationen umfassen, die von externen Parteien übermittelt werden, wie z.B. Kundenbeschwerden und Hinweise von Aufsichtsbehörden, die auf Probleme hinweisen oder Verbesserungsbedarf aufzeigen können. Der Umstand, dass der Prüfer über die Wirksamkeit der Kontrollen berichten wird, ersetzt nicht die eigenen Prozesse des Cloud-Anbieters, die eine angemessene Grundlage für seine Erklärung bilden.

3.4.6 Berücksichtigung von Dienstleistungsunternehmen (Service-Organisationen)

Soweit erforderlich, wird der Cloud-Anbieter Teile seiner Geschäftsprozesse für die Entwicklung oder den Betrieb des Cloud-Dienstes an andere Geschäftspartner, Lieferanten oder sonstige Dritte (vgl. Definition Service-Organisation) auslagern. Der Cloud-Anbieter hat diese in seiner Systembeschreibung darzulegen, indem entweder die „Inclusive Methode“ oder die „Carve-out Methode“ angewandt wird (vgl. Abschnitt „Definition“); der Prüfer hat dies entsprechend zu berücksichtigen.

Für die Zwecke dieses Kriterienkatalogs ist eine Service-Organisation des Cloud-Anbieters als Subservice-Organisation anzusehen, wenn die folgenden Merkmale kumulativ vorliegen:

1. Die von der Service-Organisation erbrachten Leistungen sind voraussichtlich relevant für das Verständnis der Cloud-Kunden hinsichtlich der Architektur des Cloud-Dienstes und dafür, wie der Cloud-Anbieter die anwendbaren C5-Kriterien erfüllt. Eine Leistung ist voraussichtlich relevant, wenn die Service-Organisation (zu) Systemkomponenten des Cloud-Dienstes beiträgt oder Zugriff auf diese hat oder auf vertrauliche Informationen zugreifen oder Informationen zwischen sich und dem Cloud-Dienst übertragen kann.
2. Korrespondierende Kontrollen der Subservice-Organisation (CSOC) bei der Service-Organisation sind in Kombination mit den Kontrollen des Cloud-Anbieters erforderlich, um die anwendbaren C5-Kriterien mit hinreichender Sicherheit zu erfüllen.

Erfüllen die Kontrollen des Cloud-Anbieters einschließlich seiner Kontrollen zur Überwachung der Wirksamkeit der Kontrollen der Service-Organisation die anwendbaren C5-Kriterien mit hinreichender Sicherheit, ist die Service-Organisation keine Subservice-Organisation im Sinne dieses Kriterienkatalogs.

Wird der Cloud-Dienst in von Dritten betriebenen Rechenzentren erbracht, ist grundsätzlich davon auszugehen, dass die vorgenannten Merkmale vorliegen und ein Subservice-Organisationsverhältnis im Sinne dieses Kriterienkatalogs besteht, insbesondere in Bezug auf Kriterien im Bereich „Physische Sicherheit

(PS)“. Gleiches gilt beispielsweise für den Bereich „Regelbetrieb (OPS)“, wenn Infrastrukturen oder Plattformen eines anderen Cloud-Anbieters genutzt werden, um den Cloud-Dienst bereitzustellen. Das Merkmal der Relevanz für das Verständnis des Cloud-Kunden sowie die Erforderlichkeit von CSOC liegen beispielsweise bei Geschäftsbeziehungen des Cloud-Anbieters mit Reinigungsunternehmen oder Werbeagenturen in der Regel nicht vor.

Der Cloud-Anbieter hat Überwachungsaktivitäten für Subservice-Organisationen gemäß den im Bereich „Steuerung und Überwachung von Service-Organisationen und Lieferanten“ in Abschnitt 5.12 dieses Katalogs festgelegten Kriterien, insbesondere Kriterium SSO-05, durchzuführen. Dies soll sicherstellen, dass der Cloud-Anbieter der Konformität mit bestimmten Kriterien dieses Katalogs Aufmerksamkeit widmet, auch wenn er die Carve-out Methode anwendet. Der Cloud-Anbieter bleibt stets dafür verantwortlich, sicherzustellen, dass die Entwicklung und der Betrieb des Cloud-Dienstes die anwendbaren C5-Kriterien erfüllen.

Der Cloud-Anbieter hat die folgenden Informationen in der Systembeschreibung offenzulegen, wie im Abschnitt „Kriterien an die Systembeschreibung“ dieses Katalogs festgelegt:

1. die Art der von der Subservice-Organisation erbrachten Dienstleistungen, einschließlich
    1. Name des Unternehmens, mit dem ein Vertragsverhältnis für die erbrachten Dienstleistungen besteht;
    2. Ort der Verarbeitung und Speicherung von Daten (Angaben auf Länderebene sind ausreichend);
    3. Bewertung der Komplexität und Einzigartigkeit der erbrachten Dienstleistungen sowie der daraus resultierenden Abhängigkeit des Cloud-Anbieters von der Subservice-Organisation (z. B. dargestellt als „Niedrig“, „Mittel“, „Hoch“, „Sehr hoch“ einschließlich einer Begründung für die Bewertung);
2. die Arten von Kontrollen, die bei der Subservice-Organisation erwartet werden (korrespondierende Kontrollen; CSOCs) und die in Kombination mit Kontrollen beim Cloud-Anbieter erforderlich sind, um mit hinreichender Sicherheit zu gewährleisten, dass die anwendbaren C5-Kriterien erfüllt werden; und
3. die Kontrollen beim Cloud-Anbieter, die gemäß Kriterium SSO-05 verwendet werden, um die Wirksamkeit der Kontrollen der Subservice-Organisation zu überwachen.

Im Falle einer direkten Prüfung, bei dem keine vom Cloud-Anbieter erstellte Systembeschreibung vorliegt, hat der Prüfer die vorgenannten Informationen darzustellen.

3.4.7 Erlangung von Prüfevidenzen hinsichtlich der Systembeschreibung

Der Prüfer hat die Anforderungen von ISAE 3402.21-22 einzuhalten, gemäß derer der Prüfer die Systembeschreibung des Cloud-Anbieters einzuholen und zu lesen sowie zu beurteilen hat, ob die in den Umfang des Auftrags fallenden Aspekte der Systembeschreibung sachgerecht dargestellt sind. Besondere Aufmerksamkeit ist dem Mindestinhalt der Systembeschreibung zu widmen, wie er im Abschnitt „Kriterien an die Systembeschreibung“ dargelegt ist.

Ferner verlangt dies, dass der Prüfer durch andere Prüfungshandlungen in Verbindung mit Befragungen feststellt, ob das System des Cloud-Anbieters implementiert wurde.

Diese anderen Prüfungshandlungen haben Beobachtungen und die Einsichtnahme in Aufzeichnungen und andere Dokumentationen über die Art und Weise zu umfassen, wie das System des Cloud-Anbieters funktioniert und wie Kontrollen angewendet werden.

Eine Darstellung gilt nur dann als sachgerecht, wenn sie in Übereinstimmung mit den im Abschnitt „Kriterien an die Systembeschreibung“ dargestellten Anforderungen dieses Katalogs erstellt wurde. Dies

erfordert unter anderem, dass sie Informationen zu den allgemeinen Rahmenbedingungen des Cloud-Dienstes gemäß den Kriterien in Abschnitt 4 sowie spezifische Informationen zu Subservice-Organisationen enthält.

3.4.8 Beurteilung der Erfüllung der C5-Kriterien

Der Prüfer hat die Erfüllung jedes Kriteriums zu beurteilen, indem er die Kombination der jedem Kriterium zugeordneten Kontrollen und deren Beitrag zur Erfüllung der entsprechenden Unterkriterien betrachtet. Die in der Systembeschreibungs des Cloud-Anbieters dargestellten Kontrollbeschreibungen decken möglicherweise nicht alle Elemente der C5-Kriterien ab, denen sie zugeordnet sind. Dies kann insbesondere dann der Fall sein, wenn der Cloud-Anbieter bereits Prüfungen gemäß anderer Standards und Veröffentlichungen durchführt und seine Kontrollen nicht vollständig an die Kriterien dieses Katalogs angepasst hat.

Der Prüfer hat dem Cloud-Anbieter identifizierte Lücken hinsichtlich derjenigen Elemente der C5-Kriterien anzuzeigen, die durch Kontrollen nicht vollständig erfüllt werden.

Kann der Cloud-Anbieter diese Lücken schließen, indem er Nachweise für zusätzliche, bisher nicht in der Systembeschreibung genannte Kontrollen vorlegt, hat der Cloud-Anbieter diese Kontrollen in die Beschreibung seines Systems aufzunehmen. Eine Anpassung der Systembeschreibung einer Kontrolle kann entfallen, wenn aus den Beschreibungen der Prüfungshandlungen des Prüfers klar hervorgeht, wie diejenigen Elemente der C5-Kriterien, die durch die Kontrollbeschreibung nicht vollständig erfüllt wurden, dennoch adressiert sind. Solche Prüfungshandlungen sind im Bericht in geeigneter Form darzustellen (z. B. „Beurteilung der Erfüllung der C5-Kriterien“).

Kann der Cloud-Anbieter die Lücke nicht schließen, hat der Prüfer seine Beurteilung im Prüfbericht hinsichtlich der C5-Kriterien, die durch Kontrollen nicht vollständig erfüllt werden, einzuschränken. In solchen Fällen hat der Prüfer zu dem Urteil zu kommen, dass die betreffenden Kontrollen nicht angemessen ausgestaltet sind.

3.4.9 Erlangung von Prüfevidenzen hinsichtlich der Ausgestaltung von Kontrollen

Der Prüfer hat festzustellen, ob die Kontrollen des Cloud-Anbieters zur Erfüllung der anwendbaren C5-Kriterien angemessen ausgestaltet waren. Eine Kontrolle ist angemessen ausgestaltet, wenn sie für sich genommen oder in Kombination mit anderen Kontrollen, bei zufriedenstellender Durchführung, mit hinreichender Sicherheit gewährleistet, dass die C5-Kriterien, auf die sie sich bezieht, erfüllt werden. Bei der Beurteilung, ob Kontrollen angemessen ausgestaltet sind, sollte der Prüfer Folgendes berücksichtigen:

1. ob die Kontrolle (gegebenenfalls in Kombination mit anderen Kontrollen) die Elemente der C5-Kriterien, auf die sie sich bezieht, auf Ebene der Unterkriterien adressiert (die Kontrolle ist den in den Unterkriterien festgelegten Maßnahmen angemessen);
2. ob, wenn ein Kriterium einen risikobasierten Ansatz verlangt, die Risikobewertung des Cloud-Anbieters angemessen durchgeführt wurde, wobei die Vollständigkeit und Genauigkeit der von der Unternehmensleitung identifizierten Bedrohungen und Schwachstellen mit der eigenen Risikobewertung des Prüfers verglichen werden;
3. die Häufigkeit oder den Zeitpunkt des Auftretens oder der Durchführung der Kontrolle;
4. die Befugnis und Kompetenz der für die Durchführung der Kontrolle verantwortlichen Person (beispielsweise die hierarchische Ebene der Person, die Rolle der Person in der Organisation und in Konflikt stehenden Aufgaben);
5. die im Rahmen der Kontrolle durchgeführten Tätigkeiten sowie die Genauigkeit und Fehleranfälligkeit dieser Tätigkeiten (zum Beispiel die Ergebnisse von Überprüfungen und damit zusammenhängende Folgeaktivitäten);

6. ob die bei der Durchführung der Kontrollen verwendeten Informationen zuverlässig sind;
7. ob die Kontrolle angemessen angepasst und weiterentwickelt wird, z. B. wenn sich die Organisation des Cloud-Anbieters verändert oder neue Risiken, Bedrohungen und Schwachstellen adressiert werden müssen;
8. ob die Kontrolle wie in der Systembeschreibung des Cloud-Anbieters dargestellt zum festgelegten Stichtag (Typ-1-Bericht) oder während des festgelegten Zeitraums (Typ-2-Bericht) implementiert ist.

3.4.10 Erlangung von Prüfevidenzen hinsichtlich der Wirksamkeit von Kontrollen

Der Prüfer hat die Anforderungen von ISAE 3402.24-29 einzuhalten.

3.4.11 Erwägungen für Erstaufträge

Wenn der Cloud-Dienst noch nicht Gegenstand eines Attestierungsauftrags nach diesem Katalog war (z. B. neu entwickelter Cloud-Dienst), sind Kontrollen möglicherweise zum festgelegten Stichtag (Typ-1-Bericht) oder während des festgelegten Zeitraums (Typ-2-Bericht) noch nicht durchgeführt. Der Cloud-Anbieter kann Nachweise für solche Kontrollen wie folgt vorlegen:

1. Sind Kontrollen noch nicht vollständig durchgeführt (z. B. Abschluss der Business Impact Analyse in allen Organisationseinheiten, Disaster-Recovery-Tests), kann der Cloud-Anbieter die Einrichtung solcher Kontrollen z. B. durch Nachweise über die Planung solcher Aktivitäten oder durch Vorlagen für deren Dokumentation belegen.
2. Wurden Kontrollen in einer Produktionsumgebung noch nicht durchgeführt, kann der Cloud-Anbieter Nachweise für solche Kontrollen in einer Nicht-Produktionsumgebung vorlegen, die so konfiguriert ist, als wäre sie eine Produktionsumgebung.

Es ist nicht erforderlich, vor einem Typ-2-Bericht zunächst einen Typ-1-Bericht zu erlangen. Typ-1-Berichte sind auf den Erstauftrag zu beschränken und dürfen nicht für aufeinanderfolgende Aufträge beauftragt werden. Ist ein Typ-2-Bericht beauftragt, sollte der Mindestzeitraum mindestens drei Monate umfassen. Bei kürzeren Zeiträumen kann der Prüfer keine ausreichenden Nachweise zur Wirksamkeit der Kontrollen erlangen. Der Höchstzeitraum sollte zwölf Monate nicht überschreiten. In Ausnahmefällen kann der festgelegte Zeitraum über zwölf Monate hinaus verlängert werden, beispielsweise zur besseren Abstimmung mit anderen Prüfungen. Generell wird Konsistenz beim festgelegten Zeitraum empfohlen.

3.4.12 Umgang mit Abweichungen

In Übernahme der Anforderungen aus ISAE 3402.55 gilt: Wenn der Prüfer zu dem Urteil kommt, dass

1. die Systembeschreibung des Cloud-Anbieters das System in allen wesentlichen Belangen nicht sachgerecht so darstellt, wie es konzipiert und implementiert wurde;
2. die anwendbaren C5-Kriterien durch Kontrollen nicht vollständig erfüllt wurden, was u.a. anzunehmen ist, wenn eines der zu einem Kriterium gehörenden Unterkriterien nicht erfüllt ist;
3. die mit den anwendbaren C5-Kriterien zusammenhängenden Kontrollen in allen wesentlichen Belangen nicht angemessen ausgestaltet waren;
4. im Falle eines Typ-2-Berichts die getesteten Kontrollen in allen wesentlichen Belangen nicht wirksam durchgeführt wurden; oder
5. der Prüfer keine ausreichenden geeigneten Nachweise erlangen kann,

dann ist das Urteil des Prüfers einzuschränken oder zu versagen, und der Prüfbericht hat einen Abschnitt mit einer klaren Beschreibung aller Gründe für die Einschränkung oder Versagung zu enthalten.

Für jede festgestellte Abweichung hinsichtlich der Systembeschreibung, hinsichtlich der Ausgestaltung von Kontrollen oder hinsichtlich ihrer Durchführung soll der Prüfer die folgenden Prüfungsschritte berücksichtigen, um festzustellen, ob das Urteil einzuschränken ist:

1. Befragung der Unternehmensleitung des Cloud-Anbieters zur Ursachenanalyse der festgestellten Abweichung;
2. Beurteilung des Umgangs des Cloud-Anbieters mit der festgestellten Abweichung;
3. Beurteilung, ob solche Abweichungen durch die Überwachungsaktivitäten des Cloud-Anbieters identifiziert wurden und welche Korrekturmaßnahmen infolgedessen ergriffen wurden; und
4. Beurteilung, ob kompensierende Kontrollen angemessen ausgestaltet und, sofern beauftragt (Typ-2-Bericht), wirksam durchgeführt werden, um die aus der Abweichung resultierenden Risiken so zu adressieren, dass das C5-Kriterium weiterhin mit hinreichender Sicherheit erfüllt ist. Dies betrifft beispielsweise die Beurteilung alternativer organisatorischer und technischer Maßnahmen des Cloud-Anbieters zur Erfüllung der anwendbaren C5-Kriterien, die bei der Ausgestaltung der in diesem Kriterienkatalog festgelegten Kriterien nicht berücksichtigt wurden.

Die durchgeführten Prüfungsschritte und deren Ergebnisse sollten im Prüfbericht dargestellt werden, unabhängig von der Beurteilung, ob das Urteil eingeschränkt werden muss. Diese Informationen sollen es den festgelegten Parteien ermöglichen, die Auswirkungen der Abweichung auf ihre Risikobewertungen zu bestimmen.

Die folgenden zusätzlichen Informationen des Cloud-Anbieters sind in den Prüfbericht aufzunehmen:

1. Falls die Abweichung vom Cloud-Anbieter selbst entdeckt wurde, wann und mittels welcher Maßnahmen dies geschehen ist.
2. Falls die Abweichung bereits in einem früheren Prüfbericht gemäß dieses Katalogs dargestellt wurde, ein Verweis auf diesen Bericht und eine Erläuterung, warum die Abweichung noch nicht Gegenstand wirksamer korrektiver und präventiver Maßnahmen war.
3. Geplante oder ergriffene korrektive und präventive Maßnahmen zur Beseitigung der Ursachen der Abweichung und zur Verhinderung des Auftretens solcher Abweichungen in der Zukunft, einschließlich des Zeitpunkts, zu dem diese Maßnahmen voraussichtlich abgeschlossen oder wirksam umgesetzt sein werden.

Diese zusätzlichen Informationen sind nicht Gegenstand der Prüfung; dementsprechend gibt der Prüfer hierzu kein Urteil ab. Die Informationen sind in einem gesondert gekennzeichneten Abschnitt des Prüfberichts bereitzustellen, z. B. „Sonstige vom Cloud-Anbieter bereitgestellte Informationen“ (vgl. den folgenden Abschnitt „Berichterstattung“).

3.4.13 Berichterstattung

Die Berichterstattung über eine Prüfung einer Erklärung basiert auf den Anforderungen von ISAE 3402.53. Im Falle einer direkten Prüfung sind diese sinngemäß anzuwenden. Einzelheiten sind im folgenden Abschnitt dargestellt.

Der Bericht über eine Prüfung einer Erklärung hat die folgenden Elemente zu enthalten:

1. **Prüfungsbericht des unabhängigen Wirtschaftsprüfers bei einem Attestierungsauftrag mit hinreichender Sicherheit**
    1. Auftrag und Gegenstand

       In diesem Abschnitt hat der Prüfer auf die vom Cloud-Anbieter erstellte Systembeschreibung und die Erklärung der gesetzlichen Vertreter Bezug zu nehmen.

Geht aus der Systembeschreibung hervor, dass korrespondierende Kontrollen der Cloud-Kunden notwendig sind, hat der Prüfer zu erläutern, dass er die Angemessenheit der Ausgestaltung oder die Wirksamkeit dieser Kontrollen der Cloud-Kunden nicht bewertet hat und dass die in der Systembeschreibung des Cloud-Anbieters genannten anwendbaren C5-Kriterien nur dann erfüllt werden können, wenn diese korrespondierenden Kontrollen der Cloud-Kunden angemessen ausgestaltet und wirksam durchgeführt werden – zusammen mit den Kontrollen des Cloud-Anbieters.

Werden Leistungen von Subservice-Organisationen erbracht, sind die Art der von den Subservice-Organisationen erbrachten Tätigkeiten, wie in der Systembeschreibung des Cloud-Anbieters dargestellt, sowie die in Bezug auf sie angewandte Carve-out Methode oder Inclusive Methode anzugeben. Wurde die Carve-out Methode angewandt, ist zu erläutern, dass sich die Prüfungshandlungen des Prüfers nicht auf korrespondierende Kontrollen bei der Subservice-Organisation erstrecken und dass die in der Systembeschreibung des Cloud-Anbieters genannten anwendbaren C5-Kriterien nur dann erfüllt werden können, wenn korrespondierende Kontrollen der Subservice-Organisation angemessen ausgestaltet sind oder wirksam durchgeführt werden – zusammen mit den Kontrollen des Cloud-Anbieters. Wurde die Inclusive Methode angewandt, ist eine Erklärung aufzunehmen, dass die Systembeschreibung des Cloud-Anbieters die Kontrollen bei den Subservice-Organisationen einschließt und dass sich die Prüfungshandlungen des Prüfers auf Kontrollen bei den Subservice-Organisationen erstreckten.

2. Verantwortlichkeiten des Cloud-Anbieters

   Eine Erläuterung, dass der Cloud-Anbieter verantwortlich ist für:

   1. das Erstellen der Beschreibung seines Systems und der Erklärung, einschließlich der Vollständigkeit, Richtigkeit und der sachgerechten Darstellung, in der Systembeschreibung und der Erklärung;
   2. das Erbringen der von der Systembeschreibung dargestellten Cloud-Dienste;
   3. die Auswahl und Darstellung der in der Systembeschreibung genannten anwendbaren C5-Kriterien;
   4. das Identifizieren der Risiken, welche die Erfüllung der anwendbaren C5-Kriterien gefährden; und
   5. das Gestalten, Implementieren, Aufrechterhalten, Überwachen und Dokumentieren von Kontrollen, die angemessen ausgestaltet sind und – im Falle eines Typ-2-Berichts – wirksam durchgeführt werden, um die in der Systembeschreibung genannten anwendbaren C5-Kriterien zu erfüllen.

3. Unabhängigkeit und Qualitätsmanagement

   Eine Erläuterung, dass die Prüfungsgesellschaft:

   1. die Unabhängigkeitsanforderungen und sonstigen ethischen Anforderungen des International Code of Ethics for Professional Accountants (including International Independence Standards) des International Ethics Standards Board for Accountants (IESBA Code) einhält, der auf den Grundprinzipien Integrität, Objektivität, fachliche Kompetenz und Sorgfalt, Vertraulichkeit sowie berufliches Verhalten beruht;
   2. den International Standard on Quality Management (ISQM) 1 oder andere berufsrechtliche Anforderungen oder gesetzliche/regulatorische Anforderungen anwendet, die mindestens ebenso anspruchsvoll sind wie ISQM 1; und
   3. die ergänzenden Anforderungen an die Qualifikation des Prüfungsteams gemäß dem Abschnitt „Qualifikation des Prüfers“ dieses Katalogs eingehalten hat.

Ist der Prüfer kein Wirtschaftsprüfer bzw. keine Wirtschaftsprüfungsgesellschaft, hat die Erklärung die angewandten berufsrechtlichen Anforderungen oder gesetzlichen/regulatorischen Anforderungen zu benennen, die mindestens ebenso anspruchsvoll sind wie der IESBA Code und ISQM 1.

4. Verantwortung des Prüfers

   Eine Erläuterung, dass es die Verantwortung des Prüfers ist, auf Grundlage seiner Prüfungshandlungen ein Urteil zur Systembeschreibung des Cloud-Anbieters sowie zur Ausgestaltung der Kontrollen zur Erfüllung der anwendbaren C5-Kriterien und – im Falle eines Typ-2-Berichts – zur Wirksamkeit dieser Kontrollen abzugeben.

5. Inhärente Grenzen von Kontrollen bei Cloud-Anbietern

   Eine Erläuterung der Grenzen von Kontrollen und – im Falle eines Typ-2-Berichts – zum Risiko, Bewertungen der Wirksamkeit von Kontrollen auf künftige Zeiträume zu projizieren.

6. Urteil

   Urteil des Prüfers entsprechend den im Abschnitt „Prüfungsgegenstand und Ziele der Prüfung“ dieses Katalogs festgelegten Zielen.

7. Verwendungsbeschränkung

   Eine Erläuterung der festgelegten Adressaten, die als vorgesehene Nutzer des Berichts betrachtet werden. Adressaten im Kontext dieses Katalogs sind Cloud-Kunden und potenzielle Cloud-Kunden, ihre unabhängigen Prüfer, die Dienstleistungen für solche (potentiellen) Cloud-Kunden erbringen, sowie Aufsichtsbehörden, die über ausreichende Kenntnisse und ein ausreichendes Verständnis bezüglich Folgendem verfügen:

   1. Name, Typ und Umfang der bereitgestellten Cloud-Dienste;
   2. die Art der bereitgestellten Cloud-Dienste;
   3. wie das System des Cloud-Anbieters mit Cloud-Kunden, Subservice-Organisationen und anderen Parteien interagiert;
   4. interne Kontrollsysteme und deren Grenzen;
   5. korrespondierende Kontrollen der Cloud-Kunden und Subservice-Organisationen und wie diese mit den entsprechenden Kontrollen des Cloud-Anbieters zur Erfüllung der anwendbaren C5-Kriterien zusammenwirken;
   6. Verantwortlichkeiten des Cloud-Kunden und wie diese die Fähigkeit des Cloud-Kunden beeinflussen können, Cloud-Dienste wirksam zu nutzen;
   7. die in diesem Katalog festgelegten Kriterien; und
   8. die Risiken, die die Erfüllung der anwendbaren C5-Kriterien gefährden können, und wie Kontrollen diese Risiken adressieren.

8. Allgemeine Auftragsbedingungen

   Verweis auf die Auftragsbedingungen, für Berufsangehörige in Deutschland typischerweise auf Grundlage der Allgemeinen Auftragsbedingungen für Wirtschaftsprüfer und Wirtschaftsprüfungsgesellschaften. Der Abschnitt hat auch Informationen zu anwendbaren Haftungsregelungen offenzulegen, da dies als wichtige Information für die vorgesehenen Nutzer des Berichts angesehen wird. Die Regelungen zur Haftung des Prüfers – bei Prüfungen außerhalb des Bereichs gesetzlicher Vorbehaltsaufgaben – beruhen grundsätzlich auf zivilrechtlichen Anforderungen und können durch vertragliche Vereinbarung konkretisiert werden. Eine Haftungsvereinbarung kann individuell oder

durch Verwendung vorformulierter Vertragsbedingungen getroffen werden. In diesem Zusammenhang ist im Bericht auf eine Haftungsvereinbarung hinzuweisen.

2. **Erklärung der gesetzlichen Vertreter (engl. Management Statement)**

   Schriftliche Erklärung der Unternehmensleitung des Cloud-Anbieters in Übereinstimmung mit den im Abschnitt „Erklärung der gesetzlichen Vertreter" dieses Katalogs festgelegten Anforderungen.

3. **Systembeschreibung des Cloud-Anbieters**

   Darstellung des für die Entwicklung und den Betrieb des Cloud-Dienstes relevanten internen Kontrollsystems in Übereinstimmung mit den im Abschnitt „Kriterien an die Systembeschreibung" dieses Katalogs festgelegten Anforderungen.

4. **Kontrollen des Cloud-Anbieters, Prüfungshandlungen des Prüfers und Ergebnisse**

   Darstellung der Kontrollen des Cloud-Anbieters entlang der anwendbaren C5-Kriterien, der Prüfungshandlungen des Prüfers und der jeweiligen Ergebnisse. Die durchgeführten Prüfungshandlungen sind in beiden Berichtstypen zu beschreiben, nicht nur in Typ-2-Berichten, sondern auch in Typ-1-Berichten. In seiner Beschreibung der Prüfungshandlungen hat der Prüfer Folgendes darzulegen:

   1. die Art der durchgeführten Prüfungshandlungen (z. B. Befragung, Beobachtung, Einsichtnahme oder Nachvollzug) in ausreichender Detailtiefe, damit die festgelegten Parteien die Auswirkungen auf ihre Risikobewertungen bestimmen können. Dies hat die Berufsbezeichnung und Rolle des Personals des Cloud-Anbieters zu umfassen, an das Befragungen gerichtet wurden, sowie abstrakte Beschreibungen der Dokumente oder elektronischen Dateien, auf die sich der Prüfer zur Erlangung von Prüfevidenzen bezogen hat.
   2. den Umfang der Prüfungshandlungen und Kontrolltests, einschließlich der Frage, ob die getesteten Elemente alle Elemente oder eine Auswahl (Stichprobe) der Elemente in der Grundgesamtheit repräsentieren. Es ist im Normalfall nicht erforderlich, die Anzahl der Elemente in der Grundgesamtheit und die Größe der Stichprobe für jede Prüfungshandlung einzeln anzugeben. Der Prüfer hat aber zumindest den allgemeinen Ansatz zur Bestimmung der Stichprobengrößen zu beschreiben, z. B. durch Angabe der genutzten Stichprobengrößen allgemein in Abhängigkeit der Anzahl der Elemente in der Grundgesamtheit bzw. der Häufigkeit der Durchführung einer Kontrolle.

   Die Darstellung der Ergebnisse kann auf die Aussage „Keine Abweichung festgestellt" beschränkt werden. Wurden Abweichungen identifiziert, hat der Prüfer den Umfang der Prüfungshandlung, Abweichungen (einschließlich der genauen Stichprobengröße, wenn Stichproben verwendet wurden), sowie Anzahl und Art der festgestellten Abweichungen anzugeben. Der Prüfer hat Abweichungen auch dann zu berichten, wenn er auf Grundlage der durchgeführten Tests zu dem Urteil gekommen ist, dass die betreffenden C5-Kriterien erfüllt wurden.

5. **Optional: Sonstige vom Cloud-Anbieter bereitgestellte Informationen**

   Der Cloud-Anbieter kann diesen Abschnitt nutzen, um weitere Informationen darzustellen, z. B. Stellungnahmen der gesetzlichen Vertreter zu festgestellten Abweichungen (vgl. Abschnitt „Umgang mit Abweichungen") oder die Abbildung von Kontrollen auf andere Standards. Diese Informationen sind nicht Gegenstand der Prüfungshandlungen des Prüfers; dementsprechend gibt der Prüfer hierzu kein Urteil ab.

Im Falle einer direkten Prüfung entfallen die Bestandteile 2 „Erklärung der gesetzlichen Vertreter" und 3 „Systembeschreibung des Cloud-Anbieters". Gleichwohl hat der Prüfer, wie im Abschnitt „Kriterien an die Systembeschreibung" ausgeführt, das System des Cloud-Anbieters in allen wesentlichen Aspekten als Teil des Prüfberichts darzustellen, damit die festgelegten Parteien ein angemessenes Verständnis der

Informationssicherheit des Cloud-Dienstes erlangen können. Solche Informationen sind in einem gesonderten Abschnitt bereitzustellen, z. B. „Darstellung des Systems des Cloud-Anbieters durch den Prüfer“.

3.5 Umgang mit Überarbeitungen dieses Kriterienkatalogs

Das BSI beabsichtigt, diesen Kriterienkatalog regelmäßig im Einklang mit allgemeinen technischen Entwicklungen und der laufenden Weiterentwicklung der zugrunde liegenden Standards zu überarbeiten und zu aktualisieren.

In diesem Zusammenhang müssen Cloud-Anbieter und Prüfer ausreichend Zeit haben, die notwendigen Anpassungen an ihrem internen Kontrollsystem sowie an der mit Überarbeitungen dieses Kriterienkatalogs verbundenen Prüfungsdurchführung vorzunehmen.

Die Kriterien dieses Kriterienkatalogs sind in Aufträgen mit festgelegten Stichtagen (Typ-1-Berichte) zum oder nach dem 1. Juni 2027 oder mit festgelegten Zeiträumen (Typ-2-Berichte), die am oder nach dem 1. Juni 2027 beginnen, anzuwenden. Eine frühere Anwendung ist zulässig.

Beginnt bei einem Typ-2-Auftrag der festgelegte Zeitraum vor dem 1. Juni 2027 und endet nach diesem Datum, sollte der Auftrag ausschließlich die Kriterien der vorherigen Fassung dieses Katalogs (C5:2020) umfassen. Es sollten keine Kombinationen der vorherigen Fassung (C5:2020) und der aktuellen Fassung (C5:2026) in demselben Auftrag verwendet werden, da dies zu Verwirrung hinsichtlich der Anwendbarkeit der Kriterien führen könnte.

Cloud-Anbieter, die über ein internes Kontrollsystem verfügen, das auf C5:2020 ausgerichtet ist, müssen ihre Kontrollen so anpassen, dass diese die in diesem überarbeiteten Katalog festgelegten Kriterien adressieren. Anpassungen von Kontrollen können z. B. Erweiterungen des Umfangs oder der Aktivität einer Kontrolle umfassen, um einen zusätzlichen Aspekt zu adressieren, der durch ein überarbeitetes Kriterium gefordert wird. Daher kann es Bewertungen der Angemessenheit der Ausgestaltung oder der Wirksamkeit von Kontrollen geben, die den Status der Kontrollen sowohl vor als auch nach der Anpassung des Cloud-Anbieters an den überarbeiteten Katalog umfassen.

Anpassungen, die der Cloud-Anbieter an seinem für die Entwicklung und den Betrieb des Cloud-Dienstes relevanten internen Kontrollsystem vornimmt, gelten als wesentliche Änderungen. Daher hat der Cloud-Anbieter Informationen über diese Änderungen in die Systembeschreibung aufzunehmen (vgl. Abschnitt „Kriterien an die Systembeschreibung“ dieses Katalogs). Im Falle einer direkten Prüfung hat der Prüfer diese Informationen einzuholen und offenzulegen.

Die Anpassung von Kontrollen ist ein Prozess, und Cloud-Anbieter haben möglicherweise nicht alle zur Erfüllung der neuen und überarbeiteten Kriterien in diesem Katalog erforderlichen Anpassungen vor einer Prüfung abgeschlossen. Wenn der festgelegte Zeitraum am oder nach dem 28. Februar 2027 endet, hat der Cloud-Anbieter daher zusätzliche Informationen über geplante Änderungen an Kontrollen in die Systembeschreibung seines für die Entwicklung und den Betrieb des Cloud-Dienstes relevanten internen Kontrollsystems aufzunehmen. Dies dient dazu, den Cloud-Kunden Transparenz über die generelle Fähigkeit des Cloud-Anbieters zu geben, die Kriterien dieses Katalogs künftig einzuhalten.

Der Cloud-Anbieter sollte – soweit anwendbar – die folgenden Aspekte zu geplanten Änderungen aufnehmen:

1. ID/Titel des überarbeiteten Kriteriums, das durch die Änderung erfüllt werden soll
2. Art der Änderung
3. Umsetzungsstatus (z. B. umgesetzt/nicht umgesetzt)
4. Umsetzungsdatum.

Da die Informationen Teil der Systembeschreibung des Cloud-Anbieters sind, hat der Prüfer Prüfungshandlungen durchzuführen, um festzustellen, ob die Informationen sachgerecht dargestellt sind. Der Prüfer hat jedoch die Angemessenheit der Ausgestaltung oder die Wirksamkeit solcher Änderungen an Kontrollen noch nicht zu bewerten.

Im Falle einer direkten Prüfung hat der Prüfer diese Informationen einzuholen und offenzulegen.

4 Angaben zu den Rahmenbedingungen des Cloud-Dienstes

Die Angaben zu den Rahmenbedingungen des Cloud-Dienstes dienen - auch kurz 'Rahmenbedingungen', auf Englisch 'General Conditions' ('GC') - der zusätzlichen Information der Kunden über das vom Cloud-Dienst gebotene Niveau an Informationssicherheit. Die Angaben ermöglichen den Cloud-Kunden, die Eignung des Cloud-Dienstes für ihren Anwendungsfall zu beurteilen. Sie sollen außerdem ein vergleichbares Niveau in der Berichterstattung sicherstellen, um Kunden das Vergleichen mehrerer Cloud-Anbieter bzw. Cloud-Dienste, für die ein C5-Bericht ausgestellt wurde, zu erleichtern.

Da die Prüfungsdurchführung bei einer direkten Prüfung nicht auf einer vom Cloud-Anbieter bereitgestellten Systembeschreibung basiert, hat der Prüfer in diesem Fall die Angaben zu den Rahmenbedingungen gemäß der vom Cloud-Anbieter zur Verfügung gestellten Informationen zu dokumentieren (vgl. Abschnitt 3.4).

Die Informationen werden so aufbereitet, dass sie den gemeinsamen Bedürfnissen einer breiten Gruppe von sachverständigem Personal der Cloud-Kunden entsprechen, die Vorgaben an die Informationssicherheit machen oder umsetzen, deren Wirksamkeit validieren oder die Eignung des Cloud-Dienstes aus rechtlicher und regulatorischer Sicht beurteilen.

GC-01 Angaben zu anwendbarem Recht, Gerichtsbarkeit, Länder, Partitionen, Regionen, Zonen und Standorte

Angaben zu den Rahmenbedingungen des Cloud-Dienstes

In der Systenbeschreibung des für die Entwicklung und den Betrieb des Cloud-Dienstes relevanten internen Kontrollsystems des Cloud-Anbieters und in den vertraglichen Vereinbarungen (z. B. Service Level Agreements) macht der Cloud-Anbieter nachvollziehbare und transparente Angaben zu:

1. Dem für ihn anwendbare Recht;
2. Seiner Gerichtsbarkeit (Gerichte, die Streitfälle verhandeln);
3. Dem Land, in dem die Stelle oder Stellen des Cloud-Anbieters, die die Systembeschreibung erstellt haben, als juristische Person registriert ist/sind;
4. Dem Land, in dem der Hauptsitz des Cloud-Anbieters (oberste Muttergesellschaft) als juristische Person registriert ist;
5. Die Partitionen, Regionen, Zonen und Standorte, die Cloud-Kunden für den Betrieb des Cloud-Dienstes bereitgestellt werden, an denen die Cloud-Kundendaten, abgeleitete Cloud-Dienstdaten und Kontodaten verarbeitet, gespeichert und gesichert werden, basierend auf der Art des Serviceangebots (SaaS, PaaS, IaaS); und
6. Falls bestimmte dieser Partitionen, Regionen, Zonen und Standorte nicht in den Umfang der Prüfung einbezogen sind, einen Hinweis auf ihren Ausschluss.

Die Informationen werden so aufbereitet, dass sie den gemeinsamen Bedürfnissen einer breiten Gruppe von sachverständigem Personal der Cloud-Kunden entsprechen, die Vorgaben an die Informationssicherheit machen oder umsetzen, deren Wirksamkeit validieren oder die Eignung des Cloud-Dienstes aus rechtlicher und regulatorischer Sicht beurteilen.

Ergänzende Informationen - Hinweise zu den Rahmenbedingungen

Für Definitionen der Begriffe Partitionen, Regionen, Zonen, Standorte und der Datentypen vgl. Abschnitt 1.2. Wenn die Verarbeitung, Sicherung und Speicherung von Cloud-Kundendaten in unterschiedlichen Partitionen, Regionen, Zonen und Standorten stattfindet, muss dies in der Systembeschreibung verständlich und transparent beschrieben werden.

GC-02 Angaben zu Verfügbarkeit und Störungsbeseitigung im Regelbetrieb

Angaben zu den Rahmenbedingungen des Cloud-Dienstes

Der Cloud-Anbieter macht in vertraglichen Vereinbarungen (z. B. Service Level Agreements) nachvollziehbare, verbindliche und transparente Angaben zur:

1. Verfügbarkeit des Cloud-Dienstes;
2. Kategorisierung und Priorisierung von Störungen;
3. Reaktionszeit bei Störungen im Regelbetrieb gemäß der Kategorisierung (Zeitraum bis zum Beginn der Störungsbeseitigung durch den Cloud-Anbieter nach Meldung der Störung);
4. Wiederherstellungszeit (Zeitraum bis zum Abschluss der Störungsbeseitigung); und
5. Rechtsfolgen bei Nichteinhaltung.

Die Angaben basieren auf Definitionen, die sachverständigem Personal der Cloud-Kunden eine Beurteilung des Cloud-Dienstes hinsichtlich geschäftlicher Anforderungen ermöglichen. Vertragliche Vereinbarungen können auf Betriebsdokumentation (z. B. Servicedokumentation, technische Spezifikationen oder andere öffentlich zugängliche Ressourcen) verweisen, die regelmäßig aktualisiert werden kann. Die Systembeschreibung des für die Entwicklung und den Betrieb des Cloud-Dienstes relevanten internen Kontrollsystems des Cloud-Anbieters gibt an, wo diese Angaben zu finden sind. Verweise beziehen sich konkret auf die oben genannten einzelnen Aspekte und ermöglichen es Lesern, die mit der vertraglichen Vereinbarung oder der Betriebsdokumentation nicht vertraut sind, die Angaben rechtzeitig zu finden.

Soweit die Angaben zur Verfügbarkeit und Störungsbeseitigung nur Durchschnittswerte darstellen, die im Einzelfall nicht verbindlich sind, wird dies gesondert hervorgehoben.

Ergänzende Informationen - Hinweise zu den Rahmenbedingungen

Neben der Information in der Systembeschreibung des Cloud-Anbieters können die Angaben selbst auch optionaler Bestandteil der Berichterstattung sein, z. B. in einem Abschnitt ‘Sonstige vom Cloud-Anbieter bereitgestellte Informationen’. Im letzteren Fall unterliegen diese Informationen nicht den Prüfungshandlungen des Prüfers, und dementsprechend gibt der Prüfer hierzu kein Prüfungsurteil ab.

GC-03 Angaben zu Wiederanlaufparametern im Notbetrieb

Angaben zu den Rahmenbedingungen des Cloud-Dienstes

Auf Anfrage von sachverständigem Personal der Cloud-Kunden stellt der Cloud-Anbieter nachvollziehbare und transparente Angaben zu folgenden Wiederanlaufparametern des Cloud-Dienstes zur Verfügung:

1. Maximal tolerierbare Ausfallzeit (MTPD) und Recovery Time Objective (RTO);
2. Maximal zulässiger Datenverlust / Recovery Point Objective (RPO);
3. Wiederherstellungszeit bis zur Aufnahme des Notbetriebs;
4. Notbetriebsniveau (MBCO, Kapazität bezogen auf den Regelbetrieb); und
5. Wiederherstellungszeit bis zum Regelbetrieb.

Die Angaben ermöglichen den Cloud-Kunden, eine Beurteilung des Cloud-Dienstes im Rahmen ihrer eigenen Business Impact Analyse durchzuführen.

Die Systembeschreibung des für die Entwicklung und den Betrieb des Cloud-Dienstes relevanten internen Kontrollsystems des Cloud-Anbieters gibt an, wo diese Informationen zu finden sind. Verweise beziehen sich präzise auf die oben genannten einzelnen Aspekte und ermöglichen es diesem sachverständigen Personal, die Informationen rechtzeitig zu finden.

Soweit die Angaben zur Verfügbarkeit und Störungsbeseitigung nur Durchschnittswerte darstellen, die im Einzelfall nicht verbindlich sind, wird dies gesondert hervorgehoben.

Ergänzende Informationen - Hinweise zu den Rahmenbedingungen

Neben der Information in der Systembeschreibung des Cloud-Anbieters können die Angaben selbst auch optionaler Bestandteil der Berichterstattung sein, z. B. in einem Abschnitt 'Sonstige vom Cloud-Anbieter bereitgestellte Informationen'. Im letzteren Fall unterliegen diese Informationen nicht den Prüfungshandlungen des Prüfers, und dementsprechend gibt der Prüfer hierzu kein Prüfungsurteil ab.

GC-04 Angaben zum Ansatz zur Sicherstellung der Dienstverfügbarkeit

Angaben zu den Rahmenbedingungen des Cloud-Dienstes

Der Cloud-Anbieter stellt sachverständigem Personal von Cloud-Kunden verständliche und transparente Informationen über seinen Ansatz zur Sicherstellung der Dienstverfügbarkeit zur Verfügung, einschließlich relevanter Verfügbarkeitsmetriken und Prinzipien des Architekturdesigns sowohl für die Rechenzentrumsinfrastruktur als auch für Cloud-Dienste. Diese Informationen behandeln sowohl die physische Infrastrukturresilienz als auch die logische Dienstresilienz und ermöglichen es Cloud-Kunden, ihre eigene Business Impact Analyse wirksam durchzuführen und zu verstehen, wie der mehrschichtige Resilienzansatz des Cloud-Anbieters mit ihren eigenen Anforderungen an die Kontinuität des Geschäftsbetriebs sowohl auf Infrastruktur- als auch auf Dienstebene zusammenpasst.

Ergänzende Informationen - Hinweise zu den Rahmenbedingungen

Die Informationen können Resilienzfähigkeiten darstellen, wie z. B. regionale Bereitstellungsstrategien, Redundanzkonfigurationen von Rechenzentren, Zusagen auf Dienstebene, historische Leistungsdaten oder architektonische Resilienzmuster.

Eine branchenübliche Klassifizierung ist das Tier-Klassifikationssystem des Uptime Institute. Dieses sieht folgende Stufen (Tiers) für die Verfügbarkeiten und Ausfallzeiten bezogen auf ein Jahr vor:

1. Tier I: 99.671 %; bis zu 28.8 Stunden kumulierte Ausfallzeit pro Jahr;
2. Tier II: 99.741 %; bis zu 22.7 Stunden kumulierte Ausfallzeit pro Jahr;
3. Tier III: 99.982 %; bis zu 1.6 Stunden kumulierte Ausfallzeit pro Jahr; und
4. Tier IV: 99.995 %; bis zu 25 Minuten kumulierte Ausfallzeit pro Jahr.

Eine alternative Definition von Verfügbarkeitsklassen (AC) wird vom BSI im 'HV-Benchmark kompakt' bereitgestellt:

1. VK 0: ohne Anforderungen an die Verfügbarkeit (~ 95 %); bis zu 438 Stunden kumulierte Ausfallzeit pro Jahr;
2. VK 1: normale Verfügbarkeit (99 %); bis zu 88 Stunden kumulierte Ausfallzeit pro Jahr;
3. VK 2: hohe Verfügbarkeit (99,9 %); bis zu 9 Stunden kumulierte Ausfallzeit pro Jahr;
4. VK 3: sehr hohe Verfügbarkeit (99,99 %); bis zu 53 Minuten kumulierte Ausfallzeit pro Jahr;
5. VK 4: höchste Verfügbarkeit (99,999 %); bis zu 6 Minuten kumulierte Ausfallzeit pro Jahr; und
6. VK 5: Desaster-tolerant.

Die Systembeschreibung des für die Entwicklung und den Betrieb des Cloud-Dienstes relevanten internen Kontrollsystems des Cloud-Anbieters gibt an, wo diese Informationen zu finden sind. Neben der Information in der Systembeschreibung des Cloud-Anbieters können die Angaben selbst auch optionaler Bestandteil der Berichterstattung sein, z. B. in einem Abschnitt 'Sonstige vom Cloud-Anbieter bereitgestellte Informationen'. Im letzteren Fall unterliegen diese Informationen nicht den Prüfungshandlungen des Prüfers, und dementsprechend gibt der Prüfer hierzu kein Prüfungsurteil ab.

GC-05 Angaben zum Umgang mit Untersuchungsanfragen von staatlichen Stellen

Angaben zu den Rahmenbedingungen des Cloud-Dienstes

Der Cloud-Anbieter macht in der Systembeschreibung des für die Entwicklung und den Betrieb des Cloud-Dienstes relevanten internen Kontrollsystems des Cloud-Anbieters nachvollziehbare und transparente Angaben wie Untersuchungsanfragen von staatlichen Stellen auf Zugriff auf oder Offenlegung von Cloud-Kundendaten behandelt werden. Die Angaben umfassen folgende Aspekte:

1. Verfahren zur Verifizierung der Rechtsgrundlage solcher Anfragen;
2. Verfahren zur Information und Einbindung der betroffenen Cloud-Kunden bei Erhalt solcher Anfragen;
3. Widerspruchsmöglichkeiten der betroffenen Cloud-Kunden;
4. Ob der Cloud-Anbieter Cloud-Kundendaten oder abgeleitete Cloud-Dienstdaten unverschlüsselt speichert;
5. Ob der Cloud-Anbieter bei Cloud-Kundendaten oder abgeleiteten Cloud-Dienstdaten im Falle solcher Anfragen die Möglichkeit zur Entschlüsselung hat und wie er diese für den Zugriff oder die Offenbarung anwendet;
6. Die Anzahl der Untersuchungsanfragen zu Cloud-Kundendaten oder abgeleiteten Cloud-Dienstdaten und die Länder, aus denen diese Anfragen stammen; und
7. Wie oft diese Anfragen dazu führten, dass der Cloud-Anbieter Cloud-Kundendaten oder abgeleitete Cloud-Dienstdaten an die Regierungsbehörde weitergab.

Der Umfang der Angaben orientiert sich am Bedarf sachverständigen Personals der Cloud-Kunden, die Vorgaben zur Informationssicherheit machen, diese umsetzen oder die Umsetzung überprüfen und die Eignung des Cloud-Dienstes aus rechtlicher und regulatorischer Sicht beurteilen (bspw. IT, Compliance, Interne Revision).

Zusätzliche Angaben zu den technischen Verfahren für die Datenoffenlegung sind gemäß INQ-04 mit den Cloud-Kunden zu kommunizieren. Falls die Systembeschreibung des für die Entwicklung und den Betrieb des Cloud-Dienstes relevanten internen Kontrollsystems des Cloud-Anbieters mehrere Cloud-Dienste behandelt, sind Unterschiede in den technischen Verfahren zwischen den einzelnen Diensten innerhalb der bereitgestellten Angaben zu erläutern.

Ergänzende Informationen - Hinweise zu den Rahmenbedingungen

Die Rechtsgrundlage, auf der diese staatlichen Stellen beruhen (z. B. Strafverfolgungsbehörden, Nachrichtendienste), kann von Land zu Land unterschiedlich sein. Insbesondere ist die anwendbare Gerichtsbarkeit an den Standorten zu berücksichtigen, an denen Cloud-Kundendaten und abgeleitete Cloud-Dienstdaten verarbeitet, gespeichert und gesichert werden.

In Deutschland werden solche Befugnisse durch die Gesetze des Bundeskriminalamts (oder die Gesetze der jeweiligen Landesämter), verschiedene Verfahrensordnungen für Gerichte und die Gesetze für Nachrichtendienste (BNDG, BVerfSchG, jeweilige Gesetze über die Verfassungsschutzämter der Bundesländer, MADG) sowie das G10-Gesetz geregelt.

Weitere innerhalb der EU geltende Regelungen sind z. B. das Budapester Übereinkommen über Computerkriminalität (ETS Nr. 185), sowie die EU-Richtlinien 2023/1543 und 2023/1544 zur Schaffung eines Rechtsrahmens für die Erlangung und Sicherung elektronischer Beweismittel in Strafverfahren in den Mitgliedstaaten der EU.

In anderen Ländern sind andere Gesetze einschlägig und dem Cloud-Kunden ggf. nur vereinzelt aus den Medien bekannt, z. B. der CLOUD Act ('Clarifying Lawful Overseas Use of Data Act') aus den USA oder das Cyber Security Law der Volkrepublik China. In Verbindung mit den anderen Informationen zum Cloud-

Dienst soll es dem Kunden möglich sein, mit diesen Informationen eine Risikoabschätzung der eigenen Betroffenheit vorzunehmen.

GC-06 Angaben zu Zertifizierungen oder Bescheinigungen

Angaben zu den Rahmenbedingungen des Cloud-Dienstes

Der Cloud-Anbieter macht in der Systembeschreibung des für die Entwicklung und den Betrieb des Cloud-Dienstes relevanten internen Kontrollsystems des Cloud-Anbieters nachvollziehbare und transparente Angaben zu vorhandenen und gültigen Zertifizierungen oder Bescheinigungen unabhängiger Dritter in Bezug auf die folgenden Aspekte des Cloud-Dienstes:

1. Konformität der Managementsysteme für Informationssicherheit, Betriebskontinuität und Qualität mit anwendbaren internationalen Standards;
2. Einhaltung der europäischen Datenschutz-Grundverordnung (DSGVO);
3. Angemessenheit der Ausgestaltung oder der Wirksamkeit von Kontrollen des internen Kontrollsystems in Bezug auf die anwendbaren Kriterien;
4. Zertifizierungen oder Bescheinigungen (Prüfberichte) gemäß branchenspezifischen Anforderungen von Cloud-Kunden; und
5. Zertifizierungen oder Bescheinigungen (Prüfberichte) in Bezug auf Umwelt-, Sozial- und Unternehmensführungs-Standards (engl. Environmental, Social and Governance, ESG).

Soweit für die Zertifizierung oder Bescheinigung anwendbar, werden folgende Angaben gemacht:

1. Ausstellungsdatum;
2. Ausstellende Organisation;
3. Anwendbarer Geltungsbereich; und
4. Datum oder Zeitraum der Gültigkeit oder Abdeckung.

Der Umfang der Angaben orientiert sich am Bedarf sachverständigen Personals der Cloud-Kunden, die Vorgaben zur Informationssicherheit machen, diese umsetzen oder die Umsetzung überprüfen und die Eignung des Cloud-Dienstes aus rechtlicher und regulatorischer Sicht beurteilen (bspw. IT, Compliance, Interne Revision).

Ergänzende Informationen - Hinweise zu den Rahmenbedingungen

Die Transparenz kann zusätzlich durch Offenlegung von SLAs, die auf dem ISO/IEC 19086 oder vergleichbaren Standards basieren, erhöht werden

Die Konformität der Managementsysteme für Informationssicherheit, Betriebskontinuität und Qualität kann beispielsweise mit Zertifikaten gemäß ISO/IEC 27001, ISO 22301 und ISO 9001 nachgewiesen werden.

Beispiele für ESG-Berichterstattung sind die Berichterstattung gemäß der EU-Richtlinie zur Nachhaltigkeitsberichterstattung von Unternehmen (CSRD) und Zertifizierungen wie ISO 50001, ISO 14001 und das deutsche Umweltzeichen Blauer Engel.

Die Erfüllung der Rahmenbedingung setzt nicht voraus, dass der Cloud-Anbieter zu allen genannten Aspekten eine Zertifizierung oder Bescheinigung vorhält.

5 Basiskriterien, Zusatzkriterien, Ergänzende Informationen

5.1 Organisation der Informationssicherheit (OIS)

Zielsetzung: Planung, Umsetzung, Aufrechterhaltung und kontinuierlich Verbesserung eines Rahmenwerks zur Informationssicherheit innerhalb der Organisation.

OIS-01 Informationssicherheitsmanagementsystem (ISMS)

Basiskriterien

OIS-01.01B

Der Cloud-Anbieter betreibt ein ISO/IEC 27001-konformes Informationssicherheitsmanagementsystem (ISMS). Der Anwendungsbereich des ISMS umfasst die Organisationseinheiten, Standorte, Zonen, Regionen und Verfahren des Cloud-Anbieters, die für die Entwicklung und den Betrieb des Cloud-Dienstes relevant sind.

OIS-01.02B

Die Maßnahmen für Aufbau, Verwirklichung, Aufrechterhaltung und fortlaufende Verbesserung des ISMS sind dokumentiert. Die Dokumentation umfasst:

1. Kontext des Cloud-Anbieters;
2. Anwendungsbereich des ISMS (Abschnitt 4.3 der ISO/IEC 27001);
3. Erklärung zur Anwendbarkeit (Abschnitt 6.1.3 der ISO/IEC 27001);
4. Überblick darüber, wie Aktivitäten im ISMS den Cloud-Dienst abdecken;
5. Beschreibung, wie der Cloud-Anbieter die Sicherheit des Cloud-Dienstes aufrechterhält und verbessert; und
6. Ergebnisse der letzten Managementbewertung (Abschnitt 9.3 der ISO/IEC 27001).

OIS-01.03B

Zusätzlich dokumentiert der Cloud-Anbieter den Umfang und die Grenzen des Cloud-Dienstes unter seiner betrieblichen Kontrolle, einschließlich etwaiger Ausschlüsse oder Bereiche mit geteilter Verantwortung.

Zusatzkriterium (Verschärfend)

OIS-01.01AS, verschärft OIS-01.01B

Das Informationssicherheitsmanagementsystem (ISMS) verfügt über eine gültige Zertifizierung nach ISO/IEC 27001 oder ISO 27001 auf Basis von BSI IT-Grundschutz. Der Anwendungsbereich der Zertifizierung umfasst die Organisationseinheiten, Standorte, Zonen, Regionen und Verfahren des Cloud-Anbieters, die für die Entwicklung und den Betrieb des Cloud-Dienstes relevant sind.

Zusatzkriterium (Erweiternd)

OIS-01.01AC

Bestehende gültige Zertifizierungen nach ISO/IEC 27001 werden von einer akkreditierten Zertifizierungsstelle ausgestellt und anerkannt.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: OIS-01.01B

Das Basiskriterium kann auch ohne gültige Zertifizierung des ISMS nach ISO/IEC 27001 oder ISO 27001 auf Basis von IT-Grundschutz erfüllt werden, soweit die vorgelegte Dokumentation die Anforderungen der ISO/IEC 27001 erfüllt. Der Prüfer hat zu bewerten, ob die Dokumentation die referenzierten Anforderungen der ISO-Norm erfüllt. Dies erfordert kein vollständiges Zertifizierungsaudit des Managementsystems gemäß ISO 17021, sondern eine gezielte Prüfung der zugehörigen Dokumentation.

Querschnittsfunktionen müssen nicht in ein einziges ISMS integriert werden. Stattdessen können mehrere ISMS eingerichtet werden, um sowohl Cloud-Dienst-spezifische interne Kontrollsysteme als auch organisationsweite/zentrale Funktionen wirksam abzudecken.

Der Anwendungsbereich des ISMS kann über den Anwendungsbereich des internen Kontrollsystems des Cloud-Anbieters für den Cloud-Dienst, der Gegenstand eines Prüfauftrags nach diesem Kriterienkatalog ist, hinausgehen. Wenn der Anwendungsbereich des ISMS breiter ist als der Anwendungsbereich des Prüfauftrags, können die über die Ausgestaltung und den Betrieb des ISMS einzuholenden Nachweise auf Aufzeichnungen beschränkt werden, die für den Cloud-Dienst, der Gegenstand des Prüfauftrags ist, relevant sind.

Korrespondierende Kriterien für Kunden

–

OIS-02 Informationssicherheitsrichtlinie

Basiskriterien

OIS-02.01B

Die oberste Geschäftsleitung des Cloud-Anbieters hat eine Informationssicherheitsrichtlinie verabschiedet.

OIS-02.02B

Die oberste Geschäftsleitung des Cloud-Anbieters hat die Informationssicherheitsrichtlinie an das interne und externe Personal sowie die Cloud-Kunden kommuniziert.

OIS-02.03B

Die Informationssicherheitsrichtlinie beschreibt:

1. Den Stellenwert der Informationssicherheit, abgeleitet von den Anforderungen der Cloud-Kunden mit Bezug zur Informationssicherheit;
2. Die Sicherheitsziele und das angestrebte Sicherheitsniveau, abgeleitet von den Geschäftszielen und Aufgaben des Cloud-Anbieters;
3. Die Verpflichtung des Cloud-Anbieters, die erforderlichen Sicherheitsmaßnahmen zur Erfüllung der festgelegten Sicherheitsziele umzusetzen;
4. Die wichtigsten Aspekte der Sicherheitsstrategie zum Erreichen der gesetzten Sicherheitsziele; und
5. Die Organisationsstruktur für Informationssicherheit im Anwendungsbereich des ISMS.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: OIS-02.01B, OIS-02.02B

Die oberste Leitung ist eine natürliche Person oder Personengruppe, welche die letztgültige Entscheidung für die Institution trifft und für diese die Verantwortung trägt.

Korrespondierende Kriterien für Kunden

–

OIS-03 Schnittstellen und Abhängigkeiten

Basiskriterien

OIS-03.01B

Der Cloud-Anbieter etabliert, dokumentiert und kommuniziert ein Modell geteilter Sicherheitsverantwortung (engl. Shared Security Responsibility Model; SSRM), um Schnittstellen und Abhängigkeiten zwischen den vom Cloud-Anbieter ausgeführten Aktivitäten zur Erbringung des Cloud-Dienstes und den von den Cloud-Kunden ausgeführten Aktivitäten zu definieren und zu steuern.

OIS-03.02B

Die SSRM-Dokumentation definiert klar die Verantwortlichkeiten zwischen beiden Parteien für den Umgang mit Schwachstellen, Sicherheitsvorfällen und Vorfällen. Art und Umfang der Dokumentation richten sich nach dem Informationsbedarf der Fachexperten der betroffenen Organisationen, um die Aktivitäten angemessen durchführen zu können (z. B. Definition von Rollen und Verantwortlichkeiten in Richtlinien, Beschreibung von Mitwirkungspflichten in Leistungsbeschreibungen und Verträgen).

OIS-03.03B

Der Cloud-Anbieter überprüft und validiert die SSRM-Dokumentation regelmäßig gemäß SP-02, um ihre Genauigkeit und Relevanz für alle Angebote des Cloud-Dienstes sicherzustellen.

OIS-03.04B

Der Cloud-Anbieter implementiert, betreibt und überprüft die SSRM-Komponenten, für die er verantwortlich ist, und stellt die Einhaltung der definierten Sicherheitsmaßnahmen sicher.

OIS-03.05B

Die Kommunikation von Änderungen am SSRM, an Schnittstellen und an Abhängigkeiten erfolgt zeitnah, damit die betroffenen Organisationen und Dritten vor Inkrafttreten der Änderungen angemessen mit organisatorischen und technischen Maßnahmen reagieren können.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: OIS-03.01B

Dritte im Sinne dieses Basiskriteriums sind z. B. Cloud-Kunden und Service-Organisationen (einschließlich Cloud-Vermittler). Ein SSRM bietet einen konsolidierten Überblick über die wichtigsten Schnittstellen und Abhängigkeiten zwischen dem Cloud-Anbieter und Dritten. Detaillierte Informationen zu Schnittstellen und Abhängigkeiten können in separaten Dokumenten festgelegt werden, auf die im SSRM verwiesen wird, wie z. B. Leitlinien und Verfahren. So sollten beispielsweise Mitwirkungspflichten der Cloud-Kunden in Leistungsbeschreibungen und Verträgen beschrieben werden. Der Cloud-Anbieter kann das zugrunde

liegende Shared Security Responsibility Model seines Cloud-Dienstes in Leitlinien und Verfahren darstellen, um den Cloud-Kunden zu helfen, ihre Rollen und Verantwortlichkeiten in Bezug auf Sicherheit und Betriebsmanagement zu verstehen.

Wenn Cloud-Dienste über einen Cloud-Vermittler erbracht werden, sollte das SSRM die Verantwortlichkeiten zwischen dem Cloud-Anbieter, dem Cloud-Vermittler und dem Cloud-Kunden klar abgrenzen, insbesondere:

1. Dateneigentum und Grenzen der Verarbeitung;
2. Umsetzung von Sicherheitskontrollen durch die jeweiligen Parteien;
3. Wege für die Benachrichtigung und Eskalation bei Vorfällen; und
4. Umfang der Compliance-Bescheinigung.

Anwendbar auf: OIS-03.01B, OIS-03.02B, OIS-03.03B, OIS-03.04B, OIS-03.05B

Der Cloud-Anbieter kann die im Basiskriterium beschriebenen Schnittstellen und Abhängigkeiten in Leitlinien und Verfahren definieren und dokumentieren. So sollten beispielsweise Mitwirkungspflichten der Cloud-Kunden in Leistungsbeschreibungen und Verträgen (oder deren Anhängen) beschrieben werden.

Der Cloud-Anbieter kann bestehende Dokumentation, wie Leitlinien, vertragliche Vereinbarungen oder Verfahren, nutzen, um das zugrunde liegende Shared Responsibility Model seines Cloud-Dienstes darzustellen und damit die Sicherheits- und Betriebsverantwortlichkeiten der Cloud-Kunden zu verdeutlichen.

Anwendbar auf: OIS-03.03B, OIS-03.05B

Durch die Pflege eines aktuellen und klar kommunizierten SSRM stellt der Cloud-Anbieter ein umfassendes Verständnis der Sicherheitsverantwortlichkeiten sicher und fördert so eine sichere und verlässliche Cloud-Umgebung für alle Beteiligten.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass die Leitlinien und Anforderungen zur Einhaltung der vertraglichen Vereinbarungen mit dem Cloud-Anbieter (d. h. Verantwortlichkeiten, Mitwirkungspflichten und Schnittstellen für die Meldung von Sicherheitsvorfällen) angemessen definiert, dokumentiert und eingerichtet sind.

OIS-04 Aufgabentrennung

Basiskriterien

OIS-04.01B

Miteinander in Konflikt stehende Aufgaben und Verantwortlichkeitsbereiche sind auf Basis einer Risikobeurteilung gemäß OIS-07 getrennt, um Risiken unbefugter oder unbeabsichtigter Änderungen oder Missbrauch von Cloud-Kundendaten, abgeleiteten Cloud-Dienstdaten und Cloud-Anbieterdaten zu reduzieren. Die Risikobeurteilung umfasst folgende Bereiche, soweit diese zur Bereitstellung des Cloud-Dienstes anwendbar sind und im Verantwortungsbereich des Cloud-Anbieters liegen:

1. Verwaltung eines Rollen-, Rechte- und Berechtigungsrahmenwerks auf Grundlage einer rollenbasierten Zugriffskontrolle und denr geschäftlichen sowie sicherheitsbezogenen Anforderungen des Cloud-Anbieters (vgl. IAM-01);
2. Entwicklung, Test und Freigabe von Änderungen (vgl. DEV-01);
3. Risikomanagement (vgl. OIS-07); und
4. Betrieb der Systemkomponenten.

OIS-04.02B

Mitigierende Maßnahmen werden im Risikobehandlungsplan (vgl. OIS-09) dargelegt und vom Cloud-Anbieter in einer Weise umgesetzt, die der Funktionstrennung Vorrang einräumt.

OIS-04.03B

Wenn eine Funktionstrennung aufgrund organisatorischer oder technischer Einschränkungen nicht umgesetzt werden kann, richtet der Cloud-Anbieter kompensierende Kontrollen ein und betreibt diese, um relevante Aktivitäten zu überwachen. Diese Kontrollen sind darauf ausgelegt, unbefugte oder unbeabsichtigte Änderungen, den Missbrauch von Daten oder Verstöße gegen betriebliche Richtlinien zu erkennen und zeitnahe sowie angemessene Reaktionsmaßnahmen zu ermöglichen.

OIS-04.04B

Ein Verzeichnis bestehend aus im Konflikt stehenden Aufgaben, Verantwortlichkeiten und auflösenden Maßnahmen wird vom Cloud-Anbieter eingerichtet und gepflegt. Bei der Zuweisung, Änderung oder Entziehung von Rollen, Rechten und Berechtigungen setzt der Cloud-Anbieter die Funktionstrennung durch.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

OIS-04.01AC

Zur Auflösung von im Konflikt stehenden Rollen werden mit der Funktionstrennung verbundene Maßnahmen vom Cloud-Anbieter überwacht und durchgesetzt.

OIS-04.02AC

Zeitnahe und angemessene Abhilfemaßnahmen adressieren alle bei der Überwachung festgestellten Abweichungen.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: OIS-04.01B

Identifizierte Ereignisse, die unbefugte oder unbeabsichtigte Änderungen an oder den Missbrauch von Cloud-Kundendaten, abgeleiteten Cloud-Dienstdaten und Cloud-Anbieterdaten darstellen können, können beispielsweise als Sicherheitsvorfall behandelt werden, vgl. SIM-01. Der Bereich des Risikomanagements im Kontext der Funktionstrennung bezieht sich auf die sogenannten unterschiedlichen Verteidigungslinien, d. h. Rollen, die Risiken überprüfen (2. Verteidigungslinie), unterscheiden sich von Rollen, die Risiken verantworten (1. Verteidigungslinie).

Korrespondierende Kriterien für Kunden

–

OIS-05 Threat Intelligence

Basiskriterien

OIS-05.01B

Der Cloud-Anbieter sammelt Informationen aus ausgewählten internen und externen Quellen, um ein umfassendes Bild der Bedrohungslandschaft zu gewinnen, die zu Cybersicherheitsrisiken führt.

OIS-05.02B

Die gesammelten Informationen werden korreliert und analysiert, um ihre potenziellen Auswirkungen auf die Organisation des Cloud-Anbieters zu identifizieren.

OIS-05.03B

Der Cloud-Anbieter integriert Threat Intelligence Erkenntnisse in seinen Risikomanagementprozess (vgl. OIS-07, OIS-08 und OIS-09).

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: OIS-05.01B

Interne Quellen, die zur Sammlung von Informationen genutzt werden können, umfassen beispielsweise die interne Sicherheitsüberwachung des Cloud-Anbieters. Externe Quellen, die zur Sammlung von Informationen genutzt werden können, umfassen beispielsweise Threat Intelligence-Feeds von Regierungsstellen, kommerziellen Threat Intelligence-Anbietern oder Branchenkonsortien. Threat Intelligence umfasst im Allgemeinen verschiedene Bereiche wie das Gewinnen von Informationen über Cybersicherheitsrisiken (z. B. durch Überwachung relevanter interner oder externer Quellen), Modellieren von Bedrohungen und Risikomanagement.

Anwendbar auf: OIS-05.02B

Dieser Prozess kann beispielsweise die Korrelation von Threat Intelligence mit organisatorischen Vermögenswerten, Schwachstellen und Geschäftsprozessen umfassen, um relevante und umsetzbare Bedrohungen zu identifizieren. Die Ergebnisse können genutzt werden, um der Geschäftsleitung des Cloud-Anbieters und den Sicherheitsteams regelmäßige Bedrohungsbriefings bereitzustellen.

Anwendbar auf: OIS-05.03B

Wenn für diesen Prozess ein Bedrohungsmodell verwendet wird, kann der Cloud-Anbieter beispielsweise:

1. Strukturierte Methodiken (z. B. STRIDE, PASTA, LINDDUN) verwenden, die für die Architektur des Cloud-Dienstes geeignet sind;
2. Erkenntnisse über die aktuelle Bedrohungslandschaft spezifischen Systemkomponenten, Datenflüssen und Trust Boundaries zuordnen;
3. Threat Intelligence in Echtzeit einbeziehen, um Bedrohungsmodelle dynamisch zu aktualisieren, anstatt sich auf statische jährliche Beurteilungen zu verlassen;
4. Neu aufkommende Angriffsvektoren, Techniken und Verfahren (TTPs) berücksichtigen, die in Rahmenwerken wie MITRE ATT&CK dokumentiert sind; und
5. Lieferketten- und Drittrisiken durch erweiterte Bedrohungsmodellierung berücksichtigen.

Das Ziel der Bedrohungsmodellierung ist es, sicherzustellen, dass die aktuellen internen und externen Bedrohungen in Maßnahmen zum Umgang mit Risiken berücksichtigt werden.

Korrespondierende Kriterien für Kunden

–

OIS-06 Kontakt zu relevanten Behörden und Interessengruppen

Basiskriterien

OIS-06.01B

Soweit der Cloud-Dienst durch Organisationen des öffentlichen Sektors in Deutschland genutzt wird, etabliert und pflegt der Cloud-Anbieter, soweit angemessen, Kontakte zum Nationalen IT-Lagezentrum und dem CERT-Bund des BSI.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: OIS-06.01B

Organisationen des öffentlichen Sektors in Deutschland sind z. B. Ministerien und Behörden. Wenn der Cloud-Anbieter keine Kunden im öffentlichen Sektor hat, ist dieses Kriterium nicht anwendbar.

Der Einschub 'soweit angemessen' bedeutet, dass Kontakte hergestellt werden, wenn ein tatsächlicher Bedarf dazu besteht. Beispielsweise umfasst die Kontaktaufnahme mit dem CERT typischerweise die Meldung von Sicherheitsvorfällen an das CERT und das Verfolgen der Kommunikationskanäle vom CERT, um über aktuelle Bedrohungen, Schwachstellen und Sicherheitshinweise informiert zu bleiben. Die Pflege von Kontakt im Sinne von OIS-06.01B erfordert in diesem Fall nicht, dass der Cloud-Anbieter proaktiv und unaufgefordert mit CERT kommuniziert.

Für KRITIS (Betreiber kritischer Anlagen) im Sinne von § 2 Abs. 22 des BSI-Gesetzes (BSIG) können nach deutschem nationalem Recht ähnliche Anforderungen zur Pflege von Kontakten mit Behörden und Interessengruppen gelten.

Korrespondierende Kriterien für Kunden

–

OIS-07 Richtlinie für Risikomanagement

Basiskriterien

OIS-07.01B

Richtlinien und Verfahren für Risikomanagementverfahren sind gemäß SP-01 dokumentiert, kommuniziert und bereitgestellt. Risikomanagementverfahren basieren auf einer Methodik für Risikobeurteilungen. Die Methodik ermöglicht Vergleichbarkeit und Reproduzierbarkeit für die folgenden Aspekte:

1. Identifikation von Cybersicherheitsrisiken im Zusammenhang mit dem Verlust der Vertraulichkeit, Integrität, Verfügbarkeit und Authentizität von Informationen innerhalb des Anwendungsbereichs des ISMS und Zuweisung von Risikoeigentümern;
2. Analyse der Eintrittswahrscheinlichkeiten und Auswirkungen bei Eintritt sowie Bestimmung des Risikoniveaus;
3. Bewertung der Risikobeurteilung auf Basis definierter Kriterien zur Risikoakzeptanz und Priorisierung des Risikomanagements;

4. Behandlung der Risiken durch Maßnahmen, einschließlich Genehmigung der Maßnahmen und Akzeptanz der Restrisiken durch Risikoeigentümer;
5. Dokumentation der Tätigkeiten zur Anwendung des Verfahrens, um bei wiederholter Anwendung konsistente, gültige und vergleichbare Ergebnisse zu erhalten; und
6. Bewertung der Risikobeurteilung und des Status von Risikobehandlungsplänen durch die Ebene der Leitung, die für die Sicherheit des Cloud-Dienstes verantwortlich ist.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: OIS-07.01B

Die Bestimmung des Risikoniveaus anhand von Eintrittswahrscheinlichkeiten und Auswirkungen kann durch qualitative, semi-quantitative und quantitative Methoden (vgl. ISO 31010) erfolgen.

Zur Identifizierung, Bewertung und Priorisierung potenzieller Bedrohungen und Schwachstellen im Zusammenhang mit Prozessen, Systemen und Datenflüssen kann Bedrohungsmodellierung eine strukturierte Methodik bereitstellen: Der Cloud-Anbieter kann Angriffsvektoren und mögliche Auswirkungen systematisch analysieren, um Prüfer und anderen Gruppen, die daran ein berechtigtes Interessen haben, bei der Validierung der Angemessenheit der Ausgestaltung implementierter Kontrollen zu unterstützen, Lücken in bestehenden Sicherheitsmaßnahmen hervorzuheben und die Ausrichtung an Best Practices für eine proaktive Risiko-Mitigation sicherzustellen.

Korrespondierende Kriterien für Kunden

–

OIS-08 Anwendung der Richtlinie für Risikomanagement - Risikobeurteilung

Basiskriterien

OIS-08.01B

Der Cloud-Anbieter führt den in OIS-07 definierten Risikomanagementprozess anlassbezogen und mindestens jährlich durch.

OIS-08.02B

Beim Identifizieren von Risiken werden folgende Aspekte berücksichtigt, soweit diese für den bereitgestellten Cloud-Dienst anwendbar sind und im Verantwortungsbereich des Cloud-Anbieters liegen:

1. Verarbeitung, Speicherung oder Übertragung von Cloud-Kundendaten und von abgeleiteten Cloud-Dienstdaten mit unterschiedlichen Schutzbedarfen;
2. Auftreten von Schwachstellen und Vorfällen in technischen Schutzmaßnahmen zur Trennung gemeinsam genutzter Ressourcen;
3. Angriffe über Zugangspunkte, einschließlich Schnittstellen, die aus öffentlichen Netzen zugänglich sind, und versehentlich offengelegte Schnittstellen;
4. Abhängigkeiten von Service-Organisationen;

5. Ein Risiko-Programm für Verschlüsselung und Schlüsselmanagement, das die Risiken der unbefugten Offenlegung, Veränderung, Zerstörung oder des Informationsverlusts kryptographischer Schlüssel adressiert; und
6. Trennung der Cloud-Kunden und ihrer Daten innerhalb von Systemen, Netzen und Speichern.

OIS-08.03B

Richtlinien und Verfahren, die für die Erbringung und den Betrieb des Cloud-Dienstes relevante Risikobeurteilungen abdecken, werden vom Cloud-Anbieter umgesetzt.

OIS-08.04B

Die Ergebnisse der Risikobeurteilung werden relevanten internen Parteien bereitgestellt.

OIS-08.05B

Relevanten externen Parteien werden Informationen aus den Risikobeurteilungen bereitgestellt, die auf die Zwecke der Parteien zugeschnitten sind.

OIS-08.06B

Die Analyse, Bewertung und Behandlung von Risiken, einschließlich der Genehmigung von Maßnahmen und der Akzeptanz von Restrisiken, wird von den Risikoeigentümern mindestens jährlich auf Angemessenheit überprüft. Zusätzlich wird bei wesentlichen Änderungen am Cloud-Dienst eine Überprüfung durchgeführt, die sich auf die für die Änderung relevanten Teile der Risikobeurteilung konzentriert.

Zusatzkriterium (Verschärfend)

OIS-08.01AS, verschärft OIS-08.01B

Der Cloud-Anbieter führt den in OIS-07 definierten Risikomanagementprozess anlassbezogen und mindestens jährlich durch. Die Entwicklung der Risiken wird überwacht und die Risikobeurteilungen werden entsprechend überprüft.

Zusatzkriterium (Erweiternd)

OIS-08.01AC

Der Cloud-Anbieter integriert Cybersicherheitsrisiken in ein dokumentiertes Enterprise Risk Management (ERM)-Programm, das die folgenden Aspekte adressiert:

1. Integration von Informationssicherheitsrisiken auf Unternehmensebene, um ein Bewusstsein für Informationssicherheitsrisiken in der gesamten Organisation zu fördern;
2. Bewusstsein der Führungsebene und Unterstützung bei Identifizierung, Analyse und Behandlung von Informationssicherheitsrisiken, um kontinuierliche Verbesserung zu fördern; und
3. Berücksichtigung der strategischen Ziele des Cloud-Anbieters beim Management von Risiken, um die Risikobehandlung an den Zielen der Organisation auszurichten.

OIS-08.02AC

Bei der Identifizierung von Risiken berücksichtigt der Cloud-Anbieter zusätzlich die Erkennung ungewöhnlicher und schädlicher Handlungen interner Bedrohungsakteure, soweit dies auf den bereitgestellten Cloud-Dienst anwendbar ist und im Verantwortungsbereich des Cloud-Anbieters liegt.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: OIS-08.01B, OIS-08.02B, OIS-08.03B, OIS-08.04B, OIS-08.05B, OIS-08.06B, OIS-08.01AS, OIS-08.01AC, OIS-08.02AC

Dieses Kriterium bezieht sich ausschließlich auf Risiken, die im Verantwortungsbereich des Cloud-Anbieters liegen. Auch beim Auslagern von Tätigkeiten zur Bereitstellung des Cloud-Dienstens auf Subservice-Organisationen verbleibt die Verantwortung für diese Risiken beim Cloud-Anbieter. Anforderungen an die Maßnahmen zur Behandlung dieser Risiken sind den Kriterien im Bereich 'Steuerung und Überwachung von Service-Organisationen und Lieferanten (SSO)' zu entnehmen.

Cloud-Anbieter können etablierte Risikomanagementstandards wie ISO 27005 oder die ISO-31000-Normenfamilie nutzen, um Risiken im Zusammenhang mit dem Cloud-Dienst zu adressieren. Bereits beim Cloud-Anbieter implementierte Risikomanagementverfahren können für OIS-08, soweit möglich, genutzt werden, um Redundanzen zu verringern. Die Dokumentation von Risiken, Behandlungsplänen und Risikoakzeptanz im Sinne dieses Kriteriums erfordert keine spezifischen formalen Rahmenwerke; schlanke Formen der Dokumentation können, soweit angemessen, genutzt werden, um die OIS-08-Unterkriterien zu adressieren.

Anwendbar auf: OIS-08.01B

Beispiele für Szenarien, in denen der Risikomanagementprozess 'anlassbezogen' durchgeführt werden kann, umfassen unter anderem die folgenden:

1. Änderungen der Bedrohungslandschaft (vgl. OIS-05);
2. Sicherheitsvorfälle oder Geschäftsunterbrechungen;
3. Änderungen der rechtlichen, regulatorischen, selbst auferlegten und vertraglichen Anforderungen an den Cloud-Anbieter, die für die Informationssicherheit des Cloud-Dienstes relevant sind (vgl. COM-01);
4. Änderungen der Organisationsstruktur des Cloud-Anbieters mit Auswirkungen auf Rollen, Verantwortlichkeiten oder Verfahren für die Bereitstellung des Cloud-Dienstes;
5. Änderungen der Architektur des Cloud-Dienstes (vgl. OPS-31);
6. Ereignisse im Zusammenhang mit Service-Organisationen des Cloud-Anbieters (vgl. SSO-05);
7. Ausnahmen von Richtlinien oder Verfahren (vgl. SP-03); und
8. Identifizierung kritischer Schwachstellen (vgl. OPS-22) oder Compliance-Abweichungen (vgl. COM-03).

Anwendbar auf: OIS-08.02B

Gemeinsam genutzte Ressourcen sind z. B. Netze, RAM oder Speicher.

Bei der Bestimmung des Schutzbedarfs von Cloud-Kundendaten und abgeleiteten Cloud-Dienstdaten sollten die für diese Datentypen geltende regulatorische Anforderungen berücksichtigt werden, wie z. B. PCI-DSS, HIPAA, DORA (Verordnung über digitale operationale Resilienz für den Finanzsektor und zur Änderung von Verordnungen), NIS-2-Richtlinie und KRITIS.

Anwendbar auf: OIS-08.04B

Relevante interne Parteien können die Geschäftsleitung und die Sicherheitsteams des Cloud-Anbieters umfassen.

Anwendbar auf: OIS-08.05B

Relevante externe Parteien können Cloud-Kunden, Subservice-Organisationen und Regulierungsbehörden umfassen.

Informationen, die in diesem Kontext relevant sein können, umfassen Informationen über identifizierte Schwachstellen, Sicherheitsvorfälle und Bedrohungsinformationen.

Der Cloud-Anbieter kann sich dafür entscheiden, diese Informationen über sein SSRM (vgl. OIS-03), seine Dokumentation und Richtlinien (vgl. PSS-01) oder seine Prozesse zur Information der Cloud-Kunden über bekannte Schwachstellen (vgl. PSS-03) zugänglich zu machen.

Korrespondierende Kriterien für Kunden

–

OIS-09 Anwendung der Richtlinie für Risikomanagement - Risikobehandlung

Basiskriterien

OIS-09.01B

Die Risikobehandlung wird entsprechend dem Niveau der mit dem Cloud-Dienst verbundenen Cybersicherheitsrisiken priorisiert.

OIS-09.02B

Ein Risikobehandlungsplan gemäß der Risikobeurteilung (vgl. OIS-08) ist dokumentiert und umgesetzt.

OIS-09.03B

Die im Risikobehandlungsplan festgelegten Maßnahmen reduzieren das Risikoniveau auf ein Restrisiko, das Risikoeigentümer akzeptieren können.

OIS-09.04B

Der Risikobehandlungsplan sowie in geeigneter Weise zusammengefasste und abstrahierte Versionen davon werden relevanten internen Parteien bereitgestellt.

OIS-09.05B

Auf Grundlage vertraglicher Vereinbarungen und relevanter rechtlicher und regulatorischer Anforderungen bestimmt der Cloud-Anbieter, welchen relevanten externen Parteien Informationen über den Risikobehandlungsplan bereitgestellt werden, die auf die Zwecke der Parteien zugeschnitten sind. Der Cloud-Anbieter bestimmt auch, in welchem Umfang dies geschehen soll.

OIS-09.06B

Die ausgewählten Optionen für die Risikobehandlung werden von den Risikoeigentümern jedes Mal überprüft, wenn die Risikobeurteilung geändert wird. Die Überprüfung berücksichtigt die Kriterien für die Risikoakzeptanz und die Priorisierung der Risikobehandlung.

OIS-09.07B

Für den Fall, dass der Cloud-Anbieter Risiken mit den Cloud-Kunden teilt, ordnet der Cloud-Anbieter geteilte Risiken korrespondierenden Kundenkontrollen zu und beschreibt sie in der Benutzerdokumentation (vgl. PSS-01).

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: OIS-09.01B, OIS-09.02B, OIS-09.03B, OIS-09.04B, OIS-09.05B, OIS-09.06B, OIS-09.07B

Dieses Kriterium bezieht sich ausschließlich auf Risiken, die im Verantwortungsbereich des Cloud-Anbieters liegen. Auch beim Auslagern von Tätigkeiten zur Bereitstellung des Cloud-Dienstens auf

Subservice-Organisationen verbleibt die Verantwortung für diese Risiken beim Cloud-Anbieter. Anforderungen an die Maßnahmen zur Behandlung dieser Risiken sind den Kriterien im Bereich ‘Steuerung und Überwachung von Service-Organisationen und Lieferanten (SSO)’ zu entnehmen.

Cloud-Anbieter können etablierte Risikomanagementstandards wie ISO 27005 oder die ISO-31000-Normenfamilie nutzen, um Risiken im Zusammenhang mit dem Cloud-Dienst zu adressieren. Bereits beim Cloud-Anbieter implementierte Risikomanagementverfahren können für OIS-09, soweit möglich, genutzt werden, um Redundanzen zu verringern. Die Dokumentation von Risiken, Behandlungsplänen und Risikoakzeptanz im Sinne dieses Kriteriums erfordert keine spezifischen formalen Rahmenwerke; schlanke Formen der Dokumentation können, soweit angemessen, genutzt werden, um die OIS-09-Unterkriterien zu adressieren.

Anwendbar auf: OIS-09.01B

Die Priorisierung kann beispielsweise durch die Festlegung geeigneter Fristen für die Behandlung der Risiken erfolgen.

Anwendbar auf: OIS-09.06B

Optionen für die Risikobehandlung können eines oder mehrere der folgenden Elemente umfassen:

1. Vermeidung des Risikos durch die Entscheidung, die Tätigkeit, die das Risiko hervorruft, nicht zu beginnen oder nicht fortzuführen;
2. Übernahme oder Erhöhung des Risikos, um eine Chance zu verfolgen;
3. Beseitigung der Risikoquelle;
4. Änderung der Wahrscheinlichkeit;
5. Änderung der Folgen;
6. Teilung des Risikos (z. B. durch Verträge, Abschluss von Versicherungen); und
7. Beibehaltung des Risikos auf Grundlage einer informierten Entscheidung.

Anwendbar auf: OIS-09.07B

Risiken, die der Cloud-Anbieter mit dem Cloud-Kunden teilt, werden als Teil des SSRM beschrieben (vgl. OIS-03).

Korrespondierende Kriterien für Kunden

–

OIS-10 Informationssicherheit im Projektmanagement

Basiskriterien

OIS-10.01B

Informationssicherheit ist in das Projektmanagement integriert. Risiken werden vom Cloud-Anbieter gemäß OIS-07 beurteilt, und die Risikobehandlung wird anlassbezogen durchgeführt. Risiken werden in allen Projekten behandelt, die einen direkten oder wesentlichen Einfluss auf die Erbringung, den Betrieb oder die Sicherheit des Cloud-Dienstes haben können.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: OIS-10.01B

Risiken mit wesentlichem Einfluss sind solche, die, falls sie eintreten, einen Schaden in einem Ausmaß verursachen würden, der die Informationssicherheit des Cloud-Dienstes, die Wirksamkeit der Kontrollen oder die Servicezusagen des Cloud-Anbieters wesentlich beeinträchtigen würde.

Korrespondierende Kriterien für Kunden

–

5.2 Sicherheitsrichtlinien und Arbeitsanweisungen (SP)

Zielsetzung: Bereitstellen von Richtlinien und Verfahren bzgl. des Sicherheitsanspruchs und zur Unterstützung der geschäftlichen Anforderungen.

SP-01 Dokumentation, Kommunikation und Bereitstellung von Richtlinien und Verfahren

Basiskriterien

SP-01.01B

Richtlinien und Verfahren (einschl. Rahmenwerke und Leitlinien) werden aus der Informationssicherheitsrichtlinie abgeleitet und gemäß einer einheitlichen Struktur dokumentiert. Die Richtlinien und Verfahren beschreiben mindestens die folgenden Aspekte:

1. Ziele;
2. Anwendungsbereiche;
3. Rollen und Verantwortlichkeiten, einschließlich Anforderungen an die Qualifikation des Personals und das Einrichten von Vertretungsregelungen;
4. Rollen und Abhängigkeiten von anderen Organisationen (insbesondere Cloud-Kunden und Subservice-Organisationen);
5. Maßnahmen zur Umsetzung der Sicherheitsstrategie; und
6. Anwendbare rechtliche und regulatorischer Anforderungen.

SP-01.02B

Die Richtlinien und Verfahren werden allem relevanten internem und externem Personal des Cloud-Anbieters sach- und bedarfsgerecht kommuniziert und zur Verfügung gestellt.

SP-01.03B

Die Richtlinien und Verfahren unterliegen einer Versionskontrolle.

SP-01.04B

Die Richtlinien und Verfahren werden von der obersten Leitung des Cloud-Anbieters oder einer autorisierten Stelle genehmigt.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: SP-01.01B

Richtlinien und Verfahren sind für die folgenden Basiskriterien erforderlich, in denen der Inhalt näher spezifiziert ist:

1. Informationssicherheitsrichtlinie (OIS-02);
2. Richtlinie für Risikomanagement (OIS-07);
3. Richtlinie für Remote-Arbeit (HR-07);
4. Rahmenwerk für Asset Management (AM-01);
5. Richtlinie für die ordnungsgemäße und sichere Nutzung von Assets (AM-05);
6. Sicherheitsanforderungen für Gebäude und Räumlichkeiten (PS-01);
7. Physische Zutrittskontrolle (PS-04);
8. Anforderungen an die Sicherheit von Arbeitsplätzen (PS-08);
9. Schutz vor Malware - Richtlinien und Verfahren (OPS-04);
10. Datensicherung und -wiederherstellung - Richtlinien und Verfahren (OPS-06);
11. Protokollierung und Überwachung - Richtlinien und Verfahren (OPS-10);
12. Protokollierung und Überwachung - Richtlinien und Verfahren für den Umgang mit abgeleiteten Cloud-Dienstdaten und Kontodaten (OPS-11);
13. Umgang mit Schwachstellen - Richtlinien und Verfahren (OPS-18);
14. Umgang mit Vorfällen und Abstürzen - Richtlinien und Verfahren (OPS-19);
15. Umgang mit Schwachstellen - Richtlinien und Verfahren zum Patch-Management (OPS-27);
16. Trennung von Datensätzen - Richtlinien und Verfahren (OPS-30);
17. Confidential Computing - Richtlinien und Verfahren (OPS-32);
18. Container-Management - Richtlinien und Verfahren (OPS-34);
19. Richtlinie für Identitäten und Zugriffsberechtigungen (IAM-01);
20. Authentisierungsmechanismen (Authentisierungsrichtlinie) (IAM-08);
21. Richtlinie für die Verwendung kryptographischer Mechanismen (CRY-01);
22. Technische Schutzmaßnahmen (COS-01);
23. Richtlinien für die Datenübertragung (COS-08);
24. Richtlinien für die Entwicklung/Beschaffung von Systemkomponenten (DEV-01);
25. Richtlinien für Änderungen an Systemkomponenten (DEV-03);
26. Sichere Nutzung von Hardware und Software Dritter (Richtlinien und Verfahren für die Nutzung von Drittanbieter- und Open-Source-Software) (DEV-14);
27. Richtlinien und Verfahren zur Steuerung und Überwachung von Service-Organisationen (SSO-01);
28. Steuerung des Austauschs mit Lieferanten funktionaler Komponenten (SSO-08);
29. Richtlinie für den Umgang mit Sicherheitsvorfällen (SIM-01);
30. Business Continuity- und Notfallmanagementsystem (BCM-01);
31. Richtlinie für die Planung und Durchführung von Audits (COM-02); und

32. Kommunikation technischer Verfahren zur Datenoffenlegung bei behördlichen Auskunfts- und Herausgabeverlangen (INQ-04).

Anwendbar auf: SP-01.02B

Die sach- und bedarfsgerechte Kommunikation und Bereitstellung sind vor dem Hintergrund der Größe und Komplexität der Organisation des Cloud-Anbieters und der Art des angebotenen Cloud-Dienstes zu beurteilen. Mögliche Kriterien sind:

1. Thematisierung der Richtlinien und Anweisungen in der Einarbeitung neuen Personals;
2. Schulungs- und Informationskampagnen bei der Einführung neuer oder der Überarbeitung bestehender Richtlinien und Verfahren; und
3. Form der Bereitstellung.

Korrespondierende Kriterien für Kunden

–

SP-02 Überprüfung und Freigabe von Richtlinien und Verfahren

Basiskriterien

SP-02.01B

Informationssicherheitsrichtlinien und -verfahren werden mindestens jährlich und im Falle wesentlicher Änderungen am Cloud-Dienst von sachverständigem Personal des Cloud-Anbieters auf Angemessenheit überprüft. Die Überprüfung hat mindestens die folgenden Aspekte zu berücksichtigen:

1. Organisatorische und technische Änderungen in den Verfahren zur Bereitstellung des Cloud-Dienstes; und
2. Gesetzliche und regulatorische Änderungen im Umfeld des Cloud-Anbieters.

SP-02.02B

Überarbeitete Richtlinien und Verfahren werden von der angemessenen Leitungsebene genehmigt, bevor sie Gültigkeit erlangen, und werden internem und externem Personal kommuniziert und zur Verfügung gestellt.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: SP-02.01B

Während eines ISO-27001-Zertifizierungsaudits werden die Kontrollen zu diesem Kriterium höchstwahrscheinlich ebenfalls geprüft. Handelt es sich um ein gemeinsames Audit (C5 und ISO), kann hier Effizienz im Sinne von ‘audit once, certify many’ erzielt werden. Handelt es sich um ein separates Audit, kann der Prüfer des C5-Attestierungsauftrags statt einer erneuten Prüfung der Kontrolle den ISO-Bericht einsehen, sofern die vorgelegten Nachweise hinreichend schlüssig sind.

Anwendbar auf: SP-02.02B

Wesentliche Änderungen umfassen unter anderem alle Umstände oder Ereignisse, die den Geltungsbereich, die Wirksamkeit oder die Ziele der Informationssicherheitsrichtlinie wesentlich beeinflussen. Konkret sind wesentliche Änderungen z. B.:

1. Größere technische oder architektonische Änderungen an der Cloud-Plattform (z. B. Einführung neuer Infrastrukturdienste, Cloud-Migration, Einführung eines neuen Serviceangebots);
2. Wesentliche Aktualisierungen nationaler oder internationaler Gesetze, Vorschriften oder sektorspezifischer Standards (z. B. NIS2, DORA, DSGVO), die die Verpflichtungen zur Informationssicherheit beeinflussen;
3. Reorganisation oder Fusion/Übernahme von Organisationseinheiten, welche die Führung, Entscheidungsfindung oder zentrale sicherheitsbezogene Verantwortlichkeiten betreffen;
4. Wesentliche Änderungen in vertraglichen Anforderungen, Risikobewertungen, operativen Prozessen oder der Bedrohungslage (z. B. neues Threat Intelligence, das auf neu entstehende Risiken hinweist, Vorfälle in der Lieferkette);
5. Größere Sicherheitsvorfälle oder -verletzungen, die eine Überarbeitung der Vorfallsbewältigung erfordern;
6. Einführung oder Außerbetriebnahme von Servicekomponenten, welche die Cloud-Kundendaten oder Trust Boundaries betreffen; und
7. Änderungen in der Zusammensetzung oder den Verantwortlichkeiten der obersten Leitung oder des Lenkungsausschusses für Informationssicherheit.

Für eine effiziente Überprüfung kann der Cloud-Anbieter die Art jeder wesentlichen Änderung, die Begründung für die Überprüfung und das Ergebnis von Richtlinienanpassungen dokumentieren. Eine automatisierte Nachverfolgung von Richtlinienänderungen und eine manuelle Verifizierung des Inhalts können ebenfalls in den Überprüfungsworkflow integriert werden.

Die oberste Leitung ist eine angemessene Leitungsebene für die Genehmigung der Informationssicherheitsrichtlinie.

Korrespondierende Kriterien für Kunden

–

SP-03 Ausnahmen von bestehenden Richtlinien und Verfahren

Basiskriterien

SP-03.01B

Alle Ausnahmen von Richtlinien und Verfahren für die Informationssicherheit werden in einer Liste geführt, einschließlich auch der mit den Ausnahmen verbundenen Kontrollen.

SP-03.02B

Ausnahmen von den Richtlinien und Verfahren für die Informationssicherheit sowie die jeweiligen Kontrollen durchlaufen Risikomanagementverfahren gemäß OIS-07, einschließlich Genehmigung der Ausnahmen und Akzeptanz der damit einhergehenden Risiken durch die Risikoeigentümer.

SP-03.03B

Die Risikomanagementverfahren gemäß OIS-07 berücksichtigen auch das aggregierte Risiko aus einer Kombination einzelner Ausnahmen.

SP-03.04B

Die Genehmigungen von Ausnahmen werden dokumentiert, mit einer festgelegten Gültigkeit versehen und mindestens jährlich von den Risikoeigentümern oder von der obersten Leitung auf Angemessenheit

überprüft. Diese Überprüfung berücksichtigt ebenfalls das aggregierte Risiko aus einer Kombination einzelner Ausnahmen.

SP-03.05B

Ausnahmen von Richtlinien und Verfahren der Informationssicherheit, die zu einer Abweichung (vgl. 3.4.12) von einem anwendbaren C5-Kriterium innerhalb des Geltungsbereichs eines Attestierungsauftrags (vgl. 3.4.1) führen würden, sind nicht zulässig.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

SP-03.01AC

Die Ausnahmen von Richtlinien oder Verfahren werden von der angemessenen Leitungsebene genehmigt.

SP-03.02AC

Der Cloud-Anbieter überwacht die Liste der Ausnahmen, um das Ablaufen genehmigter Ausnahmen zu verhindern und die Aktualität aller Überprüfungen und Genehmigungen sicherzustellen.

SP-03.03AC

Alle Ausnahmen, bei denen während der Überwachung Abweichungen festgestellt wurden, werden durch zeitnahe und angemessene Abhilfemaßnahmen behandelt.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: SP-03.01B

Während eines ISO-27001-Zertifizierungsaudits werden die Kontrollen zu diesem Kriterium höchstwahrscheinlich ebenfalls geprüft. Handelt es sich um ein gemeinsames Audit (C5 und ISO), kann hier Effizienz im Sinne von 'audit once, certify many' erzielt werden. Handelt es sich um ein separates Audit, kann der Prüfer des C5-Attestierungsauftrags statt einer erneuten Prüfung der Kontrolle den ISO-Bericht einsehen, sofern die vorgelegten Nachweise hinreichend schlüssig sind.

Anwendbar auf: SP-03.05B

Dieses Kriterium bezieht sich auf Richtlinien und Verfahren und fordert, dass auf dieser Ebene keine schriftlich niedergelegten Abweichungen von anwendbaren C5-Kriterien zulässig sind.

Anwendbar auf: SP-03.01B, SP-03.02B, SP-03.03B, SP-03.04B, SP-03.05B, SP-03.01AC, SP-03.02AC, SP-03.03AC

Ausnahmen im Sinne des Kriteriums können organisatorische oder technische Ursachen haben, wie zum Beispiel:

1. Eine Organisationseinheit soll von vorgesehen Prozessen und Verfahren abweichen, um Anforderungen eines Cloud-Kunden zu erfüllen; und
2. Einer Systemkomponente fehlen technische Eigenschaften, um sie gemäß den anwendbaren Anforderungen zu konfigurieren.

Anwendbar auf: SP-03.01AC

Die angemessene Leitungsebene für die Genehmigung ist in den meisten Fällen entweder die Leitungsebene, die die Richtlinien oder Verfahren genehmigt hat, oder die Leitungsebene, an die diese Aufgabe delegiert ist.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass sie vom Cloud-Anbieter Informationen über Ausnahmen von Richtlinien und Verfahren der Informationssicherheit erhalten, um die damit verbundenen Risiken für ihre eigene Informationssicherheit zu bewerten und angemessen zu steuern.

5.3 Personal (HR)

Zielsetzung: Sicherstellen, dass Mitarbeiter ihre Aufgaben verstehen, sich ihrer Verantwortung in Bezug auf Informationssicherheit bewusst sind und die Assets der Organisation bei Änderung der Aufgaben oder Beendigung geschützt werden.

HR-01 Überprüfung der Qualifikation und Vertrauenswürdigkeit

Basiskriterien

HR-01.01B

Der Cloud-Anbieter identifiziert für die Produktionsumgebung, welche Rollen innerhalb der Organisation auf Cloud-Kundendaten, abgeleitete Cloud-Dienstdaten, Cloud-Anbieterdaten, Kontodaten oder Systemkomponenten unter der Verantwortung des Cloud-Anbieters zugreifen können.

HR-01.02B

Die Qualifikation und Vertrauenswürdigkeit des gesamten internen und externen Personals, dem diese Rollen zugewiesen sind, wird vor der Beschäftigung überprüft. Die Überprüfung berücksichtigt die folgenden Maßnahmen, soweit dies nach lokaler Gesetzgebung und Regulierung zulässig ist und vom Cloud-Anbieter als angemessen angesehen wird, um Risiken im Zusammenhang mit unangemessenem Zugriff auf den jeweiligen Datentyp zu mitigieren:

1. Überprüfung der Identität der Person anhand des Personalausweises oder Reisepasses;
2. Überprüfung der Berufserfahrung anhand des Lebenslaufs;
3. Überprüfung akademischer Titel und Abschlüsse;
4. Anforderung eines Führungszeugnisses, einer polizeilichen Unbedenklichkeitsbescheinigung oder anderer nationaler Äquivalente; und
5. Bewertung der Erpressbarkeit.

HR-01.03B

Der Cloud-Anbieter berücksichtigt Änderungen der Rollen des Personals oder des Beschäftigungsstatus, die sich auf Zugriffsrechte, Verantwortlichkeiten oder die Risikoexposition auswirken können, und identifiziert und mitigiert damit verbundene Risiken.

HR-01.04B

Der Cloud-Anbieter klassifiziert sicherheitssensible Positionen entsprechend ihrem Risikoniveau, einschließlich IT-Administrationsrollen und aller Positionen mit Zugriff auf Cloud-Kundendaten oder auf Systemkomponenten, die zur Bereitstellung des Cloud-Dienstes in der Produktionsumgebung verwendet werden.

HR-01.05B

Der Cloud-Anbieter beurteilt die Qualifikation und Vertrauenswürdigkeit seines Personals vor einer Versetzung oder Beförderung in eine Rolle mit höherer Risikoklassifizierung.

HR-01.06B

Die Intensität der in diesem Kriterium definierten Beurteilung steht im Verhältnis zum geschäftlichen Kontext, zur Sensibilität der Informationen, auf die das Personal zugreifen wird, und zu den damit verbundenen Risiken.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

HR-01.01AC

Der Cloud-Anbieter definiert in der Personalrichtlinie Positionen mit Stufen und Risikoklassifizierung, die eine regelmäßige Beurteilung von Qualifikation und Vertrauenswürdigkeit erfordern. Der Cloud-Anbieter überprüft jährlich seine Beurteilung der Qualifikation und Vertrauenswürdigkeit für Personal, das den definierten Positionen angehört.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: HR-01.01B

Dieses Kriterium gilt sowohl für bestehendes als auch für neu eingestelltes Personal. Rollen mit Zugriff auf diese Datentypen oder Systemkomponenten können abhängig von ihren Zugriffsrechten unter anderem die folgenden umfassen:

1. Cloud-Software-Ingenieure und -entwickler;
2. Cloud-Architekten und Cloud-Infrastruktur-Ingenieure;
3. Cloud-Plattform-Ingenieure und DevOps-Ingenieure;
4. Ingenieure und Manager für den Cloud-Systembetrieb;
5. Cloud-Dienstingenieure und -manager;
6. Cloud-Netzwerkingenieure und Leitende Architekten;
7. Cloud-Sicherheitsingenieure, -Administratoren und -Sicherheitsarchitekten;
8. Spezialisten und Analysten für Cloud-Sicherheitsbetrieb;
9. Speicher- und Datenbank-Ingenieure;
10. Technische Account Manager und Customer Account Manager;
11. Kundensupport-Ingenieure;
12. IAM-Administratoren und Spezialisten für Zugriffs- und Berechtigungsmanagement;
13. Cloud-Compliance-Manager sowie Risiko- und Compliance-Analysten; und
14. Informationssicherheitsbeauftragte und Datenschutzbeauftragte.

Der Begriff Personal bezieht sich sowohl auf internes als auch auf externes Personal.

Anwendbar auf: HR-01.02B

Dieses Kriterium gilt sowohl für bestehendes als auch für neu eingestelltes Personal. Externes Personal im Sinne des Kriteriums ist solches, das Tätigkeiten in Übereinstimmung mit den Prozessen und Verfahren des Cloud-Anbieters ausführt und potenziellen Zugriff auf Cloud-Kundendaten oder abgeleitete Cloud-Dienstdaten hat. Personal von Service-Organisationen, das Tätigkeiten nach den eigenen Prozessen und Verfahren der Service-Organisation ausführt, wird von diesem Kriterium nicht erfasst.

Zulässige Überprüfungen von Qualifikation und Vertrauenswürdigkeit richten sich nach den jeweils geltenden lokalen Gesetzen und den Rollen des Personals. In einigen Rechtsordnungen ist die Erhebung, Verarbeitung oder Offenlegung solcher Informationen grundsätzlich eingeschränkt oder sogar verboten, was bedeutet, dass sie möglicherweise überhaupt nicht oder nur in sehr eingeschränkter Form erlangt werden können. Soweit zulässig, kann je nach Art und Umfang der Prüfungen die ausdrückliche Einwilligung des Personals erforderlich sein. Diese rechtlichen Beschränkungen gelten auch für sämtliche Analysen in Bezug auf Erpressbarkeit.

Die Überprüfung der Qualifikation und Vertrauenswürdigkeit kann durch einen spezialisierten Dienstleister unterstützt werden oder auf freiwilliger Selbstauskunft des Personals beruhen. Je nach nationaler Gesetzgebung sind auch nationale Pendants des deutschen Führungszeugnisses zulässig. Die Beurteilung der Erpressbarkeit potenziellen Personals kann die Bewertung seiner Kreditwürdigkeit umfassen. Diese Beurteilung kann jedoch abhängig von lokalen Regelungen nur für Positionen mit erheblicher finanzieller Verantwortung rechtlich zulässig sein.

Risiken im Zusammenhang mit unangemessenem Zugriff auf Cloud-Kundendaten können durch den Einsatz von Verschlüsselung oder die Überwachung von Systemzugriffen auf verdächtige Ereignisse mitigiert werden. Obwohl solche Maßnahmen die oben genannten Verifikationsmaßnahmen nicht vollständig ersetzen sollen, kann der Umfang dieser Verifikationsmaßnahmen reduziert werden.

Anwendbar auf: HR-01.01AC

Cloud-Anbieter können verschiedene Methoden umsetzen, um Qualifikation und Vertrauenswürdigkeit von Personal in Hochrisikopositionen zu beurteilen, wie zum Beispiel:

1. Selbstauskunft über wesentliche finanzielle Interessen zur Feststellung von Interessenkonflikten und Erpressbarkeit;
2. Regelmäßige Prüfung von Führungszeugnissen, polizeilichen Unbedenklichkeitsbescheinigungen oder anderen nationalen Äquivalenten;
3. Regelmäßige Selbsterklärung der Verpflichtung gegenüber geltenden Richtlinien und Verpflichtungen;
4. Durchsetzung regelmäßiger Ethik- und Compliance-Schulungen, einschließlich Zertifizierung und Überprüfung des Verständnisses des Personals für geltende Anforderungen und Richtlinien;
5. Durchsetzung der regelmäßigen Teilnahme an Assessment-Centern zur Bewertung der Qualifikation und Vertrauenswürdigkeit des Personals; und
6. Regelmäßige Überprüfung des Personals anhand nationaler und internationaler Sanktionslisten.

Korrespondierende Kriterien für Kunden

–

HR-02 Beschäftigungs- und Vertragsbedingungen

Basiskriterien

HR-02.01B

Der Cloud-Anbieter stellt sicher, dass die Beschäftigungs- und Vertragsbedingungen die geltenden gesetzlichen und regulatorischen Anforderungen gemäß SP-01 widerspiegeln.

HR-02.02B

Das interne und externe Personal des Cloud-Anbieters werden in den Beschäftigungs- und Vertragsbedingungen auf die Einhaltung des Verhaltenskodex und der Informationssicherheitsrichtlinie sowie der darauf basierenden Richtlinien, Verfahren und Anweisungen verpflichtet.

HR-02.03B

Der Cloud-Anbieter stellt sicher, dass eine Geheimhaltungsklausel in die Bedingungen für sämtliches internes und externes Personal aufgenommen wird. Die Geheimhaltungsklausel umfasst sämtliche Informationen, einschließlich anonymisierter und pseudonymisierter Informationen, die das Personal im Rahmen des Cloud-Dienstes erhält oder erzeugt.

HR-02.04B

Der Cloud-Anbieter weist sein Personal vor der Gewährung eines Zugriffs auf Cloud-Kundendaten, abgeleitete Cloud-Dienstdaten, Cloud-Anbieterdaten und Kontodaten oder auf Systemkomponenten unter der Verantwortung des Cloud-Anbieters, die zur Bereitstellung des Cloud-Dienstes in der Produktionsumgebung verwendet werden, in den Verhaltenskodex und die Informationssicherheitsrichtlinie sowie die darauf basierenden Richtlinien, Verfahren und Anweisungen ein.

HR-02.05B

Zusätzlich verlangt der Cloud-Anbieter, dass der Verhaltenskodex und die Informationssicherheitsrichtlinie sowie die darauf basierenden Richtlinien, Verfahren und Anweisungen vom internen und externen Personal in dokumentierter Form anerkannt werden, bevor Zugriff auf eine der vorgenannten Daten oder Systemkomponenten gewährt wird.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: HR-02.03B

Diese Vereinbarungen werden in HR-06 näher geregelt.

Korrespondierende Kriterien für Kunden

–

HR-03 Programm zur Sicherheitsausbildung und Sensibilisierung

Basiskriterien

HR-03.01B

Der Cloud-Anbieter betreibt ein zielgruppenorientiertes Sensibilisierungs- und Schulungsprogramm für Sicherheit.

HR-03.02B

Das gesamte interne und externe Personal des Cloud-Anbieters durchläuft regelmäßig und bei Änderung der Tätigkeit ein rollenbasiertes Schulungsprogramm, wobei mindestens die Risikoklassifizierung und die technischen Verantwortlichkeiten der Position des jeweiligen Personals berücksichtigt werden.

HR-03.03B

Das Programm wird, ausgehend von Änderungen an Richtlinien und Verfahren sowie der aktuellen Bedrohungslage, regelmäßig aktualisiert und umfasst, soweit sie für die Rolle des jeweiligen Personals anwendbar sind, die folgenden Aspekte:

1. Umgang mit Systemkomponenten, die zur Bereitstellung des Cloud-Dienstes in der Produktionsumgebung verwendet werden, gemäß den anwendbaren Richtlinien und Verfahren;
2. Umgang mit Cloud-Kundendaten, abgeleiteten Cloud-Dienstdaten, Cloud-Anbieterdaten und Kontodaten gemäß den anwendbaren Richtlinien und Verfahren sowie den geltenden gesetzlichen und regulatorischen Anforderungen;
3. Information über die aktuelle Bedrohungslage;
4. Richtiges Verhalten bei Sicherheitsvorfällen;
5. Sicherheits-Best-Practices; und
6. Sichere Entwicklung.

HR-03.04B

Die durch das Sensibilisierungs- und Schulungsprogramm erzielten Lernerfolge werden gemessen und ausgewertet.

Zusatzkriterium (Verschärfend)

HR-03.02AS, verschärft HR-03.02B

Das gesamte interne und externe Personal des Cloud-Anbieters durchläuft mindestens jährlich und bei Änderung der Tätigkeit ein rollenbasiertes Schulungsprogramm, wobei mindestens die Risikoklassifizierung und die technischen Verantwortlichkeiten seiner Position berücksichtigt werden.

Zusatzkriterium (Erweiternd)

HR-03.01AC

Der Cloud-Anbieter überwacht den Abschluss des Sensibilisierungs- und Schulungsprogramms für Sicherheit.

HR-03.02AC

Zeitnahe und angemessene Maßnahmen zur Behebung aller während der Überwachung identifizierten Abweichungen.

HR-03.03AC

Die durch das Sensibilisierungs- und Schulungsprogramm erzielten Lernerfolge werden zielgruppenbezogen gemessen und ausgewertet.

HR-03.04AC

Die Messungen umfassen quantitative und qualitative Aspekte.

HR-03.05AC

Die Ergebnisse fließen in die Verbesserung des Sensibilisierungs- und Schulungsangebots ein.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: HR-03.01B

Die Zielgruppen können unter Berücksichtigung der Tätigkeit, der Position und der damit verbundenen Risikoklassifizierung definiert werden. Zielgruppen dienen der Vereinfachung und Systematisierung des Sensibilisierungs- und Schulungsprogramms für Sicherheit.

Anwendbar auf: HR-03.03AC

Die Messung und Bewertung von Lernergebnissen auf zielgruppenbezogener Weise, wie durch das Zusatz-Unterkriterium festgelegt, erfordert keine Bewertung jedes einzelnen Mitglieds des Personals. Stattdessen

können Bewertungen auf aggregierter Ebene durchgeführt werden, wobei der Schwerpunkt auf der Gesamteffektivität des Schulungsprogramms für bestimmte Zielgruppen liegt. Dieser Ansatz ermöglicht die Identifizierung von Trends und Verbesserungsbereichen innerhalb des Programms unter Wahrung der Datenschutzanforderungen des Personals.

Korrespondierende Kriterien für Kunden

–

HR-04 Maßregelungsprozess

Basiskriterien

HR-04.01B

Der Cloud-Anbieter stellt sicher, dass die Richtlinien und Verfahren zum Maßregelungsprozess die geltenden gesetzlichen und regulatorischen Anforderungen gemäß SP-01 widerspiegeln.

HR-04.02B

Im Falle von Verstößen gegen Richtlinien und Verfahren oder gegen geltende gesetzliche und regulatorische Anforderungen werden Disziplinarmaßnahmen in Übereinstimmung mit einer definierten Richtlinie ergriffen, die die folgenden Aspekte umfasst:

1. Prüfung, ob ein Verstoß vorliegt; und
2. Berücksichtigung der Art und Schwere des Verstoßes sowie dessen Auswirkungen.

HR-04.03B

Das interne und externe Personal des Cloud-Anbieters wird über mögliche Disziplinarmaßnahmen informiert.

HR-04.04B

Der Einsatz von Disziplinarmaßnahmen wird in geeigneter Weise dokumentiert.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: HR-04.04B

Hinsichtlich des Einsatzes von Disziplinarmaßnahmen ist die Vorlage anonymisierter Nachweise zulässig und impliziert nicht, dass das Basiskriterium nicht vollständig erfüllt ist.

Korrespondierende Kriterien für Kunden

–

HR-05 Verantwortlichkeiten bei Beendigung oder Änderung der Beschäftigung

Basiskriterien

HR-05.01B

Internes und externes Personal ist nachweislich darüber informiert, wie lange welche Verantwortlichkeiten, die sich aus den Beschäftigungs- und Vertragsbedingungen mit Bezug zur Informationssicherheit ergeben, auch bei Beendigung oder Änderung der Beschäftigung bestehen bleiben.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

–

Korrespondierende Kriterien für Kunden

–

HR-06 Vertraulichkeitsvereinbarungen

Basiskriterien

HR-06.01B

Die mit internem Personal und Service-Organisationen des Cloud-Anbieters zu vereinbarenden Geheimhaltungs- oder Vertraulichkeitsvereinbarungen basieren auf den vom Cloud-Anbieter identifizierten Anforderungen zum Schutz vertraulicher Informationen und betrieblicher Details.

HR-06.02B

Die Vereinbarungen sind mit Service-Organisationen bei Vertragsabschluss zu schließen.

HR-06.03B

Die Vereinbarungen sind mit internem Personal des Cloud-Anbieters zu schließen, bevor die Berechtigung zum Zugriff auf Cloud-Kundendaten, abgeleitete Cloud-Dienstdaten, Cloud-Anbieterdaten und Kontodaten erteilt wird.

HR-06.04B

Die Anforderungen sind zu dokumentieren sowie in regelmäßigen Abständen (mindestens jährlich) und bei wesentlichen Änderungen des Cloud-Dienstes zu überprüfen. Soweit sich aus der Überprüfung ergibt, dass die Anforderungen anzupassen sind, werden die Geheimhaltungs- oder Vertraulichkeitsvereinbarungen aktualisiert.

HR-06.05B

Der Cloud-Anbieter informiert das interne Personal und die Service-Organisationen hierüber und schließt mit diesen die aktualisierten Geheimhaltungs- oder Vertraulichkeitsvereinbarungen.

HR-06.06B

In Fällen, in denen eine Einigung über die Aktualisierungen nicht erzielt werden kann, beurteilt der Cloud-Anbieter die daraus resultierenden Risiken für die Informationssicherheit gemäß OIS-07.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: HR-06.01B

Eine Vertraulichkeitsvereinbarung (engl. Non-Disclosure Agreement, NDA) ist ein rechtliches Dokument und enthält Informationen, die von beiden Parteien zum Schutz vertraulicher Informationen benötigt werden. Prozesse und Verfahren im Zusammenhang mit dem Umgang mit Medien können separat außerhalb des NDA verwaltet werden. Ein NDA sollte Folgendes abdecken:

1. Welche Informationen oder Datentypen vertraulich behandelt werden müssen;
2. Für welchen Zeitraum diese Vertraulichkeitsvereinbarung gilt;
3. Welche Aktionen bei Beendigung dieser Vereinbarung vorgenommen werden müssen, z. B. Vernichtung oder Rückgabe von Datenträgern;
4. Wie die Eigentumsrechte an Informationen geregelt sind;
5. Welche Regelungen für den Gebrauch und die Weitergabe von vertraulichen Informationen an weitere Partner gelten, falls dies notwendig ist;
6. Welche Konsequenzen bei Verletzung der Vereinbarung eintreten..

Diese Vereinbarungen werden allgemein in HR-02 beschrieben.

Anwendbar auf: HR-06.02B, HR-06.03B, HR-06.05B

Geheimhaltungs- oder Vertraulichkeitsvereinbarungen sollten, soweit dies rechtsverbindlich ist, mittels einer elektronischen Signatur unterschrieben werden.

Korrespondierende Kriterien für Kunden

–

HR-07 Remote-Arbeit - Richtlinie

Basiskriterien

HR-07.01B

Richtlinien und Verfahren zum Schutz von Informationen, wenn Personal remote arbeitet, werden in Übereinstimmung mit SP-01 dokumentiert, kommuniziert und bereitgestellt und behandeln die folgenden Aspekte:

1. Festlegung von Leitlinien für das Personal zum sicheren Umgang mit und zur sicheren Speicherung von sensiblen Informationen und Datentypen;
2. Definition von Sicherheitsanforderungen für den Remote-Zugriff;
3. Nutzung sicherer Kommunikationsmethoden und Durchsetzung einer sicheren Netzwerknutzung (z. B. VPN-Nutzung, Endpunktschutz, Multi-Faktor-Authentifizierung, sichere Kommunikationskanäle); und
4. Bereitstellung von Ausstattung, die von der Organisation genehmigt ist und Verbot unregulierter persönlicher Geräte.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: HR-07.01B

Bitte beachten: Dieses Kriterium bezieht sich auf Arbeitsplätze außerhalb des Standorts, während PS-08.01B Sicherheitsanforderungen für Büroarbeitsplätze vor Ort behandelt.

Die Leitlinien für das Personal zum sicheren Umgang mit und zur sicheren Speicherung von sensiblen Informationen und Datentypen beziehen sich auf organisatorische Maßnahmen, zu deren Einhaltung das Personal verpflichtet ist. Sicherheitsanforderungen für den Remote-Zugriff beziehen sich auf technische Maßnahmen wie z. B. MFA und VPN sowie auch auf Regeln für den jeweiligen Arbeitsplatz, die sich aus allgemeinen Erwägungen zum Arbeiten ergeben, z. B. an öffentlichen Orten, an denen der Bildschirm ausgespäht werden kann.

Korrespondierende Kriterien für Kunden

–

HR-08 Remote-Arbeit - Umsetzung

Basiskriterien

HR-08.01B

Der Cloud-Anbieter konzipiert, implementiert und unterhält die technischen und organisatorischen Maßnahmen, die erforderlich sind, damit sein Personal die Richtlinien und Verfahren für Remote-Arbeit einhalten kann (vgl. HR-07).

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: HR-08.01B

Bitte beachten: Dieses Kriterium bezieht sich auf Arbeitsplätze außerhalb des Standorts, während PS-08.01B Sicherheitsanforderungen für Büroarbeitsplätze vor Ort behandelt.

Korrespondierende Kriterien für Kunden

–

5.4 Asset Management (AM)

Zielsetzung: Identifizieren der organisationseigenen Assets gewährleisten und ein angemessenes Schutzniveau über deren gesamten Lebenszyklus sicherstellen.

AM-01 Rahmenwerk für Asset Management

Basiskriterien

AM-01.01B

Ein Rahmenwerk für Asset Management ist gemäß SP-01 dokumentiert, kommuniziert und bereitgestellt, in dem die folgenden Aspekte beschrieben sind:

1. Identifizierung von Assets, die verwendet werden, um den Cloud-Dienst in der Produktionsumgebung bereitzustellen;
2. Definition eines Schemas zur Ermittlung des Schutzbedarfs auf der Grundlage der Informationen, die auf dem Asset verarbeitet, gespeichert oder übertragen werden;
3. Definition von Asset-Typen unter Berücksichtigung mindestens der Unterscheidung zwischen Hardware- und Software-Objekten;
4. Definition von Asset-Lebenszyklen auf der Grundlage des Asset-Typs; und
5. Definition von Verfahren für die Inventarisierung von Hardware- und Software-Assets.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

AM-01.01AC

Die über Assets gesammelten Informationen werden in Logging- und Monitoring-Anwendungen berücksichtigt, um:

1. die Auswirkungen auf Cloud-Dienste und -Funktionen im Falle von Ereignissen zu identifizieren, die zu einer Verletzung der Schutzziele führen könnten; und
2. Informationen zur Unterstützung betroffener Cloud-Kunden gemäß den vertraglichen Vereinbarungen bereitzustellen.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: AM-01.01B, AM-01.01AC

Assets im Sinne dieses Kriterienbereichs sind die für die Informationssicherheit des Cloud-Dienstes während der Erstellung, Verarbeitung, Speicherung, Übermittlung, Löschung oder Vernichtung von Informationen benötigten Objekte im Verantwortungsbereich des Cloud-Anbieters, z. B. Firewalls, Loadbalancer, Webserver, Anwendungsserver und Datenbankserver.

Diese Objekte bestehen wiederum aus Hardware- und Software-Objekten:

Hardware-Objekte sind:

1. Physische und virtuelle Infrastruktur-Ressourcen (z. B. Server, Speichersysteme, Netzkomponenten); und
2. Endgeräte, soweit der Cloud-Anbieter in einer Risikobeurteilung festgestellt hat, dass diese bei Verlust oder unautorisierten Zugriffen die Informationssicherheit des Cloud-Dienstes gefährden könnten (z. B. Mobilgeräte, die als Security-Token zur Authentifizierung genutzt werden).

Software-Objekte sind z. B. Hypervisor, Container, Betriebssysteme, Datenbanken, Microservices und Programmierschnittstellen (APIs).

Der Lebenszyklus eines Assets umfasst:

1. Anschaffung;
2. Inbetriebnahme;
3. Instandhaltung;
4. Außerbetriebnahme; und
5. Entsorgung.

Korrespondierende Kriterien für Kunden

–

AM-02 Asset-Inventar

Basiskriterien

AM-02.01B

Der Cloud-Anbieter führt ein Asset-Inventar von Hardware- und Software-Assets gemäß dem Rahmenwerk für Asset Management (vgl. AM-01).

AM-02.02B

Die Inventarisierung erfolgt automatisch und/oder durch für die Assets zuständige Personen oder Gruppen, um eine vollständige, richtige, gültige und konsistente Erfassung über den Lebenszyklus der Assets sicherzustellen.

AM-02.03B

Zu den Assets werden jene Informationen erfasst, die zur Anwendung des Risikomanagement-Verfahrens (vgl. OIS-07), einschließlich der Maßnahmen zur Behandlung dieser Risiken über den Lebenszyklus der Assets benötigt werden.

AM-02.04B

Änderungen an den erfassten Informationen eines Assets werden protokolliert.

AM-02.05B

Der Cloud-Anbieter führt Listen aller Benutzer in seinem Verantwortungsbereich, die Zugriff auf eine bestimmte Ressource haben, zusammen mit ihren jeweiligen Zugriffsrechten.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

AM-02.01AC

Der Cloud-Anbieter stellt sicher, dass das Asset-Inventar aktuell ist, indem er Überwachungsmaßnahmen für den Prozess implementiert, der es pflegt.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: AM-02.01B, AM-02.02B, AM-02.03B, AM-02.04B, AM-02.05B

Cloud-Anbieter, die ihre Cloud-Infrastruktur als virtuelle Infrastruktur von einer Service-Organisation beziehen (z. B. virtuelle Maschinen oder Container), können von der Service-Organisation bereitgestellte Werkzeuge verwenden, um diese Assets zu inventarisieren, sofern der Cloud-Anbieter diese auf der Grundlage seines Rahmenwerks für Asset Management als geeignet erachtet.

In der Praxis kann die Umsetzung des Asset-Inventars je nach Anzahl, Größe und Komplexität der bereitgestellten Cloud-Dienste stark variieren.

Anwendbar auf: AM-02.05B

Diese Listen können, müssen aber nicht, durch das Inventarsystem bereitgestellt werden, das durch die Kriterien AM-02, AM-03 und AM-04 eingerichtet wird.

Korrespondierende Kriterien für Kunden

–

AM-03 Hardware-Asset-Inventar

Basiskriterien

AM-03.01B

Das vom Cloud-Anbieter geführte Hardware-Asset-Inventar (vgl. AM-02) enthält für jeden Eintrag Informationen, die:

1. die Identifizierung des Hardware-Assets ermöglichen;
2. Einblick in den Lebenszyklus des Hardware-Assets geben; und
3. dem Cloud-Anbieter ermöglichen, das Hardware-Asset zu kontrollieren, eine Risikobeurteilung durchzuführen und seine Informationssicherheit zu schützen.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: AM-03.01B

Dieses Basiskriterium kann, muss aber nicht, erfüllt werden, indem für jeden Eintrag des Hardware-Asset-Inventars die folgenden Details aufgenommen werden:

1. Identifizierungsdetails (wie Name, IP-Adresse, MAC-Adresse usw.);
2. Die Funktion des Assets;
3. Das Modell des Assets;
4. Der Standort des Assets;
5. Der Eigentümer des Assets; und
6. Informationssicherheitsanforderungen für das Asset.

Ein Asset Owner ist eine Person oder Rolle, welche die Verantwortung und Rechenschaftspflicht für die Verwaltung und den Schutz eines Assets einer Organisation zugewiesen ist, und impliziert kein rechtliches Eigentum an den Assets.

Wenn Cloud-Kunden virtuelle Maschinen oder Container mit dem Cloud-Dienst betreiben, inventarisiert der Cloud-Anbieter die Container und dokumentiert ihren Lebenszyklus (vgl. OPS-34).

Korrespondierende Kriterien für Kunden

–

AM-04 Software-Asset-Inventar

Basiskriterien

AM-04.01B

Der Cloud-Anbieter führt ein umfassendes Inventar aller Software-Assets, einschließlich verwendeter Software (vgl. AM-02). Dieses Inventar enthält für jeden Eintrag Informationen, die:

1. die Identifizierung des Software-Assets ermöglichen;
2. Einblick darin geben, welche anderen Assets das Software-Asset für die Bereitstellung des Cloud-Dienstes verwenden; und
3. dem Cloud-Anbieter ermöglichen, das Software-Asset zu kontrollieren, eine Risikobeurteilung durchzuführen und seine Informationssicherheit zu schützen.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

AM-04.01AC

Das Inventar enthält außerdem für jeden Eintrag Informationen, die Einblick darin geben, wie lange das Software-Asset Sicherheitsupdates von seinem Lieferanten erhalten wird, sofern ein solcher Zeitraum vom Lieferanten mitgeteilt wurde.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: AM-04.01B

Dieses Basiskriterium kann, muss aber nicht, erfüllt werden, indem für jeden Eintrag des Software-Asset-Inventars die folgenden Details aufgenommen werden:

1. Identifizierungsdetails (wie Name, IP-Adresse, MAC-Adresse usw.);
2. Die Version der Software; und
3. Die übergeordnete Ressource (Hardware-Asset oder Software-Asset), auf der die Software installiert ist.

Anwendbar auf: AM-04.01AC

Dieses Zusatz-Unterkriterium kann, muss aber nicht, erfüllt werden, indem für jeden Eintrag des Software-Asset-Inventars Lizenzinformationen, einschließlich mitgeteilter End-of-Support-Daten in Bezug auf die lizenzierte Software, aufgenommen werden.

Korrespondierende Kriterien für Kunden

–

AM-05 Richtlinie für die ordnungsgemäße und sichere Nutzung von Assets

Basiskriterien

AM-05.01B

Richtlinien und Verfahren für die ordnungsgemäße und sichere Nutzung mit Assets sind gemäß SP-01 dokumentiert, kommuniziert und bereitgestellt und adressieren folgende Aspekte im Lebenszyklus von Assets, soweit diese für das Asset anwendbar sind:

1. Genehmigungsverfahren für Anschaffung, Inbetriebnahme, Instandhaltung, Außerbetriebnahme und Entsorgung durch autorisiertes Personal oder Systemkomponenten;
2. Klassifizierung und Kennzeichnung auf Basis des Schutzbedarfs der Cloud-Kundendaten, abgeleiteten Cloud-Dienstdaten, Cloud-Anbieterdaten und Kontodaten sowie Maßnahmen zur ermittelten Sicherheitsniveau;
3. Sichere Konfiguration der Mechanismen für Fehlerbehandlung, Protokollierung, Verschlüsselung, Authentisierung und Autorisierung;
4. Anforderungen an Software- und Image-Versionen sowie Anwendung von Patches;
5. Umgang mit Software für die kein Support und keine Sicherheitsaktualisierungen mehr verfügbar sind;
6. Einschränkung von Software-Installationen oder Nutzung von Diensten;
7. Schutz vor Schadsoftware;
8. Remote-Deaktivierung, -Löschung oder -Sperrung;
9. Physische Übergabe und Transport;
10. Umgang mit Störungen und Schwachstellen;
11. Löschung von Cloud-Kundendaten, abgeleiteten Cloud-Dienstdaten, Cloud-Anbieterdaten und Kontodaten; und
12. Sichere Handhabung und Nutzung von Wechselmedien, z. B. durch Festlegung, welche Geräte mit Wechselmedien interagieren dürfen und welche Daten auf ihnen gespeichert werden können, oder durch Verbot der Wiederverwendung von Wechselmedien.

AM-05.02B

Die Anwendbarkeit dieser Aspekte wird auf der Grundlage des Rahmenwerks für Asset Management des Cloud-Anbieters definiert (vgl. AM-01).

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

–

Korrespondierende Kriterien für Kunden

–

AM-06 Inbetriebnahme von Hardware

Basiskriterien

AM-06.01B

Der Cloud-Anbieter hat einen Genehmigungsprozess für die Inbetriebnahme von Hardware implementiert, die verwendet wird, um den Cloud-Dienst in der Produktionsumgebung bereitzustellen. Dieser Prozess umfasst die Identifizierung, Analyse und Mitigierung aller mit der Inbetriebnahme verbundenen Risiken (vgl. OIS-07).

AM-06.02B

Die Genehmigung erfolgt nach Verifikation der sicheren Konfiguration der Mechanismen für Fehlerbehandlung, Protokollierung, Verschlüsselung, Authentisierung und Autorisierung gemäß der vorgesehenen Verwendung und auf Basis der anwendbaren Richtlinien.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: AM-06.01B, AM-06.02B

Das Kriterium bezieht sich nur auf physische Hardware-Objekte, z. B. Server, Speichersysteme und Netzkomponenten. Virtuelle Hardware- und Software-Objekte werden in den Kriterienbereichen (OPS) und (DEV) betrachtet. Der Genehmigungsprozess berücksichtigt typischerweise sowohl die grundsätzliche Freigabe zur Nutzung der Hardware als auch die finale Freigabe der konfigurierten Assets.

Korrespondierende Kriterien für Kunden

–

AM-07 Außerbetriebnahme von Hardware

Basiskriterien

AM-07.01B

Der Cloud-Anbieter definiert, dokumentiert und implementiert ein Verfahren für die Außerbetriebnahme von Hardware, die verwendet wird, um Systemkomponenten zu betreiben, die die Produktionsumgebung des Cloud-Dienstes unterstützen und in der Verantwortung des Cloud-Anbieters liegen. Im Rahmen dieses Verfahrens ist eine Genehmigung durch autorisiertes Personal des Cloud-Anbieters auf der Grundlage der anwendbaren Richtlinien erforderlich.

AM-07.02B

Die Außerbetriebnahme umfasst entweder:

1. Die vollständige und unwiderrufliche Löschung aller Cloud-Kundendaten, abgeleiteten Cloud-Dienstdaten, Cloud-Anbieterdaten und Kontodaten; oder
2. Die ordnungsgemäße Vernichtung der Datenträger.

Kontodaten müssen zumindest in Fällen gelöscht werden, in denen sich die Daten in der Produktionsumgebung für den Betrieb von Systemkomponenten befinden.

Zusatzkriterium (Verschärfend)

AM-07.01AS, verschärft AM-07.01B

Der Cloud-Anbieter definiert, dokumentiert und implementiert ein Verfahren für die Außerbetriebnahme von Hardware, die verwendet wird, um Systemkomponenten zu betreiben, die die Produktions-, Entwicklungs-, Test- oder Staging-Umgebung des Cloud-Dienstes unterstützen und in der Verantwortung des Cloud-Anbieters liegen. Im Rahmen dieses Verfahrens ist eine Genehmigung durch autorisiertes Personal des Cloud-Anbieters auf der Grundlage der anwendbaren Richtlinien erforderlich.

Zusatzkriterium (Erweiternd)

AM-07.01AC

Die Vernichtung von Daten auf Hardware-Komponenten erfolgt in einer solchen Weise, dass eine Datenwiederherstellung als unmöglich angesehen werden kann.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: AM-07.01B

Das Verfahren zur Außerbetriebnahme umfasst typischerweise:

1. die Verifizierung, dass das Asset für den operativen Einsatz nicht mehr benötigt wird;
2. die Bewertung zugehöriger Risiken und Abhängigkeiten;
3. die Genehmigung durch autorisiertes Personal auf der Grundlage interner Richtlinien;
4. die Durchführung sicherer Datenlöschungs- oder Bereinigungsprozesse;
5. die Aktualisierung des Asset-Inventars, um den Status der Außerbetriebnahme widerzuspiegeln; und
6. die Entsorgung oder Umwidmung der Hardware in Übereinstimmung mit Umwelt- und Sicherheitsrichtlinien.

Anwendbar auf: AM-07.02B, AM-07.01AC

Die Löschung von Daten bzw. physische Vernichtung von Datenträgern kann z. B. gemäß DIN 66399 oder BSI IT-Grundschutz-Baustein CON.6 erfolgen

Anwendbar auf: AM-07.01AC

Dieser Genehmigungsprozess stellt sicher, dass außerhalb des Standorts durchgeführte Entsorgungsaktivitäten den Sicherheits-, Compliance- und Umweltrichtlinien der Organisation entsprechen. Er umfasst typischerweise:

1. die Verifizierung von Asset-Eigentum und Nutzungshistorie;
2. die Bewertung der Anforderungen an die Datenbereinigung;
3. die Auswahl genehmigter Entsorgungsdienstleister oder -methoden;
4. die Dokumentation der Entsorgungsmaßnahmen und Genehmigungen; und
5. die Bestätigung der sicheren Datenlöschung oder Vernichtung des Datenträgers.

Anwendbar auf: AM-07.01B, AM-07.02B, AM-07.01AS, AM-07.01AC

Dieses Kriterium ist nicht anwendbar auf Hardware-Komponenten, die keine Cloud-Kundendaten, abgeleiteten Cloud-Dienstdaten, Cloud-Anbieterdaten oder Kontodaten speichern (z. B. Monitore, Router oder Tastaturen).

Korrespondierende Kriterien für Kunden

–

AM-08 Verpflichtung zur ordnungsgemäßen Nutzung, sicheren Handhabung und Rückgabe von Assets

Basiskriterien

AM-08.01B

Der Cloud-Anbieter stellt in einer Risikobeurteilung (vgl. OIS-07) fest, ob der Verlust von oder unautorisierte Zugriffe auf Assets die Informationssicherheit des Cloud-Dienstes gefährden könnten. Falls dies der Fall ist, wird das interne und externe Personal des Cloud-Anbieters nachweislich auf die Richtlinien und Verfahren für die ordnungsgemäße Nutzung und sichere Handhabung von Assets verpflichtet, bevor diese verwendet werden dürfen.

AM-08.02B

Ausgehändigte Assets werden bei Beendigung des Beschäftigungsverhältnisses nachweislich zurückgegeben.

AM-08.03B

Wenn Assets nicht vor oder am Tag der Beendigung zurückgegeben werden können, entfernt der Cloud-Anbieter die Zugriffsrechte des Personals spätestens zum Datum der Beendigung des Beschäftigungsverhältnisses.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: AM-08.01B, AM-08.02B, AM-08.03B

Das Kriterium betrifft im Wesentlichen Mobilgeräte (z. B. Notebooks, Tablets, Smartphones, FIDO2-Sicherheitsschlüssel etc.), insbesondere, wenn auf diesen Geräten vertrauliche Informationen gespeichert sind, die bei unautorisierten Zugriffen dazu genutzt werden können, privilegierten Zugriff auf den Cloud-Dienst zu erhalten (z. B. wenn diese als Security-Token zur Authentifizierung genutzt werden).

Anwendbar auf: AM-08.03B

Die Entfernung der Zugriffsrechte von ausgeschiedenem Personal kann z. B. umgesetzt werden, indem die Identität des jeweiligen Personals auf dem Gerät deaktiviert wird.

Korrespondierende Kriterien für Kunden

–

AM-09 Klassifizierung und Kennzeichnung von Assets

Basiskriterien

AM-09.01B

Assets werden klassifiziert und, falls möglich, gekennzeichnet. Klassifizierung und Kennzeichnung eines Assets entsprechen dem Schutzbedarf der Kategorie von Cloud-Kundendaten, abgeleiteten Cloud-Dienstdaten, Cloud-Anbieterdaten und Kontodaten, die es verarbeitet, speichert oder übermittelt.

AM-09.02B

Klassifizierungsstufen werden mindestens jährlich und bei wesentlichen Änderungen am Cloud-Dienst überprüft. Auf der Grundlage der Überprüfung werden die Klassifizierungsstufen gegebenenfalls aktualisiert.

AM-09.03B

Der Schutzbedarf wird durch die für Assets zuständigen Personen oder Gruppen des Cloud-Anbieters nach einem einheitlichen und dokumentierten Klassifizierungsschema ermittelt.

AM-09.04B

Das Klassifizierungsschema sieht Sicherheitsniveaus für die Schutzziele Vertraulichkeit, Integrität, Verfügbarkeit und Authentizität vor. Diese Schutzziele sind auf Liefer- und Wiederherstellungsziele abgestimmt, die in Geschäftsfortführungs- und Wiederherstellungsplänen festgelegt sind.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

AM-09.01AC

Die eindeutige Identifizierung physischer Geräte dient als zusätzliche Methode für die Verbindungsauthentifizierung.

AM-09.02AC

Die Geräteidentifizierung ist in die Prozesse der Asset-Klassifizierung und -Kennzeichnung integriert.

AM-09.03AC

Anwendungen zur Protokollierung und Überwachung berücksichtigen den Schutzbedarf der Assets, um bei Ereignissen, die zu einer Verletzung der Schutzziele führen können, das dafür zuständige Personal so zu informieren, dass erforderliche Maßnahmen mit einer geeigneten Priorität eingeleitet werden.

AM-09.04AC

Maßnahmen für Ereignisse bei Assets mit einem erhöhten Schutzbedarf haben Priorität vor Ereignissen bei Assets mit einem geringeren Schutzbedarf.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: AM-09.01B, AM-09.02B, AM-09.03B, AM-09.04B

Sofern der Cloud-Anbieter keine spezifische Klassifizierung der Assets vornimmt, können alle Assets so behandelt werden, als würden sie das höchste Sicherheitsniveau erfordern.

Anwendbar auf: AM-09.02B

Wenn eine Überprüfung durch wesentliche Änderungen am Cloud-Dienst ausgelöst wird, müssen nur die von den Änderungen betroffenen Klassifizierungsstufen in die Überprüfung einbezogen werden.

Anwendbar auf: AM-09.01AC

Um sicherzustellen, dass alle physischen Assets eindeutig identifiziert werden, kann der Cloud-Anbieter Praktiken implementieren wie:

1. die Nutzung einer zentralisierten Geräteverwaltungsplattform zur Überwachung und Steuerung aller Geräte;

2. die Zuweisung eindeutiger Identifikatoren (z. B. MAC-Adressen, Seriennummern) zu allen Geräten; und
3. die Nutzung automatisierter Mechanismen zur Registrierung verbundener Geräte.

Anwendbar auf: AM-09.02AC

Die Integration der Geräteidentifizierung stellt sicher, dass jedes Asset eindeutig erkannt und auf der Grundlage seines Schutzbedarfs angemessen klassifiziert wird. Dies ist besonders wichtig für mobile Geräte und Endgeräte, die sensible Daten enthalten oder als Zugangspunkte zu Cloud-Diensten dienen können. Eine ordnungsgemäße Kennzeichnung unterstützt die Rückverfolgbarkeit, die Risikobeurteilung und die Durchsetzung von Sicherheitskontrollen über den gesamten Asset-Lebenszyklus hinweg.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass der Schutzbedarf der Informationen, die mit dem Cloud-Dienst verarbeitet oder gespeichert werden können, angemessen bestimmt wird.

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass der Schutzbedarf der Informationen, die mit dem Cloud-Dienst verarbeitet oder gespeichert werden dürfen, angemessen ermittelt wird. Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass die mit dem Cloud-Dienst verarbeiteten oder gespeicherten Informationen gemäß ihrem Schutzbedarf vor Manipulieren, Kopieren, Modifizieren, Umleiten oder Löschen geschützt sind.

AM-10 Schutz von vorübergehend nicht genutzter Hardware

Basiskriterien

AM-10.01B

Auf der Grundlage einer Risikobeurteilung (vgl. OIS-07) hat der Cloud-Anbieter ein Verfahren zum Schutz von Hardware-Komponenten der Produktionsumgebung des Cloud-Dienstes, die vorübergehend nicht genutzt werden, dokumentiert und implementiert. Das Verfahren unterstützt die sichere Lagerung und den Schutz inaktiver Hardware vor unbefugtem Zugriff oder Beschädigung, bis sie wieder benötigt wird.

Zusatzkriterium (Verschärfend)

AM-10.01AS, verschärft AM-10.01B

Auf der Grundlage einer Risikobeurteilung (vgl. OIS-07) hat der Cloud-Anbieter ein Verfahren zum Schutz beliebiger Hardware-Komponenten, die vorübergehend nicht genutzt werden, dokumentiert und implementiert. Das Verfahren unterstützt die sichere Lagerung und den Schutz inaktiver Hardware vor unbefugtem Zugriff oder Beschädigung, bis sie wieder benötigt wird.

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

–

Korrespondierende Kriterien für Kunden

–

AM-11 Transfer von Hardware

Basiskriterien

AM-11.01B

Auf der Grundlage einer Risikobeurteilung (vgl. OIS-07) stellt der Cloud-Anbieter den sicheren und kontrollierten Transfer von Hardware-Objekten, die in der Produktionsumgebung des Cloud-Dienstes verwendet werden, an einen externen oder alternativen Standort sicher.

AM-11.02B

Der Transfer von Hardware wird durch benanntes Personal autorisiert.

AM-11.03B

Der Cloud-Anbieter stellt sicher, dass alle Transfers von Hardware-Objekten, die in der Produktionsumgebung des Cloud-Dienstes verwendet werden, unter Verwendung sicherer, dokumentierter Methoden durchgeführt werden, die darauf ausgelegt sind, unbefugten Zugriff, Manipulation, Datenabfluss oder Verlust während des Transports zu verhindern. Diese Methoden umfassen physischen Schutz, Nachverfolgung der Nachweiskette und Verifizierung bei Erhalt.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: AM-11.02B

Die Autorisierung stellt sicher, dass Transfers von Hardware-Objekten, ob intern oder extern, kontrolliert, nachvollziehbar und mit organisatorischen Richtlinien konform sind. Dies ist besonders wichtig für Assets, die sensible Daten enthalten oder in Produktionsumgebungen verwendet werden. Der Prozess umfasst typischerweise:

1. die Verifizierung von Asset-Eigentum und Klassifizierung;
2. die Bewertung zugehöriger Risiken;
3. die Dokumentation des Transferantrags und der Genehmigung; und
4. die Bestätigung der sicheren Handhabung während des Transports.

Korrespondierende Kriterien für Kunden

–

AM-12 Wechselmedien und Endgeräte

Basiskriterien

AM-12.01B

Auf der Grundlage einer Risikobeurteilung (vgl. OIS-07) entwirft, implementiert und pflegt der Cloud-Anbieter Kontrollen für Endgeräte und Wechselmedien in Bezug auf die folgenden Aspekte:

1. Außer für systemadministrative Aufgaben, für die keine andere Methode verfügbar ist, ist die Nutzung von Wechselmedien verboten;
2. Wechselmedien werden nur für festgelegte, spezifische Zwecke verwendet;

3. Speicher-Verschlüsselung ist auf verwalteten Endgeräten und Wechselmedien (außer solchen, die für unvermeidbare Systemadministrationsmaßnahmen verwendet werden) aktiviert, um Informationen vor unbefugter Offenlegung zu schützen;
4. Verwaltete Endgeräte sind mit Technologien und Diensten zur Erkennung und Verhinderung von Schadsoftware konfiguriert;
5. Selbstausführung von Wechselmedien ist deaktiviert und Speichermedien werden vor der Nutzung auf den Systemen des Cloud-Anbieters gescannt;
6. Von Benutzern sind Maßnahmen zu ergreifen, um mobile Endgeräte und Wechselmedien während des Transports und der Aufbewahrung zu schützen;
7. Der Schutz hinsichtlich Vertraulichkeit und Integrität jeglicher Geräte, die Cloud-Kundendaten enthalten, ist während des Transfers außerhalb des Standorts zur Entsorgung dem Schutz vor Ort gleichwertig;
8. Auf gemeinsam genutzten Geräten gespeicherte Cloud-Kundendaten und abgeleitete Cloud-Dienstdaten werden gemäß CRY-05 verschlüsselt oder unter Verwendung eines sicheren Löschmechanismus vernichtet, bevor die Geräte mit einer dritten Partei geteilt werden;
9. Benutzer haben mobile Endgeräte und Wechselmedien in sicherer Weise zu verwenden; dies umfasst zum Beispiel, Medien nicht offen zugänglich in öffentlichen Räumen liegen zu lassen sowie Bildschirmsperren und Blickschutzfolien zu verwenden; und
10. Maßnahmen zur Aufrechterhaltung einer ordnungsgemäßen Sicherheit von Endgeräten Dritter mit Zugriff auf organisatorische Assets sind zu definieren.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

AM-12.01AC

Richtlinien und Verfahren für Endgeräte und Wechselmedien enthalten darüber hinaus die folgenden Aspekte:

1. Verwaltete Endgeräte sind mit geeigneten Software-Firewalls konfiguriert;
2. Verwaltete Endgeräte sind gemäß einer Risikobeurteilung (vgl. OIS-07) mit Technologien und Regeln zur Verhinderung von Datenverlust (Data Loss Prevention, DLP) konfiguriert;
3. Fern-Lokalisierungsfunktionen sind für alle verwalteten mobilen Endgeräte aktiviert; und
4. Prozesse, Verfahren und technische Schutzmaßnahmen definieren, implementieren und bewerten, um die Löschung von Unternehmensdaten aus der Ferne auf verwalteten Endgeräten zu ermöglichen.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: AM-12.01B, AM-12.01AC

Ein Wechselmedium ist ein tragbares Datenspeichermedium, das einem Endgerät oder Netzwerk hinzugefügt oder daraus entfernt werden kann. Beispiele umfassen unter anderem optische Datenträger (z. B. CD, DVD, Blu-ray), externe oder entfernbare Festplatten oder Solid-State-Festplatten, magnetische oder optische Bänder und Flash-Speichergeräte (z. B. USB, eSATA, Flash-Laufwerk, Thumb Drive).

Korrespondierende Kriterien für Kunden

–

5.5 Physische Sicherheit (PS)

Zielsetzung: Verhindern von unberechtigtem physischem Zutritt und Schutz vor Diebstahl, Schaden, Verlust und Ausfall des Betriebs.

PS-01 Sicherheitsanforderungen für Gebäude und Räumlichkeiten

Basiskriterien

PS-01.01B

Der Cloud-Anbieter definiert und dokumentiert mindestens zwei Sicherheitsbereiche, mit mindestens einem sensiblen Bereich und einem öffentlichen Bereich. Ein sensibler Bereich umfasst die Gebäude und Räumlichkeiten, in denen sensible Tätigkeiten stattfinden, wie etwa das Hosting der Systemkomponenten, die für die Bereitstellung des Cloud-Dienstes verwendet werden. Ein öffentlicher Bereich umfasst alle Gebäude und Räumlichkeiten, die nicht anderweitig durch einen Sicherheitsbereich abgedeckt sind.

PS-01.02B

Sicherheitsanforderungen für Gebäude und Räumlichkeiten mit Bezug zum bereitgestellten Cloud-Dienst sind aus den Sicherheitszielen der Informationssicherheitsrichtlinie, dem identifizierten Schutzbedarf für den Cloud-Dienst und einer Risikobeurteilung hinsichtlich der physischen und umgebungsbezogenen Sicherheit abgeleitet. Die Sicherheitsanforderungen sind in einer Richtlinie oder einem Rahmenwerk gemäß SP-01 dokumentiert, kommuniziert und bereitgestellt.

PS-01.03B

Sicherheitsanforderungen für Rechenzentren basieren auf Kriterien in Übereinstimmung mit dem Stand der Technik und den Kriterien PS-02 bis PS-07. Sie sind geeignet, die folgenden Risiken im Einklang mit den anwendbaren gesetzlichen und vertraglichen Anforderungen zu adressieren:

1. Fehlerhafte Planung;
2. Unbrechtigter Zutritt (einschließlich Zutritt zum Gelände durch Drohnen);
3. Unzureichende Überwachung;
4. Blitze und Überspannung (im Einklang mit den internationalen Normen der IEC 62305);
5. Feuer und Rauch;
6. Unerwünschtes Wasser;
7. Ausfälle und/oder nicht verfügbare Telekommunikation;
8. Stromausfall; und
9. Unzureichende Heizung, Belüftung, Klimatisierung (HVAC) und Luftfiltration.

PS-01.04B

Die maximal tolerierbaren Ausfallzeiten von Versorgungseinrichtungen sind geeignet, die in der Service Level-Vereinbarung enthaltenen Verfügbarkeitsanforderungen zu erfüllen.

PS-01.05B

Wenn der Cloud-Anbieter den Cloud-Dienst in von Service-Organisationen betriebenen Rechenzentren betreibt, beschreibt das Dokument:

1. Die von den Service-Organisationen erwarteten komplementären Kontrollen der Subservice-Organisationen (CSOC); und
2. Die Maßnahmen zur Überwachung der Ausgestaltung und des Betriebs von Kontrollen bei den Service-Organisationen in Bezug auf diese CSOC (vgl. SSO-05).

PS-01.06B

Wenn der Cloud-Anbieter den Cloud-Dienst in von Service-Organisationen betriebenen Rechenzentren betreibt, führt der Cloud-Anbieter eine Überprüfung der Implementierung geeigneter CSOC gemäß den Kriterien zur Steuerung und Überwachung von Service-Organisationen durch (vgl. SSO-05).

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

PS-01.01AC

Die Sicherheitsanforderungen umfassen Zeitvorgaben für den autarken Betrieb beim Eintritt außergewöhnlicher Ereignisse (z. B. länger anhaltender Stromausfall, Hitzeperioden, Niedrigwasser bei Kälteversorgung mit Flusswasser) sowie maximal tolerierbare Ausfallzeiten von Versorgungseinrichtungen.

PS-01.02AC

Die Sicherheitsanforderungen umfassen Zeitvorgaben, um bei einem Ausfall der externen Stromversorgung einen autarken Betrieb eines Standorts für mindestens 72 Stunden zu ermöglichen, oder bis alle Dienste auf einen anderen Standort übertragen sind.

PS-01.03AC

Die Sicherheitsanforderungen für einen autarken Betrieb während einer Hitzeperiode basieren auf den höchsten Außentemperaturen, von denen vernünftigerweise geschätzt werden kann, dass sie an den Standorten der Räumlichkeiten und Gebäude innerhalb der Lebensdauer der Kühlungsversorgung auftreten können. Der Cloud-Anbieter bestimmt diese Temperaturen mit einem angemessenen Sicherheitsaufschlag.

PS-01.04AC

Die Sicherheitsanforderungen sehen vor, dass die zulässigen Betriebs- und Umgebungsparameter der Kälteversorgung auch an mindestens 5 unmittelbar aufeinander folgenden Tagen mit diesen Außentemperaturen einschließlich Sicherheitsaufschlag eingehalten werden müssen (vgl. PS-06).

PS-01.05AC

Die Sicherheitsanforderungen berücksichtigen, dass, soweit zur Klimatisierung Wasser aus einem Gewässer (z. B. Fluss oder See) entnommen wird, ermittelt wird, bei welchen Wasserständen und Wassertemperaturen die Klimatisierung wie lange aufrechterhalten werden kann.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: PS-01.01B, PS-01.02B, PS-01.03B, PS-01.04B, PS-01.05B, PS-01.06B, PS-01.01AC, PS-01.02AC, PS-01.03AC, PS-01.04AC, PS-01.05AC

Eine fehlerhafte Planung kann die Betriebssicherheit und Verfügbarkeit der Räumlichkeiten oder Gebäude gefährden. Dies kann insbesondere aus einer falschen Bewertung elementarer Gefährdungen am Standort (z. B. Luftverkehr, Erdbeben, Hochwasser, Gefahrstoffe) sowie einer fehlerhaften Konzeptionierung der Bandbreite oder Energieversorgung resultieren.

Räumlichkeiten und Gebäude mit Bezug zum bereitgestellten Cloud-Dienst umfassen Rechenzentren und Serverräume, die Systemkomponenten beherbergen, mit denen Cloud-Kundendatem verarbeitet werden (einschließlich Rechenzentren für Datensicherungs- oder Redundanzzwecke) sowie die für den Betrieb dieser Systemkomponenten benötigten technischen Versorgungseinrichtungen (z. B. Stromversorgung, Kälteversorgung, Löschtechnik, Telekommunikation, Sicherheitstechnik etc.).

Räumlichkeiten und Gebäude, in denen keine Cloud-Kundendaten verarbeitet oder gespeichert werden (z. B. Büros des Cloud-Anbieters, Serverräume mit Systemkomponenten für interne Entwicklungs- und Testsysteme), unterliegen Anforderungen, die speziell unter PS-08 behandelt werden.

Anwendbar auf: PS-01.05B

Räumlichkeiten und Gebäude, die von Dritten betrieben werden sind z. B. Serverhousing, Colocation oder IaaS.

Anwendbar auf: PS-01.03B

Der Stand der Technik ist in einschlägigen Normen definiert, z. B. EN 50600 (Einrichtungen und Infrastrukturen von Rechenzentren). Hinweis für zweisprachige Leser: Die deutsche Version des C5 verwendet den Begriff *Stand der Technik* während im Englischen *established rules of technology* verwendet wird, obwohl der deutsche Leser möglicherweise den Begriff *state of the art* erwarten könnte. *State of the art* definiert ein höheres Niveau als *Stand der Technik*, daher wird im Englischen *established rules of technology* und im Deutschen *Stand der Technik* verwendet.

Anwendbar auf: PS-01.01AC

Zeitvorgaben für den autarken Betrieb sowie maximal tolerierbare Ausfallzeiten von Versorgungseinrichtungen werden typischerweise im Rahmen der Business Impact Analyse erhoben (vgl. BCM-02, BCM-03).

Anwendbar auf: PS-01.02AC

Der Zeitraum von 72 Stunden für einen autarken Betrieb steht im Einklang mit Leitlinien für Behörden, Unternehmen und Betreiber kritischer Anlagen (KRITIS) des Bundesamts für Bevölkerungsschutz und Katastrophenhilfe (BBK).

Anwendbar auf: PS-01.03AC

Eine vernünftige Schätzung der höchsten Außentemperaturen kann auf Informationen basieren, die von amtlichen Messstationen wie dem Deutschen Wetterdienst (DWD) oder anderen verlässlichen Quellen geliefert werden, wie z. B. der American Society of Heating, Refrigerating and Air-Conditioning Engineers (ASHRAE).

Diese Schätzungen sollten die Auswirkungen der globalen Erwärmung berücksichtigen.

Was einen angemessene Sicherheitsaufschlag ausmacht, hängt vom Standort der Räumlichkeiten und Gebäude ab. In Deutschland können 3 Kelvin im Allgemeinen als angemessen angesehen werden.

Korrespondierende Kriterien für Kunden

–

PS-02 Redundanzmodell

Basiskriterien

PS-02.01B

Die Bereitstellung des Cloud-Dienstes erfolgt aus mindestens zwei Standorten. Die Standorte entsprechen den Sicherheitsanforderungen des Cloud-Anbieters (vgl. PS-01) und weisen einen hinreichenden Abstand zueinander auf, um Betriebsredundanz und -Resilienz zu erreichen.

PS-02.02B

Die Betriebsredundanz ist so ausgelegt, dass die in den Service Level-Vereinbarungen enthaltenen Verfügbarkeitsanforderungen eingehalten werden.

PS-02.03B

Die Wirksamkeit der Redundanz wird mindestens jährlich durch geeignete Tests und Übungen überprüft (vgl. BCM-04).

Zusatzkriterium (Verschärfend)

PS-02.01AS, verschärft PS-02.01B

Die Bereitstellung des Cloud-Dienstes erfolgt aus mehr als zwei Standorten. Die Standorte entsprechen den Sicherheitsanforderungen des Cloud-Anbieters (vgl. PS-01) und weisen einen hinreichenden Abstand zueinander auf, um Georedundanz und -Resilienz zu erreichen. Bei einem zeitgleichen Ausfall zweier Standorte steht mindestens ein dritter Standort weiterhin zur Verfügung, um einen Totalausfall zu verhindern.

PS-02.02AS, verschärft PS-02.02B

Die Georedundanz ist so ausgelegt, dass die in der Service Level-Vereinbarung enthaltenen Verfügbarkeitsanforderungen eingehalten werden.

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: PS-02.01B, PS-02.02B

Eine Betriebsredundanz der Standorte zueinander im Sinne dieses Kriteriums ist gegeben, wenn auf Basis der Bewertung elementarer Gefährdungen am Standort entsprechende Abstände der Räumlichkeiten und Gebäude zu diesen Gefahren eingehalten werden. Sehr großräumige Ereignisse, die aufgrund ihres Ausmaßes gleichzeitig oder zeitnah mehrere Standorte der gleichen Redundanzgruppe betreffen könnten (z. B. Hochwasser, Erdbeben), bleiben dabei unberücksichtigt.

Es gibt Cloud-Anbieter, die das Thema Ausfallsicherheit des Cloud-Dienstes auf physischer Ebene nicht mehr durch Redundanz aus zwei unabhängigen Standorten, sondern durch Resilienz adressieren. Hierbei wird der Cloud-Service simultan aus mehr als zwei Standorten erbracht. Die zugrundeliegende verteilte Rechenzentrums-Architektur stellt sicher, dass der Ausfall eines Standortes oder von Komponenten eines Standortes nicht die definierten Verfügbarkeitskriterien des Cloud-Dienstes verletzt. Eine solche Architektur kann eine alternative Erfüllung (vgl. Kapitel 3.4.12) des Kriteriums darstellen. Die im Kriterium geforderten Tests und Übungen zur Funktionsfähigkeit gelten sinngemäß auch für resiliente Architekturen.

Anwendbar auf: PS-02.01AS, PS-02.02AS

Eine Georedundanz der Standorte zueinander im Sinne dieses Kriteriums ist gegeben, wenn ein sehr großräumiges Ereignis an einem Standort keinesfalls gleichzeitig oder zeitnah mehrere Standorte der gleichen Redundanzgruppe trifft. Die BSI-Publikation ‘Kriterien für die Standortwahl von Rechenzentren’ gibt hierzu Empfehlungen.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass das vorliegende Redundanzmodell des Cloud-Anbieters und die Nachweise zur Überprüfung des Modells mit den eigenen Anforderungen zur Verfügbarkeit und Verlässlichkeit des Cloud-Dienstes konform sind.

PS-03 Perimeterschutz

Basiskriterien

PS-03.01B

Die bauliche Hülle von Räumlichkeiten und Gebäuden mit Bezug zum bereitgestellten Cloud-Dienst sind physisch solide und durch angemessene Sicherheitsmaßnahmen geschützt, die den Sicherheitsanforderungen des Cloud-Anbieters entsprechen (vgl. PS-01).

PS-03.02B

Die Sicherheitsmaßnahmen sind geeignet, unberechtigte Zutritte rechtzeitig zu erkennen und zu verhindern, damit diese die Informationssicherheit des betrachteten Cloud-Dienstes nicht beeinträchtigen.

PS-03.03B

Die äußeren Türen, Fenster und sonstigen Bauelemente weisen ein angemessenes Sicherheitsniveau auf, sodass ihre kombinierte Widerstandszeit einem Einbruchsversuch insgesamt mindestens zehn Minuten standhält. Dieser Zeitraum gilt ab dem Moment, in dem ein externer Eindringling erkannt wird (z. B. durch Perimeterüberwachung).

PS-03.04B

Die umgebenden Wandkonstruktionen sowie die Schließeinrichtungen erfüllen die damit einhergehenden Anforderungen.

PS-03.05B

Wenn die Bauelemente als Ganzes die damit verbundenen Anforderungen nicht vollständig erfüllen, werden kompensierende Kontrollen implementiert, um das angemessene Sicherheitsniveau wiederherzustellen.

PS-03.06B

Das Personal des Rechenzentrums wird darin geschult, auf unbefugte Zutritts- oder Austrittsversuche wirksam zu reagieren.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

PS-03.01AC

Die am Standort eingerichteten Sicherheitsmaßnahmen umfassen permanent anwesendes Sicherheitspersonal (mindestens zwei Personen), Videoüberwachung und Einbruchmeldeanlagen.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: PS-03.02B

Sicherheitsmaßnahmen zum Erkennen unbefugter Zutritte können Sicherheitspersonal, Videoüberwachung oder Einbruchmeldeanlagen sein.

Anwendbar auf: PS-03.03B, PS-03.04B

Die Widerstandsklasse RC4 nach DIN EN 1627 sieht vor, dass Türen, Fenster und sonstige Bauelemente einem Einbruchversuch mindestens zehn Minuten standhalten. Ein internationales Äquivalent zu dieser Norm ist der US-amerikanische Standard SD-STD-01.01 Rev.G. Die Erfüllung der Zielsetzung dieses Kriteriums impliziert jedoch nicht notwendigerweise, dass diese Normen erfüllt werden müssen.

Zudem verlangt das Unterkriterium, dass alle Bauelemente als Ganzes zu einer Widerstandszeit gegen Einbruchsversuche von mindestens zehn Minuten führen. Folglich verlangt es nicht notwendigerweise, dass alle einzelnen Bauelemente diese Anforderung jeweils für sich allein erfüllen, sofern die kombinierten Maßnahmen einen externen Angriff wirksam um die erforderliche Zeit verzögern.

Anwendbar auf: PS-03.05B

Kompensierende Maßnahmen können zusätzliche Sicherheitsebenen (z. B. Sicherheitsbereiche) auf dem Gelände, eine erhöhte Präsenz von Sicherheitspersonal, Videoüberwachung und Einbruchmeldesysteme umfassen.

Korrespondierende Kriterien für Kunden

–

PS-04 Physische Zutrittskontrolle

Basiskriterien

PS-04.01B

Präventive und detektive physische Zutrittskontrollen in Räumlichkeiten und Gebäuden, mit Bezug zum bereitgestellten Cloud-Dienst, sind implementiert. Sie stehen im Einklang mit den Sicherheitsanforderungen des Cloud-Anbieters (vgl. PS-01) und basieren auf den in IAM-01 definierten Grundsätzen, um unbefugten Zutritt zu verhindern. Sie sind dokumentiert und gemäß SP-01 in einer Richtlinie oder einem Rahmenwerk kommuniziert und umfassen die folgenden Aspekte:

1. Geregeltes Verfahren für die Vergabe und Änderung von Benutzerkonten und Zutrittsberechtigungen (vgl. IAM-02) auf Basis des ‘Least-Privilege-Principle’ und des ‘Need-to-Know-Principle’;
2. Sperrung der Zutritts-Berechtigungen, wenn diese über einen Zeitraum von zwei Monaten nicht genutzt wurden. Ausnahmen werden nur in begründeten Einzelfällen gemacht und folgen einem definierten Ausnahmeprozess gemäß SP-03;
3. Authentisierung mit mindestens einem Faktor für den Zutritt zu jedem nicht öffentlichen Bereich;
4. Multifaktor-Authentisierung für den Zutritt zu Bereichen, die Systemkomponenten beherbergen, mit denen Informationen der Cloud-Kunden verarbeitet werden;
5. Vorhandensein und Beschaffenheit einer Protokollierung der Zutritte, die es dem Cloud-Anbieter im Sinne einer Wirksamkeitsprüfung ermöglicht, zu überprüfen, ob nur definiertes Personal die Räumlichkeiten und Gebäude mit Bezug zum bereitgestellten Cloud-Dienst betreten haben;
6. Ausnahmen von der physischen Zutrittskontrolle, die im Notfall gelten, einschließlich eines Analyseverfahrens nach jeder Nutzung dieser Ausnahmen; und
7. Maßnahmen für Besucher und externes Personal, die die Identifizierung und Nachverfolgung jeder einzelnen Person sicherstellen, sodass ihre Aktivitäten nachvollziehbar und – im Fall von Aktivitäten, die die Informationssicherheit beeinträchtigen – innerhalb einer angemessenen Reaktionszeit gestoppt werden können. Diese Maßnahmen sind angemessen und verhältnismäßig zur Sensibilität der Zone, in der sich Besucher oder externes Personal befinden. Der angemessene Reaktionszeitrahmen wird auf der Grundlage einer Risikobewertung bestimmt (vgl. OIS-07).

PS-04.02B

Der Cloud-Anbieter weist am Eingang jedes betroffenen nicht öffentlichen Bereichs mit einer Warnung auf dessen Grenzen und Zutrittsbedingungen hin.

PS-04.03B

Die physische Zutrittskontrolle zum Standort wird durch ein elektronisches Zutrittskontrollsystem verwaltet, das Authentisierung, Autorisierung und Protokollierung von Ein- und Austrittsereignissen unterstützt.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: PS-04.01B

Zur Umsetzung einer Zutrittskontrolle auf der Grundlage des Need-to-Know-Prinzips kann ein Zonierungskonzept eingesetzt werden, bei dem jeder Vor-Ort-Bereich eigene Zutrittsberechtigungen hat. Wenn ein Zonierungskonzept implementiert ist, sollte jeder Vor-Ort-Bereich physisch getrennt sein und über ein eigenes Zutrittskontrollsystem verfügen. Beispiele für eine Zonierung vor Ort können sein:

1. Grüne Zone: Öffentlicher Bereich, enthält keine Ressourcen, die für die Bereitstellung des Cloud-Dienstes relevant sind;
2. Gelbe Zone: Privater Bereich, enthält Mittel zur Unterstützung des Cloud-Dienstes wie Entwicklung, Administration und Überwachung; und
3. Rote Zone: Sensibler Bereich für Produktionssysteme wie die Serverräume. Beispiele für angemessene Ausnahmen vom Entzug von Zutrittsberechtigungen nach zwei Monaten Inaktivität sind z. B. Fälle, in denen Personal mit bestimmten Rollen, wie Führungspositionen oder Aufsichtspersonen, nur gelegentlich, aber entscheidenden Zutritt benötigt. Die Begründung für die Ausnahmen sollte dokumentiert und bei der Überprüfung kritisch daraufhin bewertet werden, ob sie noch erforderlich sind.

Korrespondierende Kriterien für Kunden

–

PS-05 Schutz vor Bedrohungen von Außen und aus der Umgebung

Basiskriterien

PS-05.01B

Räumlichkeiten und Gebäuden mit Bezug zum bereitgestellten Cloud-Dienst sind durch bauliche, technische und organisatorische Maßnahmen vor Feuer, Rauch, Blitzen und unerwünschtem Wasser geschützt, die den Sicherheitsanforderungen des Cloud-Anbieters (vgl. PS-01) entsprechen.

PS-05.02B

Bauliche Maßnahmen umfassen die folgenden Aspekte:

1. Einrichtung von Brandabschnitten mit einer Feuerwiderstandsdauer von mindestens 90 Minuten bei allen raumbildenden Teilen oder alternativ gleichwertige organisatorische und technische Maßnahmen, die dasselbe Schutzniveau wie raumbildende Teile mit einer Feuerwiderstandsdauer von mindestens 90 Minuten sicherstellen, oder die Einrichtung kompensierender Maßnahmen zur Eindämmung von Bränden und zur Aufrechterhaltung der Betriebsfähigkeit. Wenn kompensierende Maßnahmen berücksichtigt werden, muss der Feuerwiderstand der raumbildenden Teile mindestens 60 Minuten betragen;

2. Wirksame Umsetzung von Maßnahmen zum Schutz vor Blitz- und Überspannungsschäden; und
3. Wirksame Umsetzung von Maßnahmen zum Schutz vor Überflutung, es sei denn, kritische Einrichtungen befinden sich deutlich oberhalb des höchsten Hochwasserstands am Standort des Cloud-Rechenzentrums. Zusätzlich werden angemessene Maßnahmen umgesetzt, um die Auswirkungen von Starkregen zu mitigieren, es sei denn, kritische Einrichtungen befinden sich deutlich oberhalb der Rückstauebene am Standort des Cloud-Rechenzentrums.

PS-05.03B

Technische Maßnahmen umfassen die folgenden Aspekte:

1. Brandfrüherkennung mit automatischer Spannungsfreischaltung. Die Überwachungsbereiche sind hinreichend kleinteilig konzipiert, damit die Verhinderung einer Ausbreitung von Entstehungsbränden in einem angemessenen Verhältnis zur Aufrechterhaltung der Verfügbarkeit des bereitgestellten Cloud-Dienstes steht;
2. Löschanlage oder Sauerstoffreduzierung; und
3. Brandmeldeanlage mit Meldung an die örtliche Feuerwehr.

PS-05.04B

Organisatorische Maßnahmen umfassen die folgenden Aspekte:

1. Regelmäßige Brandschutzbegehungen, um die Einhaltung der Brandschutzvorgaben zu prüfen; und
2. Regelmäßige Brandschutzübungen.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: PS-05.02B

Raumbildende Teile sind Wände, Decken, Böden, Türen, Fenster und andere Öffnungen der Gebäudehülle wie Lüftungsklappen etc.

Kompensierende Maßnahmen können Aspekte berücksichtigen wie:

1. Unterteilung und Aufbau von Brandabschnitten;
2. Löschanlagen innerhalb der Brandabschnitte;
3. Maßnahmen für Brandfrüh- und Brandfrühsterkennung;
4. Redundanz von Systemen und Versorgungseinrichtungen innerhalb des Geländes; und
5. Zeitraum, den die Standorte und Räumlichkeiten einem Brand standhalten können, der eine Datenhalle beeinträchtigt, ohne dass eine zweite Datenhalle Feuer fängt.

Der Cloud-Anbieter sollte die getroffenen Maßnahmen zum Schutz seiner Räumlichkeiten und Gebäude gegen Feuer als Teil der Systembeschreibung beschreiben.

Die Lage aller kritischen Einrichtungen in Bezug auf den historisch höchsten aufgezeichneten Hochwasserstand am Standort des Cloud-Rechenzentrums oder die Rückstauebene des Standorts dient als Ausgangspunkt für die Betrachtung von Schutzmaßnahmen gegen Hochwasser und Starkregen.

Anwendbar auf: PS-05.03B

Die Überwachung der Umgebungsparameter ist in PS-07 adressiert. Bei Verlassen des zulässigen Regelbereichs werden Alarmmeldungen generiert und an das dafür sachverständige Personal des Cloud-Anbieters weitergeleitet.

Korrespondierende Kriterien für Kunden

–

PS-06 Schutz vor Unterbrechungen durch Stromausfälle und ähnliche Risiken für Versorgungseinrichtungen

Basiskriterien

PS-06.01B

Maßnahmen zur Ausfallvorsorge der technischen Versorgungseinrichtungen, die für den Betrieb von Systemkomponenten benötigt werden, mit denen Cloud-Kundendaten verarbeitet werden, und zum Schutz von Geräten, die Cloud-Kundendaten enthalten, sind gemäß den Sicherheitsanforderungen des Cloud-Anbieters (vgl. PS-01) hinsichtlich der folgenden Aspekte dokumentiert und eingerichtet:

1. Betriebsredundanz (N+1) in der Strom- und Kälteversorgung;
2. Einsatz angemessen dimensionierter unterbrechungsfreier Stromversorgungen (USV) und Netzersatzanlagen (NEA), die so ausgelegt sind, dass bei einem Stromausfall alle Datenbestände unbeschädigt bleiben. Die Funktionsfähigkeit von USV und NEA wird mindestens jährlich durch geeignete Tests und Übungen überprüft (vgl. BCM-04);
3. Instandhaltung (Wartung, Inspektion, Instandsetzung/Reparatur) der Versorgungseinrichtungen in Übereinstimmung mit den Herstellerempfehlungen; und
4. Schutz der Leitungen für Stromversorgung und Telekommunikation vor Unterbrechung, Störung, Beschädigung und Abhören.

PS-06.02B

Unterbrechungsfreie Stromversorgungen (USV) und Netzersatzanlagen (NEA) sind so ausgelegt, dass die in der Service Level-Vereinbarung enthaltenen Verfügbarkeitsanforderungen eingehalten werden.

PS-06.03B

Der Schutz der Leitungen für Stromversorgung und Telekommunikation wird regelmäßig, mindestens aber alle zwei Jahre, sowie bei Manipulationsverdacht durch qualifiziertes Personal hinsichtlich der folgenden Aspekte überprüft: 1. Spuren gewaltsamer Öffnungsversuche an geschlossenen Verteilern; 2. Aktualität der im Verteiler befindlichen Dokumentation; 3. Übereinstimmung der tatsächlichen Beschaltung und Rangierungen mit der Dokumentation; 4. Unversehrtheit der Kurzschlüsse und Erdungen nicht benötigter Kabel und Leitungen; und 5. unzulässige Einbauten und Veränderungen.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

PS-06.01AC

Das Kälteversorgungssystem ist so ausgelegt, dass die zulässigen Betriebs- und Umgebungsparameter auch an mindestens fünf unmittelbar aufeinander folgenden Tagen mit den höchsten Außentemperaturen, von denen vernünftigerweise geschätzt werden kann, dass sie an den Standorten der Räumlichkeiten und Gebäude innerhalb der Lebensdauer des Kühlversorgungssystems mit einem angemessenen Sicherheitsaufschlag auftreten können, sichergestellt sind.

PS-06.02AC

Die Anbindung an das Telekommunikationsnetz ist mit ausreichender Redundanz ausgelegt, so dass der Ausfall eines Telekommunikationsnetzes keine Beeinträchtigung der Sicherheit oder Leistungsfähigkeit des Cloud-Anbieters zur Folge hat.

PS-06.03AC

Der Cloud-Anbieter implementiert Maßnahmen, um die Kompatibilität der Bedingungen für Installation, Wartung und Instandhaltung der zugehörigen technischen Ausrüstung (z. B. elektrische Energieversorgung, Klimatisierung, Brandschutz) mit den Verfügbarkeits- und Sicherheitsanforderungen des Cloud-Dienstes sicherzustellen.

PS-06.04AC

Der Cloud-Anbieter stellt sicher, dass Wartungsvereinbarungen für Geräte, die für das Hosting des Cloud-Dienstes verwendet werden, die rechtzeitige Installation von Sicherheitsupdates auf diesen Geräten ermöglichen.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: PS-06.01B

Maßnahmen zur Ausfallvorsorge technischer Versorgungseinrichtungen sind z. B. Stromversorgung, Kälteversorgung, Löschtechnik, Telekommunikation, Sicherheitstechnik etc.

Cloud-Anbieter können z. B. durch geordnetes Herunterfahren der Server sicherstellen, dass bei einem Stromausfall alle Datenbestände unbeschädigt bleiben.

Leitungen für Stromversorgung und Telekommunikation können z. B. mittels unterirdischer Zuführungen über unterschiedliche Zuleitungswege vor Unterbrechung, Störung, Beschädigung und Abhören geschützt werden.

Anwendbar auf: PS-06.03B

Das Unterkriterium verlangt, dass die Überprüfung mindestens alle zwei Jahre durchgeführt wird. Wenn während des festgelegten Zeitraums einer Typ-2-Prüfung keine solche Überprüfung durchgeführt wurde, sollt der Prüfer im Prüfbericht vermerken, dass die entsprechenden Kontrollen mit zweijährigem Zyklus im hiesigen Prüfzeitraum nicht durchgeführt wurden. Für die Bewertung der Ausgestaltung der Kontrolle kann der Prüfer Nachweise über die vorherige Überprüfung einholen, auch wenn diese Überprüfung nicht innerhalb des festgelegten Zeitraums des Auftrags stattgefunden hat. Wenn zwei Jahre lang keine Überprüfung durchgeführt wurde, soll der Prüfer eine Abweichung vermerken.

Anwendbar auf: PS-06.01AC

Dieses Unterkriterium verlangt die Umsetzung konkreter Maßnahmen zur Erfüllung der in PS-01.03AC geforderten Richtlinie. Der Cloud-Anbieter bestimmt die höchsten Außentemperaturen, von denen vernünftigerweise geschätzt werden kann, dass sie an den Standorten der Räumlichkeiten und Gebäude innerhalb der Lebensdauer des Kühlversorgungssystems auftreten können, ebenfalls als Teil von PS-01.03AC.

Korrespondierende Kriterien für Kunden

–

PS-07 Überwachung der Betriebs- und Umgebungsparameter

Basiskriterien

PS-07.01B

Betriebsparameter der technischen Versorgungseinrichtungen (vgl. PS-06) sowie die Umgebungsparameter der Räumlichkeiten und Gebäuden mit Bezug zum bereitgestellten Cloud-Dienst werden gemäß den Sicherheitsanforderungen des Cloud-Anbieters (vgl. PS-01) überwacht und geregelt.

PS-07.02B

Bei Verlassen des zulässigen Regelbereichs wird das dafür sachverständige Personal oder die autorisierten Systemkomponenten des Cloud-Anbieters automatisch informiert, um zeitnah die erforderlichen Maßnahmen zur Rückführung in den Regelbereich einzuleiten.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: PS-07.01B

Zu diesen Maßnahmen gehören typischerweise unter anderem:

1. Umgebungsüberwachungssysteme (z. B. Temperatur- und Feuchtigkeitssensoren);
2. Feuerunterdrückungssysteme;
3. Heizungs-, Lüftungs- und Klimatechnik (HVAC); und
4. Leckageerkennung und -Alarme.

Korrespondierende Kriterien für Kunden

–

PS-08 Anforderungen an die Sicherheit von Arbeitsplätzen

Basiskriterien

PS-08.01B

Auf der Grundlage einer Risikobewertung gemäß OIS-07 werden Sicherheitsanforderungen für Büroumgebungen dokumentiert, kommuniziert und gemäß SP-01 bereitgestellt. Die Sicherheitsanforderungen für gemietete Büros berücksichtigen Verhältnismäßigkeit und Angemessenheit und können potenziell weniger umfangreich sein als diejenigen in eigenen Büroumgebungen. Diese Sicherheitsanforderungen umfassen verschiedene Aspekte für eine sichere und geschützte Arbeitsumgebung, einschließlich mindestens:

1. Physische Zutrittskontrollen, wie Schlüsselkarten und biometrische Scanner, für Bürogebäude;
2. Verwendung von Bildschirmsperren und Sichtschutzfiltern für Arbeitsplätze;
3. Keine offen sichtbaren vertraulichen Daten an vorübergehend unbeaufsichtigten Arbeitsplätzen;
4. Entsorgung aller Unternehmensdokumente, die nicht mehr benötigt werden, innerhalb des Unternehmensgeländes;
5. Verbot der Nutzung von Drittgeräten; und

6. Sicherung der Eingänge von Büroräumlichkeiten mit Alarmsystemen und Überwachungskameras.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: PS-08.01B

Als Ergebnis der Risikobewertung gemäß OIS-07 muss möglicherweise nicht jeder im Kriterium aufgeführte Aspekt durch entsprechende Sicherheitsanforderungen adressiert werden. Wenn sich beispielsweise in einem Bürogebäude keine Assets mit Bezug zur Entwicklung oder dem Betrieb des Cloud-Dienstes befinden, sind Alarmsysteme und Überwachungskameras möglicherweise nicht erforderlich.

Korrespondierende Kriterien für Kunden

–

5.6 Regelbetrieb (OPS)

Zielsetzung: Sicherstellen eines ordnungsgemäßen Regelbetriebs einschließlich angemessener Maßnahmen für Planung und Überwachung der Kapazität, Schutz vor Schadprogrammen, Protokollierung und Überwachung von Ereignissen sowie den Umgang mit Schwachstellen, Störungen und Fehlern.

OPS-01 Kapazitätsmanagement - Planung

Basiskriterien

OPS-01.01B

Die Planung von Kapazitäten und Ressourcen (Personal und Systemkomponenten) folgt einem etablierten Verfahren, um mögliche Kapazitätsengpässe zu vermeiden.

OPS-01.02B

Zu den Verfahren gehört die Prognose zukünftiger Kapazitätsanforderungen, um Nutzungstrends zu erkennen und Systemüberlastungen zu bewältigen.

OPS-01.03B

Der Cloud-Anbieter stellt durch geeignete Maßnahmen sicher, dass er bei Kapazitätsengpässen oder Ausfällen hinsichtlich Personal und Systemkomponenten die mit den Cloud-Kunden vereinbarten Anforderungen an die Bereitstellung des Cloud-Dienstes, gemäß der jeweiligen Vereinbarungen weiterhin erfüllt. Dies gilt insbesondere hinsichtlich der dedizierten Nutzung von Systemkomponenten gemäß den jeweiligen Vereinbarungen.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

OPS-01.01AC

Die Prognosen werden in Abstimmung mit der Service Level-Vereinbarung zur Planung und Vorbereitung der Provisionierung berücksichtigt.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: OPS-01.01B, OPS-01.02B, OPS-01.03B, OPS-01.01AC

Aus Wirtschaftlichkeitsgründen streben Cloud-Anbieter typischerweise eine hohe Auslastung der Systemkomponenten (CPU, Arbeitsspeicher, Speicherplatz, Netz) an. In Multi-Mandanten-Umgebungen sollten die vorhandenen Ressourcen zwischen den Cloud-Kunden (Mandanten) trotzdem so aufgeteilt werden, dass die Service Level-Vereinbarungen eingehalten werden. Insoweit sind die angemessene Planung und Überwachung von IT-Ressourcen kritisch für die Verfügbarkeit und Wettbewerbsfähigkeit des Cloud-Dienstes. Soweit die Verfahren nicht dokumentiert sind oder als Betriebsgeheimnis des Cloud-Anbieters einer höheren Vertraulichkeit unterliegen, sollte der Cloud-Anbieter die Verfahren im Rahmen dieser Prüfung mindestens mündlich erläutern können.

Anwendbar auf: OPS-01.01B

Kapazitätsengpässe sind Beschränkungen der Ressourcen des Cloud-Anbieters, die zu Störungen des Cloud-Dienstes führen oder die Einhaltung vertraglicher Vereinbarungen und Servicelevel beeinträchtigen.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen durch geeignete Kontrollen sicher, dass der vom Cloud-Anbieter abzudeckende Kapazitäts- und Ressourcenbedarf geplant und in der Service Level-Vereinbarung (SLA) mit dem Cloud-Anbieter abgebildet wird. Die Anforderungen werden regelmäßig überprüft und die SLA-Anpassung entsprechend eingefordert.

OPS-02 Kapazitätsmanagement - Überwachung

Basiskriterien

OPS-02.01B

Verfahren und technische Maßnahmen zur Überwachung und Provisionierung bzw. De-Provisionierung von Cloud-Dienstleistungen sind definiert. Der Cloud-Anbieter stellt sicher, dass die Ressourcen wie vertraglich mit den Cloud-Kunden vereinbart bereitgestellt werden. Der Cloud-Anbieter stellt die Einhaltung der Service Level-Vereinbarungen sicher.

OPS-02.02B

Kapazitätsengpässe, die zu Verstößen gegen vertragliche Pflichten führen, sind Cloud-Kunden gemäß OPS-24 zu melden.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

OPS-02.01AC

Zur Überwachung der vom Cloud-Kunden verwalteten Kapazität und Verfügbarkeit stehen dem Cloud-Kunden die relevanten Informationen in einem Self-Service-Portal zur Verfügung.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: OPS-02.01B

Zu den Verfahren und technischen Maßnahmen gehören typischerweise:

1. Einsatz von Monitoring Tools mit Alarmierungsfunktion beim Überschreiten definierter Schwellwerte;

2. Prozess zum Korrelieren von Events und Schnittstelle zum Vorfallsmanagement;
3. Eine durchgängige Überwachung der Systeme durch qualifiziertes Personal; und
4. Redundanzen in den IT-Systemen.

Anwendbar auf: OPS-02.02B

Cloud-Anbieter stellen dem Cloud-Kunden möglicherweise ein Health Dashboard zur Verfügung. Dieses Unterkriterium kann durch die Bereitstellung eines solchen Health Dashboards erfüllt werden, wenn das Health Dashboard den Cloud-Kunden über Verstöße gegen vertragliche Pflichten, wie z. B. Service Level-Vereinbarungen (SLAs), informiert.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen durch geeignete Kontrollen sicher, dass die mit dem Cloud-Anbieter getroffenen vertraglichen Vereinbarungen zur Bereitstellung von Ressourcen oder Diensten überwacht werden können. Bei Abweichungen wird durch entsprechende Kontrollen sichergestellt, dass der Cloud-Anbieter informiert wird, sodass dieser entsprechende Maßnahmen ergreifen kann.

OPS-03 Kapazitätsmanagement - Steuerung von Ressourcen

Basiskriterien

OPS-03.01B

Entsprechend den Möglichkeiten des jeweiligen Service-Modells ist der Cloud-Kunde in der Lage die Aufteilung der ihm zur Verwaltung/Nutzung zugeordneten Systemressourcen zu steuern und zu überwachen, um eine Überbelegung der Ressourcen zu vermeiden und eine hinreichende Performance zu erreichen.

OPS-03.02B

Ergeben sich bei den im Rahmen des Cloud-Diensts bereitgestellten und dem Cloud-Kunden zugeordneten Systemkomponenten wesentliche oder geplante wesentliche Sicherheitsänderungen, informiert der Cloud-Anbieter den Cloud-Kunden hierüber.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: OPS-03.01B

Zu den dem Cloud-Kunden zugeordneten und von diesem zu steuernden Systemkomponenten können entsprechend den Möglichkeiten des Service-Modells gehören:

1. Rechenkapazität;
2. Speicherkapazität;
3. Konfiguration der Netzeigenschaften;
4. Application Programming Interfaces (APIs); und
5. Datenbanken.

Bei der Zuweisung von Systemkomponenten muss möglicherweise die in den Service-Modellen verwendete Container-basierte Infrastruktur berücksichtigt werden.

Anwendbar auf: OPS-03.02B

Wesentliche Sicherheitsänderungen in diesem Zusammenhang können die Änderung eines Sicherheitsmerkmals selbst sein, beispielsweise bei der Änderung der Dienstarchitektur. Zu den nicht wesentliche Änderungen kann die Änderung der Implementierung eines Sicherheitsmerkmals in einer Weise gehören, die seine Funktionalität nicht verändert oder sein Sicherheitsniveau nicht verringert, beispielsweise wenn ein verwendetes kryptographisches Primitiv durch ein anderes, gleichwertiges ersetzt wird.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen durch geeignete Kontrollen sicher, dass sie die Systemressourcen in ihrem Verantwortungsbereich steuern und überwachen.

OPS-04 Schutz vor Malware - Richtlinien und Verfahren

Basiskriterien

OPS-04.01B

Richtlinien und Verfahren mit Vorgaben zum Schutz vor Malware sind hinsichtlich der folgenden Aspekte gemäß SP-01 dokumentiert, kommuniziert und bereitgestellt:

1. Nutzung systemspezifischer Schutzmechanismen;
2. Betrieb von Schutzprogrammen auf Systemkomponenten im Verantwortungsbereich des Cloud-Anbieters;
3. Betrieb von Schutzprogrammen für Endgeräte des Personals; und
4. Betrieb von Schutzprogrammen für Datenströme, die über Endgeräte des Cloud-Anbieters eingehen, sowie für alle anderen eingehenden Datenströme.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: OPS-04.01B

Schutzprogramme für Endgeräten des Personal können beispielsweise serverbasierte Schutzprogramme sein, bei denen Dateien in Anhängen auf dem Server geprüft werden oder der Netzverkehr gefiltert wird.

Korrespondierende Kriterien für Kunden

–

OPS-05 Schutz vor Malware - Umsetzung

Basiskriterien

OPS-05.01B

Systemkomponenten im Verantwortungsbereich des Cloud-Anbieters, die zum Betrieb des Cloud-Dienstes in der Produktionsumgebung verwendet werden, werden gemäß den Richtlinien und Verfahren mit Malware-Schutz konfiguriert.

OPS-05.02B

Soweit Schutzprogramme mit einer signatur- und/oder verhaltensbasierten Detektion und Entfernung von Malware eingerichtet sind, werden diese Schutzprogramme regelmäßig, mindestens täglich, mit den neuesten Malware-Definitionen aktualisiert, sobald diese verfügbar sind.

OPS-05.03B

Der Cloud-Anbieter erstellt regelmäßige Berichte über die durchgeführten Überprüfungen der betriebenen Schutzprogramme, die von autorisierten Personen, Teams oder Gremien überprüft und analysiert werden.

Zusatzkriterium (Verschärfend)

OPS-05.02AS, verschärft OPS-05.02B

Soweit Schutzprogramme mit einer signatur- und/oder verhaltensbasierten Detektion und Entfernung von Malware eingerichtet sind, werden diese Schutzprogramme regelmäßig, mit der höchsten Häufigkeit, die der bzw. die Anbieter gegebenenfalls anbieten, mit den neuesten Malware-Definitionen aktualisiert, sobald diese verfügbar sind.

Zusatzkriterium (Erweiternd)

OPS-05.01AC

Richtlinien und Verfahren beschreiben die technischen Maßnahmen, die ergriffen werden, um die Managementkonsole (sowohl den Self-Service des Cloud-Kunden als auch die Cloud-Administration des Cloud-Anbieter) sicher zu konfigurieren und zu überwachen, um sie vor Malware zu schützen.

OPS-05.02AC

Die Konfiguration der Schutzmechanismen wird automatisch überwacht.

OPS-05.03AC

Abweichungen von den Vorgaben werden automatisch an das dafür sachverständige Personal berichtet, um diese umgehend einer Beurteilung zu unterziehen und erforderliche Maßnahmen einzuleiten.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: OPS-05.01B, OPS-05.02B, OPS-05.02AS

Der Schutz vor Malware kann durch betriebssystemspezifische Schutzmechanismen oder explizite Schutzprogramme (z. B. zur signatur- und verhaltensbasierten Detektion und Entfernung von Malware) umgesetzt.

Betreibt der Cloud-Anbieter zur Bereitstellung des Cloud-Dienstes Schadsoftware-geschützte Container oder virtuelle Maschinen, sollte der Schadsoftware-Schutz containerspezifische Maßnahmen umfassen. Dies kann beispielsweise die Überwachung der Container-Images und der Container-Laufzeit sowie aufgrund des häufigen Startens und Stoppens der Container auch Echtzeit-Scans und -Überwachungsprozesse umfassen.

Anwendbar auf: OPS-05.01B

Für Endgeräte, die vom Personal des Cloud-Anbieters verwendet werden, wird die Anwendbarkeit dieses Unterkriteriums auf der Grundlage der gemäß AM-08 durchgeführten Risikobeurteilung bestimmt.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen durch geeignete Kontrollen sicher, dass die Schichten des Cloud-Dienstes, für die sie verantwortlich sind, über Sicherheitsprodukte zur Detektion und Entfernung von Schadsoftware verfügen.

OPS-06 Datensicherung und -wiederherstellung - Richtlinien und Verfahren

Basiskriterien

OPS-06.01B

Richtlinien und Verfahren für die regelmäßige Sicherung oder Replikation und regelmäßige Wiederherstellung von Cloud-Kundendaten, abgeleitete Cloud-Dienstdaten und Cloud-Anbieterdaten entsprechend der Sensibilität der Daten sind hinsichtlich der folgenden Aspekte gemäß SP-01 dokumentiert, kommuniziert und bereitgestellt:

1. Umfang und Häufigkeit der Datensicherung sowie die Dauer der Datenaufbewahrung stehen im Einklang mit den vertraglichen Vereinbarungen mit den Cloud-Kunden und den Anforderungen des Cloud-Anbieters an die Betriebskontinuität für Recovery Time Objective (RTO) und Recovery Point Objective (RPO);
2. Die Datensicherung erfolgt in verschlüsselter, dem Stand der Technik entsprechender Form;
3. Sichere Aufbewahrung, Übertragung, Verwaltung und Entsorgung von Daten aus der Datensicherung;
4. Der Zugriff auf die gesicherten Daten und die Durchführung von Wiederherstellungen erfolgt nur durch autorisierte Personen;
5. Tests der Datenwiederherstellungsverfahren durch den Cloud-Anbieter (vgl. OPS-08); und
6. Sofern Bestandteil der vertraglichen Vereinbarung: Durchführung tatsächlicher Datenwiederherstellungsanfragen oder Wiederherstellungstests, die vom Cloud-Kunden initiiert wurden.

Die Richtlinien und Verfahren enthalten Bedingungen für diejenigen Teile der Cloud-Anbieterdaten, die keine Sicherung erfordern. Für diese Teile der Cloud-Anbieterdaten ist dieses Unterkriterium nicht anwendbar.

Zusatzkriterium (Verschärfend)

OPS-06.01AS, verschärft OPS-06.01B

Richtlinien und Verfahren für die mindestens tägliche Sicherung oder Replikation und regelmäßige Wiederherstellung von Cloud-Kundendaten, abgeleitete Cloud-Dienstdaten und Cloud-Anbieterdaten entsprechend der Sensibilität der Daten sind hinsichtlich der folgenden Aspekte gemäß SP-01 dokumentiert, kommuniziert und bereitgestellt:

1. Umfang und Häufigkeit der Datensicherung sowie die Dauer der Datenaufbewahrung stehen im Einklang mit den vertraglichen Vereinbarungen mit den Cloud-Kunden und den Anforderungen des Cloud-Anbieters an die Betriebskontinuität für Recovery Time Objective (RTO) und Recovery Point Objective (RPO);
2. Die Datensicherung erfolgt in verschlüsselter, dem Stand der Technik entsprechender Form;
3. Sichere Aufbewahrung, Übertragung, Verwaltung und Entsorgung von Daten aus der Datensicherung;
4. Der Zugriff auf die gesicherten Daten und die Durchführung von Wiederherstellungen erfolgt nur durch autorisierte Personen;
5. Tests der Datenwiederherstellungsverfahren durch den Cloud-Anbieter (vgl. OPS-08); und
6. Sofern Bestandteil der vertraglichen Vereinbarung: Durchführung tatsächlicher Datenwiederherstellungsanfragen oder Wiederherstellungstests, die vom Cloud-Kunden initiiert wurden.

Die Richtlinien und Verfahren enthalten Bedingungen für diejenigen Teile der Cloud-Anbieterdaten, die keine Sicherung erfordern. Für diese Teile der Cloud-Anbieterdaten gilt dieses Unterkriterium nicht.

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: OPS-06.01B, OPS-06.01AS

Insbesondere bei IaaS- und PaaS-Dienstmodellen liegt die Verantwortung für die Sicherung und Wiederherstellung von Cloud-Kundendaten häufig beim Cloud-Kunden und ist daher nicht Teil der vertraglichen Vereinbarungen zwischen Cloud-Anbieter und Cloud-Kunde.

Ist die Datensicherung von Cloud-Kundendaten nicht Vertragsbestandteil, gilt dieses Kriterium nicht für Cloud-Kundendaten, wohl aber für abgeleitete Cloud-Dienstdaten und Cloud-Anbieterdaten. Inwieweit das Kriterium auf den Cloud-Dienst anwendbar ist, wird in der Systembeschreibung dargestellt.

Die Datensicherungsrichtlinien und -verfahren legen fest, welche Art der Datensicherung durchgeführt werden soll (z. B. Umfang, Häufigkeit und Dauer) und legen fest, welche Daten in Sonderfällen (z. B. reine Nutzung von Rechenknoten ohne Datenspeicherung) zusätzlich gesichert werden sollen. Bei der Sicherung von Daten muss zwischen *Backups* und *Snapshots* virtueller Maschinen unterschieden werden. Snapshots ersetzen keine Backups, können aber Teil der Datensicherungs-Strategie zur Erreichung von Recovery Point Objectives (RPO) sein, wenn sie zusätzlich außerhalb des ursprünglichen Datenspeicherorts gespeichert werden. Die geschäftlichen Anforderungen des Cloud-Anbieters an Umfang, Häufigkeit und Dauer der Datensicherung ergeben sich aus der Business-Impact-Analyse (vgl. BCM-02) für Entwicklungs- und Betriebsprozesse des Cloud-Dienstes. Sofern für Cloud-Kundendaten und Cloud-Anbieterdaten unterschiedliche Datensicherungs- und -wiederherstellungsverfahren bestehen, sind beide Varianten Gegenstand der Prüfungen von Kontrollen nach diesem Kriterienkatalog.

Bestehende vertragliche Vereinbarungen vor einer C5-Attestierung müssen nicht aktualisiert werden, um die in diesem Kriterium genannten Anforderungen zu berücksichtigen. Stattdessen sollten neue vertragliche Vereinbarungen so gestaltet werden, dass bestimmte Anforderungen klar definiert und mit Cloud-Kunden vereinbart werden.

Anwendbar auf: OPS-06.01B

Teile der Cloud-Anbieterdaten, für die keine Sicherung erforderlich ist, umfassen unter anderem Teile von Cloud-Anbieterdaten, die ohne Sicherung von Grund auf neu erstellt werden können.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen durch geeignete Kontrollen sicher, dass die mit dem Cloud-Anbieter getroffenen vertraglichen Vereinbarungen über Umfang, Häufigkeit und Dauer der Datenspeicherung den geschäftlichen Anforderungen entsprechen. Die Geschäftsanforderungen werden im Rahmen der Business-Impact-Analyse (vgl. BCM-02) beurteilt.

OPS-07 Datensicherung und -wiederherstellung - Überwachung

Basiskriterien

OPS-07.01B

Die Durchführung von Datensicherungen von Cloud-Kundendaten, abgeleitete Cloud-Dienstdaten und Cloud-Anbieterdaten wird durch technische und organisatorische Maßnahmen überwacht, die gemäß den Richtlinien und Verfahren für Datensicherung und -wiederherstellung dokumentiert und umgesetzt werden (vgl. OPS-06).

OPS-07.02B

Vorfälle werden von qualifiziertem Personal untersucht und zeitnah behoben, um die Einhaltung vertraglicher Verpflichtungen gegenüber Cloud-Kunden bzw. der Geschäftsanforderungen des Cloud-Anbieters hinsichtlich Umfang und Häufigkeit der Datensicherung sowie der Speicherdauer sicherzustellen.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

OPS-07.01AC

Zur Überwachung der Datensicherung stehen dem Cloud-Kunden die relevanten Protokolldaten oder die zusammengefassten Ergebnisse in einem Self-Service Portal zur Verfügung.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: OPS-07.01B, OPS-07.02B, OPS-07.01AC

Sofern die Datensicherung von Cloud-Kundendaten nicht Bestandteil des zwischen dem Cloud-Anbieter und dem Cloud-Kunden geschlossenen Vertrages ist, gilt dieses Kriterium nicht für Cloud-Kundendaten, wohl aber für abgeleitete Cloud-Dienstdaten und Cloud-Anbieterdaten. Inwieweit das Kriterium auf den Cloud-Dienst anwendbar ist, wird in der Systembeschreibung dargestellt.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen durch geeignete Kontrollen sicher, dass die Sicherung der Daten in ihrem Verantwortungsbereich durch technische und organisatorische Maßnahmen überwacht wird.

OPS-08 Datensicherung und -wiederherstellung - Regelmäßige Tests

Basiskriterien

OPS-08.01B

Wiederherstellungsverfahren werden regelmäßig, mindestens jährlich, getestet. Die Tests umfassen Cloud-Anbieterdaten und, sofern vertraglich vereinbart, Cloud-Kundendaten und abgeleitete Cloud-Dienstdaten.

OPS-08.02B

Die Tests ermöglichen eine Beurteilung, ob die vertraglichen Vereinbarungen sowie die Vorgaben zur maximal tolerierbaren Ausfallzeit (Recovery Time Objective, RTO) und zum maximal zulässigen Datenverlust (Recovery Point Objective, RPO) eingehalten werden (vgl. BCM-02).

OPS-08.03B

Cloud-Kundendaten werden nur in Umgebungen wiederhergestellt, die denselben Zugriffsbeschränkungen unterliegen wie die Produktionsumgebung.

OPS-08.04B

Durchgeführte Wiederherstellungstests werden ausführlich dokumentiert. Dazu gehört auch die Dokumentation der sicheren Entsorgung der wiederhergestellten Daten.

OPS-08.05B

Abweichungen von den Vorgaben werden an das dafür zuständige Personal oder die dafür zuständigen Systemkomponenten beim Cloud-Anbieter berichtet, damit diese die Abweichungen zeitnah beurteilen und erforderliche Maßnahmen einleiten können.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

OPS-08.01AC

Auf Wunsch des Cloud-Kunden informiert der Cloud-Anbieter den Cloud-Kunden über die Ergebnisse der Wiederherstellungstests.

OPS-08.02AC

Wiederherstellungstests sind im Business Continuity Management des Cloud-Anbieters enthalten.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: OPS-08.01B, OPS-08.02B, OPS-08.03B, OPS-08.04B, OPS-08.05B, OPS-08.01AC, OPS-08.02AC

Sofern die Datensicherung nicht vertraglich zwischen dem Cloud-Anbieter und dem Cloud-Kunden vereinbart wurde, ist dieses Kriterium nicht anwendbar. Dieser Sachverhalt ist vom Cloud-Anbieter in der Systembeschreibung transparent darzustellen.

Anwendbar auf: OPS-08.01B

Die im Basiskriterium beschriebene Nutzung von Cloud-Kundendaten bei Sicherungs- und Wiederherstellungsverfahren stellt eine wohlüberlegte Ausnahme dar. Diese Ausnahme erstreckt sich nicht auf allgemeine Softwareentwicklungs- oder andere Testumgebungen und die Verwendung von Cloud-Kundendaten für Tests ist speziell auf Sicherungs- und Wiederherstellungsverfahren beschränkt.

Anwendbar auf: OPS-08.03B

Wenn Cloud-Kundendaten in einer Umgebung mit unterschiedlichen Zugriffsbeschränkungen wiederhergestellt werden, kann die Vertraulichkeit der Daten beeinträchtigt werden.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen durch geeignete Kontrollen sicher, dass sie aktiv Informationen über die Ergebnisse von Wiederherstellungstests beim Cloud-Anbieter anfordern. Cloud-Kunden bewerten die Wirksamkeit angewandter Datenwiederherstellungsstrategien und integrieren Erkenntnisse in ihre eigenen Notfallpläne im Einklang mit ihren Geschäftsanforderungen und Sicherheitsstandards.

OPS-09 Datensicherung und -wiederherstellung - Aufbewahrung

Basiskriterien

OPS-09.01B

Der Cloud-Anbieter überträgt die Cloud-Anbieterdaten und, sofern vertraglich vereinbart, die Cloud-Kundendaten und die abgeleiteten Cloud-Dienstdaten zur Sicherung an einen entfernten Standort oder transportiert diese auf Sicherungsmedien an einen entfernten Standort.

OPS-09.02B

Die Schutzbedarfe, die sich aus der Datenklassifizierung der Originaldaten ergeben (z. B. Verschlüsselung, Zugriffskontrolle), gelten auch für Datensicherungen.

OPS-09.03B

Soweit die Datensicherung über ein Netz zum Remote-Standort übertragen wird, erfolgt die Datensicherung oder die Übertragung der Daten in einer verschlüsselten Form, die dem Stand der Technik entspricht (vgl. CRY-04).

OPS-09.04B

Die Entfernung zum Hauptstandort wird unter ausreichender Berücksichtigung der Faktoren Wiederherstellungszeiten und Auswirkungen von Katastrophen auf beide Standorte gewählt.

OPS-09.05B

Die Maßnahmen zur physischen und umgebungsbezogenen Sicherheit am Remote-Standort entsprechen denen am Hauptstandort.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: OPS-09.01B, OPS-09.02B, OPS-09.03B, OPS-09.04B, OPS-09.05B

Sofern die Datensicherung nicht vertraglich zwischen dem Cloud-Anbieter und dem Cloud-Kunden vereinbart wurde, entfällt dieses Kriterium. Der Cloud-Anbieter stellt diesen Sachverhalt in der Systembeschreibung transparent dar.

Anwendbar auf: OPS-09.01B, OPS-09.03B, OPS-09.04B, OPS-09.05B

Ein entfernter Standort kann z.B. ein weiteres Rechenzentrum des Cloud-Anbieters sein.

Korrespondierende Kriterien für Kunden

–

OPS-10 Protokollierung und Überwachung - Richtlinien und Verfahren

Basiskriterien

OPS-10.01B

Der Cloud-Anbieter hat Richtlinien und Verfahren festgelegt, die die Protokollierung und Überwachung von Ereignissen auf Systemkomponenten in seinem Verantwortungsbereich regeln. Diese Richtlinien und Verfahren werden gemäß SP-01 in Bezug auf die folgenden Aspekte dokumentiert, kommuniziert und bereitgestellt:

1. Definition von Ereignissen, die zu einer Verletzung der Schutzziele führen könnten;
2. Vorgaben zum Aktivieren, Stoppen und Pausieren der verschiedenen Protokolldaten;
3. Informationen über den Zweck und die Aufbewahrungsfrist der Protokolldaten;
4. Definition von Rollen, Verantwortlichkeiten und Befugnissen für die Einrichtung und Überwachung der Protokollierung;
5. Definition der Protokolldaten, die zur Übertragung an Cloud-Kunden zugelassen sind, und technische Anforderungen einer solchen Übertragung;
6. Informationen zu Zeitstempeln, die bei der Ereigniserstellung verwendet werden;
7. Zeitsynchronisation von Systemkomponenten mit mindestens einer zugelassenen Zeitquelle, die der Cloud-Anbieter aufgrund definierter Kriterien als zuverlässig erachtet. Werden mehrere Zeitquellen verwendet, sind diese miteinander konsistent. Die Zeitquellen können auch mit mehreren externen zuverlässigen Quellen synchronisiert werden, außer bei Verwendung für isolierte Netze; und

8. Einhaltung gesetzlicher und regulatorischer Rahmenbedingungen.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: OPS-10.01B

Zu den im Basiskriterium genannten Protokolldaten gehören abgeleitete Cloud-Dienstdaten und Cloud-Anbieterdaten. Gesetzliche und regulatorische Rahmenbedingungen können z.B. gesetzliche Vorgaben zu Aufbewahrungsfristen und zur Löschung von Daten festlegen.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen durch geeignete Kontrollen sicher, dass eine angemessene Protokollierung und Überwachung von Ereignissen, die die Sicherheit und Verfügbarkeit des Cloud-Dienstes beeinträchtigen können (z. B. Administratoraktivitäten, Systemausfälle, Authentifizierungsprüfungen, Datenlöschungen usw.), für die in ihrem Verantwortungsbereich liegenden Schichten des Cloud-Dienstes erfolgt.

OPS-11 Protokollierung und Überwachung - Richtlinien und Verfahren für den Umgang mit abgeleiteten Cloud-Dienstdaten und Kontodaten

Basiskriterien

OPS-11.01B

Richtlinien und Verfahren für den sicheren Umgang mit abgeleiteten Cloud-Dienstdaten und Kontodaten werden gemäß SP-01 dokumentiert, kommuniziert und bereitgestellt, und zwar im Hinblick auf mindestens die folgenden Aspekte:

1. Abgeleitete Cloud-Dienstdaten und Kontodaten werden ausschließlich zur Verwaltung und zum Betrieb des Cloud-Dienstes erfasst und verwendet, einschließlich Zwecken im Zusammenhang mit der Implementierung von Sicherheitskontrollen.
2. Keine kommerzielle Nutzung über den oben genannten Zweck zur Verwaltung und zum Betrieb des Cloud-Dienstes hinaus;
3. Aufbewahrung für einen festgelegten Zeitraum, der im angemessenen Verhältnis zu den Zwecken der Erhebung steht;
4. Die Vertraulichkeit und Integrität der Protokolldaten wird durch geeignete Sicherheitskontrollen geschützt;
5. Soweit technisch möglich, werden anonymisierte, abgeleitete Cloud-Dienstdaten nur in einer Weise genutzt, dass keine Rückschlüsse auf das Nutzungsverhalten einzelner Nutzer des Cloud-Kunden möglich sind;
6. Abgeleitete Cloud-Dienstdaten, die vollständig anonymisiert sind und nicht auf einzelne Cloud-Kunden zurückgeführt werden können, dürfen weiterverarbeitet und aufbewahrt werden, sofern keine vertraglichen oder gesetzlichen Beschränkungen bestehen, andernfalls sofortige Löschung, wenn die Zwecke der Erhebung erfüllt sind und eine weitere Aufbewahrung nicht mehr erforderlich ist; und
7. Bereitstellung an Cloud-Kunden gemäß vertraglicher Vereinbarung.

OPS-11.02B

Der Cloud-Anbieter legt in den vertraglichen Vereinbarungen mit Cloud-Kunden alle Zwecke fest, für die abgeleitete Cloud-Dienstdaten erhoben und verwendet werden, mit Ausnahme derjenigen Zwecke, die dem allgemeinen Betrieb aller Cloud-Dienste innewohnen.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

OPS-11.01AC

Personenbezogene Daten werden vor der Verarbeitung durch den Cloud-Anbieter automatisch aus den Protokolldaten entfernt, soweit dies technisch möglich ist. Die Entfernung erfolgt in einer Weise, die es dem Cloud-Anbieter ermöglicht, die Protokolldaten weiterhin für den Zweck zu verwenden, für den sie erfasst wurden.

OPS-11.02AC

Abgeleitete Cloud-Dienstdaten, insbesondere Protokolldaten, werden in die Bewertung der Einhaltung gesetzlicher Vorschriften einbezogen.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: OPS-11.01B

Die Erhebung und Nutzung der abgeleiteten Cloud-Dienstdaten und Kontodaten für die Verwaltung und den Betrieb des Cloud-Dienstes umfasst auch die Auswertung der vorgenannten Daten zum Zweck der Verbesserung des bereitgestellten Cloud-Dienstes, es sei denn, diese Verbesserung dient ausschließlich wirtschaftlichen Interessen des Cloud-Anbieters. Wenn der Cloud-Anbieter als Cloud-Vermittler fungiert, sollten die Richtlinien und Verfahren die Komplexität der Handhabung von abgeleiteten Cloud-Dienstdaten und Kontodaten im Rahmen dieser Rolle besonders berücksichtigen.

Anwendbar auf: OPS-11.02B

Mit dem allgemeinen Betrieb vieler Cloud-Dienste verbundene Zwecke sind:

1. Kapazitätsplanung und Ressourcenmanagement;
2. Sicherheitsüberwachung und Reaktion auf Vorfälle;
3. Einhaltung regulatorischer Anforderungen; und
4. Serviceleistung und Zuverlässigkeit.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen durch geeignete Kontrollen sicher, dass ihre Verträge mit dem Cloud-Anbieter die zulässigen Nutzungen der abgeleiteten Cloud-Dienstdaten klar regeln. Cloud-Kunden vergewissern sich, dass die Datenverarbeitung den vertraglichen oder gesetzlichen Beschränkungen entspricht und nehmen zur Kenntnis, dass der Anbieter verpflichtet ist, Daten zu löschen, wenn sie für seine ursprünglichen Zwecke nicht mehr erforderlich sind, sofern nichts anderes vereinbart wurde.

OPS-12 Protokollierung und Überwachung - Zugriff, Aufbewahrungsfristen und Löschung

Basiskriterien

OPS-12.01B

Die Vorgaben zur Protokollierung und Überwachung von Ereignissen sowie zum sicheren Umgang mit abgeleiteten Cloud-Dienstdaten und Cloud-Anbieterdaten (vgl. OPS-10, OPS-11) werden durch technisch gestützte Verfahren hinsichtlich der folgender Beschränkungen umgesetzt:

1. Zugriff nur für autorisierte Benutzer und Systeme;
2. Aufbewahrung für den festgelegten Zeitraum; und
3. Löschung, wenn weitere Aufbewahrung für den Zweck der Erhebung nicht mehr erforderlich ist.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

–

Korrespondierende Kriterien für Kunden

–

OPS-13 Protokollierung und Überwachung - Sicherheitsinformations- und Ereignismanagement

Basiskriterien

OPS-13.01B

Der Cloud-Anbieter integriert relevante Protokolldaten (vom Cloud-Dienst abgeleitete Daten und Cloud-Anbieterdaten) in ein SIEM-System (Security Information and Event Management), um eine nahtlose Verbindung zwischen Protokollierung, Überwachung und Sicherheitsvorfallmanagement herzustellen.

OPS-13.02B

Das SIEM-System wird innerhalb der Cloud-Umgebung oder extern bereitgestellt und umfasst die folgenden Funktionen:

1. Standardisierung von Protokolldaten;
2. Automatisierte Analyse zur Identifizierung und Korrelation potenzieller Sicherheitsvorfälle;
3. Fähigkeiten zur Detektion ungewöhnlichen Verhaltens und potenzieller Bedrohungen;
4. Echtzeit-Alarmierung, um das Incident-Response-Team über kritische Ereignisse zu informieren;
5. Meldung an das Incident-Response-Team, falls neue, für ein Ereignis relevante Informationen verfügbar werden; und
6. Automatisierte Reaktionsmechanismen zur Bewältigung von Sicherheitsvorfällen.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

OPS-13.01AC

Der Cloud-Anbieter validiert den korrekten Betrieb der Ereigniserkennungsprozesse auf den entsprechenden Assets. Die Angemessenheit der Assets wird gemäß dem Asset-Klassifizierungsschema (vgl. AM-09) ermittelt.

OPS-13.02AC

Bei der Validierung festgestellte Abweichungen werden durch zeitnahe und angemessene Maßnahmen zur Behebung adressiert.

OPS-13.03AC

Wenn ein Ereignis identifiziert wird, das zu Sicherheitsvorfällen führen kann, werden unverzüglich Maßnahmen zur Vorfallbehandlung durch den Cloud-Anbieter ausgelöst.

Ergänzende Informationen

Zum Kriterium

–

Korrespondierende Kriterien für Kunden

–

OPS-14 OPS-14 Protokollierung und Überwachung - Aufbewahrung der Protokolldaten

Basiskriterien

OPS-14.01B

Der Cloud-Anbieter bewahrt die erstellten Protokolldaten, einschließlich SIEM-Protokolldaten, unabhängig von der Quelle dieser Daten, geeignet und unveränderlich aggregiert auf, sodass eine zentrale, autorisierte Auswertung der Daten möglich ist.

OPS-14.02B

Protokolldaten werden gelöscht, wenn sie zur Erreichung des Zwecks nicht mehr erforderlich sind.

OPS-14.03B

Zwischen Protokollierungsservern und den zu protokollierenden Assets sind Authentisierung-Maßnahmen vorhanden, um die Integrität und Authentizität der übertragenen und gespeicherten Informationen zu schützen. Die Übertragung erfolgt nach einer dem Stand der Technik entsprechenden Verschlüsselung oder über ein eigenes Administrationsnetz (Out-of-Band-Management).

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

–

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass sie festlegen, ob sie Zugriff auf den kundenspezifischen Teil der abgeleiteten Cloud-Dienstdaten, bestehend aus Protokolldaten, benötigen und diesen gegebenenfalls aktiv anfordern.

OPS-15 Protokollierung und Überwachung - Zurechenbarkeit

Basiskriterien

OPS-15.01B

Die erstellten Protokolldaten - die sowohl abgeleitete Cloud-Dienstdaten als auch Cloud-Anbieterdaten umfassen - ermöglichen eine eindeutige Identifizierung des Benutzerzugriffs auf Mandantenebene und unterstützen so eine effektive forensische Analyse im Falle eines Sicherheitsvorfalls.

OPS-15.02B

Jedes protokollierte Ereignis enthält einen Zeit-/Datumsstempel, um genaue und nachvollziehbare Aufzeichnungen zu gewährleisten.

OPS-15.03B

Der Cloud-Anbieter ist in der Lage, die forensische Analyse von Vorfällen zu unterstützen und eine Beweiskette aufzubewahren. Dies bedeutet, dass der Cloud-Anbieter den Zustand von Hardwareobjekten und Netzkommunikation bei Sicherheitsereignissen erfasst.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

OPS-15.01AC

Der Cloud-Anbieter stellt auf Anfrage des Cloud-Kunden die ihn betreffenden Protokolldaten in angemessener Form und zeitnah zur Verfügung, damit dieser die ihn betreffenden Vorfälle selbst untersuchen kann.

OPS-15.02AC

Die oben genannten Protokolldaten werden mithilfe von Kontrollen und Prozessen gesammelt und verwaltet, die ihre Integrität und Zuverlässigkeit für Sicherheitsüberwachungs- und Vorfalluntersuchungszwecke wahren. Dies impliziert, ist aber nicht beschränkt auf:

1. Die Aufzeichnungen sind vollständig und wurden in keiner Weise manipuliert.
2. Protokollierungssysteme sind taktsynchron, Protokolldaten enthalten genaue Zeitstempel;
3. Kopien elektronischer Beweismittel sind nachweislich mit den Originalen identisch; und
4. Jedes Informationssystem, aus dem Beweise gesammelt wurden, funktionierte zum Zeitpunkt der Beweisaufnahme ordnungsgemäß.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: OPS-15.01AC

Das Zusatzkriterium bezieht sich auch auf Protokolldaten von Systemkomponenten, die im Verantwortungsbereich des Cloud-Anbieters liegen und auf die der Cloud-Kunde grundsätzlich keinen Zugriff hat, sofern diese Protokolldaten für die Analyse von Sicherheitsvorfällen und für die Identifizierung von Zugriffen auf Cloud-Kundendaten relevant sind (vgl. IAM-07 und INQ-03). Zur Protokollierung von Systemkomponenten im Verantwortungsbereich des Cloud-Kundens vgl. PSS-04.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass eindeutige Benutzerkennungen vergeben werden, die im Falle eines Vorfalls eine entsprechende Analyse zulassen.

OPS-16 Protokollierung und Überwachung - Konfiguration

Basiskriterien

OPS-16.01B

Der Zugriff auf Systemkomponenten zur Protokollierung und Überwachung im Verantwortungsbereich des Cloud-Anbieters ist auf autorisierte Benutzer beschränkt und erfordert eine Authentisierung mit zwei oder mehr Faktoren.

OPS-16.02B

Änderungen an der Konfiguration erfolgen gemäß den anwendbaren Richtlinien (vgl. DEV-03).

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

–

Korrespondierende Kriterien für Kunden

–

OPS-17 Protokollierung und Überwachung - Verfügbarkeit der Überwachungssoftware

Basiskriterien

OPS-17.01B

Der Cloud-Anbieter überwacht die Verfügbarkeit der Systemkomponenten zur Protokollierung und Überwachung in seinem Verantwortungsbereich.

OPS-17.02B

Ausfälle werden automatisch und zeitnah an das dafür zuständige Personal oder die dafür zuständigen Systemkomponenten des Cloud-Anbieters berichtet, sodass diese die Ausfälle beurteilen und erforderliche Maßnahmen einleiten können.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

OPS-17.01AC

Der Cloud-Anbieter sorgt für Ausfallsicherheit der Protokolldaten und der zugehörigen Infrastruktur, indem er Maßnahmen zum Schutz ihrer Integrität, Verfügbarkeit und Vertraulichkeit definiert, dokumentiert und implementiert.

OPS-17.02AC

Die Systemkomponenten zur Protokollierung und Überwachung sind so konzipiert, dass bei Ausfällen einzelner Komponenten die Funktionalität insgesamt nicht eingeschränkt ist.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: OPS-17.02AC

Einzelne Komponenten, die die Funktionalität ingesamt einschränken können, sind Single Points of Failure. Solche Einschränkungen können vermieden werden, indem potenzielle einzelne Fehlerquellen identifiziert und durch Redundanz oder den Entwurf und die Implementierung einer ausfallsicheren Architektur behoben werden.

Korrespondierende Kriterien für Kunden

–

OPS-18 Umgang mit Schwachstellen - Richtlinien und Verfahren

Basiskriterien

OPS-18.01B

Richtlinien und Verfahren mit technischen und organisatorischen Maßnahmen sind gemäß SP-01 dokumentiert, kommuniziert und bereitgestellt, um das zeitnahe Identifizieren und Adressieren von Schwachstellen der Systemkomponenten, die für die Bereitstellung des Cloud-Dienstes verwendet werden, zu regeln. Diese Richtlinien und Verfahren enthalten Vorgaben zu folgenden Aspekten:

1. Regelmäßige (proaktive) Identifizierung von Schwachstellen durch geeignete Maßnahmen, einschließlich Schwachstellenscans und Penetrationstests, unter Berücksichtigung typischer Schwachstellenklassen und gemeinsamer Schwachstellen (Common Weaknesses, CWEs);
2. Beurteilung des Schweregrads identifizierter Schwachstellen mithilfe des Common Vulnerability Scoring System (CVSS);
3. Priorisierung und Umsetzung von Maßnahmen unter Berücksichtigung bestehender Standards zur zeitnahen Behebung und/oder Mitigation identifizierter Schwachstellen basierend auf dem Schweregrad gemäß definierter Zeitrahmen und unter Bezugnahme auf häufig verwendete Bewertungssysteme wie das Exploit Prediction Scoring System (EPSS) und die Stakeholder-Specific Vulnerability Categorization (SSVC);
4. Bereitstellung von Sicherheitspatches;
5. Umgang mit Systemkomponenten, für die basierend auf einer Risikobeurteilung keine Maßnahmen zur zeitnahen Behebung oder Mitigation der Schwachstellen eingeleitet werden;
6. Schnittstellen zum Vorfallsmanagement für den Fall, dass Schwachstellen zu Vorfällen werden;
7. Sofern KI-basierte Tools zur Durchführung von Schwachstellenscans oder Penetrationstests eingesetzt werden, Anforderungen an die verständliche (nachvollziehbare, transparente) Dokumentation des Einsatzes dieser Tools und dass diese Tools zur Unterstützung der Fachexperten des Cloud-Anbieters eingesetzt werden und nicht als deren Ersatz; und
8. Bereitstellung von Informationen über die Konfiguration von Systemkomponenten und Cloud-Diensten, die bestehenden Schwachstellen und die verfügbaren Patches und/oder Maßnahmen zur Behebung unter Verwendung weit verbreiteter, vorzugsweise automatisierter Formate.

OPS-18.02B

Die Richtlinien und Verfahren für die zeitnahe Identifizierung und Behebung von Schwachstellen legen fest, dass bei als 'kritisch' eingestuften Schwachstellen zeitnah nach der Identifizierung mit dem Umgang mit diesen begonnen werden muss, auch wenn dies außerhalb der regulären Arbeitszeiten geschieht. Sie definieren auch, wie mit einer solchen Sicherheitslücke umgegangen wird.

OPS-18.03B

In den Richtlinien und Verfahren zur zeitnahen Identifizierung und Behebung von Schwachstellen ist außerdem festgelegt, dass bei als 'hoch' eingestuften Schwachstellen der Umgang mit diesen innerhalb eines Arbeitstags nach ihrer Identifizierung beginnen muss. Sie definieren auch, wie mit einer solchen Sicherheitslücke umgegangen wird.

OPS-18.04B

Der Umgang mit einer Schwachstelle gemäß den Richtlinien und Verfahren zur zeitnahen Identifizierung und Behebung von Schwachstellen umfasst die regelmäßige Nachverfolgung der Schwachstelle bis zu ihrer Behebung.

OPS-18.05B

Basierend auf einer Risikobeurteilung (vgl. OIS-07) kann der Cloud-Anbieter entscheiden, identifizierte Schwachstellen nicht zu beheben oder zu mitigieren. Eine solche Risikobeurteilung und die kompensierenden oder mitigierende Maßnahmen werden regelmäßig und bei wesentlichen Änderungen des Cloud-Dienstes überprüft.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: OPS-18.01B

Geeignete Maßnahmen zur Identifizierung von Schwachstellen umfassen die Implementierung von RFC 9116 in Verbindung mit einer CVD-Richtlinie (Coordinated Vulnerability Disclosure) gemäß etablierten Richtlinien wie ISO/IEC TR 5895:2022 und ISO/IEC 29147:2018 sowie Community-Standards wie der Project Zero Vulnerability Disclosure Policy von Google.

Das Common Vulnerability Scoring System (CVSS) ist ein technischer Standard, der zur Bewertung des Schweregrads identifizierter Schwachstellen verwendet werden kann. Die Bewertungen werden auf der Grundlage einer Formel mit mehreren Metriken berechnet, die die Leichtigkeit und Auswirkung eines Exploits abschätzen. In CVSS Version 4.0 können die Scores wie folgt auf qualitative Bewertungen abgebildet werden:

1. Niedrig: 0,1 - 3,9;
2. Mittel: 4,0 - 6,9;
3. Hoch: 7,0 - 8,9; und
4. Kritisch: 9,0 - 10,0.

Zu den weit verbreiteten Formaten zur Konfiguration von Systemkomponenten und Cloud-Diensten, den bestehenden Schwachstellen und den verfügbaren Patches und/oder Mitigationsmaßnahmen gehören unter anderem:

1. Software Bill of Materials (SBOM),
2. Common Vulnerabilities and Exposures (CVE) oder European Vulnerability Database (EUVD),
3. Vulnerability, Exploitability eXchange (VEX); und
4. Common Security Advisory Frameworks (CSAF).

Anwendbar auf: OPS-18.01B, OPS-18.02B, OPS-18.03B

ISO/IEC 30111:2019 stellt Anforderungen und Empfehlungen für die Priorisierung und Umsetzung von Maßnahmen bereit, um die zeitnahe Behebung oder Minderung identifizierter Schwachstellen sicherzustellen.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass sie Systemkomponenten in ihrem Verantwortungsbereich regelmäßig auf Schwachstellen überprüfen und diese durch geeignete Maßnahmen adressieren.

OPS-19 Umgang mit Vorfällen und Abstürzen - Richtlinien und Verfahren

Basiskriterien

OPS-19.01B

Richtlinien und Verfahren mit technischen und organisatorischen Maßnahmen sind gemäß SP-01 dokumentiert, kommuniziert und bereitgestellt, um das zeitnahe Identifizieren und Bewältigen von Vorfällen und Abstürzen in den Systemkomponenten, die zur Bereitstellung des Cloud-Dienstes verwendet werden, oder von Teilen oder dem gesamten Cloud-Dienst zu regeln. Diese Richtlinien und Verfahren enthalten Vorgaben zu folgenden Aspekten:

1. Klassifizierung und Priorisierung von Vorfällen und Abstürzen;
2. Standardisierte Verfahren zur Behandlung von Vorfällen zur Behebung bekannter Probleme;
3. Eskalationsregeln und -verfahren, einschließlich Kriterien für die Auslösung von Sicherheitsvorfallsmanagement-Prozessen (SIM-Prozessen) gemäß SIM-02 oder internen Vorfallsmanagement-Verfahren;
4. Wissensquellen für Vorfälle und Abstürze;
5. Kriterien zur Bestimmung, wann Abstürze als Vorfälle eingestuft werden und wann sie Vorfallsmanagement-Prozesse auslösen;
6. Mechanismen, die sicherstellen, dass der Zugriff auf Absturzabbild-Dateien (engl. ‘Crash Dumps’) nur autorisiertem Personal vorbehalten ist;
7. Schutzmaßnahmen, um die Offenlegung sensibler, persönlicher oder vertraulicher Daten in Absturzabbild-Dateien zu verhindern;
8. Verschlüsselung von Absturzabbild-Dateien zur Aufbewahrung und während der Übertragung;
9. Zugriffsverwaltungs-, Protokollierungs- und Überprüfungsprozesse für Zugriffsprotokolldaten von Absturzabbild-Dateien; und
10. Aufbewahrungsfristen und sichere Löschprozesse für Absturzabbild-Dateien, sobald sie nicht mehr benötigt werden.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: OPS-19.01B

Ein Absturz ist ein Vorfall, der zu einem plötzlichen und vollständigen Ausfall eines Systems oder einer Systemkomponente führt. Dies kann ein Hinweis auf ein größeres Problem sein, beispielsweise auf einen versuchten DDoS-Angriff oder eine vollständige Schwachstelle.

Eine Absturzdatei ist ein Dump des Ausführungsstatus eines Systems, normalerweise einschließlich des Inhalts seines Speichers oder seiner Register zum Zeitpunkt des Absturzes (z. B. Speicherdump).

Zu den Kriterien zur Bestimmung, wann ein Vorfall oder Absturz die Sicherheitsvorfallsmanagement-Prozesse (SIM-Prozesse) auslöst, können unter anderem folgende Vorfälle oder Abstürze zählen, die zu einem oder mehreren der folgenden Ereignisse führen:

1. Nichteinhaltung interner Sicherheitsrichtlinien, vertraglicher Vereinbarungen oder relevanter gesetzlicher und behördlicher Anforderungen;
2. Unbefugter Zugriff auf Cloud-Kundendaten oder Systemkomponenten, die zur Bereitstellung des Cloud-Dienstes in der Produktionsumgebung verwendet werden;
3. Verlust oder Exfiltration von Cloud-Kundendaten;
4. Unerlaubte Änderungen an Systemkomponenten, die zur Bereitstellung des Cloud-Dienstes in der Produktionsumgebung verwendet werden; und
5. Nichteinhaltung der in der Service Level-Vereinbarung enthaltenen Verfügbarkeitsanforderungen.

Korrespondierende Kriterien für Kunden

–

OPS-20 Umgang mit Vorfällen - Umsetzung

Basiskriterien

OPS-20.01B

Der Cloud-Anbieter identifiziert, erfasst, klassifiziert, priorisiert und behandelt Vorfälle gemäß den Richtlinien und Verfahren zur Identifizierung und Behandlung von Vorfällen und Abstürzen (vgl. OPS-19).

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

–

Korrespondierende Kriterien für Kunden

–

OPS-21 Umgang mit Abstürzen - Implementierung

Basiskriterien

OPS-21.01B

Abstürze von Systemkomponenten, Teilen oder dem gesamten Cloud-Dienst unter der Verantwortung des Cloud-Anbieters werden gemäß den Richtlinien und Verfahren zur Identifizierung und Behandlung von Vorfällen und Abstürzen (vgl. OPS-19) identifiziert, aufgezeichnet und behandelt.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

–

Korrespondierende Kriterien für Kunden

–

OPS-22 Umgang mit Schwachstellen, Vorfällen und Abstürzen - Penetrationstests

Basiskriterien

OPS-22.01B

Der Cloud-Anbieter führt mindestens jährlich und bei wesentlichen Änderungen am Cloud-Dienst gemäß den Richtlinien zum Schwachstellenmanagement (vgl. OPS-18) Penetrationstests durch qualifiziertes internes Personal oder externe Penetrationstester durch.

OPS-22.02B

Penetrationstests werden gemäß eines dokumentierten Rahmenwerks für Penetrationstests durchgeführt, das die Anzahl und Art der durchzuführenden Penetrationstests sowie die Anforderungen an die Qualifikation und Kompetenz des Personals zur Durchführung solcher Tests umreißt. Die Anzahl und Art der durchzuführenden Penetrationstests werden auf Basis einer Risikobeurteilung festgelegt (vgl. OIS-07).

OPS-22.03B

Penetrationstests zielen auf die für die Bereitstellung des Cloud-Dienstes relevanten Systemkomponenten im Verantwortungsbereich des Cloud-Anbieters ab. In einer Risikobeurteilung werden die anzugreifenden Systemkomponenten identifiziert.

OPS-22.04B

Penetrationstests werden in Übereinstimmung mit Testplänen durchgeführt, die alle relevanten Systemkomponenten abdecken und festlegen, welche Systemkomponenten getestet werden sollen.

OPS-22.05B

Erfolgen Penetrationstests in Übereinstimmung mit mehrjährigen Testplänen, wird jede relevante Systemkomponente innerhalb eines Zeitraums von maximal drei Jahren mindestens einem Penetrationstest unterzogen.

OPS-22.06B

Der Cloud-Anbieter beurteilt den Schweregrad der identifizierten Schwachstellen nach dem Common Vulnerability Scoring System (CVSS) in der zum Zeitpunkt der Beurteilung aktuellen Fassung.

OPS-22.07B

Maßnahmen zur Behebung oder Mitigation werden in Übereinstimmung mit den Zeitrahmen ergriffen, die in den Richtlinien für den Umgang mit Schwachstellen definiert sind (vgl. OPS-18).

OPS-22.08B

Die durch Penetrationstests entdeckten Schwachstellen werden einer Ursachenanalyse unterzogen. Die Ursachenanalyse ermöglicht eine Einschätzung, inwieweit ähnliche Schwachstellen im Cloud-Dienst vorhanden sein können.

Zusatzkriterium (Verschärfend)

OPS-22.01AS, verschärft OPS-22.01B

Der Cloud-Anbieter führt mindestens alle sechs Monate und bei wesentlichen Änderungen am Cloud-Dienst gemäß den Richtlinien zum Schwachstellenmanagement (vgl. OPS-18) Penetrationstests durch unabhängige externe Penetrationstester durch. Der Einsatz externer Penetrationstester erfolgt nur dann, wenn das für die Durchführung des Tests vorgesehene Personal nachweislich die Qualifikations- und Kompetenzanforderungen des Cloud-Anbieters erfüllt. Internes Personal für Penetrationstests kann das externe Personal unterstützen.

OPS-22.02AS, verschärft OPS-22.02B

Pre-Launch- und Post-Launch-Penetrationstests werden gemäß eines dokumentierten Rahmenwerks für Penetrationstests durchgeführt, der die Anzahl und Art der durchzuführenden Penetrationstests sowie die Anforderungen an die Qualifikation und Kompetenz des Personals zur Durchführung solcher Tests umreißt. Die Anzahl und Art der durchzuführenden Penetrationstests werden auf Basis einer Risikobeurteilung festgelegt (vgl. OIS-07).

OPS-22.03AS, verschärft OPS-22.03B

Penetrationstests zielen auf für die Bereitstellung des Cloud-Dienstes relevante Systemkomponenten im Verantwortungsbereich des Cloud-Anbieters ab. In einer Risikobeurteilung, gegebenenfalls unter Einbeziehung einer Bedrohungsmodellierung, werden die anzugreifenden Systemkomponenten identifiziert.

Zusatzkriterium (Erweiternd)

OPS-22.01AC

Penetrationstests werden auf der Grundlage von Überprüfungen der Architektur und Konfiguration der Systemkomponenten sowie des Quellcodes des Cloud-Anbieters durchgeführt.

OPS-22.02AC

Der Cloud-Anbieter entwirft einen mehrjährigen Testplan für seine Penetrationstestaktivitäten.

OPS-22.03AC

Der Cloud-Anbieter überprüft die Wirksamkeit von Penetrationstests an Systemkomponenten mindestens jährlich und bei wesentlichen Änderungen am Cloud-Dienst.

OPS-22.04AC

Der Cloud-Anbieter verwendet den Bedrohungsmodellierungsprozess, um Systemkomponenten mit der höchsten Risikoexposition für Penetrationstests zu priorisieren, indem er Cloud-Komponenten, Dienste, Datenflüsse, Trust Boundaries und für den Cloud-Dienst kritische Assets systematisch analysiert, um potenzielle Bedrohungen, Schwachstellen und Angriffsvektoren aufzulisten.

OPS-22.05AC

Der Cloud-Anbieter korreliert die möglichen Ausnutzungen entdeckter Schwachstellen mit früheren Informationssicherheitsvorfällen, um festzustellen, ob die Schwachstelle möglicherweise bereits vor ihrer Entdeckung ausgenutzt wurde.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: OPS-22.01B, OPS-22.02B, OPS-22.03B, OPS-22.04B, OPS-22.05B, OPS-22.06B, OPS-22.07B, OPS-22.08B, OPS-22.01AS, OPS-22.02AS, OPS-22.03AS, OPS-22.01AC, OPS-22.02AC, OPS-22.03AC, OPS-22.04AC, OPS-22.05AC

Siehe Abschnitt „1.2 Definitionen“ für die Begriffe „Penetrationstest“ und „wesentliche Änderung“.

Im Gegensatz zu Schwachstellenscans, die Code analysieren, zielen Penetrationstests im Sinne dieses Kriteriums hauptsächlich darauf ab, das Live-System zu untersuchen, um reale Schwachstellen oder Schwächen aufzudecken, die sich nur im tatsächlichen Betrieb des Cloud-Dienstes zeigen, und stellen so den Bezug zum Kriterium OPS-18 her.

Es gibt drei Arten von Penetrationstests:

1. Black-Box-Tests: Tests, die ohne vorherige Kenntnis der internen Struktur/des Designs/der Implementierung des zu testenden Objekts durchgeführt werden;
2. Grey-Box-Tests: Tests, die mit teilweiser Kenntnis der internen Struktur/des Designs/der Implementierung des zu testenden Objekts durchgeführt werden; und
3. White-Box-Tests: Tests werden mit Kenntnis der internen Struktur/des Designs/der Implementierung des zu testenden Objekts durchgeführt.

Es kann weiter unterschieden werden zwischen

1. Pre-Launch-Penetrationstests: Tests, die bereits im Rahmen des Softwareentwicklungsprozesses während der Testphase des Cloud-Dienstes durchgeführt werden (vgl. DEV-07); und
2. Post-Launch-Penetrationstests: Tests, die während des regulären Betriebs des Cloud-Dienstes durchgeführt werden.

Zu den wesentlichen Änderungen können unter anderem die folgenden Ereignisse gehören:

1. Ersetzen zentraler Cloud-Infrastrukturtechnologien oder Durchführen größerer Versions-Upgrades;
2. Wechsel zwischen Service-Organisationen, z. B. Wechsel zu einem neuen IaaS- oder Rechenzentrumsanbieter;
3. Wesentliche Änderungen in der Art und Weise, wie Cloud-Kundendaten verarbeitet und aufbewahrt werden, wie z. B. neue Datensicherungstechniken oder neue Regionen, von denen aus der Dienst betrieben wird;
4. Ersetzen oder Durchführen größerer Upgrades von Sicherheitstechnologien wie Authentisierungsworkflows, Netzsicherheitsmechanismen oder Überwachungsmechanismen; und
5. Wesentliche Änderungen am Cloud-Servicemodell oder an der Funktionalität, die dem Cloud-Kunden zur Verfügung gestellt wird.

Anwendbar auf: OPS-22.01B, OPS-22.01AS

Die Qualifikation und Kompetenz des Personals für Penetrationstests kann anhand professioneller Zertifizierungen, z.B. als BSI-zertifizierter IS-Penetrationstester oder CREST-zertifizierter Cyber Security Professional, nachgewiesen werden.

Anwendbar auf: OPS-22.02B, OPS-22.02AS

Wie viele Penetrationstests innerhalb eines Jahres durchgeführt werden sollten, hängt von Faktoren wie der Größe und Komplexität des bereitgestellten Cloud-Dienstes ab. Wenn Penetrationstests mehrjährigen Testplänen folgen, sollten diese bei der Festlegung der Anzahl und Art der innerhalb eines Jahres durchzuführenden Penetrationstests berücksichtigt werden.

Anwendbar auf: OPS-22.03B, OPS-22.03AS

Mithilfe der Risikobeurteilung sollen die Systemkomponenten identifiziert werden, die für die Bereitstellung des Cloud-Dienstes am kritischsten bzw. für Penetrationstests am relevantesten sind.

Anwendbar auf: OPS-22.03B, OPS-22.05B

Für die Bereitstellung des Cloud-Dienstes relevante Systemkomponenten im Verantwortungsbereich des Cloud-Anbieters können solche Systemkomponenten sein, die am externen Perimeter des Netzes exponiert sind, oder Komponenten, die nur von innerhalb des Netzes zugänglich sind.

Anwendbar auf: OPS-22.04AC

Dieses Unterkriterium ist nur anwendbar, wenn auch das Unterkriterium OPS-22.03AS angewendet wird.

Das risikobasierte Scoping stellt sicher, dass sich Penetrationstests auf die Bereiche konzentrieren, die am anfälligsten für Sicherheitsbedrohungen sind, verbessert die geschäftliche Ausrichtung und Zusammenarbeit und liefert klare technische Erkenntnisse darüber, welche Komponenten Tests erfordern, die über die standardmäßige Risikobeurteilung hinausgehen.

Für den Bedrohungsmodellierungsprozess können ein strukturierter Bedrohungsmodellierungsansatz wie STRIDE, DREAD, PASTA oder hybride Methoden verwendet werden, die auf Cloud-Umgebungen zugeschnitten sind.

Korrespondierende Kriterien für Kunden

–

OPS-23 Umgang mit Schwachstellen, Vorfällen und Abstürzen - Messungen, Analysen und Bewertungen von Abläufen

Basiskriterien

OPS-23.01B

Der Cloud-Anbieter misst, analysiert und beurteilt regelmäßig die Verfahren, mit denen Schwachstellen und Vorfälle behandelt werden, um deren fortdauernde Eignung, Angemessenheit und Wirksamkeit zu überprüfen.

OPS-23.02B

Ergebnisse werden mindestens quartalsweise von verantwortlichen Personen oder Gruppen des Cloud-Anbieters in dokumentierter Form beurteilt, um Maßnahmen zur fortlaufenden Verbesserung zu initiieren oder deren Wirksamkeit zu überprüfen.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: OPS-23.01B

Die Beurteilung der Eignung, Angemessenheit und Wirksamkeit von Verfahren zur Behandlung von Schwachstellen und Vorfällen kann auf folgenden Informationen basieren:

1. Regelmäßige Berichterstattung über KPIs (Key Performance Indicators), die volumen-, zeit- oder auflösungs-/qualitätsbasiert sind;
2. Cloud-Kundenbeschwerden oder Ergebnisse von Cloud-Kundenbefragungen über deren Zufriedenheit mit den Verfahren; und
3. Ergebnisse interner oder externer Audits.

Zu den KPIs für Schwachstellen zählen beispielsweise: 1. Mean Time to Detect (MTTD, durchschnittliche Zeit, die benötigt wird, um eine Schwachstelle von ihrer Offenlegung oder Entstehung zu entdecken); 2. Mean Time to Remediate (MTTR, durchschnittliche Zeit, die zum Beheben oder Patchen einer Schwachstelle benötigt wird, nachdem diese erkannt wurde); 3. Anzahl offener Schwachstellen je Schweregrad; und 4. Prozentsatz der Schwachstellen, die innerhalb eines festgelegten Zeitraums behoben wurden.

Zu den KPIs für Vorfälle zählen beispielsweise: 1. Anzahl der über einen bestimmten Zeitraum gemeldeten Vorfälle und wie sich diese im Laufe der Zeit entwickelt haben; 2. Durchschnittliche Reaktions- und Lösungszeit; 3. Prozentsatz der Vorfälle, die im Rahmen der vereinbarten Service Level-Vereinbarung gelöst wurden; und 4. Prozentsatz der Vorfälle, die beim ersten Lösungsversuch gelöst wurden.

Korrespondierende Kriterien für Kunden

–

OPS-24 Einbindung des Cloud-Kunden bei Vorfällen

Basiskriterien

OPS-24.01B

Der Cloud-Anbieter informiert den Cloud-Kunden regelmäßig und in angemessener Form, die den vertraglichen Vereinbarungen entspricht, über den Status der den Cloud-Kunden betreffenden Vorfälle und bindet diesen, soweit angemessen und erforderlich, in die Behebung ein.

OPS-24.02B

Sobald ein Vorfall aus Sicht des Cloud-Anbieters behoben wurde, wird der Cloud-Kunde gemäß den vertraglichen Vereinbarungen über die getroffenen Maßnahmen informiert.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

OPS-24.01AC

Der Cloud-Anbieter definiert und dokumentiert Verfahren in vertraglichen Vereinbarungen mit Cloud-Kunden, die die Beteiligung des Cloud-Kunden an der Bestätigung, dass eine Lösung die Grundursache eines Vorfalls wirksam behoben hat, innerhalb eines bestimmten Zeitraums festlegen.

Ergänzende Informationen

Zum Kriterium

–

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass sie Benachrichtigungen des Cloud-Anbieters bezüglich sie betreffender Vorfälle erhalten, und dass diese Benachrichtigungen zeitnah an die für die

Bearbeitung verantwortliche Stelle weitergeleitet werden, damit entsprechende Maßnahmen ergriffen werden können.

OPS-25 Umgang mit Schwachstellen, Vorfällen und Abstürzen - Schwachstellenscans

Basiskriterien

OPS-25.01B

Systemkomponenten im Verantwortungsbereich des Cloud-Anbieters für die Bereitstellung des Cloud-Dienstes werden gemäß den Richtlinien zum Umgang mit Schwachstellen (vgl. OPS-18) mindestens monatlich einem Schwachstellenscan unterzogen. Diese Schwachstellenscans umfassen einen Vergleich von Softwarekomponentendaten mit aktuellen Schwachstellendatenbanken (z. B. CVE, EUVD usw.), um bekannte Schwachstellen zu identifizieren.

OPS-25.02B

Der Cloud-Anbieter beurteilt den Schweregrad von Schwachstellen anhand definierter Kriterien.

OPS-25.03B

Maßnahmen zur zeitnahen Behebung oder Mitigation werden innerhalb definierter Zeitfenster eingeleitet.

OPS-25.04B

Die Ergebnisse der Schwachstellenscans werden verwendet, um die SIEM-Systemregeln (vgl. OPS-13) des Cloud-Anbieters zu aktualisieren, sodass das System erkennen kann, wenn bekannte Schwachstellen aktiv ausgenutzt werden.

Zusatzkriterium (Verschärfend)

OPS-25.01AS, verschärft OPS-25.01B

Systemkomponenten im Verantwortungsbereich des Cloud-Anbieters für die Bereitstellung des Cloud-Dienstes werden gemäß den Richtlinien zum Umgang mit Schwachstellen (vgl. OPS-18) mindestens täglich einem Schwachstellenscan unterzogen. Diese Schwachstellenscans umfassen einen Vergleich von Softwarekomponentendaten mit aktuellen Schwachstellendatenbanken (z. B. CVE, EUVD usw.), um bekannte Schwachstellen zu identifizieren.

OPS-25.02AS, verschärft OPS-25.02B

Der Cloud-Anbieter beurteilt den Schweregrad von Schwachstellen anhand der zum Zeitpunkt der Bewertung aktuellsten Version des Common Vulnerability Scoring System (CVSS).

Zusatzkriterium (Erweiternd)

OPS-25.01AC

Zeitrahmen für die Einleitung von Behebungs- oder Minderungsbemühungen nach der Identifizierung einer Schwachstelle werden gemäß einem risikobasierten Klassifizierungsrahmenwerks definiert und überwacht. Dieses Rahmenwerk berücksichtigt unter anderem den CVSS-Schweregrad von Schwachstellen.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: OPS-25.01B, OPS-25.01AS

Im Gegensatz zu Penetrationstests (vgl. OPS-22), die manuell und nach einem individuellen Schema durchgeführt werden, erfolgt die Prüfung auf offene Schwachstellen automatisch mithilfe sogenannter Schwachstellenscanner.

Definitionen der Begriffe ‘CVE’ und ‘EUVD’ sowie anderer Begriffe mit Bezug zu Schwachstellen befinden sich in den ergänzenden Informationen zum Kriterium OPS-18.01B.

Die Daten der Softwarekomponenten, die mit aktuellen Schwachstellendatenbanken abgeglichen werden sollen, können, müssen aber nicht, mithilfe einer Software Bill of Materials (SBOM) ermittelt werden.

Anwendbar auf: OPS-25.01AC

Ein Beispiel für ein Rahmenwerk zur risikobasierten Klassifizierung und Definition von Zeitrahmen kann sein:

1. Kritisch (CVSS = 9,0 - 10,0): 24 - 48 Stunden;
2. Hoch (CVSS = 7,0 - 8,9): 48 - 72 Stunden;
3. Mittel (CVSS = 4,0 - 6,9): 5 Tage; und
4. Niedrig (CVSS = 0,1 - 3,9): 1 Monat.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass in ihrem Verantwortungsbereich liegende Systemkomponenten regelmäßig auf Schwachstellen überprüft werden und sie diese durch geeignete Maßnahmen mitigieren. Wenn Cloud-Kunden virtuelle Maschinen oder Container mit dem Cloud-Dienst betreiben, umfasst dies auch die Durchführung von Schwachstellenscans, um sicherzustellen, dass sichere Images (sog. Golden Images) verwendet werden, die entweder vom Cloud-Anbieter oder vom Cloud-Kunden selbst bereitgestellt werden.

OPS-26 Umgang mit Schwachstellen, Vorfällen und Abstürzen - Systemhärtung

Basiskriterien

OPS-26.01B

Systemkomponenten im Verantwortungsbereich des Cloud-Anbieters, die für die Bereitstellung des Cloud-Dienstes in der Produktionsumgebung verwendet werden, sind gemäß allgemein anerkannten Branchenstandards gehärtet.

OPS-26.02B

Die je Systemkomponente anzuwendenden Vorgaben zur Härtung sind dokumentiert.

OPS-26.03B

Soweit nicht veränderliche (‘immutable’) Images eingesetzt werden, wird die Einhaltung der Vorgaben zur Härtung in einem konsistenten Verfahren überprüft.

OPS-26.04B

Konfigurations- und Protokolldaten (Cloud-Anbieterdaten) bezüglich der kontinuierlichen Bereitstellung dieser Images werden aufbewahrt.

OPS-26.05B

Der Cloud-Anbieter implementiert Überwachungsmaßnahmen, um sicherzustellen, dass Systemkomponenten den Vorgaben zur Härtung entsprechen.

OPS-26.06B

Erkannte Abweichungen von diesen Vorgaben werden zeitnah an die zuständigen Abteilungen gemeldet, damit diese umgehend beurteilt und Maßnahmen ergriffen werden können.

Zusatzkriterium (Verschärfend)

OPS-26.05AS, verschärft OPS-26.05B

Systemkomponenten im Verantwortungsbereich des Cloud-Anbieters werden automatisch auf Einhaltung der Vorgaben zur Härtung überwacht.

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: OPS-26.01B, OPS-26.05B, OPS-26.05AS

Systemkomponenten im Sinne des Kriteriums sind die für die Informationssicherheit des Cloud-Dienstes während der Erstellung, Verarbeitung, Speicherung, Übertragung, Löschung oder Zerstörung von Informationen benötigten Objekte im Verantwortungsbereich des Cloud-Anbieters, z.B. Firewalls, Loadbalancer, Webserver, Anwendungsserver und Datenbankserver. Diese Systemkomponenten bestehen wiederum aus Hardware- und Softwareobjekten. Dieses Kriterium beschränkt sich auf Softwareobjekte, z.B Hypervisor, Betriebssysteme, Datenbanken, Programmierschnittstellen (APIs), Images (z. B. für virtuelle Maschinen und Container) und Anwendungen zur Protokollierung und Überwachung sicherheitsrelevanter Ereignisse.

Anwendbar auf: OPS-26.01B

Allgemein anerkannte Branchenstandards sind beispielsweise der Security Configuration Benchmark des Center for Internet Security (CIS) oder die entsprechenden Module im BSI IT-Grundschutz-Kompendium.

Anwendbar auf: OPS-26.04B

Die Konfigurations- und Protokolldaten bezüglich nicht veränderlicher Images beinhalten beispielsweise:

1. Konfiguration der eingesetzten Images bezüglich umgesetzter Vorgaben zur Härtung;
2. Vorgaben inklusive Versionshistorie; und
3. Protokolldaten bezüglich der Datei-Integritätsüberwachung der im produktiven Einsatz befindlichen Images.

Anwendbar auf: OPS-26.05B, OPS-26.05AS

Die Einhaltung der Vorgaben zur Härtung kann z.B. durch eine Datei-Integritätsüberwachung überwacht werden.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass jene Ebenen des Cloud-Dienstes, die unter ihrer Verantwortung stehen, gemäß allgemein etablierter und akzeptierter Branchenstandards zu härten. Die angewendeten Härtungsmaßnahmen resultieren aus einer Risikobeurteilung der geplanten Nutzung des Cloud-Dienstes.

OPS-27 Umgang mit Schwachstellen - Richtlinien und Verfahren zum Patch-Management

Basiskriterien

OPS-27.01B

Richtlinien und Verfahren mit technischen und organisatorischen Maßnahmen werden gemäß SP-01 dokumentiert, kommuniziert und bereitgestellt, um sicherzustellen, dass Systemkomponenten, die in der Verantwortung des Cloud-Anbieters liegen, innerhalb eines angemessenen Zeitrahmens gepatcht werden, abhängig von vertraglichen Vereinbarungen und identifizierten Schwachstellen oder Exploits. Diese Richtlinien und Verfahren enthalten Vorgaben zu folgenden Aspekten:

1. Die Software wird auf dem neuesten Stand gehalten, einschließlich der zeitnahen Bereitstellung von Sicherheitspatches.
2. Patches werden gegebenenfalls innerhalb der Wartungsfenster geplant, um Dienstunterbrechungen zu minimieren; und
3. Patches werden in Nicht-Produktionsumgebungen getestet, bevor sie in der Produktionsumgebung bereitgestellt werden, vorausgesetzt, der Test war erfolgreich. Es sind Mechanismen vorhanden, um bei unerwarteten Problemen auf frühere Softwareversionen zurückgreifen zu können.

OPS-27.02B

Patch-Management-Verfahren sind mit dem gesamten Software-Change-Management-Prozess des Cloud-Anbieters abgestimmt (vgl. DEV-03).

OPS-27.03B

Gemäß den Maßnahmen und Verfahren des gesamten Änderungsmanagement werden von Dritten bereitgestellte Patches identifiziert, getestet und bereitgestellt.

OPS-27.04B

Systeme werden nach der Anwendung von Patches gescannt, um sicherzustellen, dass Schwachstellen und Exploits behoben werden und keine bekannten oder nicht behobenen Schwachstellen oder Exploits eingesetzt werden.

Zusatzkriterium (Verschärfend)

OPS-27.03AS, verschärft OPS-27.03B

Gemäß den Maßnahmen und Verfahren des gesamten Änderungsmanagements werden von Dritten bereitgestellte Patches identifiziert, getestet und automatisiert bereitgestellt. Für Patches, bei denen ein manueller Eingriff erforderlich ist, wird ein Ausnahmebehandlungsprozess für manuelles Patchen definiert.

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: OPS-27.01B, OPS-27.02B, OPS-27.03B, OPS-27.04B, OPS-27.03AS

Unter Patches versteht man Software-Updates für Systemkomponenten mit dem Ziel, die Sicherheit durch Behebung von Problemen, Schwachstellen oder Exploits zu erhöhen.

Anwendbar auf: OPS-27.01B

Was als zeitnah im Sinne dieses Unterkriteriums gilt, hängt von der Kritikalität des gepatchten Problems, der Schwachstelle oder des Exploits ab.

Anwendbar auf: OPS-27.04B

Die nach der Anwendung eines Patches durchgeführten Scans können, müssen aber nicht, auf die Systemkomponenten beschränkt sein, auf die der Patch angewendet wurde.

Korrespondierende Kriterien für Kunden

–

OPS-28 Umgang mit Schwachstellen - Implementierung des Patch-Managements

Basiskriterien

OPS-28.01B

Der Cloud-Anbieter entwirft, implementiert und pflegt technische und organisatorische Maßnahmen für die Bereitstellung von Patches auf den Systemen und Anwendungen unter seiner Verantwortung gemäß den Patch-Management-Richtlinien und -Verfahren (vgl. OPS-27).

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

–

Korrespondierende Kriterien für Kunden

–

OPS-29 Umgang mit Schwachstellen, Vorfällen und Abstürzen - extern bezogene Komponenten

Basiskriterien

OPS-29.01B

Der Cloud-Anbieter entwirft, implementiert und pflegt technische und organisatorische Maßnahmen zum Management von Aktualisierungen der Systemkomponenten, die zur Bereitstellung des Cloud-Dienstes verwendet werden und Bibliotheken Dritter oder Open-Source-Bibliotheken einbinden. Dazu gehört:

1. Regelmäßige Identifizierung verfügbarer Updates und bekannter Schwachstellen in Bibliotheken von Drittanbietern oder Open-Source-Bibliotheken, die in Anwendungen verwendet werden;
2. Bewertung der potenziellen Auswirkungen identifizierter Updates und Schwachstellen auf die Anwendungen und die allgemeine Sicherheitslage;
3. Rechtzeitige Implementierung notwendiger Updates und Patches, um identifizierte Schwachstellen zu beheben; und
4. Kontinuierliche Überwachung von Anwendungen, um sicherzustellen, dass Updates effektiv angewendet werden und keine bekannten oder nicht behobenen Schwachstellen entstehen.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

–

Korrespondierende Kriterien für Kunden

–

OPS-30 Trennung von Datensätzen - Richtlinien und Verfahren

Basiskriterien

OPS-30.01B

Basierend auf einer Risikobeurteilung (vgl. OIS-07) hat der Cloud-Anbieter Richtlinien und Verfahren mit technischen und organisatorischen Maßnahmen festgelegt, um die Trennung von Cloud-Kundendaten zwischen verschiedenen Cloud-Kunden sowie zwischen Cloud-Kunden und dem Cloud-Anbieter sicherzustellen. Diese Richtlinien und Verfahren werden gemäß SP-01 dokumentiert, kommuniziert und bereitgestellt und enthalten Spezifikationen zur Mandantentrennung auf der Grundlage eines dokumentierten Cloud-Schichten-Modells und umfassen Folgendes:

1. Darstellung, welche Cloud-Schichten für den jeweiligen Cloud-Dienst verwendet werden. Die verwendeten Cloud-Schichten sollten geeignet sein, eine Mandantentrennung zu ermöglichen;
2. Maßnahmen zur Trennung von Cloud-Kundendaten entlang der verwendeten Cloud-Schichten. Diese Maßnahmen werden nach den Schutzzielen Vertraulichkeit, Integrität und Verfügbarkeit kategorisiert und danach, ob es sich um präventive, detektive oder reaktive Maßnahmen handelt;
3. Überwachung und Einhaltung dieser Maßnahmen; und
4. Einleitung geeigneter Maßnahmen bei Abweichungen.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: OPS-30.01B

Die Richtlinien und Verfahren dieser Kriterien sollen als übergeordnete Richtlinie für alle Cybersicherheitsmaßnahmen gegen alle Bedrohungen dienen, die aus der gemeinsamen Nutzung physischer oder virtueller Ressourcen resultieren und zu einem Verlust der Trennung von Datensätzen führen. Idealerweise hat der Cloud-Anbieter die Trennung der Datensätze zwischen verschiedenen Cloud-Kunden sowie zwischen Cloud-Kunden und Cloud-Anbieter bereits über alle anderen Richtlinien, Verfahren und die entsprechenden Maßnahmen sichergestellt. Der systematische Ansatz der in diesem Kriterium behandelten Richtlinien und Verfahren stellt sicher, dass kein Aspekt dieser Trennung übersehen wird. Außerdem bietet es eine gute Grundlage, um dem Cloud-Kunden die Cybersicherheit des Cloud-Dienstes ansprechend zu erklären (vgl. PSS-01).

Cloud-Schichten im Sinne dieses Kriteriums finden sich in der *CISA Cloud Security Technical Reference Architecture*. Die in Version 2.0 dieses Dokuments bereitgestellten Schichten umfassen Identitäts-, Anmeldeinformations- und Zugriffsverwaltung, Daten, Netz, Anwendungen, Laufzeit, Middleware, Betriebssysteme, Virtualisierung, Server, Speicher und physische Sicherheit. Der Cloud-Anbieter kann je nach bereitgestelltem Cloud-Dienst seine eigene Kategorisierung von Cloud-Schichten verwenden.

Es gibt neun Kombinationen für Vertraulichkeit, Integrität und Verfügbarkeit mit Prävention, Detektion und Reaktion. Die Anwendung auf jede Cloud-Schicht kann zu einer großen Anzahl von Kombinationen führen. Je nach Cloud-Dienst kann es jedoch akzeptabel sein, dass nicht für jede mögliche Kombination aus Prävention, Detektion und Reaktion sowie Vertraulichkeit, Integrität und Verfügbarkeit aussagekräftige

Informationen in der Richtlinie bereitgestellt werden können. Diese Fälle sollten in den Richtlinien und Verfahren nachvollziehbar dokumentiert werden.

Korrespondierende Kriterien für Kunden

–

OPS-31 Trennung von Datensätzen - Implementierung

Basiskriterien

OPS-31.01B

Der Cloud-Anbieter entwirft, implementiert und pflegt Maßnahmen und Verfahren gegen Bedrohungen der Trennung von Datensätzen gemäß den Richtlinien und Verfahren von OPS-30. Die Maßnahmen zielen auf die Prävention, Detektion und Reaktion auf trennungswidrige Vorkommnisse ab.

OPS-31.02B

Auf gemeinsam genutzten virtuellen und physischen Ressourcen gespeicherte und verarbeitete Cloud-Kundendaten sind gemäß eines dokumentierten Ansatzes, auf Basis einer Risikobeurteilung nach OIS-07 und den Richtlinien zur Kryptographie (vgl. CRY-01) folgend sicher und strikt getrennt, um die Vertraulichkeit und Integrität dieser Daten zu gewährleisten.

OPS-31.03B

Die Risikobeurteilung wird bei Bedarf, insbesondere bei Änderungen an der Architektur des Cloud-Dienstes, mindestens jedoch jährlich überprüft. Maßnahmen werden gegebenenfalls angepasst oder verbessert, um sicherzustellen, dass sie den Risiken angemessen bleiben.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: OPS-31.02B

Zu den gemeinsam genutzten Ressourcen gehören CPU, RAM, Speicherplatz und Netze. Die Trennung von Cloud-Kundendaten auf gemeinsam genutzten Ressourcen kann beispielsweise gemäß den in der *CISA Cloud Security Technical Reference Architecture* beschriebenen Cloud-Schichten erfolgen. Die Trennung auf jeder gemeinsam genutzten Ressource wird auf der Grundlage der durchgeführten Risikobeurteilung so umgesetzt, dass sie als angemessen erachtet wird. Dazu kann auch gehören, dass für bestimmte gemeinsam genutzte Ressourcen keine kryptographische Trennung implementiert wird.

Wenn die Angemessenheit und Wirksamkeit der Trennung nicht mit hinreichender Sicherheit beurteilt werden kann (z. B. aufgrund einer komplexen Implementierung), kann der Nachweis auch durch die Ergebnisse von Expertenprüfungen Dritter erbracht werden (z. B. Penetrationstests zur Validierung der Richtlinien und Verfahren).

Die Trennung der übertragener Daten ist Gegenstand des Kriteriums COS-06.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass die vom Cloud-Dienst bereitgestellten Funktionen zur Trennung gemeinsam genutzter virtueller und physischer Ressourcen so genutzt werden,

dass Risiken mit Bezug zur Trennung entsprechend dem Schutzbedarf der Daten hinreichend adressiert werden.

OPS-32 Confidential Computing - Richtlinien und Verfahren

Basiskriterien

OPS-32.01B

Wenn der Cloud-Dienst Funktionen für Confidential Computing umfasst, werden Richtlinien und Verfahren sowie technische Sicherheitsmaßnahmen gemäß SP-01 dokumentiert, kommuniziert und bereitgestellt, in dem die folgenden Aspekte beschrieben werden:

1. Zweck und Umfang, einschließlich der Frage, welche Cyberssicherheitsrisiken auf Seiten des Cloud-Anbieters durch den Einsatz von Confidential Computing mitigiert werden sollen (vgl. OIS-07) und wie die Cloud-Kunden die bereitgestellten Funktionen nutzen können, um Cybersicherheitsrisiken auf ihrer Seite zu steuern;
2. Verfügbare Confidential Computing Techniken;
3. Bestimmung, welche Teile des Cloud-Stacks mit welcher Technologie geschützt sind und wo ein Zugriff Dritter möglich ist;
4. Auflistung der beteiligten Lieferanten/Service-Organisationen; und
5. Nutzung von Trusted Execution Environments (TEEs) oder sicheren Enklaven.

OPS-32.02B

Der Cloud-Anbieter stellt seinen Cloud-Kunden Informationen zu den in OPS-32.01B genannten Aspekten gemäß PSS-01 zur Verfügung.

OPS-32.03B

Zu den weiteren Aspekten, die in den Richtlinien und Verfahren zum Confidential Computing behandelt werden und nicht unbedingt in den den Cloud-Kunden bereitgestellten Informationen enthalten sind, gehören:

1. Verantwortlichkeiten für die Umsetzung und Überwachung von Confidential Computing Maßnahmen;
2. Sicherheitsanforderungen zur Gewährleistung der Vertraulichkeit, Integrität und Authentizität der Daten während der Verarbeitung; und
3. Relevante rechtliche und behördliche Anforderungen an Confidential Computing.

Zu diesen Sicherheitsanforderungen zur Gewährleistung der Vertraulichkeit, Integrität und Authentizität der Daten während der Verarbeitung gehören:

1. Weder der Cloud-Anbieter noch eine andere unbefugte Stelle darf auf die Cloud-Kundendaten oder die zum Schutz dieser Daten verwendeten Schlüssel zugreifen; und
2. Es werden kryptographische Algorithmen verwendet, die der Richtlinie des Cloud-Anbieters zur Nutzung kryptographischer Mechanismen (vgl. CRY-01) entsprechen.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

OPS-32.01AC

Der Cloud-Anbieter dokumentiert und implementiert ein technisches Rahmenwerk für Confidential Computing und zeigt, wie bestimmte Cybersicherheitsrisiken mitigiert werden (vgl. OIS-07). Das Rahmenwerk umfasst mindestens die folgenden Verfahren und technischen Schutzmaßnahmen:

1. Nutzung von Trusted Execution Environments (TEEs) oder sicheren Enklaven zur Verarbeitung sensibler Daten während der Nutzung (engl. 'data in use') in einer geschützten Umgebung;
2. Dokumentation aller zugehörigen Schnittstellen;
3. Berücksichtigung vorhandener Hardware-Nachweise;
4. Einsatz von Verschlüsselungstechniken zur Sicherung der Daten während der Verarbeitung, einschließlich sicherer Schlüsselverwaltung;
5. Remote-Attestierung zur Überprüfung der Identität und des gemessenen Zustands des TEE sowie des im TEE ausgeführten Codes;
6. Implementierung von Überwachungs- und Protokollierungsmechanismen zur Detektion und Reaktion auf Sicherheitsvorfälle;
7. Durchführung von Sicherheitsüberprüfungen und Penetrationstests (vgl. OPS-22) regelmäßig sowie anlassbezogen, um die Wirksamkeit Confidential Computing Maßnahmen zu überprüfen; und
8. Regelmäßige Aktualisierungen der Trusted Computing Base des TEE durchführen.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: OPS-32.01B, OPS-32.02B, OPS-32.03B, OPS-32.01AC

Confidential Computing im Sinne des Confidential Computing Consortium und im Sinne dieses Kriteriums ist der Schutz von Daten während der Nutzung (engl. 'data in use') durch die Durchführung von Berechnungen in einem hardwarebasierten, zertifizierten Trusted Execution Environment (TEE).

Ein TEE stellt einen isolierten Teil innerhalb eines Systems dar, der eine besonders geschützte Laufzeitumgebung bereitstellt. Der TEE kann Teil des Hauptprozessors (CPU) oder Teil des System-on-Chip (SoC) sein. Im Allgemeinen erzwingt ein TEE, dass nur autorisierter Code innerhalb des TEE ausgeführt werden kann und die von diesem Code verwendeten Daten nicht von Code außerhalb des TEE gelesen oder manipuliert werden können. Die Attestierung des TEE und der innerhalb des TEE laufenden Anwendung dient der Validierung der Vertrauenswürdigkeit der Verarbeitung.

Zu den Confidential Computing Maßnahmen gehört die Implementierung und Überwachung technischer und organisatorischer Kontrollen, um den sicheren Einsatz und Betrieb der Confidential Computing-Technik zu gewährleisten. Zu diesen Maßnahmen können die Validierung von TEE-Konfigurationen, kontinuierliche Attestierungsprozesse, die Überwachung auf nicht autorisierte Codeänderungen und die Lebenszyklusverwaltung zertifizierter Umgebungen gehören.

Korrespondierende Kriterien für Kunden

–

OPS-33 Confidential Computing - Remote-Attestierung

Basiskriterien

OPS-33.01B

Wenn der Cloud-Dienst Funktionen für Confidential Computing umfasst, bietet der Cloud-Anbieter Remote-Attestierungsfunktionen zum Schutz der genutzten Daten an.

OPS-33.02B

Die Funktionen der Remote-Attestierung basieren auf kryptographischen Mitteln, die in vertrauenswürdiger Hard- und Software verankert sind.

OPS-33.03B

Remote-Attestierungsfunktionen umfassen eine Schnittstelle, die es dem Cloud-Kunden ermöglicht, die Integrität der Remote-Attestierung zu überprüfen.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

OPS-33.01AC

Der Cloud-Anbieter definiert, dokumentiert und kommuniziert klar die verfügbaren Attestierungsstufen.

OPS-33.02AC

Die Informationen sind Teil der Richtlinien und Empfehlungen zur sicheren Nutzung des bereitgestellten Cloud-Dienstes (vgl. PSS-01).

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: OPS-33.03B

Die Schnittstelle zur Remote-Attestierung ermöglicht es Cloud-Kunden, Attestierungsnachweise sicher aus der Confidential Computing-Umgebung abzurufen. Die Überprüfung dieser Nachweise kann durch den Cloud-Kunden oder durch vertrauenswürdige Drittanbieter erfolgen.

Anwendbar auf: OPS-33.01AC

Die Remote-Attestierung kann an verschiedenen Stellen und mit unterschiedlichen Vertrauensstufen durchgeführt werden:

1. Cloud-Kunden rufen Nachweise von TEEs ab und führen die Verifizierung in einer Umgebung durch, der sie völlig vertrauen. Es wird allgemein davon ausgegangen, dass dieses Szenario eine sehr starke Attestierung darstellt;
2. Cloud-Anbieter rufen Nachweise von TEEs ab, führen Überprüfungen in von ihnen kontrollierten Überprüfungsdiensten durch und stellen dem Cloud-Kunden Überprüfungsergebnisse und Nachweise zur Verfügung. Cloud-Kunden überprüfen den Nachweis in einer Umgebung, der sie voll und ganz vertrauen. Es wird allgemein davon ausgegangen, dass dieses Szenario eine sehr starke Attestierung darstellt;
3. Cloud-Kunden rufen Nachweise von TEEs ab und senden sie an einen Nachweisverifizierungsdienst, dem sie vertrauen. Es wird allgemein davon ausgegangen, dass dieses Szenario eine starke Attestierung darstellt; und
4. Cloud-Anbieter rufen Nachweise von TEEs ab, senden sie an einen Verifizierungsdienst unter ihrer Kontrolle und geben nur die Verifizierungsergebnisse an Cloud-Kunden zurück. Es wird allgemein davon ausgegangen, dass dieses Szenario eine schwache Attestierung liefert.

Korrespondierende Kriterien für Kunden

–

OPS-34 Container-Management - Richtlinien und Verfahren

Basiskriterien

OPS-34.01B

Richtlinien und Verfahren mit technischen und organisatorischen Maßnahmen zur Planung und Verwaltung von Containern werden gemäß SP-01 dokumentiert, kommuniziert und bereitgestellt. Diese Richtlinien und Verfahren enthalten Vorgaben für den gesamten Container-Lebenszyklus, die mindestens folgende Aspekte betreffen:

1. Image-Erstellung, -Test und -Validierung;
2. Image-Aufbewahrung und -Abruf;
3. Containerbereitstellung und -verwaltung;
4. Containerbetrieb; und
5. Außerbetriebnahme von Images und Containern.

OPS-34.02B

Die Richtlinien und Verfahren beschreiben Maßnahmen entlang des Lebenszyklus von Containern und adressieren mindestens folgende Aspekte:

1. Container werden nach einem dokumentierten Prozess inventarisiert (vgl. AM-02, AM-03, AM-09);
2. Der Bedarf an Malware-Schutz wird beurteilt und ggf. sichergestellt (vgl. OPS-05);
3. Die Protokollierung und Überwachung von Ereignissen erfolgt entlang des Container-Lebenszyklus und wird gemäß einem definierten Protokollierungsrahmenwerks durchgeführt (vgl. OPS-10, OPS-12);
4. Cloud-Kundendaten werden auf der Grundlage einer Risikobeurteilung getrennt (vgl. OPS-30);
5. Der Zugriff auf den Container-Host sollte gemäß einem Rollen- und Rechterahmenwerk und einer Richtlinie zur Verwaltung des Zugriffs und der Zugriffsberechtigungen erfolgen (vgl. IAM-01, IAM-06);
6. Auf Containern gespeicherte Daten und Daten im Transport sollten vom Anbieter soweit möglich gemäß der Verschlüsselungsrichtlinie (vgl. CRY-01) verschlüsselt werden;
7. Maßnahmen zur Gewährleistung der Netzsicherheit werden festgelegt. Dazu gehören beispielsweise Maßnahmen zur Detektion von Netzanomalien (vgl. COS-01 und COS-03) wie unerwartete Datenflüsse innerhalb des Netzes oder unerwünschte Zugriffsversuche;
8. Änderungen an Containern und Images erfolgen nach einem geregelten Prozess (vgl. DEV-03); und
9. Härtungsprozesse werden nach allgemeinen Branchenstandards durchgeführt, um sicherzustellen, dass keine unnötigen Systemdienste ausgeführt werden (vgl. PSS-11).

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

OPS-34.01AC

Darüber hinaus beschreiben die Richtlinien und Verfahren Maßnahmen entlang des Lebenszyklus von Containern, die mindestens folgende Aspekte adressieren:

1. Container-Images werden kryptographisch signiert und der Signaturschlüssel sicher gespeichert (vgl. CRY-10), um ihre Authentizität und Integrität sicherzustellen;

2. Das Containerverhalten wird mithilfe von Laufzeitsicherheitskontrollen überwacht und eingeschränkt; und
3. Softwareprodukte, die für die Bereitstellung von Container-Images verwendet werden, werden, soweit möglich, regelmäßig auf bekannte Schwachstellen oder schädliche Komponenten in Container-Images und Abhängigkeiten überprüft.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: OPS-34.01AC

Im Falle von Drittanbieter- und Open-Source-Softwareprodukten, die für die Bereitstellung von Container-Images verwendet werden, entsprechen die Scanverfahren den in DEV-14 definierten Richtlinien und Verfahren.

Korrespondierende Kriterien für Kunden

–

OPS-35 Containermanagement - Implementierung

Basiskriterien

OPS-35.01B

Der Cloud-Anbieter entwirft, implementiert und pflegt technische und organisatorische Maßnahmen zur Planung und Verwaltung von Containern entlang ihres Lebenszyklus gemäß den Container-Management-Richtlinien und -Verfahren (vgl. OPS-34).

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

–

Korrespondierende Kriterien für Kunden

–

5.7 Identitäts- und Berechtigungsmanagement (IAM)

Zielsetzung: Absichern der Autorisierung und Authentifizierung von Benutzern des Cloud-Anbieters (in der Regel privilegierte Benutzer) zur Verhinderung von unberechtigten Zugriffen

IAM-01 Richtlinie für Identitäten und Zugriffsberechtigungen

Basiskriterien

IAM-01.01B

Der Cloud-Anbieter dokumentiert, kommuniziert und stellt gemäß SP-01 zur Verfügung:

1. Ein Berechtigungsrahmenwerk auf der Grundlage rollenbasierter Zugriffskontrolle und der geschäftlichen sowie sicherheitsbezogenen Anforderungen des Cloud-Anbieters; und

2. Eine Richtlinie für die Verwaltung von Identitäten und Zugriffsberechtigungen für internes und externes Personal des Cloud-Anbieters sowie Systemkomponenten, die eine Rolle in automatisierten Autorisierungsprozessen des Cloud-Anbieters innehaben.

IAM-01.02B

Zum Zweck der geschäftlichen und sicherheitsbezogenen Anforderungen behandeln diese Dokumente mindestens die folgenden Aspekte:

1. Aspekte, die für Zugriffskontrollentscheidungen relevant sind;
2. Vergabe eindeutiger Benutzernamen;
3. Gewährung und Änderung von Identitäten und Zugriffsberechtigungen auf der Grundlage des 'Least-Privilege-Prinzips' und des 'Need-to-Know-Prinzips';
4. Anwendung eines rollenbasierten Mechanismus zur Vergabe von Zugriffsberechtigungen;
5. Definition der unterstützten Identitäts- und rollenbasierten Zugriffstypen, einschließlich einer Zuordnung von Zugriffskontrollparametern und für jeden Typ zu berücksichtigenden Rollen;
6. Funktionstrennung zwischen operativen und kontrollierenden Funktionen ('Segregation of Duties');
7. Vergabe und Überwachung privilegierter Zugriffsberechtigungen;
8. Genehmigung der Vergabe oder Änderung von Identitäten und Zugriffsberechtigungen durch autorisiertes Personal oder autorisierte Systemkomponenten bevor auf Cloud-Kundendaten, abgeleitete Cloud-Dienstdaten und Cloud-Anbieterdaten zugegriffen werden kann;
9. Regelmäßige Überprüfung zugewiesener Identitäten und Zugriffsberechtigungen;
10. Sperrung und Entzug von Identitäten oder Beschränkung des Zugriffs bei von Inaktivität;
11. Spezifische Maßnahmen für die Verwaltung von Identitäten, deren Verwendung auf Notfallwiederherstellung und ähnliche Szenarien beschränkt ist;
12. Zeitbasierter oder anlassbezogener Entzug bzw. Anpassung von Zugriffsberechtigungen bei Veränderungen des Aufgabengebiets;
13. Multi-Faktor-Authentisierung (MFA) für Cloud-Nutzer mit privilegierten Zugriffsberechtigungen;
14. Remote-Zugriff und Zugriff über geografische Grenzen hinweg;
15. Anforderungen an die Genehmigung und Dokumentation der Verwaltung von Identitäten und Zugriffsberechtigungen; und
16. Maßnahmen, die beim Erkennen einer potenziellen Kompromittierung einer Identität zu ergreifen sind, wie etwa das Deaktivieren und der Entzug der betroffenen Identitäten.

IAM-01.03B

Der Cloud-Anbieter ist in der Lage, für jede Identität in seinem Verantwortungsbereich eine Liste der aktuell gewährten Cloud-basierten Zugriffsberechtigungen zu erstellen.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

IAM-01.01AC

Zugriffsprotokolle werden mindestens jeden Monat überprüft, um Versuche unbefugten Zugriffs oder verdächtige Zugriffsmuster zu erkennen.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: IAM-01.01B

Externes Personal umfasst Freiberufler, Zeitarbeitnehmer, Lieferanten und Service-Organisationen mit Zugriff auf Systemkomponenten.

Anwendbar auf: IAM-01.02B

Systemkomponenten im Sinne des Kriteriums sind in OPS-26 definiert. Automatisierte Autorisierungsprozesse im Sinne dieses Basiskriterium betreffen Verfahren zur automatisierten Softwareauslieferung (Continuous Delivery) sowie zum automatisierten Provisionieren und Deprovisionieren von Identitäten und Zugriffsberechtigungen auf Basis genehmigter Anträge.

Für Container sollten Identitäten und Zugriffsberechtigungen nach einem geregelten Prozess verwaltet werden, insbesondere für automatisierte Autorisierungsprozesse in Container-Umgebungen.

Wenn ein Cloud-Anbieter alternative Zugriffsmethoden verwendet, bei denen es nicht möglich oder praktikabel ist, Identitäten zu sperren und zu entziehen (wie zeitlich begrenzte Zugriffsmethoden), ist die Beschränkung des Zugriffs auf eine Identität eine weitere Lösung für den Umgang mit Inaktivität, die dieses Unterkriterium erfüllt.

Anwendbar auf: IAM-01.01B, IAM-01.02B

Anforderungen an die physische Zutrittskontrolle gemäß der Richtlinie für Identitäten und Zugriffsberechtigungen werden in der Richtlinie zur physischen Zutrittskontrolle (vgl. PS-04) näher spezifiziert.

Wenn der Cloud-Anbieter föderierte Identitätsdienste anbietet, insbesondere wenn der Cloud-Anbieter diese Dienste als Cloud-Vermittler anbietet, sollten die in diesen Unterkriterien definierten Dokumente die Komplexität der jeweiligen Cloud-Dienstarchitektur berücksichtigen. Dies kann unter anderem die folgenden Aspekte umfassen:

1. Verwaltung der Trust Boundaries zwischen den verschiedenen Parteien, die am Authentisierungsprozess einer föderierten Identität beteiligt sind;
2. Weitergabe identitätsverwaltungsbezogener Ereignisse über alle Parteien hinweg, die am Authentisierungsprozess einer föderierten Identität beteiligt sind;
3. Protokollierung von Ereignissen im Zusammenhang mit dem Authentisierungsprozess einer föderierten Identität; und
4. Benachrichtigung von Cloud-Kunden im Fall, dass eine Föderationsberechtigung kompromittiert oder eine Trust Boundary verletzt wird.

Anwendbar auf: IAM-01.03B

Auf der Grundlage dieser Liste ist der Cloud-Anbieter in der Lage, die Cloud-basierten Zugriffsberechtigungen der betreffenden Identität zu überprüfen.

‘Cloud-basiert’ bezieht sich in diesem Fall auf alle Zugriffsberechtigungen, die in den Geltungsbereich des internen Kontrollsystems des Cloud-Anbieters fallen.

Anwendbar auf: IAM-01.01AC

Eine Überprüfung kann manuell oder auf automatisierte Weise durchgeführt werden. Bei einer monatlichen Überprüfung können verdächtige Verhaltensweisen wie z. B. Zugriffsfehler über einen längeren Zeitraum (z. B. einmal täglich) oder aufeinanderfolgende Anmeldungen aus verschiedenen Ländern sichtbar werden, die ein SIEM, das nur Anmeldeversuche in Echtzeit analysiert, möglicherweise übersieht.

Korrespondierende Kriterien für Kunden

–

IAM-02 Vergabe und Änderung von Identitäten und Zugriffsberechtigungen

Basiskriterien

IAM-02.01B

Geregelte Verfahren für die Vergabe und Änderung von Identitäten und Zugriffsberechtigungen für internes und externes Personal des Cloud-Anbieters sowie für Systemkomponenten, die eine Rolle in automatisierten Autorisierungsprozessen des Cloud-Anbieters innehaben, stellen die Einhaltung der Rollen- und Rechterichtlinien sowie der Richtlinie zur Verwaltung von Identitäten und Zugriffsberechtigungen sicher.

IAM-02.02B

Die vorgenannten Verfahren umfassen unter anderem:

1. Prozesse und technische Kontrollen, um den Zugriff auf die Daten und Systemfunktionen des Cloud-Anbieters auf autorisiertes Personal zu beschränken; und
2. Prozesse und technische Kontrollen zur Verwaltung und Überprüfung von Zugriffsberechtigungen innerhalb der Systeme des Cloud-Anbieters.

IAM-02.03B

Falls der Cloud-Anbieter Notfallkonten für den Fall einer Nichtverfügbarkeit des Hauptverfahrens zur Authentisierung definiert, werden spezifische Anforderungen und Verfahren für die sichere Nutzung dieser Konten definiert und umgesetzt.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: IAM-02.01B

Dieses Kriterium gilt für Identitäten, die sich auf einzelne, mehrere oder nicht-menschliche Entitäten beziehen.

Korrespondierende Kriterien für Kunden

–

IAM-03 Risikobasiertes Verfahren zur Sperrung und zum Entzug von Identitäten

Basiskriterien

IAM-03.01B

Der Cloud-Anbieter verfügt über ein risikobasiertes Verfahren zur Verwaltung von Identitäten (vgl. IAM-01), unter Berücksichtigung der Arten von Daten, auf die über die Identitäten des internen und externen Personals zugegriffen werden können.

IAM-03.02B

Im Rahmen dieses Verfahrens werden spezifische Parameter für das automatische Sperren und Entziehen von Zugriffen aufgrund von Inaktivität oder Hinweisen auf Brute-Force-Angriffe definiert, mit Ausnahmen für Identitäten, deren Verwendung auf Notfallwiederherstellung und ähnliche Szenarien beschränkt ist.

IAM-03.03B

Der Cloud-Anbieter dokumentiert und implementiert einen Prozess zur Überwachung gestohlener und kompromittierter Anmeldeinformationen, der auch die Deaktivierung jeder Identität umfasst, für die ein Problem festgestellt wird. Dieser Prozess wird für alle Identitäten im Verantwortungsbereich des Cloud-Anbieters umgesetzt, die privilegierte Zugriffsberechtigungen haben.

IAM-03.04B

Der vorgenannte Prozess umfasst einen Ausnahmemechanismus, der angewendet wird, wenn alle Identitäten, die zur Bewältigung der Situation benötigt werden, potenziell kompromittiert sind.

Zusatzkriterium (Verschärfend)

IAM-03.03AS, verschärft IAM-03.03B

Der Cloud-Anbieter dokumentiert und implementiert einen Prozess zur Überwachung gestohlener und kompromittierter Anmeldeinformationen, der auch die Deaktivierung jeder Identität umfasst, für die ein Problem festgestellt wird. Dieser Prozess wird für alle Identitäten im Verantwortungsbereich des Cloud-Anbieters umgesetzt.

Zusatzkriterium (Erweiternd)

IAM-03.01AC

Der Kontext von Authentisierungsversuchen wird überwacht und verdächtige Ereignisse werden, soweit relevant, autorisierten Personen gemeldet.

IAM-03.02AC

Die Wirksamkeit der Verfahren zur Sperrung und zum Entzug von Identitäten wird validiert.

IAM-03.03AC

Zeitnahe und angemessene Abhilfemaßnahmen beheben alle bei der Validierung festgestellten Abweichungen.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: IAM-03.01B, IAM-03.02B, IAM-03.03B, IAM-03.04B, IAM-03.03AS, IAM-03.01AC, IAM-03.02AC, IAM-03.03AC

Dieses Kriterium gilt für Identitäten, die sich auf einzelne, mehrere oder nicht-menschliche Entitäten beziehen.

Anwendbar auf: IAM-03.02B

Eine Sperrung kann aus einer längeren Abwesenheit des Personals resultieren, zum Beispiel aufgrund von Krankheit, Elternzeit oder Sabbatical. Mehrere fehlgeschlagene Anmeldeversuche können Hinweise auf Brute-Force-Angriffe sein.

Anwendbar auf: IAM-03.03B, IAM-03.03AS

Dieser Prozess kann automatisch oder manuell durch autorisiertes Personal durchgeführt werden.

Anwendbar auf: IAM-03.04B

Dieser Ausnahmemechanismus sollte als Teil des Systems für Business Continuity und Notfallmanagement (vgl. BCM-01) umgesetzt werden, da Fälle, in denen alle Identitäten, die zur Bewältigung der in IAM-03.03B beschriebenen Situation benötigt werden, potenziell kompromittiert sind, einen Notfall oder Krise darstellen können.

Anwendbar auf: IAM-03.01AC

Der Kontext eines Authentisierungsversuchs kann, muss aber nicht, IP-Adressen, das Datum und die Uhrzeit oder das verwendete Gerät umfassen.

Korrespondierende Kriterien für Kunden

–

IAM-04 Entzug oder Anpassung von Zugriffsberechtigungen bei Veränderungen des Aufgabengebiets

Basiskriterien

IAM-04.01B

Zugriffsberechtigungen werden bei Änderungen im Aufgabengebiet des internen und externen Personals des Cloud-Anbieters oder der Systemkomponenten, die eine Rolle in automatisierten Autorisierungsprozessen des Cloud-Anbieters innehaben, zeitnah angepasst oder entzogen.

IAM-04.02B

Privilegierte Zugriffsberechtigungen werden spätestens 48 Stunden nach Inkrafttreten der Änderung angepasst oder entzogen.

IAM-04.03B

Alle anderen Zugriffsberechtigungen werden spätestens nach 14 Tagen angepasst oder entzogen.

IAM-04.04B

Nach Entzug ist das Verfahren für die Vergabe von Identitäten und Zugriffsberechtigungen (vgl. IAM-02) erneut zu durchlaufen.

IAM-04.05B

In Fällen von Rollenwechseln, in denen möglicherweise vorübergehender Zugriff gewährt werden muss, werden diese Zugriffsberechtigungen genehmigt, zeitlich befristet und dokumentiert.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: IAM-04.01B, IAM-04.02B, IAM-04.03B, IAM-04.04B, IAM-04.05B

Dieses Kriterium gilt für Identitäten, die sich auf einzelne, mehrere oder nicht-menschliche Entitäten beziehen.

Anwendbar auf: IAM-04.01B

Auslöser von Änderungen des Aufgabengebiets von internem und externem Personal können Änderungen im Beschäftigungsverhältnis (z. B. Kündigung, Versetzung) oder in Verträgen und Vereinbarungen sein.

Anwendbar auf: IAM-04.02B

Für privilegierte Zugriffsberechtigungen gilt die Definition in IAM-06.

Korrespondierende Kriterien für Kunden

–

IAM-05 Regelmäßige Überprüfung von Zugriffsberechtigungen

Basiskriterien

IAM-05.01B

Identitäten und die zugehörigen Zugriffsberechtigungen des internen und externen Personals des Cloud-Anbieters sowie von Systemkomponenten, die eine Rolle in automatisierten Autorisierungsprozessen des Cloud-Anbieters innehaben, werden mindestens jährlich und bei wesentlichen Änderungen am Cloud-Dienst daraufhin überprüft, ob diese noch dem tatsächlichen Aufgaben- bzw. Einsatzgebiet entsprechen.

IAM-05.02B

Die Überprüfung erfolgt durch hierzu autorisierte Personen aus den Organisationseinheiten des Cloud-Anbieters, die aufgrund ihres Wissens über die Aufgabengebiete des Personals oder der Systemkomponenten die Angemessenheit der vergebenen Zugriffsberechtigungen beurteilen können.

IAM-05.03B

Identifizierte Abweichungen werden zeitnah, spätestens aber sieben Tage nach ihrer Feststellung durch geeignetes Ändern oder Entziehen der Zugriffsberechtigungen behandelt.

IAM-05.04B

Beim Entziehen von Identitäten stellt das System sicher, dass alle produktionszugehörigen Systemkomponenten (z. B. virtuelle Maschinen, Speicher, Zugriffsberechtigungen) identifiziert, neu zugewiesen oder gelöscht werden, um die Entstehung verwaister Ressourcen zu verhindern. Klare Prozesse und technische Kontrollen werden eingerichtet, um trotz präventiver Maßnahmen auftretende verwaiste Ressourcen zu identifizieren und zu behandeln und ihre rechtzeitige Neuzuweisung oder sichere Löschung sicherzustellen.

IAM-05.05B

Für Systemkomponenten, die nicht produktionszugehörig sind, entwirft, implementiert und pflegt der Cloud-Anbieter auf der Grundlage einer Risikobeurteilung (vgl. OIS-07) angemessene Kontrollen zur Verhinderung verwaister Ressourcen.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

IAM-05.01AC

Privilegierte Zugriffsberechtigungen werden mindestens alle sechs Monate sowie bei wesentlichen Änderungen am Cloud-Dienst überprüft.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: IAM-05.01B, IAM-05.02B, IAM-05.03B, IAM-05.04B, IAM-05.05B

Dieses Kriterium gilt für Identitäten, die sich auf einzelne, mehrere oder nicht-menschliche Entitäten beziehen. Als Alternative zu den regelmäßigen Überprüfungen von Zugriffsberechtigungen können auch zeitlich befristete Zugriffsberechtigungen vergeben werden, die automatisch ablaufen.

Anwendbar auf: IAM-05.01B, IAM-05.01AC

Wenn eine Überprüfung durch wesentliche Änderungen am Cloud-Dienst ausgelöst wird, müssen nur die von der Änderung betroffenen Identitäten und Zugriffsberechtigungen in die Überprüfung einbezogen werden.

Anwendbar auf: IAM-05.05B

Die hier gemeinten Systemkomponenten sind Systemkomponenten in Entwicklungs-, Test- oder anderen nicht-produktiven Umgebungen. Verwaiste Ressourcen sind Systemkomponenten, denen kein Eigentümer zugewiesen ist.

Korrespondierende Kriterien für Kunden

–

IAM-06 Privilegierte Zugriffsberechtigungen

Basiskriterien

IAM-06.01B

Privilegierte Zugriffsberechtigungen für internes und externes Personal sowie technische Cloud-Nutzer des Cloud-Anbieters werden in Übereinstimmung mit der Richtlinie zur Verwaltung von Identitäten und Zugriffsberechtigungen (vgl. IAM-01) oder einer separaten spezifischen Richtlinie vergeben und geändert.

IAM-06.02B

Privilegierte Zugriffsberechtigungen werden personalisiert sowie gemäß einer Risikobeurteilung zeitlich befristet und wie es für die Aufgabenwahrnehmung notwendig ist ('Need-to-Know-Prinzip') zugewiesen.

IAM-06.03B

Auf anonyme technische Cloud-Nutzer wird nur durch Authentisierung mit einer personalisierten Identität zugegriffen.

IAM-06.04B

Aktivitäten von Cloud-Nutzern mit privilegierten Zugriffsberechtigungen werden protokolliert, um in verdächtigen Fällen einen Missbrauch des privilegierten Zugriffs zu erkennen.

IAM-06.05B

Die protokollierten Informationen werden automatisch auf definierte Ereignisse überwacht, die auf Missbrauch hinweisen können.

IAM-06.06B

Wird ein solches Ereignis festgestellt, wird das verantwortliche Personal automatisch informiert, damit es zeitnah beurteilen kann, ob ein Missbrauch vorliegt, und entsprechende Maßnahmen ergreifen kann.

IAM-06.07B

Im Fall eines nachgewiesenen Missbrauchs privilegierter Zugriffsberechtigungen werden Disziplinarmaßnahmen gemäß HR-04 ergriffen.

IAM-06.08B

Für Container und Images werden Aktivitäten von Cloud-Nutzer mit privilegiertem Zugriff gemäß OPS-10 protokolliert.

IAM-06.09B

Der Zugriff auf die Administrationsschnittstellen des Cloud-Anbieters erfordert die Verwendung von Multi-Faktor-Authentisierung.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

IAM-06.01AC

Der Cloud-Anbieter führt eine Liste der Identitäten mit privilegierten Zugriffsberechtigungen in seinem Verantwortungsbereich. Diese Liste wird aktuell gehalten.

IAM-06.02AC

Der Cloud-Anbieter führt eine Liste des Personals, das für eine Identität verantwortlich ist, die einer nicht-menschlichen Entität innerhalb des Verantwortungsbereichs des Cloud-Anbieters zugewiesen ist. Diese Liste wird alle sechs Monate und bei wesentlichen Änderungen am Cloud-Dienst überprüft.

IAM-06.03AC

Für privilegierte Cloud-Nutzer werden phishing-resistente Multi-Faktor-Authentisierungen wie FIDO2-Sicherheitsschlüssel oder vergleichbare Mechanismen unter Verwendung von Public-Key-Kryptographie und Domain-Bindung implementiert.

IAM-06.04AC

Privilegierte Zugriffsberechtigungen werden durch eine Privileged-Access-Management-(PAM)-Lösung mit Unterstützung für 'Just-in-Time'-Erhöhung des Zugriffsrechts und 'Just-enough'-Zugriff durchgesetzt.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: IAM-06.01B, IAM-06.02B, IAM-06.03B, IAM-06.04B, IAM-06.05B, IAM-06.06B, IAM-06.07B, IAM-06.08B, IAM-06.09B, IAM-06.01AC, IAM-06.02AC, IAM-06.03AC, IAM-06.04AC

Privilegierte Zugriffsberechtigungen im Sinne des Kriteriums sind diejenigen, welche das Personal des Cloud-Anbieters dazu befähigen, eine der folgenden Tätigkeiten auszuführen:

1. Lesenden oder schreibenden Zugriff auf die im Cloud-Dienst verarbeiteten, gespeicherten oder übertragenen Cloud-Kundendaten, soweit diese nicht verschlüsselt sind oder die Verschlüsselung für den Zugriff durch den Cloud-Anbieter aufgehoben werden kann; und
2. Änderungen an der betrieblichen und/oder sicherheitstechnischen Konfiguration der Systemkomponenten in der Produktionsumgebung, insbesondere das Starten, Stoppen, Löschen oder Deaktivieren von Systemkomponenten, wenn dies die Vertraulichkeit, Integrität oder Verfügbarkeit der Cloud-Kundendaten beeinträchtigen kann (auch mittelbar, z. B. durch Deaktivieren der Protokollierung und Überwachung sicherheitsrelevanter Ereignisse).

Anwendbar auf: IAM-06.06B

Verantwortliches Personal für Ereignisse, die auf Missbrauch hindeuten können, kann z. B. das Personal des Security Operations Centre des Cloud-Anbieters sein.

Missbräuchlich genutzte privilegierte Zugriffsberechtigungen können z. B. als Sicherheitsvorfall behandelt werden, vgl. SIM-01.

Anwendbar auf: IAM-06.02AC

Wenn eine Überprüfung durch wesentliche Änderungen am Cloud-Dienst ausgelöst wird, müssen nur die von der Änderung betroffenen Teile der Liste in die Überprüfung einbezogen werden.

Korrespondierende Kriterien für Kunden

–

IAM-07 Zugriff auf Cloud-Kundendaten

Basiskriterien

IAM-07.01B

Der Cloud-Anbieter implementiert Maßnahmen für Trennungsmechanismen, die:

1. Hinreichend sind, um die Systemkomponenten zur Bereitstellung des Cloud-Dienstes von den Systemkomponenten der anderen Informationssysteme des Cloud-Anbieters zu trennen; und
2. Geeignet sind, unterschiedliche Cloud-Kunden voneinander zu trennen (vgl. OPS-30 und OPS-31).

IAM-07.02B

Die Maßnahmen für Trennungsmechanismen des Cloud-Anbieters stellen sicher, dass Sicherheitsvorfälle, sofern sie die Systemkomponenten kompromittieren, die die Cloud-Kundendaten speichern, nicht auch die Systemkomponenten kompromittieren, die den Zugriff darauf verwalten.

IAM-07.03B

Sofern dies nicht durch anwendbares Recht verboten ist, wird der Cloud-Kunde durch den Cloud-Anbieter über Ereignisse informiert, bei denen internes oder externes Personal des Cloud-Anbieters, ohne vorherige Zustimmung des Cloud-Kunden, lesend oder schreibend auf die im Cloud-Dienst verarbeiteten, gespeicherten oder übertragenen Daten der Cloud-Kunden zugreifen werden oder zugegriffen haben. Die Information erfolgt je Ereignis, soweit auf die Cloud-Kundendaten in unverschlüsselter Form zugegriffen wird/wurde oder die vertraglichen Vereinbarungen eine solche Information nicht explizit ausschließen.

IAM-07.04B

Sofern vertraglich nichts anderes vereinbart ist, gehen aus der Information Anlass, Zeitpunkt, Dauer, geografischer Ort, Art und Umfang des Zugriffs, sowie die Aufbewahrungsdauer anderer während des Zugriffs erzeugter Daten, wie Protokolle oder Kopien, die Cloud-Kundendaten enthalten, hervor. Die Informationen sind hinreichend detailliert, um sachverständigen Personen des Cloud-Kunden eine Risikobeurteilung des Zugriffs zu ermöglichen. Die Information erfolgt gemäß der vertraglichen Vereinbarung, spätestens aber 72 Stunden nach dem Zugriff.

IAM-07.05B

Die Information wird gemäß den vertraglichen Vereinbarungen, jedoch spätestens 72 Stunden ab Einleitung des Zugriffs bereitgestellt.

IAM-07.06B

Der Cloud-Anbieter legt durch vertragliche Vereinbarungen und vor dem Anbieten seiner Dienste alle Fälle offen, in denen der Cloud-Anbieter auf Cloud-Kundendaten in unverschlüsselter Form zugreifen kann, während diese im Cloud-Dienst verarbeitet, gespeichert oder übertragen werden.

Zusatzkriterium (Verschärfend)

IAM-07.03AS, verschärft IAM-07.03B

Zugriffe auf Cloud-Kundendaten und abgeleitete Cloud-Dienstdaten durch internes oder externes Personal des Cloud-Anbieters bedürfen der vorherigen Zustimmung durch autorisiertes Personal des Cloud-Kunden, soweit die Daten des Cloud-Kunden in unverschlüsselter Form zugänglich sind oder die vertraglichen Vereinbarungen eine solche Zustimmung nicht explizit ausschließen. Wenn verschlüsselte Daten und ihr Entschlüsselungsschlüssel innerhalb derselben Cloud-Umgebung getrennt gespeichert werden, ist außerdem eine vorherige Zustimmung nicht nur für den Zugriff auf den Entschlüsselungsschlüssel erforderlich, sondern auch für den Zugriff auf die verschlüsselten Daten selbst (möglicherweise zusammen mit dem Schlüssel).

IAM-07.04AS, verschärft IAM-07.04B

Sofern vertraglich nichts anderes vereinbart ist, enthält die für die Zustimmung bereitgestellte Information die Ursache, den Zeitpunkt, die Dauer, den geografischen Ort, die Art und den Umfang des Zugriffs sowie die Aufbewahrungsdauer anderer während des Zugriffs erzeugter Daten, wie Protokolle oder Kopien, die Cloud-Kundendaten enthalten. Die Information ist hinreichend detailliert, um Fachexperten des Cloud-Kunden in die Lage zu versetzen, die Risiken des Zugriffs zu bewerten. Zusätzlich zu den bereitgestellten Informationen legt der Cloud-Anbieter einen Zeitrahmen fest, innerhalb dessen der Cloud-Kunde auf die Zugriffsanfrage reagieren soll.

IAM-07.06AS, verschärft IAM-07.06B

Der Cloud-Anbieter legt durch vertragliche Vereinbarungen und vor dem Anbieten seiner Dienste alle Fälle offen, in denen der Cloud-Anbieter auf Cloud-Kundendaten oder abgeleitete Cloud-Dienstdaten in unverschlüsselter Form zugreifen kann, während diese im Cloud-Dienst verarbeitet, gespeichert oder übertragen werden.

Zusatzkriterium (Erweiternd)

IAM-07.01AC

Falls der Cloud-Anbieter möglicherweise auf die im Cloud-Dienst übertragenen, verarbeiteten oder gespeicherten Cloud-Kundendaten in unverschlüsselter Form zugreifen könnte, nimmt der Cloud-Anbieter durch vertragliche Vereinbarungen Regelungen für Fälle auf, in denen es nicht praktikabel ist, vor einem solchen Zugriff eine vorherige Zustimmung einzuholen.

IAM-07.02AC

Um direkt oder indirekt auf Cloud-Kundendaten zugreifen zu können, muss jegliches internes oder externes Personal des Cloud-Anbieters eine angemessene Überprüfung bestanden haben oder andernfalls durch Personal beaufsichtigt werden, das eine angemessene Überprüfung bestanden hat (vgl. HR-01). Der Cloud-Anbieter verifiziert, dass eine dieser Bedingungen erfüllt ist, bevor der Zugriff gewährt wird. Dies gilt auch für Supporttätigkeiten.

IAM-07.03AC

Falls der durchgeführte Zugriff beaufsichtigt wird, stellt der Cloud-Anbieter sicher, dass:

1. Die Mechanismen, die zur Durchführung des beaufsichtigten Zugriffs verwendet werden, es dem beaufsichtigenden Personal erlauben, einzelne Aktionen der beaufsichtigten Person zu genehmigen oder abzulehnen und in Echtzeit Erklärungen zu verlangen;
2. Alle Zugriffsberechtigungen, die im Rahmen des beaufsichtigten Zugriffs gewährt werden, am Ende des Vorgangs widerrufen werden;
3. Alle Vorgänge, die im Rahmen des beaufsichtigten Zugriffs durchgeführt werden, als Administrationsaktionen protokolliert werden;
4. Die beaufsichtigte Person und das Gerät, das zur Durchführung des beaufsichtigten Zugriffs verwendet wird, durch die Aufsichtslösung authentisiert werden;
5. Die Vorgänge, die die beaufsichtigte Person vorschlägt, und die Handlungen des beaufsichtigenden Personals von der Aufsichtslösung protokolliert werden, einschließlich Vorgängen, die abgelehnt wurden; und
6. Informationsflüsse in Richtung des Geräts der beaufsichtigten Person durch die Aufsichtslösung verhindert werden.

IAM-07.04AC

Falls dem Cloud-Kunden im Rahmen des Cloud-Dienstes Zugriff auf Schnittstellen für Administratoren und für Cloud-Nutzer gegeben wird, trennt der Cloud-Anbieter diese Schnittstellen voneinander und stellt

sicher, dass sich die Zugriffspfade für Administratoren der Cloud-Kunden von denen für Cloud-Nutzer unterscheiden.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: IAM-07.01AC

Dieses Unterkriterium ist nur anwendbar, wenn auch Unterkriterium IAM-07.03S angewendet wird.

Die Einholung einer vorherigen Zustimmung könnte zum Beispiel dann nicht praktikabel sein, wenn der Cloud-Dienst zur Wahrung der Vertraulichkeit, Integrität und Verfügbarkeit der Cloud-Kundendaten auf Fehler hin analysiert werden muss.

Anwendbar auf: IAM-07.04B, IAM-07.04AS

Sachverständige Personen im Sinne dieses Kriteriums sind Personen aus z. B. IT, Compliance oder Interne Revision.

Anwendbar auf: IAM-07.03B, IAM-07.04B, IAM-07.05B, IAM-07.06B, IAM-07.03AS, IAM-07.04AS, IAM-07.01AC, IAM-07.02AC, IAM-07.03AC

Der Zugriff auf Cloud-Kundendaten umfasst auch die Offenlegung von Daten im Rahmen von Untersuchungsanfragen gemäß INQ-03. Diese sind den Cloud-Kunden mitzuteilen, soweit dies rechtlich nicht verboten ist.

Das Kriterium zielt darauf ab, die Fähigkeit des Cloud-Anbieters zum Zugriff auf Cloud-Kundendaten zu minimieren. Die Minimierung der Möglichkeit des Cloud-Anbieters, auf Cloud-Kundendaten zuzugreifen, ist oft eine Frage des Radius des Kollusionskreises. Wenn beispielsweise das Vier-Augen-Prinzip für den Zugriff angewendet wird und der Zugriff protokolliert wird, dann bilden drei Personen den Kollusionskreis. Um Vertrauen in solche Zugriffsaussagen aufzubauen, sollte der Cloud-Anbieter in der Systembeschreibung die Maßnahmen beschreiben, die zur Vergrößerung des Kollusionskreises ergriffen wurden.

Anwendbar auf: IAM-07.04B, IAM-07.04AS

Der dem Cloud-Kunden bereitgestellte geografische Ort des Zugriffs muss kein GPS-Standort sein, sollte aber mindestens so präzise sein wie das Land, von dem aus der Zugriff durchgeführt wurde oder durchgeführt werden soll.

Anwendbar auf: IAM-07.02AC, IAM-07.03AC

Der Cloud-Anbieter sollte Details dazu, wie der beaufsichtigte Zugriff durchgeführt wird, für Cloud-Kunden zugänglich machen.

Anwendbar auf: IAM-07.04AC

Die Trennung sollte so entworfen und umgesetzt werden, dass Administratoren von Cloud-Kunden auf den Cloud-Dienst zugreifen können, selbst wenn die Schnittstellen der Cloud-Nutzer nicht verfügbar sind.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass ihre Verträge mit dem Cloud-Anbieter eine umfassende Liste aller Fälle enthalten, in denen der Cloud-Anbieter auf Cloud-Kundendaten in unverschlüsselter Form zugreifen könnte. Cloud-Kunden verifizieren, dass diese Bedingungen gründlich dokumentiert sind, bevor sie die Dienste in Anspruch nehmen, damit sie informierte Entscheidungen über Datensicherheit und Compliance treffen können.

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass sie innerhalb eines in den vertraglichen Vereinbarungen festgelegten Zeitrahmens eine Antwort auf Datenzugriffsanfragen des Cloud-Anbieters bereitstellen.

IAM-08 Authentisierungsmechanismen

Basiskriterien

IAM-08.01B

Systemkomponenten im Verantwortungsbereich des Cloud-Anbieters, die für die Bereitstellung des Cloud-Dienstes verwendet werden, authentifizieren Cloud-Nutzer des internen und externen Personals des Cloud-Anbieters sowie der Systemkomponenten, die eine Rolle in automatisierten Autorisierungsprozessen des Cloud-Anbieters innehaben.

IAM-08.02B

Der Cloud-Anbieter setzt Multi-Faktor-Authentisierung für jeden Zugriff auf die Produktionsumgebung durch. Diese Anforderung gilt sowohl für menschliche Cloud-Nutzer als auch für automatisierte Prozesse und stellt sicher, dass nur autorisierte Entitäten auf Systeme und Daten in der Produktionsumgebung zugreifen können.

IAM-08.03B

Innerhalb der Produktionsumgebung erfolgt die Authentisierung der Cloud-Nutzer durch Passwörter, digital signierte Zertifikate oder Verfahren, die mindestens ein gleichwertiges Sicherheitsniveau erreichen. Wenn digital signierte Zertifikate verwendet werden, erfolgt die Administration in Übereinstimmung mit den Richtlinien und Verfahren für den Einsatz kryptographischer Mechanismen (vgl. CRY-01).

IAM-08.04B

Die Authentisierungsvorgaben werden aus einer Risikobeurteilung abgeleitet und in einer Authentisierungsrichtlinie gemäß SP-01 dokumentiert, kommuniziert und bereitgestellt. Die Einhaltung der Vorgaben wird durch die Konfiguration der Systemkomponenten erzwungen, soweit dies technisch möglich ist. Die Authentisierungsrichtlinie beschreibt mindestens die folgenden Aspekte:

1. Die Auswahl geeigneter Mechanismen für jedes Risikoniveau und jeden Identitätstyp;
2. Den Schutz der Anmeldeinformationen, die die Authentisierungsmechanismen verwenden, einschließlich der Vertraulichkeit persönlicher oder geteilter Authentisierungsinformationen und der Nichtweitergabe von Anmeldeinformationen;
3. Die Erzeugung und Verteilung von Anmeldeinformationen für jede neue Identität;
4. Die Nichtwiederverwendung von Anmeldeinformationen;
5. Regeln zur Speicherung von Anmeldeinformationen;
6. Regeln für die Erneuerung von Anmeldeinformationen, einschließlich regelmäßiger Erneuerungen und Erneuerungen für den Fall, dass eine Anmeldeinformation verloren geht oder kompromittiert wird; und
7. Regeln zur erforderlichen Stärke von Anmeldeinformationen, einschließlich Abwägungen zwischen Entropie und Merkfähigkeit, wo anwendbar, sowie Mechanismen zur Kommunikation und Durchsetzung dieser Regeln.

IAM-08.05B

Der Cloud-Anbieter bestimmt mittels einer Risikobeurteilung (vgl. OIS-07) das Risiko, dass die in die Systemkomponenten unter seiner Verantwortung integrierten Authentisierungsmechanismen, die zur Bereitstellung des Cloud-Dienstes verwendet werden, veralten. Auf der Grundlage der Ergebnisse der Risikobeurteilung implementiert der Cloud-Anbieter angemessene Maßnahmen zum Austausch veralteter Authentisierungsmechanismen oder der Systemkomponenten, in die sie integriert sind.

IAM-08.06B

Jeder in die zur Bereitstellung des Cloud-Dienstes verwendeten Systemkomponenten integrierte Authentisierungsmechanismus verfügt über einen Mechanismus zur Deaktivierung einer Identität nach einer vordefinierten Anzahl erfolgloser Authentisierungsversuche.

IAM-08.07B

Der Cloud-Anbieter implementiert Maßnahmen, die verlangen, dass Cloud-Nutzer nur dann auf nicht-personenbezogene Identitäten, die mehreren Personen zugewiesen sind, zugreifen können, nachdem sie bereits mit ihrer einer einzelnen Person zugewiesenen Identität authentisiert wurden.

Zusatzkriterium (Verschärfend)

IAM-08.02AS, verschärft IAM-08.02B

Der Cloud-Anbieter setzt Multi-Faktor-Authentisierung für jeden Zugriff auf jede Umgebung durch. Diese Anforderung gilt sowohl für menschliche Cloud-Nutzer als auch für automatisierte Prozesse und stellt sicher, dass nur autorisierte Entitäten in allen Umgebungen auf Systeme und Daten zugreifen können.

IAM-08.03AS, verschärft IAM-08.03B

Innerhalb einer Umgebung erfolgt die Authentisierung der Cloud-Nutzer durch Passwörter, digital signierte Zertifikate oder Verfahren, die mindestens ein gleichwertiges Sicherheitsniveau erreichen. Wenn digital signierte Zertifikate verwendet werden, erfolgt die Administration in Übereinstimmung mit den Richtlinien und Verfahren für den Einsatz kryptographischer Mechanismen (vgl. CRY-01).

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: IAM-08.02B

Multi-Faktor-Authentisierung bedeutet, dass verschiedene Quellen zur Identitätsprüfung verwendet werden. Dies gilt sowohl für menschliche Cloud-Nutzer als auch für automatisierte Prozesse. Menschliche Cloud-Nutzer können verschiedene Faktoren wie ein Passwort und ein Hardware-Token verwenden. Multi-Faktor-Authentisierung für automatisierte Prozesse bedeutet die Verwendung unabhängiger Quellen zur Identitätsprüfung wie z. B. kryptographischer Schlüssel und eines Kurzzeit-Tokens aus einer anderen Quelle.

Anwendbar auf: IAM-08.02AS, IAM-08.03AS

Diese Umgebungen umfassen Produktions-, Entwicklungs-, Test- und Staging-Umgebungen.

Korrespondierende Kriterien für Kunden

–

IAM-09 Vertraulichkeit von Authentisierungsinformationen

Basiskriterien

IAM-09.01B

Die Zuweisung von Authentisierungsinformationen für den Zugriff auf Systemkomponenten, die zur Bereitstellung des Cloud-Dienstes für interne und externe Cloud-Nutzer des Cloud-Anbieters sowie für Systemkomponenten verwendet werden, die an automatisierten Autorisierungsprozessen des Cloud-Anbieters beteiligt sind, erfolgt in geordneter Weise, die die Vertraulichkeit der Informationen sicherstellt.

IAM-09.02B

Authentisierungsnachweise werden mit einem Sicherheitsniveau verwaltet, das der Klassifizierung der Systemkomponente, die sie schützen, entspricht oder diese übertrifft.

IAM-09.03B

Soweit Passwörter als Authentisierungsinformationen eingesetzt werden, ist deren Vertraulichkeit durch folgende Verfahren sichergestellt, soweit dies technisch möglich ist:

1. Cloud-Nutzer können das Passwort initial selbst erstellen oder müssen ein initial vorgegebenes Passwort bei der ersten Anmeldung an der Systemkomponente ändern. Ein initial vorgegebenes Passwort verliert nach maximal 14 Tagen seine Gültigkeit;
2. Beim Erstellen von Passwörtern wird das Einhalten der Authentisierungsrichtlinie (vgl. IAM-08) erzwungen, soweit dies technisch möglich ist;
3. Der Cloud-Nutzer wird über das Ändern oder Zurücksetzen des Passworts informiert; und
4. Die serverseitige Speicherung erfolgt unter Verwendung kryptographischer Hashfunktionen nach dem Stand der Technik, mit Ausnahme von Passwörtern, die zur späteren Verwendung in Klartextform gespeichert werden, beispielsweise in einem Passwortmanager. In diesem Fall werden kryptographische Mechanismen nach dem Stand der Technik verwendet, um die Passwörter zu schützen.

IAM-09.04B

Abweichungen werden mittels einer Risikobeurteilung gemäß OIS-07 bewertet und daraus abgeleitete mindernde Maßnahmen werden umgesetzt.

IAM-09.05B

Regeln und Empfehlungen für die Verwaltung von Anmeldeinformationen in Übereinstimmung mit der Authentisierungsrichtlinie (vgl. IAM-08) werden dokumentiert, kommuniziert und allen Cloud-Nutzern im Verantwortungsbereich des Cloud-Anbieters zur Verfügung gestellt. Sie umfassen Empfehlungen zu Passwortmanagern und Empfehlungen, um insbesondere klassische Angriffe wie Phishing, Social Attacks und Whaling zu adressieren.

IAM-09.06B

Verwendete kryptographische Mechanismen entsprechen den Richtlinien und Anweisungen für kryptographische Mechanismen (vgl. CRY-01).

IAM-09.07B

Passwort-Zurücksetzungsverfahren sind höchstens 24 Stunden gültig. Nachdem das Zurücksetzungsverfahren verwendet wurde, ist das Passwort durch den Cloud-Nutzer zu ändern.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

IAM-09.01AC

Die Cloud-Nutzer bestätigen in einer Erklärung, dass sie persönliche (bzw. geteilte) Authentisierungsinformationen vertraulich behandeln und ausschließlich für sich (bzw. innerhalb der Gruppe) behalten.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: IAM-09.01B, IAM-09.02B, IAM-09.03B, IAM-09.01AC

Authentisierungsinformationen im Sinne des Basiskriteriums sind Cloud-Anbieterdaten.

Anwendbar auf: IAM-09.07B

Dieses Unterkriterium ist nur auf passwortbasierte Authentisierungsschemata anwendbar.

Anwendbar auf: IAM-09.01AC

Soweit dies rechtsverbindlich ist, können Erklärungen unter Verwendung einer elektronischen Signatur unterzeichnet werden.

Korrespondierende Kriterien für Kunden

–

5.8 Kryptographie und Schlüsselmanagement (CRY)

Zielsetzung: Sicherstellen eines angemessenen und wirksamen Gebrauchs von Kryptographie zum Schutz der Vertraulichkeit, Authentizität oder Integrität von Information.

CRY-01 Richtlinie für die Verwendung kryptographischer Mechanismen

Basiskriterien

CRY-01.01B

Richtlinien und Verfahren mit prozessualen und technischen Sicherheitsmaßnahmen für kryptographische Mechanismen sind gemäß SP-01 dokumentiert, kommuniziert und bereitgestellt, in denen die folgenden Aspekte beschrieben sind:

1. Verwendung von Verschlüsselungsverfahren und sicheren Netzprotokollen, die dem Stand der Technik entsprechen;
2. Verwendung von Hash-Funktionen und Salt-Werten, die beide dem Stand der Technik entsprechen;
3. Verwendung von Signaturschemata, die dem Stand der Technik entsprechen;
4. Risikobasierte Vorschriften für den Einsatz von Verschlüsselung und Authentisierung, die mit Schemata zur Informationsklassifikation (vgl. AM-09) abgeglichen sind und den Kommunikationskanal sowie die Art, Stärke und Qualität der Verschlüsselung berücksichtigen;
5. Anforderungen an die sichere Erzeugung, Speicherung, Archivierung, Abruf, Verteilung, Zurückziehung, Sicherung, Wiederherstellung und Löschung der Schlüssel;
6. Anforderungen an die Rotation kryptographischer Schlüssel, die den Best Practices der Branche folgen und das potenzielle Risiko einer Offenlegung von Informationen berücksichtigen;
7. Berücksichtigung der relevanten rechtlichen und regulatorischen Verpflichtungen und Anforderungen;
8. Dokumentation eines Änderungsmanagementprozesses zur Steuerung von Änderungen an kryptographischen, Verschlüsselungs-, Authentisierungs- und Schlüsselmanagementtechnologien; und
9. Berücksichtigung von Kryptoagilität, um einen effizienten Austausch implementierter kryptographischer Mechanismen während ihrer vorgesehenen Lebensdauer zu ermöglichen.

CRY-01.02B

Überprüfungen von Richtlinien und Verfahren bezüglich kryptographischer Mechanismen umfassen Prüfungen, dass die Richtlinien und Verfahren aktuell sind und der Technischen Richtlinie des BSI (BSI TR-

02102) oder geeigneten NIST-Richtlinien (z. B. FIPS-140-Reihe und SP-800-Reihe) entsprechen. Abweichungen werden in einer Risikobewertung für zum jeweiligen Zeitpunkt gültigen kryptographischen Mechanismen analysiert und dokumentiert. Maßnahmen zur Abhilfe sind risikobasiert zu ergreifen.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

CRY-01.01AC

Der Cloud-Anbieter hat gemäß SP-01 eine Post-Quanten-Kryptographie-(PQC)-Strategie definiert und dokumentiert, um Bedrohungen zu begegnen, die von Gegnern ausgehen, die im Besitz eines Quantencomputers sind.

CRY-01.02AC

Die PQC-Strategie des Cloud-Anbieters ist mit den Kryptographie-Richtlinien und -Verfahren abgestimmt und umfasst die folgenden Aspekte:

1. Pflege eines Verzeichnisses der verwendeten kryptographischen Mechanismen, einschließlich Prioritätsstufen für jeden Verzeichniseintrag auf Grundlage der Auswirkungen und Wahrscheinlichkeiten der durch Quantencomputing-Angriffe verursachten Risiken sowie des Aufwands zur Behebung solcher Risiken;
2. Sich über Verschlüsselungsmaßnahmen informiert zu halten, die als Stand der Technik und als sicher gegen Gegner gelten, die im Besitz eines Quantencomputers sind;
3. Verwendung hybrider Kryptographiemodelle, um Sicherheit sowohl gegen auf Quantencomputing als auch gegen nicht auf Quantencomputing basierende Angriffe zu gewährleisten; und
4. Definition von auslösenden Ereignissen, erforderlichen Ressourcen, Übergangsplänen und Erfolgskriterien für die Implementierung post-quantenkryptographischer Mechanismen.

CRY-01.03AC

Die PQC-Strategie, einschließlich des Verzeichnisses und der Risikobeurteilung, wird mindestens jährlich oder bei wesentlichen Änderungen, die sich auf die PQC-Strategie auswirken, überprüft.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: CRY-01.01B, CRY-01.02B, CRY-01.01AC, CRY-01.02AC

Die folgenden Technischen Richtlinien (in der jeweils aktuellen Fassung) enthalten Empfehlungen und Schlüssellängen für kryptographische Mechanismen nach dem Stand der Technik:

1. BSI TR-02102-1 Kryptographische Verfahren: Empfehlungen und Schlüssellängen;
2. BSI TR-02102-2 Kryptographische Verfahren: Empfehlungen und Schlüssellängen – Verwendung von Transport Layer Security (TLS);
3. BSI TR-02102-3 Kryptographische Verfahren: Empfehlungen und Schlüssellängen – Verwendung von Internet Protocol Security (IPSec) und Internet Key Exchange (IKEv2); und
4. BSI TR-02102-4 Kryptographische Verfahren: Empfehlungen und Schlüssellängen – Verwendung von Secure Shell (SSH).

Ein Änderungsmanagementprozess im Sinne des Basiskriteriums kann entweder durch den in DEV-03 beschriebenen Standard-Änderungsmanagementprozess abgedeckt oder als separater Prozess umgesetzt werden.

Anwendbar auf: CRY-01.01B

Kryptoagilität bezieht sich auf die Fähigkeit, die verwendeten kryptographischen Mechanismen oder die Implementierung solcher Mechanismen zu ändern, z. B. so, dass ein Wechsel zu größeren Schlüssellängen und stärkeren kryptographischen Mechanismen möglich ist. Für weitere Informationen wird auf BSI TR-02102-1 verwiesen.

Anwendbar auf: CRY-01.01AC, CRY-01.02AC, CRY-01.03AC

Empfehlungen für die Migration zu PQC und die zukunftssichere Nutzung von Kryptographie werden beispielsweise bereitgestellt in:

1. der BSI-Leitlinie 'Kryptografie quantensicher gestalten - Grundlagen, Entwicklungen, Empfehlungen';
2. der von der Europäischen Kommission veröffentlichten Roadmap 'Ein koordinierter Implementierungsfahrplan für den Übergang zur Post-Quantum-Kryptographie'; und
3. den vorläufigen Entwürfen für die NIST-Veröffentlichung 'NIST SP 1800-38: NIST SP 1800-38: Migration to Post-Quantum Cryptography: Preparation for Considering the Implementation and Adoption of Quantum Safe Cryptography' (ausschließlich in englischer Sprache verfügbar).

Anwendbar auf: CRY-01.02AC

Hybride Kryptographiemodelle, wie sie im Kontext der Post-Quanten-Kryptographie definiert sind, kombinieren klassische und quantensichere Mechanismen, um sicherzustellen, dass das System auch dann sicher bleibt, wenn eine Komponente kompromittiert wird. Der Zweck solcher Modelle besteht darin, langfristigen Schutz vor Bedrohungen wie 'store now, decrypt later' (jetzt speichern, später entschlüsseln) und anderen auf klassischem oder Quantencomputing basierenden Angriffen zu bieten.

Anwendbar auf: CRY-01.03AC

Die Risikobeurteilung als Teil der Post-Quanten-Kryptographie-Strategie sollte Folgendes berücksichtigen:

1. die Bedrohungslandschaft, die durch Fortschritte im Quantencomputing entsteht;
2. Fortschritte bei kryptographischen Mechanismen, die als sicher gegen Angreifer angesehen werden, die im Besitz eines Quantencomputers sind;
3. dem kryptographischen Mechanismus innewohnende Schwachstellen; und
4. Schwachstellen, die sich daraus ergeben, wie kryptographische Mechanismen eingesetzt werden (z. B. Schlüssel, die über einen längeren Zeitraum verwendet werden und die durch diese Schlüssel geschützten Cloud-Dienstdaten, abgeleitete Cloud-Dienstdaten, Cloud-Kundendaten und Kontodaten könnten bereits heute abgegriffen und zu einem späteren Zeitpunkt entschlüsselt werden).

Korrespondierende Kriterien für Kunden

–

CRY-02 Kryptographisches Änderungsmanagement

Basiskriterien

CRY-02.01B

Bei der Umsetzung von Änderungen an kryptographischen Systemen führt der Cloud-Anbieter eine Bewertung ihrer potenziellen Auswirkungen gemäß DEV-06 durch. Dieser Prozess umfasst eine Analyse der Cloud-Infrastruktur des Cloud-Dienstes sowie eine Analyse potenzieller Störungen von vom Cloud-Kunden verwalteten Workloads und die Bewertung von Restrisiken, Kostenauswirkungen und Integrationsvorteilen. Der Cloud-Anbieter informiert Cloud-Kunden über diese nachgelagerten Auswirkungen, um unvorhergesehene Ausfälle innerhalb der spezifischen kryptographischen Implementierungen des Cloud-Kunden zu verhindern.

CRY-02.02B

Alle Änderungen und Anpassungen an kryptographischen Systemen sind dokumentiert und nachvollziehbar.

CRY-02.03B

Das für kryptographische Systeme verantwortliche Personal wird regelmäßig geschult und über entsprechende Änderungen informiert.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: CRY-02.01B

Bei der Bewertung der potenziellen Auswirkungen von Änderungen sollte der Cloud-Anbieter die Komplexität der verteilten Architektur seines Cloud-Dienstes berücksichtigen.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass sie, falls sie vom Cloud-Anbieter über Änderungen an kryptographischen Systemen informiert werden, sich aktiv an einer gründlichen Bewertung der potenziellen Auswirkungen auf ihre Nutzung des Cloud-Dienstes beteiligen.

CRY-03 Überprüfung kryptographischer Verfahren

Basiskriterien

CRY-03.01B

Der Cloud-Anbieter stellt sicher, dass Verschlüsselungs-, Authentisierungs- und Schlüsselmanagementverfahrenn gemäß COM-02 und COM-03 regelmäßig auditiert werden, um potenzielle Schwachstellen zu identifizieren und zu beheben. Mindestens werden Überprüfungen jährlich und unmittelbar nach Sicherheitsvorfällen durchgeführt, an denen kryptographische Komponenten beteiligt sind.

CRY-03.02B

Im Rahmen der Überprüfungen stellt der Cloud-Anbieter fest, ob die kryptographischen Verfahren mit dem Stand der Technik übereinstimmen, und aktualisiert sie bei Bedarf.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: CRY-03.01B

Weitere Kriterien für das Schlüsselmanagement finden sich in den Kriterien CRY-06, CRY-07, CRY-09 - CRY-19

Anwendbar auf: CRY-03.02B

Der Cloud-Anbieter sollte den kryptographischen Änderungsmanagementprozess (vgl. CRY-02) anwenden, wenn er die kryptographischen Verfahren aktualisiert, um sie an den Stand der Technik anzupassen.

Korrespondierende Kriterien für Kunden

–

CRY-04 Schutz von Daten bei der Übertragung

Basiskriterien

CRY-04.01B

Der Cloud-Anbieter hat für das Übertragen von Cloud-Kundendaten und abgeleiteten Cloud-Dienstdaten über öffentliche Netze Verfahren und technische Sicherheitsmaßnahmen zur Verschlüsselung und Authentisierung nach dem Stand der Technik eingerichtet.

CRY-04.02B

Beim Fernzugriff auf die Produktionsumgebung verwendet der Cloud-Anbieter kryptographische Mechanismen nach dem Stand der Technik, einschließlich der Authentisierung des Personals, um die Kommunikation zu schützen.

Zusatzkriterium (Verschärfend)

CRY-04.01AS, verschärft CRY-04.01B

Der Cloud-Anbieter hat für das Übertragen aller Cloud-Dienstdaten, abgeleiteten Cloud-Dienstdaten, Cloud-Kundendaten und Kontodaten über öffentliche Netze Verfahren und technische Sicherheitsmaßnahmen zur Verschlüsselung und Authentisierung nach dem Stand der Technik eingerichtet.

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: CRY-04.01B, CRY-04.02B, CRY-04.01AS

Bei der Übertragung von Daten mit einem normalen Schutzbedarf innerhalb der Infrastruktur des Cloud-Anbieters ist keine zwingende Verschlüsselung anzuwenden, soweit die Übertragung nicht über öffentliche Netze erfolgt. In diesem Fall kann die nicht-öffentliche Umgebung des Cloud-Anbieters grundsätzlich als vertrauenswürdig angesehen werden. Die Konfiguration des TLS-Protokolls sollte den Empfehlungen der aktuellen Version der Technischen Richtlinie TR-02102-2 ‘Kryptographische Verfahren: Empfehlungen und Schlüssellängen. Teil 2 - Verwendung von Transport Layer Security (TLS)’ des BSI entsprechen. Cipher Suites sollten Perfect Forward Secrecy bereitstellen. Im Allgemeinen sollten Wildcard-Zertifikate nicht verwendet werden.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen für diejenigen Teile des Cloud-Dienstes unter ihrer Verantwortung sicher, dass ihre Cloud-Kundendaten über verschlüsselte Verbindungen entsprechend dem jeweiligen Schutzbedarf übertragen werden.

CRY-05 Verschlüsselung von sensiblen Daten bei der Speicherung

Basiskriterien

CRY-05.01B

Der Cloud-Anbieter hat Verfahren und technische Maßnahmen zur Verschlüsselung von Cloud-Kundendaten bei der Speicherung (d. h. im Ruhezustand) eingerichtet.

CRY-05.02B

Im Allgemeinen sind die privaten Schlüssel (für asymmetrische Algorithmen) oder geheimen Schlüssel (für symmetrische Algorithmen), die für die Verschlüsselung verwendet werden, in Übereinstimmung mit geltenden rechtlichen und regulatorischen Verpflichtungen und Anforderungen, nur für den Cloud-Kunden zugänglich. Wenn der Cloud-Anbieter aufgrund der Art des Cloud-Dienstes auf die privaten oder geheimen Schlüssel des Cloud-Kunden zugreifen muss, um den Cloud-Dienst bereitzustellen, erfolgt dieser Zugriff gemäß IAM-07. Ausnahmen folgen einem festgelegten Verfahren.

CRY-05.03B

Die Verfahren für die Verwendung privater Schlüssel, inklusive gegebenenfalls bestehender Ausnahmen, werden mit dem Cloud-Kunden abgestimmt.

CRY-05.04B

Wenn Änderungen dieser Verfahren und technischen Sicherheitsmaßnahmen die Vertraulichkeit der Cloud-Kundendaten beeinträchtigen können, kommuniziert der Cloud-Anbieter diese Änderungen an die Cloud-Kunden.

CRY-05.05B

Wenn der Cloud-Anbieter einen Master-Schlüssel verwendet, testet der Cloud-Anbieter regelmäßig die Eignung des Designs und die betriebliche Wirksamkeit der jeweiligen Kontrollen zum Schutze des Master-Keys.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

CRY-05.01AC

Der Cloud-Anbieter stellt sicher, dass sichere Verschlüsselungsmechanismen vorhanden sind, um die Wiederherstellung von Cloud-Kundendaten zu verhindern, wenn Ressourcen neu zugewiesen oder physische Medien wiedereingesetzt werden.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: CRY-05.02B, CRY-05.03B, CRY-05.04B, CRY-05.01AC

Die Anforderung ‘nur für den Cloud-Kunden zugänglich’ bedeutet, dass Verschlüsselungsschlüssel ausschließlich im Wissen und unter der Kontrolle des Eigentümers (d. h. des Cloud-Kunden) verbleiben. Dies kann durch die Implementierung eines sicheren Schlüsselmanagementsystems adressiert werden. Wenn ein Schlüsselmanagementsystem verwendet wird, müssen die Schlüssel vor einer Nutzung geschützt werden, die nicht ausdrücklich vom Eigentümer des Schlüssels autorisiert wurde, und sie müssen im Klartext unzugänglich bleiben.

Dieses Kriterium gilt nicht für Daten, die aus funktionalen Gründen für die Bereitstellung des Cloud-Dienstes nicht verschlüsselt werden können.

Anwendbar auf: CRY-05.02B

Szenarien, in denen der Cloud-Anbieter auf die geheimen oder privaten Schlüssel des Cloud-Kunden zugreifen muss, umfassen unter anderem die Nutzung von vom Cloud-Anbieter verwalteten Schlüsseln in einem SaaS-Dienst.

Anwendbar auf: CRY-05.02B, CRY-05.05B

Die Nutzung eines Master-Schlüssels durch den Cloud-Anbieter kann eine Ausnahme von der Anforderung darstellen, dass Schlüssel nur für die Cloud-Kunden zugänglich sind.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen für diejenigen Teile des Cloud-Dienstes unter ihrer Verantwortung (z. B. virtuelle Maschinen innerhalb einer IaaS-Lösung) sicher, dass ihre Cloud-Kundendaten während der Speicherung entsprechend dem jeweiligen Schutzbedarf verschlüsselt sind.

CRY-06 Sichere Schlüsselerzeugung

Basiskriterien

CRY-06.01B

Verfahren und technische Sicherheitsmaßnahmen für die sichere Schlüsselgenerierung für verschiedene kryptographische Systeme und Anwendungen sind dokumentiert und umgesetzt. Diese Sicherheitsmaßnahmen erfordern die Verwendung sicherer Zufallszahlengeneratoren oder eine Erzeugung auf Grundlage von Schlüsseln, die auf diese Weise erstellt wurden.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: CRY-06.01B

Für die Definition sicherer Zufallszahlengeneratoren sollten sich Cloud-Anbieter auf BSI TR-02102-1 (Kapitel 8) beziehen.

Der Cloud-Anbieter schützt die Schlüssel, die von den Cloud-Kunden erstellt und in den Cloud-Dienst eingebracht werden, nach denselben Kriterien wie die vom Cloud-Anbieter erstellten Schlüssel.

Korrespondierende Kriterien für Kunden

–

CRY-07 Rotation kryptographischer Schlüssel

Basiskriterien

CRY-07.01B

Der Cloud-Anbieter hat einen Zeitplan für die Rotation kryptographischer Schlüssel festgelegt, der mit den in CRY-01 festgelegten Anforderungen an die Rotation kryptographischer Schlüssel übereinstimmt. Falls der Cloud-Anbieter auf Grundlage der Ergebnisse einer Risikobewertung keine Schlüsselrotation durchführt, wird diese Entscheidung dem Cloud-Kunden transparent kommuniziert.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

–

Korrespondierende Kriterien für Kunden

–

CRY-08 Ausstellung von Public-Key-Zertifikaten

Basiskriterien

CRY-08.01B

Der Cloud-Anbieter hat Verfahren dokumentiert und umgesetzt, um Public-Key-Zertifikate sicher auszustellen, einzuholen und dabei die Integrität und Authentizität kryptographischer Schlüssel sicherzustellen. Diese Verfahren umfassen:

1. Überprüfung der Identität vor der Ausstellung von Public-Key-Zertifikaten, die vom Cloud-Anbieter oder in seinem Auftrag für seine eigenen Systemkomponenten oder sein Personal ausgestellt werden, um sicherzustellen, dass sie legitimen Entitäten gewährt werden;
2. Sichere Methoden für die Ausstellung von Zertifikaten, die vom Cloud-Anbieter oder in seinem Auftrag für seine eigenen Systemkomponenten oder sein Personal ausgestellt werden, um unbefugten Zugriff zu verhindern; und
3. Verfahren zur Einholung von Public-Key-Zertifikaten von vertrauenswürdigen Zertifizierungsstellen, um die Authentizität der vom Cloud-Anbieter verwendeten Zertifikate sicherzustellen.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: CRY-08.01B

Die ersten beiden Aufzählungspunkte gelten für Zertifikate, die vom Cloud-Anbieter oder in seinem Auftrag für seine eigenen Systemkomponenten und sein Personal ausgestellt werden. Wenn der Cloud-Anbieter Zertifizierungsstellendienste für Cloud-Kunden anbietet, gilt das Prinzip der geteilten Verantwortung, d. h. der Cloud-Anbieter sollte sicherstellen, dass der Cloud-Dienst angemessene technische Maßnahmen bereitstellt, damit Cloud-Kunden eine angemessene Identitätsprüfung durchführen können (vgl. auch die korrespondierenden Kontrollen der Cloud-Kunden). Der dritte Aufzählungspunkt gilt für Zertifikate, die der Cloud-Anbieter von externen Zertifizierungsstellen zur Verwendung in seinen eigenen Cloud-Dienst und Systemkomponenten einholt. Der Cloud-Anbieter sollte sicherstellen, dass Zertifikate nur von vertrauenswürdigen Zertifizierungsstellen eingeholt werden und dass die Authentizität erhaltener Zertifikate vor der Nutzung verifiziert wird. Dieses Kriterium erstreckt sich nicht notwendigerweise auf Zertifikate, die Cloud-Kunden von externen Zertifizierungsstellen für ihre eigenen Zwecke einholen; die Auswahl und Validierung externer Zertifizierungsstellen durch Cloud-Kunden fällt im Modell der geteilten Verantwortung in den Verantwortungsbereich der Cloud-Kunden.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass dort, wo sie vom Cloud-Anbieter bereitgestellte Zertifizierungsstellendienste nutzen, dem ausgestellten Zertifikat angemessene Identitätsprüfungsverfahren umgesetzt werden und die vom Cloud-Dienst bereitgestellten technischen Kontrollen so konfiguriert sind, dass sie die Identitätsprüfung ermöglichen und durchsetzen. Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass dort, wo sie Zertifikate von externen Zertifizierungsstellen für ihre eigene Nutzung beschaffen, Verfahren zur Auswahl vertrauenswürdiger Zertifizierungsstellen und zur Validierung der Authentizität beschaffter Zertifikate festgelegt sind.

CRY-09 Sichere Schlüsselbereitstellung

Basiskriterien

CRY-09.01B

Der Cloud-Anbieter hat Verfahren und technische Sicherheitsmaßnahmen dokumentiert und umgesetzt, um sicherzustellen, dass kryptographische Schlüssel innerhalb seines Verantwortungsbereichs sicher bereitgestellt und aktiviert werden. Diese Verfahren umfassen die Überprüfung von Identität und Berechtigung vor der Bereitstellung und Aktivierung von Schlüsseln, um sicherzustellen, dass sie legitimen Entitäten gewährt werden.

CRY-09.02B

Bereitgestellte Schlüssel enthalten Aktivierungs- und Deaktivierungsfristen, um sicherzustellen, dass ihre Nutzung zeitlich begrenzt ist.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

–

Korrespondierende Kriterien für Kunden

–

CRY-10 Sichere Speicherung von Schlüsseln

Basiskriterien

CRY-10.01B

Der Cloud-Anbieter hat technische Sicherheitsmaßnahmen für die sichere Speicherung kryptographischer Schlüssel dokumentiert und umgesetzt. Dazu gehört, die Trennung des Schlüsselmanagementsystems von den Anwendungs- und Middleware-Ebenen sicherzustellen, festzulegen, wie autorisierte Nutzer Zugang erhalten, und die geografische Verortung der Schlüssel zu berücksichtigen, um vertragliche, rechtliche, regulatorische und sicherheitsbezogene Anforderungen einzuhalten.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

CRY-10.01AC

Auf Grundlage einer Risikbeurteilung (vgl. OIS-07) verwendet der Cloud-Anbieter ein geeignetes Software- oder Hardware-Sicherheitsmodul für die sichere Speicherung kryptographischer Schlüssel.

Ergänzende Informationen

Zum Kriterium

–

Korrespondierende Kriterien für Kunden

–

CRY-11 Archivierung kryptographischer Schlüssel

Basiskriterien

CRY-11.01B

Der Cloud-Anbieter hat Verfahren und technische Sicherheitsmaßnahmen für die sichere Archivierung kryptographischer Schlüssel dokumentiert und umgesetzt. Diese umfassen:

1. Speicherung archivierter Schlüssel in einem Repository, um unbefugten Zugriff zu verhindern;
2. Beschränkung des Zugriffs auf archivierte Schlüssel auf autorisiertes Personal nach dem 'Least-Privilege-Prinzip';
3. Unterstützung der späteren Wiederherstellung von Informationen durch archivierte Schlüssel;
4. Aufbewahrung archivierter Schlüssel nur so lange, wie es erforderlich ist, und anschließende sichere Vernichtung; und
5. Protokollierung aller Aktivitäten im Zusammenhang mit der Speicherung und Wiederherstellung archivierter Schlüssel.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

–

Korrespondierende Kriterien für Kunden

–

CRY-12 Management von Statusänderungen kryptographischer Schlüssel

Basiskriterien

CRY-12.01B

Der Cloud-Anbieter hat Verfahren dokumentiert und umgesetzt, um Statusänderungen kryptographischer Schlüssel zu überwachen, einschließlich ihres Statuswechsels in und aus der Aussetzung. Diese Verfahren stellen sicher, dass alle Statuswechsel aller Schlüssel gründlich überwacht, überprüft und genehmigt werden, um die Sicherheit aufrechtzuerhalten, sowie geltendes Recht und Vorschriften einzuhalten.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: CRY-12.01B

Die Aussetzung eines kryptographischen Schlüssels bezieht sich auf einen vorübergehenden Zustand, in dem der Schlüssel deaktiviert ist und nicht für kryptographische Operationen verwendet werden kann, später aber wieder reaktiviert werden kann. Die Deaktivierung eines kryptographischen Schlüssels stellt dagegen einen dauerhaften Zustand dar, in dem der Schlüssel aus der Nutzung zurückgezogen wird und nicht wieder reaktiviert werden kann.

Korrespondierende Kriterien für Kunden

–

CRY-13 Umgang mit kompromittierten Schlüsseln

Basiskriterien

CRY-13.01B

Der Cloud-Anbieter steuert die Nutzung kompromittierter kryptographischer Schlüssel, um sicherzustellen, dass sie nur unter kontrollierten Umständen und ausschließlich zur Entschlüsselung oder Verifikation (im Fall von Signaturschlüsseln) verwendet werden, unter Einhaltung rechtlicher und regulatorischer Anforderungen.

CRY-13.02B

Der Cloud-Anbieter benachrichtigt betroffene Cloud-Kunden unverzüglich darüber, dass ihre Schlüssel kompromittiert wurden und nicht länger für Verschlüsselung oder Signaturen verwendet werden.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

–

Korrespondierende Kriterien für Kunden

–

CRY-14 Sichere Deaktivierung kryptographischer Schlüssel

Basiskriterien

CRY-14.01B

Der Cloud-Anbieter hat Verfahren dokumentiert und umgesetzt, um kryptographische Schlüssel zu deaktivieren. Diese Verfahren stellen sicher, dass:

1. abgelaufene Schlüssel nicht länger für Verschlüsselungszwecke verwendet werden, aber bei Bedarf weiterhin zur Entschlüsselung verwendet werden können;
2. abgelaufene Schlüssel nicht länger zur Erstellung von Signaturen verwendet werden, aber weiterhin zur Signaturverifikation verwendet werden können;
3. deaktivierte Schlüssel schließlich vernichtet werden, wenn sie nicht mehr benötigt werden, wobei relevante Metadaten für Audit-Zwecke aufbewahrt werden; und
4. alle Maßnahmen im Zusammenhang mit der Deaktivierung und Vernichtung von Schlüsseln im Schlüsselmanagementsystem aufgezeichnet werden, um ein detailliertes Audit-Log aufrechtzuerhalten.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

–

Korrespondierende Kriterien für Kunden

–

CRY-15 Anforderungen an Pre-Shared Keys

Basiskriterien

CRY-15.01B

Wenn Pre-Shared Keys oder Wildcard-Zertifikate verwendet werden, hat der Cloud-Anbieter dedizierte Verfahren und technische Sicherheitsmaßnahmen dokumentiert und umgesetzt, um deren sichere Nutzung und Bereitstellung sicherzustellen.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

–

Korrespondierende Kriterien für Kunden

–

CRY-16 Betriebliche Kontinuität für das Schlüsselmanagement

Basiskriterien

CRY-16.01B

Der Cloud-Anbieter hat die Vor- und Nachteile der Durchführung von Backups des in einem Hardware Security Module (HSM) gespeicherten Schlüsselmaterials zur Schlüsselwiederherstellung und dem Aufbau

von Redundanz oder vergleichbaren Maßnahmen zur Sicherung von Schlüsseln zur Gewährleistung der betrieblichen Kontinuität abgewogen. Diese Abwägung umfasst die Beurteilung des Risikos einer Offenlegung von Schlüsseln, wenn die Kontrolle über das Schlüsselmaterial verloren geht. Entscheidungen darüber, ob Schlüssel-Backups verwendet oder Redundanz aufgebaut werden sollen, sind dokumentiert, und die gewählten Maßnahmen werden auf ihre Wirksamkeit und ihre Übereinstimmung mit vertraglichen, rechtlichen und regulatorischen Anforderungen überprüft.

CRY-16.02B

Verfahren zur Wiederherstellung verlorener oder beschädigter Schlüssel sind vorhanden.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: CRY-16.01B, CRY-16.02B

Der Cloud-Anbieter sollte die folgenden Optionen zur Sicherung von Schlüsselmaterial berücksichtigen:

1. Backup von Schlüsseln: Verschlüsselte Backups von Schlüsseln werden sicher außerhalb des HSM gespeichert. Der Backup-Prozess sollte sicherstellen, dass die Schlüssel während der Speicherung und Übertragung verschlüsselt sind, um unbefugten Zugriff zu verhindern. Regelmäßige Tests der Backup- und Wiederherstellungsverfahren sollten durchgeführt werden, um die Wirksamkeit und Integrität der Backups zu verifizieren. Backups außerhalb eines HSM sollten nur nach sorgfältiger Risikobeurteilung in Betracht gezogen werden.
2. Redundante HSMs: Implementierung mehrerer HSMs an geografisch verteilten Standorten, um Redundanz zu schaffen und sicherzustellen, dass Schlüssel auch dann verfügbar und sicher bleiben, wenn ein HSM ausfällt. Die HSMs sollten synchronisiert sein, um die Konsistenz des Schlüsselmaterials über alle Geräte hinweg sicherzustellen. Regelmäßige Health-Checks und Failover-Tests sind erforderlich, um sicherzustellen, dass Redundanzmechanismen korrekt funktionieren. Die konkrete Art und Weise, wie diese Redundanz aufgebaut wird, kann von den Einzelheiten der vertraglichen Vereinbarungen zwischen Cloud-Anbieter und Cloud-Kunde abhängen. Wenn der Cloud-Kunde beispielsweise einen bestimmten Standort, eine Zone oder Region wählt, gilt diese Wahl auch für die in diesem Kriterium genannte Redundanz.

Korrespondierende Kriterien für Kunden

–

CRY-17 Management des Lebenszyklus kryptographischer Schlüssel

Basiskriterien

CRY-17.01B

Der Cloud-Anbieter hat Verfahren und technische Sicherheitsmaßnahmen dokumentiert und umgesetzt, um den Lebenszyklus kryptographischer Schlüssel und kryptographischen Materials zu überwachen und zu dokumentieren.

CRY-17.02B

Für alle Schlüssel mit Ausnahme ephemerer Schlüssel stellen die vorgenannten Sicherheitsmaßnahmen detaillierte Aufzeichnungen über jeden Schlüssel von der Erstellung bis zur Vernichtung sicher, einschließlich etwaiger Statusänderungen.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

–

Korrespondierende Kriterien für Kunden

–

CRY-18 Nutzung externer Schlüsselmanagementsysteme

Basiskriterien

CRY-18.01B

Für den Fall, dass externe Schlüsselmanagementsysteme (KMS) als Option im Cloud-Dienst vorgesehen sind, stellt der Cloud-Anbieter sicher, dass Verfahren und technische Sicherheitsmaßnahmen für die Nutzung externer KMS eingerichtet sind. Dabei werden die folgenden Aspekte berücksichtigt:

1. Die externen KMS verfügen über anerkannte Sicherheitszertifizierungen, die den Stand der Technik widerspiegeln, um rechtliche, regulatorische und vertragliche Anforderungen einzuhalten;
2. Die Integration der externen KMS in die Cloud-Infrastruktur ist sicher, um die Vertraulichkeit, Integrität und Verfügbarkeit der Schlüssel zu gewährleisten;
3. Strenge Zugriffskontrollen werden umgesetzt, um sicherzustellen, dass nur autorisierte Nutzer und Systeme Zugriff auf die Schlüssel haben (vgl. IAM-01);
4. Verfahren für die regelmäßige Rotation und Erneuerung von Schlüsseln werden definiert und umgesetzt, um die Sicherheit der Schlüssel zu gewährleisten (vgl. CRY-07);
5. Alle Zugriffe und Operationen auf die externen KMS werden protokolliert und überwacht, um verdächtige Aktivitäten zu erkennen und darauf zu reagieren; und
6. Der Cloud-Anbieter stellt sicher, dass die externen KMS regelmäßig auf Schwachstellen geprüft (vgl. OPS-25) und aktualisiert (vgl. OPS-28) werden, um aktuellen Bedrohungen und technologischen Entwicklungen zu begegnen.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

–

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen sicher, dass ihre eigenen Schlüsselmanagementverfahren mit den Anforderungen des externen KMS kompatibel sind und dass sie geeignete Kontrollen umsetzen, um die Sicherheit ihrer Schlüssel zu gewährleisten.

CRY-19 Sicherer Umgang mit kundenseitig verwalteten Schlüsseln

Basiskriterien

CRY-19.01B

Der Cloud-Anbieter setzt Verfahren und technische Sicherheitsmaßnahmen um, um den sicheren Umgang mit kryptographischen Schlüsseln sicherzustellen, die von Cloud-Kunden verwaltet werden. In diesen Verfahren werden die folgenden Aspekte berücksichtigt:

1. Sichere Integration von kundenseitig erzeugten Schlüsseln ('Bring-Your-Own-Key'; BYOK) in die Cloud-Umgebung;
2. Protokollierung aller Aktivitäten im Zusammenhang mit kundenseitig verwalteten Schlüsseln; und
3. Definition von Zugriffskontrollmechanismen, um zu ermöglichen, dass nur autorisierte Nutzer Zugriff auf kundenseitig verwaltete Schlüssel erhalten.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

–

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass ihre Vereinbarungen mit dem Cloud-Anbieter robuste Verfahren und technische Sicherheitsmaßnahmen für den sicheren Umgang mit kundenseitig verwalteten kryptographischen Schlüsseln umfassen. Cloud-Kunden stellen sicher, dass diese Verfahren die sichere Integration ihrer Schlüssel in die Cloud-Umgebung, eine umfassende Protokollierung aller Aktivitäten im Zusammenhang mit ihren Schlüsseln und klar definierte Zugriffskontrollmechanismen behandeln, um den Zugriff ausschließlich auf autorisierte Nutzer zu beschränken.

5.9 Kommunikationssicherheit (COS)

Zielsetzung: Sicherstellen des Schutzes von Informationen in Netzen und den entsprechenden informationsverarbeitenden Systemen.

COS-01 Technische Schutzmaßnahmen

Basiskriterien

COS-01.01B

Basierend auf den Ergebnissen einer gemäß OIS-07 durchgeführten Risikobeurteilung hat der Cloud-Anbieter technische Schutzmaßnahmen implementiert, die geeignet sind, netzbasierte Angriffe auf Systemkomponenten, die für die Bereitstellung des Cloud-Dienstes verwendet werden, zeitnah zu erkennen und darauf zu reagieren.

COS-01.02B

Für diese technischen Schutzmaßnahmen werden auf mehreren Ebenen Präventions- und Schutzmaßnahmen implementiert (Defense in Depth), um das Risiko eines Durchbrechens des eingesetzten Verteidigungssystems zu mindern. Dies schließt netzbasierte Cyberangriffe ein, wie zum Beispiel:

1. Angriffe auf Basis anomaler Eingangs- oder Ausgangs-Traffic-Muster;
2. Distributed-Denial-of-Service-(DDoS-)Angriffe;
3. Spoofing-Angriffe;
4. Code-Injection-Angriffe;
5. DNS-Tunneling; und
6. IoT-Angriffe, die auf Geräte innerhalb eines Netzes abzielen.

COS-01.03B

Aus entsprechend implementierten technischen Schutzmaßnahmen stammende Daten (Teil der Cloud-Anbieterdaten) werden in das SIEM-System des Cloud-Anbieters (vgl. OPS-13) eingespeist, sodass für miteinander korrelierte Ereignisse erforderliche (Gegen-) Maßnahmen initiiert werden können. Die Schutzmaßnahmen sind gemäß SP-01 dokumentiert, kommuniziert und bereitgestellt.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

COS-01.01AC

Der Cloud-Anbieter stellt mit technischen Maßnahmen sicher, dass seinem (physischen oder virtuellen) Netz keine unbekannten (physischen oder virtuellen) Geräte beitreten.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: COS-01.02B, COS-01.01AC

Technische Schutzmaßnahmen, die Schutz und Prävention auf mehreren Ebenen bieten, sind z. B. eine spezielle Trennung im Identitäts- und Berechtigungsmanagement, eine separate Protokollierung für Schutzsysteme und Web Application Firewalls (WAFs) für den Zugriff auf Schutzsysteme.

Netzbasierte Angriffe können z. B. durch MAC-Spoofing und ARP-Poisoning-Angriffe erfolgen. Technische Maßnahmen zum Verhindern des Beitretens unbekannter physischer oder virtueller Geräte zu einem physischen oder virtuellen Netz können sich z. B. an MACSec gemäß IEEE 802.1X:2010 orientieren.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen für jene Teile des Cloud-Dienstes, die in ihrem Verantwortungsbereich liegen (z. B. virtuelle Maschinen innerhalb einer IaaS-Lösung), sicher, dass sie netzbasierte Angriffe auf Basis anomaler Eingangs- und Ausgangs-Traffic Muster (z. B. durch MAC-Spoofing und ARP-Poisoning-Angriffe) und/oder Distributed-Denial-of-Service (DDoS) Angriffe zeitnah erkennen und auf diese reagieren.

COS-02 Sicherheitsanforderungen an Verbindungen im Netz des Cloud-Anbieters

Basiskriterien

COS-02.01B

Spezifische Sicherheitsanforderungen werden für die Herstellung von Verbindungen innerhalb des Netzes des Cloud-Anbieters konzipiert, dokumentiert und bereitgestellt. Die Sicherheitsanforderungen definieren für den Verantwortungsbereich des Cloud-Anbieters:

1. In welchen Fällen die Sicherheitszonen zu trennen sind und in welchen Fällen Cloud-Kunden logisch oder physisch voneinander zu trennen sind;
2. Welche Kommunikationsbeziehungen und welche Netz- und Anwendungsprotokolle jeweils zugelassen werden;
3. Wie der Datenverkehr für Administration und Überwachung auf Netzebene voneinander getrennt wird;
4. Wie Büronetze mit Firewalls und sicheren WIFI-Konfigurationen sowie VPN für den Remote-Zugriff abgesichert werden;
5. Welche interne, partitionsübergreifende Kommunikation zulässig ist; und
6. Welche netzübergreifende Kommunikation erlaubt ist.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: COS-02.01B

Partitionsübergreifende Kommunikation kann z. B. für einzelne Regionen oder Standorte über z. B. WAN, LAN, VPN, RAS realisiert werden.

Korrespondierende Kriterien für Kunden

–

COS-03 Überwachung von Verbindungen im Netz des Cloud-Anbieters

Basiskriterien

COS-03.01B

Der Cloud-Anbieter unterscheidet zwischen vertrauenswürdigen und nicht vertrauenswürdigen Netzen. Auf Grundlage einer Risikobeurteilung gemäß OIS-07 werden diese in verschiedene Sicherheitszonen für interne und externe Netzbereiche (und DMZ, falls vorhanden) getrennt.

COS-03.02B

Physische und virtualisierte Netzumgebungen werden so konzipiert und konfiguriert, dass die hergestellte Verbindung zu vertrauenswürdigen oder nicht vertrauenswürdigen Netzen gemäß den definierten Sicherheitsanforderungen eingeschränkt und überwacht wird (vgl. COS-02).

COS-03.03B

Der Cloud-Anbieter stellt sicher, dass die Konfiguration der Netze den Sicherheitsanforderungen entspricht (vgl. COS-02). Der Cloud-Anbieter überprüft mindestens jährlich und im Falle wesentlicher Änderungen am Cloud-Dienst den Entwurf und die Umsetzung der Konfiguration der Verbindungen im Hinblick auf die definierten Sicherheitsanforderungen.

COS-03.04B

Identifizierte Schwachstellen und Abweichungen werden gemäß dem Risikomanagementverfahren einer Risikobeurteilung unterzogen (vgl. OIS-07), und Folgemaßnahmen werden definiert und nachverfolgt (vgl. OPS-18).

COS-03.05B

In festgelegten Abständen wird die geschäftliche Begründung für die Nutzung aller Dienste, Protokolle und Ports überprüft. Die Überprüfung umfasst auch die Begründungen für kompensierende Maßnahmen für die Nutzung von Protokollen, die als unsicher gelten.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: COS-03.03B, COS-03.04B, COS-03.05B

Die Überprüfung der Sicherheitsanforderungen hängt von den eingerichteten Maßnahmen zur Ausgestaltung der Netze ab und kann z. B. die Überwachung und Durchsicht von Firewall-Regeln oder Protokolldateien auf Auffälligkeiten sowie Sichtprüfungen physischer Netzkomponenten auf Veränderungen umfassen.

Anwendbar auf: COS-03.03B

Wenn die Überprüfung durch wesentliche Änderungen am Cloud-Dienst verursacht wird, müssen nur der Entwurf und die Umsetzung der Konfiguration der von diesen Änderungen betroffenen Verbindungen in die Überprüfung einbezogen werden.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass die virtuellen Netze innerhalb des Cloud-Dienstes, für die sie verantwortlich sind, gemäß ihren Netzsicherheitsanforderungen konzipiert, konfiguriert und dokumentiert werden (z. B. logische Segmentierung der Organisationseinheiten des Cloud-Kunden).

COS-04 Netzübergreifender Zugriff

Basiskriterien

COS-04.01B

Jeder Netzperimeter wird durch Sicherheitsgateways kontrolliert.

COS-04.02B

Die Autorisierung des Systemzugriffs für einen netzübergreifenden Zugriff basiert auf einer Sicherheitsbeurteilung auf Grundlage der Anforderungen der Cloud-Kunden.

Zusatzkriterium (Verschärfend)

COS-04.01AS, verschärft COS-04.01B

Jeder Netzperimeter wird durch redundante und hochverfügbare Sicherheitsgateways kontrolliert.

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: COS-04.02B

Ein Sicherheitsgateway ist ein Stack aus verketteten Filter- und Firewall-Komponenten, welche die Kommunikation auf ausdrücklich erlaubten Verkehr beschränken. Sicherheitsgateways können beispielsweise eine P-A-P-Struktur aufweisen, bestehend aus einem äußeren Paketfilter, einem Gateway auf Anwendungsebene, das als Deep-Inspection-Proxy fungiert, und einem inneren Paketfilter. Der Stack kann weiter um ein Intrusion Detection System, ein Intrusion Prevention System oder einen Virenscanner ergänzt werden. Diese Struktur ist jedoch nicht verpflichtend. Sie dient dazu, Filter- und Prüffunktion funktional voneinander unabhängig zu halten, sodass ein Ausfall in der einen Schicht nicht automatisch zu einem Ausfall der anderen Schicht führt.

Anwendbar auf: COS-04.02B

Netzübergreifende Zugriffe sind Zugriffe von einem Netz in ein anderes Netz über einen definierten Netzperimeter.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass der Zugriff entsprechend ihrem Schutzbedarf durch Sicherheitsgateways an den Perimetern der virtuellen Netze innerhalb des Cloud-Dienstes, für die sie verantwortlich sind, kontrolliert wird.

COS-05 Netze für die Administration

Basiskriterien

COS-05.01B

Es gibt separate Netze für die administrative Verwaltung der Infrastruktur und für den Betrieb von Management-Konsolen. Diese Netze sind logisch oder physisch vom Netz des Cloud-Kunden getrennt und durch Multi-Faktor-Authentisierung (vgl. IAM-08) vor unbefugtem Zugriff geschützt.

COS-05.02B

Netze, die vom Cloud-Anbieter verwendet werden, um Compute-Workloads (z. B. virtuelle Maschinen, Container, Funktionen) zu erstellen, zu migrieren oder zu orchestrieren, sind physisch oder logisch von Netzen der Cloud-Kunden getrennt.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

COS-05.01AC

Bei nicht-physischer Trennung zwischen den Administrationsnetzen und anderen Netzen wird der Verkehr des Administrationsnetzes nach dem Stand der Technik (vgl. CRY-01) verschlüsselt.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: COS-05.01B

Die Trennung kann physisch oder logisch erfolgen (z. B. VLAN, SDN, VRF).

Korrespondierende Kriterien für Kunden

–

COS-06 Trennung des Datenverkehrs in gemeinsam genutzten Netzumgebungen

Basiskriterien

COS-06.01B

Der Datenverkehr der Cloud-Kunden in gemeinsam genutzten Netzumgebungen wird auf Netzebene gemäß eines dokumentierten Rahmenwerks getrennt, um die Vertraulichkeit und Integrität der übertragenen Daten sicherzustellen.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

COS-06.01AC

Im Falle von IaaS/PaaS wird die sichere Trennung durch physisch getrennte Netze oder durch Verschlüsselung nach dem Stand der Technik in Kombination mit logischer Netztrennung oder -Kapselung sichergestellt.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: COS-06.01B, COS-06.01AC

Wenn der Cloud-Anbieter keine gemeinsam genutzten Netzumgebungen für Cloud-Kunden verwendet und stattdessen eine physische Trennung nutzt, ist das Basiskriterium nicht anwendbar.

Soweit Angemessenheit und Wirksamkeit der logischen Segmentierung nicht mit hinreichender Sicherheit beurteilt werden können (z. B. aufgrund einer komplexen Implementierung), kann der Nachweis auch über Prüfungsergebnisse sachverständiger Dritter erfolgen (z. B. Sicherheitsaudit zur Validierung des Rahmenwerks). Die Trennung gespeicherter und verarbeiteter Cloud-Kundendaten ist Gegenstand der Kriterien OPS-30 und OPS-31. Nach erfolgreicher Authentisierung über einen ungesicherten Kommunikationskanal (HTTP) soll auf einen gesicherten Kommunikationskanal (HTTPS) gewechselt werden.

Bei IaaS/PaaS wird die sichere Trennung durch physisch getrennte Netze oder durch eine Verschlüsselung der Netze sichergestellt, die dem Stand der Technik entspricht. Für die Definition einer Verschlüsselung nach dem Stand der Technik sollte die Technische Richtlinie TR-02102 des BSI berücksichtigt werden (vgl. CRY-01).

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen für diejenigen Teile des Cloud-Dienstes in ihrer Verantwortung sicher, dass virtuelle Netze gemäß ihren Netzsicherheitsanforderungen konzipiert, konfiguriert und dokumentiert werden (z. B. logische Segmentierung von Organisationseinheiten).

COS-07 Dokumentation der Netztopologie

Basiskriterien

COS-07.01B

Die Dokumentation der logischen Struktur des Netzes, das zur Bereitstellung oder zum Betrieb des Cloud-Dienstes verwendet wird, ist nachvollziehbar und aktuell, um administrative Fehler im Wirkbetrieb zu vermeiden und eine zeitnahe Wiederherstellung im Falle von Vorfällen gemäß den vertraglichen Verpflichtungen sicherzustellen. Die Dokumentation zeigt:

1. Wie die Subnetze zugewiesen sind;
2. Wie das Netz zoniert und segmentiert ist;
3. Wie das Netz mit Drittanbieter- und öffentlichen Netzen verbunden ist; und
4. Wie die Daten zwischen verschiedenen Subnetzen und Systemkomponenten innerhalb des Netzes fließen, um das Management, die Überwachung und die Analyse des Netzes zu unterstützen.

COS-07.02B

Die Partitionen, Regionen, Zonen oder der Standort, an denen die Cloud-Kundendaten gespeichert werden, sind angegeben.

COS-07.03B

Der Cloud-Anbieter erstellt und pflegt auf Grundlage der Dokumentation der Netztopologie und des Asset-Inventars (vgl. AM-02) eine zutreffende Darstellung der technischen und logischen Struktur der Systeme des Cloud-Anbieters. Die Dokumentation umfasst die Systemkomponenten, die Sicherheitsfunktionen bereitstellen, und die Systemkomponenten, welche die entsprechenden Cloud-Kundendaten und abgeleitete Cloud-Dienstdaten hosten oder sensible Funktionen bereitstellen.

COS-07.04B

Die Dokumentation der Netztopologie wird mindestens einmal pro Jahr überprüft. Zeitnahe und angemessene Abhilfemaßnahmen adressieren alle bei der Überprüfung identifizierten Abweichungen.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: COS-07.01B, COS-07.02B, COS-07.03B

Die Netzdokumentation kann je nach Umfang des Betriebs einem hierarchischen oder gruppierten Ansatz folgen.

Anwendbar auf: COS-07.01B

Bei einer Zonierung handelt es sich um eine Segmentierung der Subnetze mit einer an den Netzperimetern implementierten Firewall.

Korrespondierende Kriterien für Kunden

–

COS-08 Richtlinien für die Datenübertragung

Basiskriterien

COS-08.01B

Richtlinien und Verfahren mit technischen und organisatorischen Schutzmaßnahmen zum Schutz der Übertragung von Cloud-Kundendaten, vom abgeleitete Cloud-Dienstdaten, von Cloud-Anbieterdaten und Kontodaten gegen unbefugtes Abfangen, Manipulation, Kopieren, Ändern, Umleiten, Zerstören oder das Eindringen von Schadsoftware sind dokumentiert, kommuniziert und gemäß SP-01 bereitgestellt. Die Richtlinien und Verfahren stellen einen Bezug zur Asset-Klassifizierung und -Kennzeichnung (vgl. AM-09) und zu kryptographischen Mechanismen (vgl. CRY-01) her.

COS-08.02B

Technische Schutzmaßnahmen, die in den dokumentierten Richtlinien und Verfahren zum Schutz der Datenübertragung beschrieben sind, werden implementiert und regelmäßig sowie im Falle wesentlicher Änderungen am Cloud-Dienst überprüft.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: COS-08.01B, COS-08.02B

Eine Schutzmaßnahme gegen unbefugtes Abfangen, Manipulation, Kopieren, Ändern, Umleiten oder Zerstören von Daten während der Übertragung ist z. B. die Verwendung von Transportverschlüsselung gemäß CRY-04.

Anwendbar auf: COS-08.02B

Wenn eine Überprüfung durch wesentliche Änderungen am Cloud-Dienst verursacht wird, müssen nur die von diesen Änderungen betroffenen technischen Schutzmaßnahmen in die Überprüfung einbezogen werden.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass die an den Cloud-Dienst übertragenen Daten entsprechend ihrem Schutzbedarf gegen Manipulation, Kopieren, Ändern, Umleiten oder Löschen geschützt sind.

5.10 Portabilität und Interoperabilität (PI)

Zielsetzung: Ermöglichen der Eigenschaft, den Cloud-Dienst über andere Cloud-Dienste oder IT-Systemen der Cloud-Kunden ansprechen zu können, die gespeicherten Cloud-Kundendaten bei beendigung des Auftragsverhältnisses zu beziehen und beim Cloud-Anbieter sicher zu löschen.

PI-01 Sicherheit von Eingabe- und Ausgabeschnittstellen

Basiskriterien

PI-01.01B

Für die Eingabe- und Ausgabeschnittstellen, über die auf den Cloud-Dienst durch andere Cloud-Dienste oder IT-Systeme von Cloud-Kunden zugegriffen werden kann, entwirft, implementiert und pflegt der Cloud-Anbieter Kontrollen hinsichtlich der folgenden Aspekte:

1. Die Verwendung standardisierter Kommunikationsprotokolle für Interaktionen zwischen verschiedenen Anwendungsschnittstellen, um die Vertraulichkeit und Integrität der übertragenen Informationen entsprechend ihrem Schutzbedarf sowie die angemessene Authentisierung des Nutzers sicherzustellen;
2. Die Verwendung von Verschlüsselung gemäß CRY-02 bei Kommunikation über nicht vertrauenswürdige Netze;
3. Die Verwendung standardisierter Datenformate und gemeinsamer Standards der Datenverarbeitung, um die Interoperabilität der Informationsverarbeitung zu erleichtern;
4. Die Implementierung von Mechanismen zur Validierung der Datenintegrität und zur Etablierung von Sicherungs- und Wiederherstellungsprozessen, um Datensicherheit und Zuverlässigkeit während Austausch, Nutzung und Übertragung sicherzustellen; und
5. Die Bereitstellung aktueller Informationen über die verfügbaren Kommunikationsprotokolle sowie die anwendbaren Datenformate und Standards der Datenverarbeitung.

PI-01.02B

Der Cloud-Anbieter stellt dem Cloud-Kunden geeignete technische Mittel zur Extraktion von Cloud-Kundendaten gemäß dem vorherigen Unterkriterium zur Verfügung. Soweit Datenvolumen, Format oder Architektur eine kundenseitige Extraktion nicht praktikabel machen, stellt der Cloud-Anbieter dem Cloud-Kunden angemessene Extraktionsdienste zur Verfügung.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

PI-01.01AC

Der Cloud-Anbieter richtet eine Anwendungs-Firewall ein, um die über öffentliche Netze erreichbaren Administrationsschnittstellen für Cloud-Kunden zu schützen.

PI-01.02AC

Der Cloud-Dienst stellt Cloud-Kunden Schnittstellen für kundenspezifische Identitätsanbieter zur Verfügung, um die Authentisierungsinformationen von Nutzern unter der Verantwortung des Cloud-Kunden zu verwalten. Diese Schnittstellen werden von einem standardisierten Protokoll begleitet, um die Kommunikation zwischen dem Cloud-Dienst und dem externen Identitätsanbieter zu erleichtern.

PI-01.03AC

Die Schnittstellen sind klar dokumentiert, um sachverständigem Personal des Cloud-Kunden die Integration ihres Identitätsanbieters mit dem Cloud-Dienst zu ermöglichen.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: PI-01.01B, PI-01.02B, PI-01.01AC, PI-01.02AC, PI-01.03AC

In diesem Kontext ist eine Schnittstelle ein Systemzugangspunkt oder eine Bibliotheksfunktion mit einer wohldefinierten Syntax. Sie umfasst dokumentierte Methoden, die es Cloud-Kunden ermöglichen, sicher auf den Cloud-Dienst zuzugreifen und mit ihm zu interagieren, wodurch der Austausch von Daten ermöglicht wird.

Diese Schnittstellen und ihre Dokumentation sollten ausreichende Informationen über den Cloud-Dienst enthalten, um die Entwicklung von Software zu ermöglichen, die zum Zweck der Datenportabilität und Interoperabilität mit ihm kommuniziert. Der Cloud-Anbieter ist jedoch nicht verpflichtet, zu diesem Zweck neue Technologien zu entwickeln oder Informationen weiterzugeben, die durch Rechte des geistigen Eigentums geschützt sind oder ein Geschäftsgeheimnis darstellen.

Während diese Schnittstellen die Mittel zur Kommunikation mit dem Cloud-Dienst bereitstellen, bedeuten sie nicht, dass Cloud-Kunden ihre kundenspezifischen Systeme direkt anschließen können, als wären diese nativ integriert. Stattdessen können Cloud-Kunden ihre Systeme konfigurieren, indem sie Methoden wie API-Aufrufe verwenden und die vom Cloud-Anbieter bereitgestellten festgelegten Protokolle und Datenformate einhalten.

Um eine nahtlose und sichere Kommunikation zwischen Schnittstellen sicherzustellen, verwendet der Cloud-Anbieter branchenübliche API-Protokolle und implementiert dem Stand der Technik entsprechende Transportschichtsicherheit. Der Cloud-Anbieter unterstützt plattformübergreifende Informationsverarbeitung durch den Einsatz von Containerisierungstechnologien und Cloud-Anbieter-agnostischen Entwicklungs-Frameworks. Infrastructure as Code Verfahren werden übernommen, um die Bereitstellung von Infrastruktur zu standardisieren. Gemeinsame Richtlinien zur Datennutzung werden definiert und durchgesetzt, um einen konsistenten und sicheren Zugriff auf Cloud-Kundendaten sowie deren Nutzung und Weitergabe sicherzustellen. Nach Vertragsbeendigung unterstützt der Cloud-Anbieter Cloud-Kunden beim Export und bei der Übertragung ihrer Cloud-Kundendaten, z. B. durch die Bereitstellung technischer Dokumentation und von Datenexportwerkzeugen.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass die bereitgestellten Schnittstellen (und deren Sicherheit) durch geeignete Prüfungen vor Beginn der Nutzung des Cloud-Dienstes und jedes Mal, wenn die Schnittstellen geändert werden, für ihren Schutzbedarf angemessen sind.

PI-02 Vertragliche Vereinbarungen zur Bereitstellung von Cloud-Kundendaten

Basiskriterien

PI-02.01B

In vertraglichen Vereinbarungen werden für die Bereitstellung von Cloud-Kundendaten nach Beendigung des Vertragsverhältnisses die folgenden Aspekte definiert, soweit diese auf den Cloud-Dienst anwendbar sind:

1. Art, Umfang und Format der Cloud-Kundendaten, die der Cloud-Anbieter dem Cloud-Kunden bereitstellt;
2. Methoden zur Bereitstellung der Cloud-Kundendaten an den Cloud-Kunden;

3. Bedingungen und Zeitrahmen für die Bereitstellung von Cloud-Kundendaten über die Dauer des Vertragsverhältnisses hinweg;
4. Recht zur Kündigung des Vertrags und Definition des Zeitrahmens, innerhalb dessen der Cloud-Anbieter dem Cloud-Kunden die Cloud-Kundendaten nach Vertragsbeendigung zur Verfügung stellt;
5. Definition des Zeitpunkts, ab dem der Cloud-Anbieter die Cloud-Kundendaten für den Cloud-Kunden unzugänglich macht und diese nach Vertragsbeendigung löscht;
6. Die Verantwortlichkeiten und Mitwirkungspflichten der Cloud-Kunden für die Bereitstellung der Cloud-Kundendaten; und
7. Cloud-Kundendaten bleiben während des gesamten Vertragsverhältnisses Eigentum des Cloud-Kunden. Nach dessen Beendigung sind die Cloud-Kundendaten wieder das alleinige Eigentum und der alleinige Besitz des Cloud-Kunden.

Die Definitionen orientieren sich an den Bedürfnissen von sachverständigem Personal potenzieller Cloud-Kunden, die die Eignung des Cloud-Dienstes im Hinblick auf eine Abhängigkeit vom Cloud-Anbieter sowie rechtliche und regulatorische Anforderungen bewerten.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

PI-02.01AC

Die Ausgestaltung der Aspekte basiert auf rechtlichen und regulatorischen Anforderungen im Umfeld des Cloud-Anbieters. Der Cloud-Anbieter identifiziert die Anforderungen regelmäßig, mindestens einmal im Jahr, prüft diese auf Aktualität und passt die vertraglichen Vereinbarungen entsprechend an.

PI-02.02AC

Der Cloud-Anbieter stellt dem Cloud-Kunden bei Beendigung des Vertragsverhältnisses auch abgeleitete Cloud-Dienstdaten zur Verfügung. Die Bereitstellung dieser abgeleiteten Cloud-Dienstdaten ist ebenfalls in den vertraglichen Vereinbarungen definiert und umfasst die im Basiskriterium genannten Aspekte.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: PI-02.01B, PI-02.01AC, PI-02.02AC

Art und Umfang der von diesem Kriterium umfassten Cloud-Kundendaten sowie die Verantwortlichkeiten für deren Bereitstellung hängen vom Servicemodell des Cloud-Dienstes oder von den bereitgestellten Diensten und Funktionen ab:

Im Fall von IaaS- und PaaS-ähnlichen Diensten ist der Cloud-Kunde grundsätzlich dafür verantwortlich, die im Cloud-Dienst gespeicherten Cloud-Kundendaten vor Beendigung des Vertragsverhältnisses zu extrahieren und zu sichern (vgl. korrespondierendes Kundenkriterium).

Die Verantwortung des Cloud-Anbieters ist typischerweise auf die Bereitstellung von Cloud-Kundendaten für die Konfiguration der Infrastruktur oder Plattform beschränkt, die der Cloud-Kunde innerhalb seiner Umgebung eingerichtet hat (z. B. Konfiguration von Netzen, Images virtueller Maschinen und Container).

Bei SaaS stützt sich der Cloud-Kunde typischerweise auf vom Cloud-Anbieter bereitgestellte Exportfunktionen. Vom Cloud-Kunden erzeugte Daten sollten in demselben Format verfügbar sein, in dem sie im Cloud-Dienst gespeichert sind. Andere solcher Cloud-Kundendaten, einschließlich relevanter Protokolldateien und Metadaten, sollten in einem anwendbaren Standardformat wie CSV, JSON oder XML verfügbar sein.

Rechtliche Anforderungen können beispielsweise den EU Data Act umfassen. In Deutschland lassen sich gesetzliche Vorgaben zur Aufbewahrung beispielsweise der Abgabenordnung (§147 AO) und dem Handelsgesetzbuch (§ 257 HGB) entnehmen. Diese sehen eine Aufbewahrungspflicht von sechs oder zehn Jahren vor.

Falls vertragliche Vereinbarungen die im Basiskriterium aufgeführten Aspekte nicht enthalten und diese aufgrund des Servicemodells anwendbar sind, ist das Kriterium nicht erfüllt und eine Abweichung ist vom Auditor festzuhalten.

Anwendbar auf: PI-02.01B

Falls der Cloud-Anbieter als Cloud-Vermittler agiert, sollte vertraglichen Klauseln zur Datenportabilität besondere Beachtung geschenkt werden, die die Komplexität des jeweiligen Cloud-Vermittler-Szenarios berücksichtigen. Dies kann unter anderem die Definition von Folgendem umfassen:

1. Verantwortung für den Export von Cloud-Kundendaten;
2. Falls mehrere zugrunde liegende Cloud-Anbieter vorhanden sind, den Exportumfang, das konsolidierte Format, etwaige Vollständigkeitsgrenzen und den Umgang mit vom Cloud-Vermittler erzeugten Artefakten wie aggregierten Protokollierungen;
3. Ob Cloud-Kunden direkt über APIs auf die Cloud-Dienste zugrunde liegender Cloud-Anbieter zugreifen können oder auf die Exportschnittstelle des Cloud-Vermittlers angewiesen sind und ob es zeitliche oder nutzungsbezogene Einschränkungen gibt; und
4. Zeitrahmen für die Bereitstellung von Exporten der Cloud-Kundendaten an den Cloud-Kunden.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass die Daten, auf die sie vertraglich Anspruch haben, am Ende des Vertrags vom Cloud-Anbieter angefordert oder über definierte Schnittstellen abgerufen werden (Art und Umfang der Daten entsprechen den vertraglichen Vereinbarungen, die vor der Nutzung des Cloud-Dienstes geschlossen wurden) und dass sie in Übereinstimmung mit den für diese Daten geltenden rechtlichen Anforderungen gespeichert werden.

PI-03 Sichere Datenlöschung

Basiskriterien

PI-03.01B

Die Verfahren des Cloud-Anbieters zur Löschung von Cloud-Kundendaten, abgeleiteten Cloud-Dienstdaten und Kontodaten bei Beendigung des Vertragsverhältnisses stellen die Einhaltung der vertraglichen Vereinbarungen sicher (vgl. PI-02). Ausnahmen sind nur zulässig, falls sie durch eine gültige gerichtliche Anordnung erforderlich sind oder zur Erfüllung bekannter zukünftiger finanzieller und rechtlicher Verpflichtungen benötigt werden.

PI-03.02B

Die Löschverfahren verhindern eine Wiederherstellung durch forensische Mittel, die dem Stand der Technik entsprechen.

PI-03.03B

Die Löschung der Cloud-Kundendaten, abgeleiteten Cloud-Dienstdaten und Kontodaten wird in einer Weise dokumentiert, die es dem Cloud-Kunden ermöglicht, einen Nachweis über die Löschung seiner Daten zu erhalten.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: PI-03.01B, PI-03.02B

Geeignete Methoden zur Datenlöschung sind z. B. mehrfaches Überschreiben oder die Löschung des Verschlüsselungsschlüssels.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass die rechtlichen und regulatorischen Rahmenbedingungen (z. B. rechtliche Anforderungen an Aufbewahrung und Löschung) identifiziert wird und die Löschung ihrer Daten entsprechend veranlasst wird.

5.11 Beschaffung, Entwicklung und Änderung von Informationssystemen (DEV)

Zielsetzung: Sicherstellen der Informationssicherheit im Entwicklungszyklus von Systemkomponenten des Cloud-Dienstes.

DEV-01 Richtlinien für die Entwicklung/Beschaffung von Systemkomponenten

Basiskriterien

DEV-01.01B

Richtlinien und Verfahren mit technischen und organisatorischen Maßnahmen für die sichere Entwicklung von Systemkomponenten des Cloud-Dienstes sind gemäß SP-01 dokumentiert, kommuniziert und bereitgestellt.

Die Richtlinien und Verfahren enthalten Leitlinien für den gesamten Lebenszyklus des Cloud-Dienstes und orientieren sich hinsichtlich der folgenden Aspekte an:

1. Sicherheit und Qualität in der Softwareentwicklung (Anforderungen, Design, Implementierung, Testen und Überprüfungen), einschließlich des Vorhandenseins eines Security-by-Design-Prinzips, das die Berücksichtigung von Anforderungen der Informationssicherheit in der Softwareentwicklungsphase durchsetzt;
2. Sicherheit und Qualität bei der Softwarebereitstellung (einschließlich kontinuierlicher Bereitstellung (Continuous Delivery));
3. Sicherheit und Qualität im Betrieb (Reaktion auf identifizierte Fehler und Schwachstellen); und
4. Standards und Verfahren für sicheres Programmieren (Reduzierung des Einbringens von Schwachstellen in den Code).

DEV-01.02B

Leitlinien für die sichere Entwicklung des Cloud-Dienstes definieren Grundsätze, um sicherzustellen, dass die Systemarchitektur und die vom Cloud-Anbieter innerhalb der Produktionsumgebung betriebene Software so gestaltet sind, dass der Zugriff des Cloud-Anbieters auf Cloud-Kundendaten soweit wie möglich minimiert wird.

DEV-01.03B

Der Cloud-Anbieter definiert Maßnahmen, um die festgelegten Standards und Leitlinien als Teil der Richtlinien und Verfahren für die sichere Entwicklung von Systemkomponenten des Cloud-Dienstes durchzusetzen.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

DEV-01.01AC

Bei der Beschaffung werden Produkte bevorzugt, die gemäß den 'Common Criteria für die Sicherheitsevaluierung von Informationstechnik' (kurz: Common Criteria - CC) auf dem Evaluation Assurance Level EAL 4 zertifiziert wurden. Sollen nicht zertifizierte Produkte anstelle verfügbarer zertifizierter Produkte beschafft werden, wird eine Risikobeurteilung gemäß OIS-07 durchgeführt.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: DEV-01.01B, DEV-01.01AC

Die Software-Bereitstellung kann z. B. mit Continuous Delivery-Verfahren erfolgen.

Anerkannte Standards und Methoden für die sichere Entwicklung sind zum Beispiel:

1. ISO/IEC 27034; und
2. OWASP Secure Software Development Lifecycle (S-SDLC).

Die Minimierung des Zugriffs auf Cloud-Kundendaten während des Betriebs kann bei der Entwicklung der Cloud-Architektur durch die Befolgung robuster Sicherheitsmodelle, wie Zero Trust, unterstützt werden. Darüber hinaus sind Aspekte wie die Begrenzung von Datenschnittstellen, API-Aufrufen und Zugriffen sowie die Sicherstellung einer Ende-zu-Ende-Verschlüsselung vom Transport bis zur Speicherung relevante Gesichtspunkte.

Für die Qualitätssicherung in der Softwareentwicklung können die folgenden Prozesse als relevant betrachtet werden:

1. Planung und Definition von Qualitätszielen: Definition von Qualitätsanforderungen auf Grundlage von Bedürfnissen der Cloud-Kunden und Zielen unter Berücksichtigung der Anforderungen des zu entwickelnden Cloud-Systems;
2. Designphase: Durchführung von Design-Reviews und Inspektionen des Cloud-Dienstes, um sicherzustellen, dass das Design die Qualitätsanforderungen erfüllt;
3. Entwicklungsphase: Einsatz von Code-Reviews und Pair Programming, um die Codequalität sicherzustellen. Einsatz statischer Analysewerkzeuge, um den Code auf potenzielle Fehler und Verstöße gegen Programmierstandards zu prüfen;
4. Testphase: Durchführung (wo möglich automatisiert) verschiedener Testarten (z. B. Unit-Tests, Integrationstests, Systemtests, Abnahmetests), um die Funktionalität und Qualität der Software sicherzustellen;
5. Integration und Continuous Integration (CI): Integration der verschiedenen Softwarekomponenten und kontinuierliche Überprüfung der Integrationen durch automatisierte Builds und Tests. Einsatz von CI/CD-Pipelines, um sicherzustellen, dass der Code regelmäßig integriert und getestet wird;
6. Release und Bereitstellung: Vorbereitung und Umsetzung des Software-Releases gemäß definierten Qualitätsstandards; und

7. Wartung und kontinuierliche Verbesserung: Überwachung der Software im Betrieb, um sicherzustellen, dass sie weiterhin die Qualitätsanforderungen erfüllt. Dies umfasst Aktivitäten nach dem Release wie Fehlerbehebungs- und Leistungsoptimierungsprozesse. Zusätzlich sollten Post-Mortem-Analysen durchgeführt werden, um aus Vorfällen zu lernen und Prozesse für zukünftige Releases zu optimieren.

Ein anerkannter Standard und eine Methode für Qualität in Entwicklungsprozessen ist zum Beispiel Google Site Reliability Engineering (SRE).

Der Anwendungsbereich der DEV-Kriterien und der darin enthaltenen Anforderungen umfasst nicht nur die Entwicklung von Softwareanwendungen, sondern auch Plattformen, virtuelle Infrastruktur und andere Systemkomponenten.

Korrespondierende Kriterien für Kunden

–

DEV-02 Auslagerung der Entwicklung

Basiskriterien

DEV-02.01B

Im Fall der ausgelagerten Entwicklung des Cloud-Dienstes (oder einzelner Systemkomponenten) werden Spezifikationen zu den folgenden Aspekten zwischen dem Cloud-Anbieter und der Service-Organisation vertraglich vereinbart:

1. Sicherheit in der Softwareentwicklung (Anforderungen, Design, Implementierung, Tests und Überprüfungen) gemäß anerkannten Standards und Methoden, wobei ein Sicherheitsniveau sichergestellt wird, das dem der internen Entwicklung des Cloud-Anbieters gleichwertig ist;
2. Abnahmeprüfung der Qualität der erbrachten Leistungen gemäß den vereinbarten funktionalen und nicht-funktionalen Anforderungen; und
3. Vorlage von Nachweisen, dass ausreichende Überprüfungen durchgeführt wurden, um das Vorhandensein bekannter Schwachstellen auszuschließen.

DEV-02.02B

Bevor die Entwicklung des Cloud-Dienstes oder von dessen Komponenten ausgelagert wird, führt der Cloud-Anbieter eine Risikobeurteilung gemäß mindestens die folgenden Aspekte berücksichtigt:

1. Verwaltung des Quellcodes durch die Service-Organisation;
2. Zugänglichkeit des Quellcodes für den Cloud-Anbieter;
3. Von der Service-Organisation implementierte Personalverfahren;
4. Erforderlicher Zugang zu den Entwicklungs-, Test- und Vorproduktionsumgebungen des Cloud-Anbieters; und
5. Management von Unterauftragnehmern, die von der Service-Organisation eingesetzt werden.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

DEV-02.01AC

Der Cloud-Anbieter dokumentiert und implementiert ein Verfahren, das die Aufsicht und Kontrolle der ausgelagerten Entwicklungstätigkeit ermöglicht, um sicherzustellen, dass sie der Richtlinie des Cloud-

Anbieters für sichere Entwicklung entspricht und dass das dadurch erreichte Sicherheitsniveau dem durch interne Entwicklung erreichten Sicherheitsniveau entspricht.

DEV-02.02AC

Wenn eine Änderung Arbeiten aus ausgelagerter Entwicklung enthält, führt das Personal des Cloud-Anbieters die Tests durch, die benötigt werden, um zu entscheiden, ob die Änderung bereitgestellt werden kann.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: DEV-02.01B, DEV-02.02B

Ausgelagerte Entwicklung im Sinne des Basiskriteriums bezieht sich auf die Entwicklung von Systemkomponenten, die dediziert für den Cloud-Dienst verwendet werden, durch eine Service-Organisation des Cloud-Anbieters. Die Entwicklung erfolgt nach den Prozessen der Service-Organisation.

Die Risiken, die entstehen könnten und berücksichtigt werden sollten, können, müssen aber nicht, die folgenden umfassen:

1. Risiken, die daraus resultieren können, dass die Service-Organisation den Quellcode ohne angemessene Kontrollen verwaltet, einschließlich unbefugter Änderungen, unzureichender Versionskontrolle oder unzureichenden Schutzes vor Verlust oder Diebstahl geistigen Eigentums;
2. Risiken, die daraus resultieren können, dass die Service-Organisation dem Cloud-Anbieter oder Drittprüfern Zugang zum Quellcode gewährt, einschließlich unbefugter Offenlegung, Verlust der Vertraulichkeit oder unzureichender Kontrollen darüber, wie ein solcher Zugang verwaltet und beschränkt wird;
3. Risiken, die aus unzureichender Personalüberprüfung, unzureichenden Hintergrundprüfungen, mangelnder Schulung zum Sicherheitsbewusstsein oder hoher Personalfluktuation innerhalb der Service-Organisation resultieren können, einschließlich Insider-Bedrohungen oder unkontrolliertem Verlust sensiblen Wissens;
4. Risiken, die daraus resultieren können, dass der Service-Organisation Zugang zu internen Entwicklungs-, Test- oder Vorproduktionsumgebungen gewährt wird, einschließlich übermäßiger Berechtigungen, unzureichender Zugriffskontrollen oder unzureichender Protokollierung und Überwachung eines solchen Zugangs; und
5. Risiken, die daraus resultieren können, dass die Service-Organisation Teile der Leistung ohne angemessene Sicherheitskontrollen an Unterauftragnehmer vergibt, einschließlich unzureichender vertraglicher Sicherheitsanforderungen an Unterauftragnehmer oder mangelnder Transparenz hinsichtlich der Zusammensetzung der Lieferkette.

Der Erwerb von auf dem Markt verfügbarer Software sowie die Integration externen Personals in die Prozesse des Cloud-Anbieters stellen keine Auslagerung im Sinne dieses Basiskriteriums dar.

Korrespondierende Kriterien für Kunden

–

DEV-03 Richtlinien für Änderungen an Systemkomponenten

Basiskriterien

DEV-03.01B

Richtlinien und Verfahren mit technischen und organisatorischen Maßnahmen für das Änderungsmanagement von Systemkomponenten des Cloud-Dienstes im Rahmen der Software-

Bereitstellung sind hinsichtlich der folgenden Aspekte gemäß SP-01 dokumentiert, kommuniziert und bereitgestellt:

1. Kriterien zur Risikobeurteilung, Kategorisierung und Priorisierung von Änderungen und damit verbundene Anforderungen an Art und Umfang durchzuführender Tests sowie erforderliche Freigaben für die Entwicklung/Implementierung der Änderung sowie der Freigaben zur Bereitstellung in der Produktionsumgebung durch autorisiertes Personal oder Systemkomponenten;
2. Anforderungen an die Durchführung und Dokumentation von Tests;
3. Anforderungen an die Funktionstrennung während Entwicklung, Test und Freigabe von Änderungen;
4. Anforderungen zur sachgerechten Information der Cloud-Kunden über Art und Umfang der Änderung sowie daraus resultierende Mitwirkungspflichten gemäß den vertraglichen Vereinbarungen;
5. Anforderungen an die Dokumentation von Änderungen in der System-, Betriebs- und Benutzerdokumentation;
6. Anforderungen an die Umsetzung und Dokumentation von Notfalländerungen, sodass sie - soweit vernünftigerweise möglich - dem gleichen Sicherheitsniveau wie normale Änderungen entsprechen;
7. Anforderungen an den Umgang mit unerwarteten Auswirkungen dieser Änderungen, einschließlich Korrekturmaßnahmen;
8. Anforderungen an verstärkte Tests für die Entwicklung von Sicherheitsfunktionen, die technische Mechanismen und Schutzmaßnahmen implementieren; und
9. Anforderungen an die Handhabung von Ausnahmen, einschließlich Notfalländerungen, um sicherzustellen, dass damit verbundene Risiken angemessen gemindert werden.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: DEV-03.01B

Änderungen im Sinne des Basiskriteriums sind solche, die zu Änderungen an der Konfiguration, Funktionalität oder Sicherheit von Systemkomponenten des Cloud-Dienstes in der Produktionsumgebung führen können. Dies umfasst sowohl Änderungen an der Infrastruktur als auch am Quellcode.

Soweit einzelne Änderungen zur Software-Bereitstellung in einem neuen Release, Update, Patch oder einem vergleichbaren Softwareobjekt zusammengefasst werden, gilt dieses Softwareobjekt als Änderung im Sinne des Basiskriteriums, nicht aber die einzelnen darin enthaltenen Änderungen.

Änderungen an der bestehenden Netzkonfiguration fallen ebenfalls unter dieses Kriterium und sollten ebenfalls ein festgelegtes Verfahren durchlaufen, da sie für eine wirksame Trennung der Cloud-Kunden erforderlich sind.

Änderungen an den Containerumgebungen, einschließlich des Managements von Container-Images und -Versionen, sollten ebenfalls einen geregelten Prozess durchlaufen.

Personal oder Systemkomponenten werden gemäß den Vorgaben für Zugangs- und Zugriffsberechtigungen (vgl. IAM-01) im Rahmen eines geregelten Verfahrens (vgl. IAM-02) für Genehmigungen und Freigaben autorisiert.

Die Mitwirkungspflichten des Cloud-Kunden können festlegen, dass z. B. der Cloud-Kunde bestimmte Tests durchführen muss.

Ein zentralisierter Änderungsmanagementprozess ist nicht verpflichtend. Der Cloud-Anbieter hat die Flexibilität, Änderungsmanagementverfahren anzuwenden, die am besten zu seinen betrieblichen Anforderungen passen, einschließlich agiler Methoden, solange sie die Verfahren und technischen Schutzmaßnahmen einhalten.

Korrespondierende Kriterien für Kunden

–

DEV-04 Programm für Sicherheitsschulungen und Sensibilisierung in Bezug auf kontinuierliche Software-Bereitstellung und zugehörige Systeme, Komponenten oder Werkzeuge

Basiskriterien

DEV-04.01B

Der Cloud-Anbieter stellt ein Schulungsprogramm für regelmäßige, rollenbasierte Sicherheitsschulungen und Sensibilisierung für internes und externes Personal zu Standards und Methoden für Folgendes bereit:

1. Sichere Softwareentwicklung und -bereitstellung sowie die Nutzung der dafür verwendeten Werkzeuge; und
2. Mit Schadcode verbundene Risiken und bewährte Verfahren zur Reduzierung der Auswirkungen einer Infektion.

DEV-04.02B

Das Programm wird regelmäßig im Hinblick auf die anwendbaren Richtlinien und Verfahren, die zugewiesenen Rollen und Verantwortlichkeiten sowie die verwendeten Werkzeuge überprüft und aktualisiert.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: DEV-04.01B

Dies ist ein spezialisiertes Kriterium für Programme zu Sicherheitsschulungen und Sensibilisierung für eine bestimmte Zielgruppe. In HR-03 werden allgemeine Eigenschaften solcher Schulungen und Programme definiert.

Korrespondierende Kriterien für Kunden

–

DEV-05 Designdokumentation für Sicherheitsfunktionen

Basiskriterien

DEV-05.01B

Die Designdokumentation für Sicherheitsfunktionen basiert auf einer Sicherheitsanalyse der Angemessenheit und der geplanten Wirksamkeit der Funktionen. Eine Spezifikation der erwarteten Eingaben, Ausgaben und möglichen Fehler ist in der Dokumentation enthalten.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: DEV-05.01B

Sicherheitsfunktionen sind typischerweise Funktionen, die Vertraulichkeit (z. B. durch die Integration von Kryptographie), Integrität (z. B. durch die Einführung von Prüfsummen oder die Validierung von Eingabedaten), Verfügbarkeit (z. B. durch Redundanz oder Resilienz), Authentisierung (z. B. durch MFA oder sicheres Session Management) und Autorisierung (z. B. durch unterschiedliche Rollen) steuern. Sie ergeben sich üblicherweise aus Bedrohungsmodellierung und Risikobeurteilung. Idealerweise sind Sicherheitsfunktionen ein integraler Bestandteil des Softwareentwicklungsprozesses und keine Ergänzungen, die erst vorgenommen werden, nachdem neue Softwarefunktionen erstellt wurden.

Korrespondierende Kriterien für Kunden

–

DEV-06 Risikobeurteilung, Kategorisierung und Priorisierung von Änderungen

Basiskriterien

DEV-06.01B

Gemäß den anwendbaren Richtlinien werden Änderungen einer Risikobeurteilung unterzogen, die ihre potenziellen Auswirkungen auf den gesamten im Geltungsbereich befindlichen Cloud-Dienst bewertet. Darüber hinaus werden, wenn mehrere Änderungen gleichzeitig umgesetzt werden, auch ihre wechselseitigen Interaktionen und kumulativen Auswirkungen der Risikobeurteilung unterzogen, um potenzielle Konflikte oder Abhängigkeiten zu identifizieren. Alle identifizierten Risiken und Abhängigkeiten werden entsprechend kategorisiert und priorisiert.

DEV-06.02B

Wenn das mit einer geplanten Änderung verbundene Risiko hoch ist, werden geeignete Minderungsmaßnahmen ergriffen, bevor die Änderung in der Produktionsumgebung des Cloud-Dienstes bereitgestellt wird.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

DEV-06.01AC

Gemäß den vertraglichen Vereinbarungen werden aussagekräftige Informationen über Anlass, Zeitpunkt, Dauer, Art und Umfang der Änderung an autorisierte Stellen des Cloud-Kunden übermittelt, damit diese ihre eigene Risikobeurteilung durchführen können, bevor die Änderung in der Produktionsumgebung verfügbar gemacht wird. Unabhängig von den vertraglichen Vereinbarungen erfolgt dies bei Änderungen, die auf Grundlage ihrer Risikobeurteilung die höchste Risikokategorie haben. Dies schließt Änderungen ohne Auswirkung auf die Cloud-Dienstnutzung oder die Sicherheitslage des Cloud-Dienstes nicht ein.

Ergänzende Informationen

Zum Kriterium

–

Korrespondierende Kriterien für Kunden

–

DEV-07 Testen von Änderungen

Basiskriterien

DEV-07.01B

Änderungen am Cloud-Dienst werden während der Software-Entwicklung und -Bereitstellung gemäß dokumentierten Testverfahren angemessenen Tests unterzogen.

DEV-07.02B

Art und Umfang der Tests entsprechen der Risikobeurteilung. Die Tests werden von angemessen qualifiziertem Personal des Cloud-Anbieters oder durch automatisierte Testverfahren durchgeführt, die dem Stand der Technik entsprechen. Cloud-Kunden werden gemäß den vertraglichen Anforderungen in die Tests einbezogen.

DEV-07.03B

Bevor Cloud-Kundendaten für Tests verwendet werden, holt der Cloud-Anbieter zunächst die Genehmigung dieses Cloud-Kunden ein und anonymisiert die Cloud-Kundendaten. Der Cloud-Anbieter stellt die Vertraulichkeit der Cloud-Kundendaten während des gesamten Prozesses sicher.

DEV-07.04B

Die Sicherheitsfunktionen des Cloud-Dienstes werden Tests unterzogen, die die Spezifikation der Sicherheitsfunktionen (vgl. DEV-05), einschließlich aller spezifizierten Fehlerbedingungen, vollständig abdecken. Die Dokumentation dieser Tests umfasst mindestens die folgenden Aspekte:

1. Eine Beschreibung des Tests;
2. Die Ausgangsbedingungen;
3. Das erwartete Ergebnis; und
4. Verfahren zur Durchführung des Tests.

DEV-07.05B

Der Schweregrad der in den Tests identifizierten Fehlern und Schwachstellen, welche für die Abnahme relevant sind, wird nach definierten Kriterien beurteilt und Maßnahmen zur zeitnahen Behebung oder Mitigation eingeleitet.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

DEV-07.01AC

Pre-Launch-Tests werden während der Testphase des Cloud-Dienstes gemäß dem Penetrationstest-Rahmenwerk (vgl. OPS-22 Zusatzkriterium) durchgeführt. Der Schweregrad identifizierter Schwachstellen wird nach definierten Kriterien bewertet, und Maßnahmen zur zeitnahen Behebung oder Minderung werden eingeleitet.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: DEV-07.01B, DEV-07.01AC

Es sollten Tests verwendet werden, die sowohl zur Qualitätssicherung der Softwareentwicklung als auch zur Sicherheit des Cloud-Dienstes beitragen.

Die in Tests identifizierten Fehler und Schwachstellen können beispielsweise nach dem Common Vulnerability Scoring System (CVSS) bewertet werden.

Anwendbar auf: DEV-07.01B

Testverfahren für Software-Assets können statisch (SAST), dynamisch (DAST) oder interaktiv (IAST) sein.

Korrespondierende Kriterien für Kunden

Soweit Änderungen gemäß den vertraglichen Vereinbarungen vor der Bereitstellung in der Produktionsumgebung von den Cloud-Kunden getestet werden sollen, stellen die Cloud-Kunden mit geeigneten Kontrollen sicher, dass die Tests angemessen durchgeführt werden, um Fehler zu identifizieren. Dies umfasst insbesondere die zeitnahe Durchführung der Tests durch qualifiziertes Personal gemäß den vom Cloud-Anbieter festgelegten Bedingungen.

DEV-08 Protokollierung von Änderungen

Basiskriterien

DEV-08.01B

Systemkomponenten für Versionskontrolle und Softwarebereitstellung, die verwendet werden, um Änderungen an Systemkomponenten des Cloud-Dienstes in der Produktionsumgebung zu verwalten, unterliegen einem Rollen- und Berechtigungsrahmenwerk gemäß IAM-01 und Autorisierungsmechanismen.

DEV-08.02B

Die Konfiguration dieser Systemkomponenten stellt sicher, dass alle vom Cloud-Anbieter an Systemkomponenten in der Produktionsumgebung vorgenommenen Änderungen aufgezeichnet werden und auf die Personen oder Systemkomponenten zurückgeführt werden können, die zu ihrer Entwicklung, Bereitstellung oder Umsetzung beigetragen haben.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

DEV-08.01AC

Der Cloud-Anbieter setzt das Rollen- und Berechtigungsrahmenwerk durch, indem er die an Systemkomponenten des Cloud-Dienstes in der Produktionsumgebung vorgenommenen Änderungen

überwacht. Zeitnahe und angemessene Abhilfemaßnahmen beheben alle bei der Überwachung identifizierten Abweichungen.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: DEV-08.02B

Wenn die Änderung einen externen Beitrag hat (z. B. die Verwendung von Drittprodukten oder Bibliotheken), ist eine Rückverfolgung einzelner Änderungen in der Entwicklung oft nicht möglich. In diesem Fall ist es ausreichend, den externen Beitrag in der Liste der Softwarekomponenten oder der Software Bill of Materials (SBOM, vgl. DEV-13.01B) zu erfassen. Darüber hinaus können abhängig von der Art des externen Beitrags das Kriterium für die Auslagerung der Entwicklung (vgl. DEV-02) und die Kriterien für Kontrolle und Überwachung von Dienstleistern und Lieferanten (SSO) Anwendung finden.

Korrespondierende Kriterien für Kunden

–

DEV-09 Versionskontrolle

Basiskriterien

DEV-09.01B

Der Cloud-Anbieter verwendet ein Versionskontrollsystem, das die Vertraulichkeit, Integrität und Authentizität des Quellcodes während aller Entwicklungsphasen angemessen sicherstellt.

DEV-09.02B

Die Verfahren zur Versionskontrolle verfolgen Abhängigkeiten einzelner Änderungen nach und ordnen jede Änderung einzelnen Mitwirkenden zu. Die Verfahren zur Versionskontrolle sind in der Lage, betroffene Systemkomponenten in einen vorherigen Zustand zurückzuversetzen.

DEV-09.03B

Die Versionskontrolle umfasst alle intern und extern entwickelten Softwarekomponenten, Konfigurationen und kommerziellen Produkte Dritter unter der Verantwortung des Cloud-Anbieters.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

DEV-09.01AC

Die Verfahren zur Versionskontrolle sehen geeignete Schutzmaßnahmen vor, um sicherzustellen, dass die Integrität und Verfügbarkeit von Cloud-Kundendaten nicht beeinträchtigt werden, wenn Systemkomponenten in ihren vorherigen Zustand zurückversetzt werden.

DEV-09.02AC

Der Cloud-Anbieter führt Aufzeichnungen über alle bereitgestellten Softwareversionen und Systemkonfigurationen. Diese Aufzeichnung ermöglicht die Nachbildung einer zuvor umgesetzten Umgebung in einer Testumgebung.

Die Aufbewahrungszeit für diese Historie ist risikobasiert (vgl. OIS-07), in der Richtlinie für Versionskontrolle definiert und am Support-Lebenszyklus des Cloud-Dienstes ausgerichtet.

Ergänzende Informationen

Zum Kriterium

–

Korrespondierende Kriterien für Kunden

–

DEV-10 Freigaben für die Bereitstellung in der Produktionsumgebung

Basiskriterien

DEV-10.01B

Autorisiertes Personal oder autorisierte Systemkomponenten des Cloud-Anbieters genehmigen Änderungen am Cloud-Dienst auf Grundlage definierter Kriterien (z. B. Testergebnisse und erforderliche Freigaben), bevor diese den Cloud-Kunden in der Produktionsumgebung verfügbar gemacht werden.

DEV-10.02B

Cloud-Kunden werden gemäß vertraglichen Vereinbarungen in die Freigabe einbezogen.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

DEV-10.01AC

Der Genehmigungsprozess wird überwacht. Zeitnahe und angemessene Abhilfemaßnahmen beheben alle bei der Überwachung identifizierten Abweichungen.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: DEV-10.01B

Es gelten die Definitionen für Kriterium DEV-03.

Anwendbar auf: DEV-10.02B

Falls die vertraglichen Vereinbarungen keine Beteiligung des Cloud-Kunden an der Genehmigung vorsehen, sollte dies in den vertraglichen Vereinbarungen klar angegeben werden, um dieses Kriterium zu erfüllen.

Korrespondierende Kriterien für Kunden

Soweit Änderungen gemäß den vertraglichen Vereinbarungen vor ihrer Bereitstellung in der Produktionsumgebung von den Cloud-Kunden genehmigt werden sollen, stellen die Cloud-Kunden mit geeigneten Kontrollen sicher, dass autorisiertes und qualifiziertes Personal die bereitgestellten Informationen erhält, die Auswirkungen auf den ISMS-Rahmen bewertet und gemäß den vom Cloud-Anbieter festgelegten Bedingungen über die Genehmigung entscheidet.

DEV-11 Schutz von Entwicklungs- und Testumgebungen

Basiskriterien

DEV-11.01B

Entwicklungs- und Testumgebungen unter der Verantwortung des Cloud-Anbieters werden einer Risikobeurteilung (vgl. OIS-07) unterzogen und mit angemessenen Sicherheitsmaßnahmen gegen

identifizierte Risiken geschützt. Dies schließt auch die Erweiterung des Datensicherungsplans (vgl. OPS-06) auf die notwendigen Teile dieser Umgebungen ein.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: DEV-11.01B

Den Richtlinien und Verfahren für Datensicherungen (vgl. OPS-06) geht eine Risikobeurteilung voraus, sodass diese nicht alle Elemente dieser Umgebungen umfassen, sondern nur diejenigen, die auf Grundlage der Risikobeurteilung als notwendig erachtet werden. In manchen Situationen lassen sich einige Teile leichter von Grund auf neu aufbauen, als sie zu sichern.

Korrespondierende Kriterien für Kunden

–

DEV-12 Trennung der Umgebungen

Basiskriterien

DEV-12.01B

Produktionsumgebungen sind von Test- oder Entwicklungsumgebungen physisch oder logisch getrennt, um unautorisierte Zugriffe auf Cloud-Kundendaten, die Ausbreitung von Schadprogrammen oder unbeabsichtigte Änderungen an Systemkomponenten zu verhindern. Cloud-Kundendaten aus Produktionsumgebungen werden nicht in Test- oder Entwicklungsumgebungen verwendet, es sei denn, dies wurde von den Cloud-Kunden ausdrücklich genehmigt, um deren Vertraulichkeit nicht zu gefährden.

DEV-12.02B

Sofern dies nicht unvermeidbar ist, verwendet der Cloud-Anbieter die in Produktionsumgebungen verwendeten kryptographischen Geheimnisse und privaten Schlüssel sowie andere Geheimnisse nicht in anderen Nicht-Produktionsumgebungen wieder. Jede unvermeidbare Wiederverwendung kryptographischer Geheimnisse und privater Schlüssel zwischen Produktions- und Nicht-Produktionsumgebungen wird gemäß dem Prozess für die Behandlung von Ausnahmen (vgl. SP-03) und den Risikomanagementverfahren (vgl. OIS-07) dokumentiert und begründet.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

–

Korrespondierende Kriterien für Kunden

–

DEV-13 Transparenz über Softwarekomponenten

Basiskriterien

DEV-13.01B

Der Cloud-Anbieter stellt sicher, dass im Rahmen des Softwareentwicklungsprozesses für jede entwickelte oder integrierte Softwarekomponente eine Liste von Softwarekomponenten erstellt, gepflegt und aktuell gehalten wird.

DEV-13.02B

Der Cloud-Anbieter pflegt auch für integrierte Softwarekomponenten eine Liste von Softwarekomponenten, außer wenn solche Informationen nicht verfügbar sind und nicht mit vertretbarem Aufwand erstellt werden können. Das aus diesen Ausnahmen resultierende Risiko wird gemäß SP-03 behandelt.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: DEV-13.01B

Dieses Kriterium kann durch eine hinreichend detaillierte Liste von Softwarekomponenten erfüllt werden. Hinreichende Detaillierung bedeutet, dass die Liste dem Cloud-Anbieter ermöglicht, alle Cloud-Dienste zu identifizieren, die von einer gegebenen bekannten Schwachstelle betroffen sind. Dieses Kriterium kann auch durch eine Software Bill of Materials (SBOM) erfüllt werden. Der Stand der Technik hinsichtlich der Erstellung, Pflege und Nutzung von SBOMs, einschließlich ihrer Bestandteile und Formate, werden in der jeweils aktuellen Version der Technischen Richtlinie TR-03183-2 des BSI beschrieben. Automatisierte Werkzeuge zum Erzeugen, Pflegen und Validieren von Listen von Softwarekomponenten oder SBOMs werden empfohlen, um Genauigkeit und Integration in Sicherheits- und Schwachstellenmanagementprozesse sicherzustellen. Es ist möglicherweise nicht notwendig, jede Version der SBOM zu speichern - genau wie in den anderen Entwicklungsprozessen für Komponenten -, solange der Cloud-Anbieter in der Lage ist, die Änderungen nachzuverfolgen.

Anwendbar auf: DEV-13.02B

Dieses Unterkriterium gilt nur für integrierte Softwarekomponenten. Falls integrierte Softwarekomponenten z. B. Open Source sind und dieses Kriterium über SBOMs erfüllt wird, kann es Fälle geben, in denen eine SBOM nicht verfügbar ist und nicht mit vertretbarem Aufwand erstellt werden kann. Vertretbar impliziert, dass der Austausch dieser Komponente gegen eine mit SBOM wirtschaftlich nicht machbar ist. Die Risiken aus diesen Ausnahmen werden jedoch innerhalb des Ausnahmeprozesses behandelt (vgl. SP-03).

Korrespondierende Kriterien für Kunden

–

DEV-14 Sichere Nutzung von Hardware und Software Dritter

Basiskriterien

DEV-14.01B

Richtlinien und Verfahren für die Nutzung von Drittanbieter- und Open-Source-Software sind gemäß SP-01 dokumentiert, kommuniziert und bereitgestellt.

DEV-14.02B

Für die bei der Entwicklung des Cloud-Dienstes verwendeten Hardware- und Softwareprodukte (vgl. DEV-13) wird eine Liste der Abhängigkeiten zu diesen Produkten geführt.

DEV-14.03B

Es werden nur vertrauenswürdige Quellen verwendet, um Software Dritter zu beziehen. Wann immer möglich, wird die Authentizität der Software verifiziert.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

DEV-14.01AC

Bei der Beschaffung für die Entwicklung des Cloud-Dienstes führt der Cloud-Anbieter für jedes Hardware- und Softwareprodukt eine Risikobeurteilung gemäß OIS-07 durch.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: DEV-14.01B

Die Richtlinie sollte, soweit anwendbar, dieselben Aspekte berücksichtigen wie die Richtlinie für die ordnungsgemäße und sichere Nutzung von Assets (vgl. AM-05).

Korrespondierende Kriterien für Kunden

–

DEV-15 Ausnahmen vom Änderungsmanagementprozess

Basiskriterien

DEV-15.01B

Der Änderungsmanagementprozess des Cloud-Anbieters implementiert Verfahren für die Handhabung von Ausnahmen, einschließlich Notfalländerungen, um sicherzustellen, dass damit verbundene Risiken angemessen gemindert werden.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: DEV-15.01B

Dieses Kriterium bezieht sich hauptsächlich auf den in SP-03 geforderten Ausnahmeprozess, obwohl hier alle Ausnahmen vom Standardverfahren für Änderungen gemeint sind.

Korrespondierende Kriterien für Kunden

–

5.12 Steuerung und Überwachung von Service-Organisationen und Lieferanten (SSO)

Zielsetzung: Sicherstellen des Schutzes von Informationen auf die Dienstleister bzw. Lieferanten des Cloud-Anbieters (Service-Organisationen) zugreifen können, sowie Überwachung der vereinbarten Leistungen und Sicherheitsanforderungen.

SSO-01 Richtlinien und Verfahren zur Steuerung und Überwachung von Service-Organisationen

Basiskriterien

SSO-01.01B

Richtlinien und Verfahren zur Steuerung und Überwachung von Service-Organisationen, deren Leistungen zur Entwicklung oder zum Betrieb des Cloud-Dienstes beitragen, sind hinsichtlich der folgenden Aspekte gemäß SP-01 dokumentiert, kommuniziert und bereitgestellt:

1. Anforderungen an die Beurteilung von Risiken, die sich aus der Beschaffung von Dienstleistungen Dritter ergeben;
2. Anforderungen an die Klassifizierung der Service-Organisationen auf Basis einer Risikobeurteilung durch den Cloud-Anbieter und der Feststellung, ob es sich um eine Subservice-Organisation handelt;
3. Informationssicherheitsanforderungen für die Verarbeitung, Speicherung oder Übertragung von Informationen durch Service-Organisationen auf der Grundlage des Stands der Technik und unter Berücksichtigung der Kriterien in diesem Katalog;
4. Anforderungen an die Sensibilisierung und die Schulung des Personals;
5. Anwendbare rechtliche und regulatorische Anforderungen;
6. Anforderungen an den Umgang mit Schwachstellen, Sicherheitsvorfällen und Vorfällen;
7. Vorgaben für die vertragliche Vereinbarung dieser Anforderungen;
8. Vorgaben für die Überwachung dieser Anforderungen; und
9. Vorgaben für die Weitergabe dieser Anforderungen auch an Subservice-Organisationen, die von den Service-Organisationen eingesetzt werden, soweit Leistungen dieser Subservice-Organisationen ebenso zur Entwicklung oder zum Betrieb des Cloud-Dienstes beitragen.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

SSO-01.01AC

Subservice-Organisationen des Cloud-Anbieters sind vertraglich verpflichtet, regelmäßige Berichte unabhängiger Prüfer über die Angemessenheit der Ausgestaltung und die wirksame Umsetzung ihres dienstleistungsbezogenen internen Kontrollsystems bereitzustellen, die es dem Cloud-Anbieter

ermöglichen festzustellen, ob die Subservice-Organisation Kontrollen ausgestaltet und betrieben hat, die den erwarteten korrespondierenden Kontrollen von Subservice-Organisationen (CSOC) angemessen sind.

SSO-01.02AC

Falls solche Berichte nicht bereitgestellt werden können, vereinbart der Cloud-Anbieter geeignete Informations- und Prüfungsrechte, um die Ausgestaltung und den Betrieb des dienstleistungsbezogenen internen Kontrollsystems hinsichtlich der erwarteten CSOCs zu bewerten.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: SSO-01.01B, SSO-01.01AC

Das Basiskriterium gilt für alle Service-Organisationen des Cloud-Anbieters, unabhängig davon, ob die 'inclusive'- oder die 'carve-out method' angewendet wird. Das Zusatzkriterium gilt nur für diejenigen Service-Organisationen, die als Subservice-Organisationen angesehen werden. Siehe Abschnitt 'Berücksichtigung von Dienstleistungsunternehmen (Service-Organisationen)'.

Berichte unabhängiger Prüfer über die Angemessenheit der Ausgestaltung und die wirksame Umsetzung ihres dienstleistungsbezogenen internen Kontrollsystems sind beispielsweise Prüfungsberichte nach ISAE 3402, IDW PS 951, SOC 2 oder BSI C5.

Anwendbare rechtliche und regulatorische Anforderungen können z. B. in den Bereichen Datenschutz, Recht am geistigen Eigentum oder Urheberrecht bestehen.

Falls gesetzliche oder regulatorische Anforderungen eine von diesen Kriterien abweichende Regelung für die Steuerung von Subservice-Organisationen vorsehen, bleiben diese Regelungen von den C5-Kriterien unberührt.

Korrespondierende Kriterien für Kunden

–

SSO-02 Risikobeurteilung von Service-Organisationen

Basiskriterien

SSO-02.01B

Service-Organisationen des Cloud-Anbieters unterliegen vor ihrem Einsatz zur Entwicklung oder zum Betrieb des Cloud-Dienstes einer Risikobeurteilung in Übereinstimmung mit den Richtlinien und Verfahren zur Steuerung und Überwachung von Service-Organisationen.

Die Risikobeurteilung umfasst die Identifizierung, Analyse, Bewertung, Behandlung und Dokumentation von Risiken in Bezug auf die folgenden Aspekte:

1. Schutzbedarf hinsichtlich der Vertraulichkeit, Integrität, Verfügbarkeit und Authentizität von Cloud-Kundendaten, abgeleitete Cloud-Dienstdaten, Cloud-Anbieterdaten und Kontodaten, die von der Service-Organisation verarbeitet, gespeichert oder übertragen werden;
2. Auswirkungen einer Schutzverletzung auf die Erbringung des Cloud-Dienstes;
3. Die Abhängigkeit des Cloud-Anbieters von der Service-Organisation hinsichtlich Umfang, Komplexität und Einzigartigkeit der erbrachten Dienstleistung, einschließlich der Berücksichtigung möglicher Alternativen;
4. Korrespondierende Kontrollen von Subservice-Organisationen (CSOC), die bei der Ausgestaltung der Kontrollen des Cloud-Anbieters zur Erfüllung der anwendbaren C5-Kriterien vorausgesetzt werden;

5. Abweichungen hinsichtlich der Ausgestaltung und des Betriebs von CSOCs, die bei als Subservice-Organisationen betrachteten Service-Organisationen vorausgesetzt werden, sowie mitigierende Maßnahmen des Cloud-Anbieters zur Behandlung solcher Abweichungen;
6. Die Fähigkeit des Cloud-Anbieters, Bezugsquellen zu diversifizieren und Vendor Lock-in zu begrenzen;
7. Ob vom Cloud-Anbieter genutzte Service-Organisationen selbst unterbeauftragte Service-Organisationen (Subunternehmer) nutzen, die zur Entwicklung und zum Betrieb des Cloud-Dienstes beitragen; und
8. Falls vom Cloud-Anbieter genutzte Service-Organisationen selbst Subunternehmer nutzen, die Arten von Daten, die von den Subunternehmern verarbeitet werden.

SSO-02.02B

Die Angemessenheit der Risikobeurteilung wird während des Leitungsbezugs regelmäßig, mindestens jährlich, durch qualifiziertes Personal des Cloud-Anbieters überprüft.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: SSO-02.01B

Zur Bewertung von Risiken bei Service-Organisationen kann der Cloud-Anbieter koordinierte Sicherheitsrisikobeurteilungen spezifischer kritischer IKT-Dienstleistungen, IKT-Systeme oder IKT-Produkte durchführen, die von Service-Organisationen bereitgestellt werden. Abgesehen von den in diesem Unterkriterium aufgeführten Aspekten sollte eine solche Risikobeurteilung technische und, soweit relevant, nichttechnische Risikofaktoren berücksichtigen.

Informationen zu CSOCs sind nur für Subservice-Organisationen einzuholen. Nicht jede Service-Organisation ist eine Subservice-Organisation (vgl. Abschnitt ‘Berücksichtigung von Dienstleistungsunternehmen (Service-Organisationen)’).

Korrespondierende Kriterien für Kunden

–

SSO-03 Datenverarbeitung von Service-Organisationen

Basiskriterien

SSO-03.01B

Falls sich der Cloud-Anbieter für den Betrieb des Cloud-Dienstes auf Assets eines Lieferanten oder auf Dienstleistungen von Subservice-Organisationen stützt, erlaubt er diesen Lieferanten oder Service-Organisationen keinen Zugriff auf Cloud-Kundendaten, abgeleitete Cloud-Dienstdaten oder Kontodaten. Ausnahmen sind nur zulässig, falls der Cloud-Anbieter eine Risikobeurteilung gemäß OIS-07 hinsichtlich der Möglichkeit durchgeführt hat, dass Cloud-Kundendaten, abgeleitete Cloud-Dienstdaten oder Kontodaten offengelegt werden.

SSO-03.02B

Der Cloud-Anbieter holt vor der Verarbeitung von Cloud-Kundendaten, abgeleiteten Cloud-Dienstdaten oder Kontodaten die schriftliche Genehmigung des Cloud-Kunden ein, falls er Service-Organisationen einsetzt. Dies kann durch eine Genehmigung des Cloud-Kunden je Service-Organisation oder im Wege einer allgemeinen Vorabgenehmigung zwischen dem Cloud-Anbieter und dem Cloud-Kunden erreicht werden.

Zusatzkriterium (Verschärfend)

SSO-03.01AS, verschärft SSO-03.01B

Falls sich der Cloud-Anbieter für den Betrieb des Cloud-Dienstes auf Assets eines Lieferanten oder auf Dienstleistungen von Subservice-Organisationen stützt, erlaubt er diesen Lieferanten oder Service-Organisationen keinen Zugriff auf Cloud-Kundendaten, abgeleitete Cloud-Dienstdaten oder Kontodaten. Ausnahmen sind nur zulässig, falls der Cloud-Anbieter eine Risikobeurteilung gemäß OIS-07 hinsichtlich der Möglichkeit durchgeführt hat, dass Cloud-Kundendaten, abgeleitete Cloud-Dienstdaten oder Kontodaten offengelegt werden, und sichergestellt ist, dass alle Vorgänge, die Zugriff auf diese Datentypen erfordern, von autorisiertem Personal durchgeführt oder überwacht werden (vgl. HR-01).

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: SSO-03.02B

Dieses Unterkriterium gilt nicht für abgeleitete Cloud-Dienstdaten, die keine kundeneigenen Daten enthalten. Beispiele für solche abgeleiteten Cloud-Dienstdaten sind Betriebskennzahlen oder technische Telemetriedaten.

Korrespondierende Kriterien für Kunden

–

SSO-04 Verzeichnis von Service-Organisationen

Basiskriterien

SSO-04.01B

Der Cloud-Anbieter führt ein Verzeichnis zur Steuerung und Überwachung der Service-Organisationen, die Dienstleistungen zur Erbringung des Cloud-Dienstes beitragen. Die folgenden Informationen werden im Verzeichnis geführt:

1. Firmenname;
2. Anschrift des Hauptsitzes;
3. Geltende Rechtsordnung;
4. Standorte, an denen Cloud-Kundendaten, abgeleitete Cloud-Dienstdaten, Cloud-Anbieterdaten und Kontodaten verarbeitet und gespeichert werden;
5. Verantwortliche Kontaktgruppe/-person bei der Service-Organisation;
6. Verantwortliche Kontaktgruppe/-person beim Cloud-Anbieter;
7. Beschreibung der Dienstleistung;
8. Klassifizierung auf Basis der Risikobeurteilung;

9. Beginn der Dienstleistungsnutzung; und
10. Nachweise über die Einhaltung der vertraglich vereinbarten Anforderungen.

SSO-04.02B

Das Verzeichnis wird mindestens jährlich auf Vollständigkeit, Genauigkeit und Gültigkeit der Informationen überprüft.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: SSO-04.01B

Zur Erfüllung des Basiskriteriums ist es nicht notwendig, ein einziges zentrales Verzeichnis zu führen.

Korrespondierende Kriterien für Kunden

–

SSO-05 Überwachung der Einhaltung von Anforderungen

Basiskriterien

SSO-05.01B

Der Cloud-Anbieter überwacht die Einhaltung von Informationssicherheitsanforderungen und geltenden gesetzlichen und regulatorischen Anforderungen in Übereinstimmung mit Richtlinien und Verfahren zur Steuerung und Überwachung von Service-Organisationen.

SSO-05.02B

Die Überwachung umfasst eine regelmäßige Überprüfung der folgenden Informationen, soweit diese Informationen von Service-Organisationen gemäß den vertraglichen Vereinbarungen bereitzustellen sind:

1. Berichte über die Qualität der Leistungserbringung;
2. Zertifikate über die Konformität der Managementsysteme mit internationalen Standards;
3. Aufzeichnungen der Service-Organisationen über den Umgang mit Schwachstellen, Sicherheitsvorfällen und Vorfällen;
4. Berichte unabhängiger Dritter über die Ausgestaltung und den Betrieb ihres dienstleistungsbezogenen internen Kontrollsystems; und
5. Falls vom Cloud-Anbieter genutzte Service-Organisationen selbst Subunternehmer nutzen, die Einhaltung relevanter vertraglicher, gesetzlicher und regulatorischer Anforderungen durch ihre Subunternehmer.

SSO-05.03B

Die Regelmäßigkeit der Durchführung entspricht der Klassifizierung der Service-Organisationen auf Basis der Risikobeurteilung des Cloud-Anbieters (vgl. SSO-02).

SSO-05.04B

Falls eine Service-Organisation als Subservice-Organisation betrachtet wird, beurteilt der Cloud-Anbieter diese Beziehung und führt geeignete Verfahren durch, um sicherzustellen, dass die anwendbaren C5-Kriterien erfüllt sind. Geeignete Verfahren liefern hinreichende Sicherheit:

1. Dass die Subservice-Organisation relevante Kontrollen ausgestaltet und betrieben hat; und
2. Dass die Kontrollen der Subservice-Organisation den erwarteten korrespondierenden Kontrollen von Subservice-Organisationen (CSOC) entsprechen, die bei der Ausgestaltung der Kontrollen des Cloud-Anbieters vorausgesetzt wurden.

SSO-05.05B

Identifizierte Abweichungen werden in Übereinstimmung mit der Risikobeurteilung von Service-Organisationen (vgl. SSO-02) einer Analyse, Bewertung und Behandlung unterzogen.

SSO-05.06B

Wenn eine zur Erbringung des Cloud-Dienstes beitragende Service-Organisation eine Änderung durchläuft, die sich wesentlich zum Nachteil auf das Sicherheitsniveau des Cloud-Anbieters auswirkt, kommuniziert der Cloud-Anbieter dies allen seinen Cloud-Kunden unverzüglich.

SSO-05.07B

Der Cloud-Anbieter legt ein Verfahren fest, um Anforderungen an Geheimhaltungs- oder Vertraulichkeitsvereinbarungen für alle an der Erbringung des Cloud-Dienstes beteiligten Service-Organisationen regelmäßig zu überprüfen. Dieses Verfahren wird in der Praxis umgesetzt, und die Überprüfung wird mindestens einmal pro Jahr durchgeführt.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

SSO-05.01AC

Die Verfahren zur Überwachung der Einhaltung der Anforderungen werden durch automatische Verfahren in Bezug auf die folgenden Aspekte ergänzt:

1. Konfiguration von Systemkomponenten;
2. Leistung und Verfügbarkeit von Systemkomponenten;
3. Reaktionszeit auf Vorfälle und Sicherheitsvorfälle; und
4. Wiederherstellungszeit (Zeit bis zum Abschluss der Fehlerbehandlung).

SSO-05.02AC

Identifizierte Verstöße und Unstimmigkeiten werden automatisch an das verantwortliche Personal oder die verantwortlichen Systemkomponenten des Cloud-Anbieters gemeldet, damit eine zeitnahe Bewertung und Maßnahmen erfolgen können.

SSO-05.03AC

Der Cloud-Anbieter definiert und implementiert einen Prozess zur Durchführung periodischer Sicherheitsbeurteilungen für alle Service-Organisationen. Art und Umfang dieser Sicherheitsbeurteilungen entsprechen dem mit jeder Service-Organisation verbundenen Risiko. Diese risikobasierten Sicherheitsbeurteilungen stellen sicher, dass Service-Organisationen die erforderlichen Sicherheitsstandards erfüllen und dass potenzielle Risiken angemessen identifiziert und mitigiert werden.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: SSO-05.01B, SSO-05.02B, SSO-05.03B, SSO-05.04B, SSO-05.05B, SSO-05.06B, SSO-05.07B, SSO-05.01AC, SSO-05.02AC, SSO-05.03AC

Informationen, die für die Überwachung der Ausgestaltung und des Betriebs des dienstleistungsbezogenen internen Kontrollsystems eingeholt werden, umfassen typischerweise Berichte nach ISAE 3402, IDW PS 951, SOC 2 oder BSI C5, ANSSI SecNumCloud oder CSA CCM. Auch Second-Party-Audits auf Grundlage solcher Rahmenwerke können hier nützlich sein. Für die strukturierte Analyse von BSI-C5-Berichten hat das BSI einen Excel-basierten Auswertungsleitfaden veröffentlicht.

Falls solche Berichte von den Service-Organisationen bereitgestellt werden, überprüft der Cloud-Anbieter beispielsweise die folgenden Aspekte und bezieht die Feststellungen bei Bedarf in die Risikobeurteilung ein, um Risiko-mitigierende Maßnahmen abzuleiten und einzuleiten:

1. Den Geltungsbereich und die Gültigkeit beziehungsweise den vom Bericht abgedeckten Zeitraum;
2. Modifikationen des Prüfungsurteils, festgestellte Abweichungen/Ausnahmen und die Stellungnahme der Geschäftsleitung hierzu;
3. Korrespondierende Kundenkontrollen (engl. Complementary User Entity Controls, CUEC), die vom Cloud-Anbieter ausgestaltet und betrieben werden müssen;
4. Offengelegte Subservice-Organisationen einschließlich etwaiger Änderungen unter diesen (z. B. zusätzliche Subservice-Organisationen); und
5. Angegebene Sicherheitsvorfälle.

Informationen zu CSOCs sind nur für Subservice-Organisationen einzuholen. Nicht jede Service-Organisation ist eine Subservice-Organisation, vgl. Abschnitt ‘Berücksichtigung von Dienstleistungsunternehmen (Service-Organisationen)’). Geeignete Verfahren können die Überprüfung von Berichten unabhängiger Dritter oder vom Cloud-Anbieter bei der Subservice-Organisation durchgeführte Prüfungsverfahren umfassen.

Die im Zusatzkriterium beschriebenen automatisierten Überwachungsverfahren sind nur auf Service-Organisationen anwendbar, für die eine Überwachungsautomatisierung aufgrund der Art der für den Cloud-Anbieter erbrachten Dienstleistungen machbar ist.

Anwendbar auf: SSO-05.02B

Bei der Überprüfung der von der Service-Organisation bereitgestellten Informationen sollte der Cloud-Anbieter zwischen fehlerhaften Informationen, die in gutem Glauben erstellt wurden (wie Berichte über mutmaßliche Sicherheitsvorfälle, die sich letztlich als unbegründet herausstellten), und bewusst falschen oder böswilligen Informationen unterscheiden.

Die Überwachung von Subunternehmern kann über Audits, Zertifizierungen und Berichte Dritter erfolgen (vgl. SSO-05) und von den Service-Organisationen des Cloud-Anbieters durchgeführt werden. Der Cloud-Anbieter bleibt dafür verantwortlich, die Ergebnisse der Compliance-Überwachung zu überprüfen und das Risiko zu bewerten.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass sie über die Subservice-Organisationen ihres Cloud-Anbieters informiert bleiben (z. B. auf Grundlage der Informationen im C5-Prüfungsbericht) und entscheiden auf Grundlage des Schutzbedarfs ihrer im Cloud-Dienst verarbeiteten und gespeicherten Daten, ob weitere Maßnahmen zur Überwachung und Prüfung dieser Subservice-Organisationen ergriffen werden sollten.

SSO-06 Strategie zur Vertragsbeendigung für Service-Organisationen

Basiskriterien

SSO-06.01B

Der Cloud-Anbieter hat Strategien zur Vertragsbeendigung oder zum Ausstieg für den Bezug von Dienstleistungen definiert und dokumentiert, falls die Risikobeurteilung der Service-Organisationen hinsichtlich Umfang, Komplexität und Einzigartigkeit der erbrachten Dienstleistung eine sehr hohe Abhängigkeit festgestellt hat (vgl. Ergänzende Informationen).

SSO-06.02B

Die Ausstiegsstrategien sind mit den Plänen zur betrieblichen Kontinuität abgestimmt und umfassen die folgenden Aspekte:

1. Analyse der potenziellen Kosten, Auswirkungen, Ressourcen und des zeitlichen Rahmens für den Übergang einer bezogenen Dienstleistung zu einer alternativen Service-Organisation;
2. Festlegung und Zuweisung von Rollen, Verantwortlichkeiten und ausreichenden Ressourcen zur Durchführung der Aktivitäten für einen Übergang;
3. Festlegung von Erfolgskriterien für den Übergang; und
4. Festlegung von Indikatoren zur Überwachung der Leistung von Dienstleistungen, die den Rückzug aus der Dienstleistung einleiten sollten, wenn die Ergebnisse nicht akzeptabel sind.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: SSO-06.01B, SSO-06.02B

Von einer sehr hohen Abhängigkeit kann insbesondere ausgegangen werden, wenn die bezogene Dienstleistung für die Erbringung des Cloud-Dienstes unverzichtbar ist. Diese Situation liegt vor, wenn der Cloud-Anbieter:

1. Den Cloud-Dienst aus Rechenzentren erbringt, die von Service-Organisationen betrieben werden; oder
2. Einen SaaS-Dienst erbringt und das IaaS oder PaaS eines anderen Cloud-Anbieters nutzt.

Von einer sehr hohen Abhängigkeit kann auch ausgegangen werden, wenn die Dienstleistung nicht innerhalb eines Monats von einer alternativen Service-Organisation bezogen werden kann, da:

1. Sie auf dem Markt einzigartig ist und keine andere Service-Organisation sie liefern kann;
2. Sie durch die Service-Organisation und/oder den Cloud-Anbieter stark individualisiert ist;
3. Sie von keiner anderen Service-Organisation in der erforderlichen Dienstgüte erbracht werden kann; oder
4. Sie spezifisches Wissen erfordert, das nur/hauptsächlich der aktuellen Service-Organisation und nicht dem Cloud-Anbieter zur Verfügung steht.

Ausstiegsstrategien können je nach Art und Grad der Abhängigkeit des Cloud-Dienstes von Drittleistungen und Service-Organisationen in ihrer Komplexität variieren. Die Nutzung eines Cloud-Service-Vermittlers ist ein Beispiel für ein komplexes Szenario. Die in SSO-06.02B aufgeführten Aspekte sollten auf Grundlage der

Ergebnisse der Risikobeurteilung des Cloud-Anbieters berücksichtigt werden. Wurde ein geringerer Grad der Abhängigkeit festgestellt, sind Ausstiegsstrategien oder einzelne Aspekte davon im Sinne dieses Kriteriums nicht verpflichtend.

Korrespondierende Kriterien für Kunden

–

SSO-07 Sicherstellung von Transparenz innerhalb von Service-Organisationen

Basiskriterien

SSO-07.01B

Der Cloud-Anbieter entwirft, implementiert und pflegt Kontrollen, um Transparenz innerhalb seiner Service-Organisationen in Bezug auf die folgenden Aspekte sicherzustellen:

1. Datenflüsse und Schnittstellen zwischen dem Cloud-Anbieter und den vom Cloud-Anbieter genutzten Service-Organisationen sind dokumentiert, einschließlich Maßnahmen zur sicheren Übertragung und Zugriffskontrolle für Daten, die mit Service-Organisationen geteilt werden; und
2. Cloud-Kunden werden über die vom Cloud-Anbieter für Entwicklung und Betrieb des Cloud-Dienstes genutzten Service-Organisationen informiert und darüber, welche Art von Daten diese Service-Organisationen und ihre Subunternehmer verarbeiten.

Cloud-Kunden werden darüber informiert, welche der Service-Organisationen selbst Subunternehmer zur Verarbeitung von Cloud-Kundendaten nutzen.

SSO-07.02B

Der Cloud-Anbieter dokumentiert diese Informationen und überprüft mindestens jährlich ihre Vollständigkeit, Genauigkeit und Aktualität.

Zusatzkriterium (Verschärfend)

SSO-07.01AS, verschärft SSO-07.01B

Der Cloud-Anbieter entwirft, implementiert und pflegt Kontrollen, um Transparenz innerhalb seiner Service-Organisationen in Bezug auf die folgenden Aspekte sicherzustellen:

1. Datenflüsse und Schnittstellen zwischen dem Cloud-Anbieter und den vom Cloud-Anbieter genutzten Service-Organisationen sind dokumentiert, einschließlich Maßnahmen zur sicheren Übertragung und Zugriffskontrolle für Daten, die mit Service-Organisationen geteilt werden; und
2. Cloud-Kunden werden über die vom Cloud-Anbieter für Entwicklung und Betrieb des Cloud-Dienstes genutzten Service-Organisationen und ihre Subunternehmer informiert und darüber, welche Art von Daten diese Service-Organisationen und ihre Subunternehmer verarbeiten.

Cloud-Kunden werden darüber informiert, welche der Service-Organisationen selbst Subunternehmer zur Verarbeitung von Cloud-Kundendaten nutzen.

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: SSO-07.01B

Dieses Kriterium adressiert die Notwendigkeit, Risiken in der Lieferkette zu steuern (z. B. Schwachstellen von Service-Organisationen, Praktiken der Datenverarbeitung, Compliance-Lücken oder

Betriebsunterbrechungen) und diese Risiken an Cloud-Kunden zu kommunizieren, damit diese ihre eigenen Risiken in der Lieferkette wirksam überwachen und steuern können.

Korrespondierende Kriterien für Kunden

–

SSO-08 Steuerung des Austauschs mit Lieferanten funktionaler Komponenten

Basiskriterien

SSO-08.01B

Wenn funktionale Komponenten, die für die Erbringung des Cloud-Dienstes verwendet werden, direkt oder indirekt auf Cloud-Kundendaten zugreifen können, definiert und implementiert der Cloud-Anbieter eine Richtlinie gemäß SP-01, die keinen direkten Austausch zwischen solchen Komponenten und ihren Lieferanten erlaubt.

SSO-08.02B

Darüber hinaus werden gemäß SP-01 Verfahren definiert und implementiert, die vom Cloud-Anbieter verlangen, Inhalte zu genehmigen, die von einem Lieferanten für seine funktionalen Komponenten bereitgestellt oder von einer funktionalen Komponente an ihren Lieferanten gesendet werden sollen. Die Genehmigung erfolgt vor der Übertragung des Inhalts und für jede Übertragung.

SSO-08.03B

Wenn ein Verfahren zur Genehmigung von Inhalten vor ihrer Übertragung automatisiert ist, implementiert der Cloud-Anbieter es unter Verwendung einer Lösung, die Nachvollziehbarkeit über folgende Aspekte enthält:

1. Die Vorgänge, die vom Lieferanten der funktionalen Komponente vorgeschlagen werden;
2. Die Überprüfung, die durchgeführt wird, um den Inhalt vor seiner Übertragung zu genehmigen; und
3. Die Übertragungen, sowohl eingehende als auch ausgehende, die tatsächlich durchgeführt werden.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: SSO-08.01B, SSO-08.02B, SSO-08.03B

Ein Lieferant einer funktionalen Komponente ist typischerweise eine Service-Organisation des Cloud-Anbieters. Die Genehmigung für die Übertragung kann automatisiert werden. Von dem Lieferanten bereitgestellte Inhalte beziehen sich auf Aktualisierungen der funktionalen Komponenten.

Korrespondierende Kriterien für Kunden

–

5.13 Umgang mit Sicherheitsvorfällen (SIM)

Zielsetzung: Gewährleisten eines konsistenten und umfassenden Vorgehens zur Erfassung, Bewertung, Kommunikation und Behandlung von Sicherheitsvorfällen.

SIM-01 Richtlinie für den Umgang mit Sicherheitsvorfällen

Basiskriterien

SIM-01.01B

Richtlinien, Verfahren und technische Maßnahmen sind gemäß SP-01 dokumentiert, kommuniziert und bereitgestellt, um eine schnelle, wirksame und ordnungsgemäße Reaktion auf alle bekannten Sicherheitsvorfälle zu gewährleisten.

Der Cloud-Anbieter definiert Vorgaben zur Klassifizierung, Priorisierung, Eskalation und Ursachenanalysen von Sicherheitsvorfällen und schafft Schnittstellen zum Incident Management und zum Business Continuity Management.

SIM-01.02B

Der Cloud-Anbieter hat ein 'Computer Security Incident Response Team' (CSIRT) eingerichtet, das zur koordinierten Lösung auftretender Sicherheitsvorfälle beiträgt.

SIM-01.03B

Kommunikationskanäle mit den Cloud-Kunden sind identifiziert und festgelegt, und von Sicherheitsvorfällen betroffene Cloud-Kunden werden zeitnah und in angemessener Weise informiert.

SIM-01.04B

Es gibt Verfahren dazu, wie bei einem Sicherheitsvorfall die Daten eines verdächtigen Systems beweisfest gesammelt werden können.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

–

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass sie Benachrichtigungen des Cloud-Anbieters bezüglich sie betreffender Sicherheitsvorfälle erhalten, und dass diese Benachrichtigungen zeitnah an die für die Bearbeitung verantwortliche Stelle weitergeleitet werden, sodass eine angemessene Reaktion erfolgen kann.

SIM-02 Pläne zur Reaktion auf Sicherheitsvorfälle

Basiskriterien

SIM-02.01B

Der Cloud-Anbieter hat einen oder mehrere Pläne zur Reaktion auf Sicherheitsvorfälle dokumentiert, genehmigt und kommuniziert. Die Pläne behandeln alle Phasen der Vorfallreaktion, einschließlich Identifizierung, Eindämmung, Beseitigung, Wiederherstellung und kontinuierlicher Verbesserung. Sie

werden von sachverständigem Personal des Cloud-Anbieters genehmigt und allen relevanten Stakeholdern kommuniziert.

SIM-02.02B

Die Pläne werden mindestens jährlich oder nach Bedarf bewertet und aktualisiert, um Änderungen in der Organisationsstruktur oder der Umgebung widerzuspiegeln.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: SIM-02.01B

Relevante Stakeholder im Sinne dieses Kriteriums sind diejenigen, die den Plan zur Reaktion auf Vorfälle kennen müssen, zum Beispiel aufgrund ihrer Beteiligung an seiner Ausführung oder aufgrund vertraglicher oder regulatorischer Vereinbarungen.

Korrespondierende Kriterien für Kunden

–

SIM-03 Bearbeitung von Sicherheitsvorfällen

Basiskriterien

SIM-03.01B

Sachverständiges Personal des Cloud-Anbieters führt für Ereignisse die einen Sicherheitsvorfall darstellen könnten, Klassifizierungen, Priorisierungen sowie Ursachenanalysen durch.

SIM-03.02B

Die Ergebnisse dieser Ursachenanalysen werden dokumentiert, mit relevanten Stakeholdern geteilt und als Teil von Bewertungs- und Lernprozessen verwendet.

SIM-03.03B

Wenn der Cloud-Anbieter feststellt, dass er externe Unterstützung für die Bearbeitung eines Sicherheitsvorfalls benötigt, wählt er einen Dienst zur Reaktion auf Vorfälle auf der Grundlage von dessen Kompetenz und Vertrauenswürdigkeit oder durch Befolgung der Empfehlungen einer nationalen Cybersicherheitsbehörde aus.

SIM-03.04B

Ein Katalog, der eine eindeutige Identifizierung von Informationssicherheitsvorfällen ermöglicht, die Cloud-Kundendaten betreffen, wird gepflegt und für die Klassifizierung von Informationssicherheitsvorfällen verwendet.

SIM-03.05B

Der Cloud-Anbieter verwendet den Mechanismus zur Klassifizierung von Vorfällen auch für die Korrelation von Informationssicherheitsereignissen und bewertet sowie klassifiziert die korrelierten Informationssicherheitsereignisse entsprechend ihrer Kritikalität.

SIM-03.06B

Alle Dokumente und Nachweise, die Einzelheiten zu Sicherheitsvorfällen im Zusammenhang mit dem Cloud-Dienst enthalten, werden im Einklang mit Kritikalität und regulatorischen Anforderungen sicher und manipulationssicher archiviert.

SIM-03.07B

Der Analyseprozess bietet eine zum Risiko und zur Auswirkung des Sicherheitsvorfalls angemessene Nachvollziehbarkeit, um Ursachen und Angriffsverlauf zu verstehen.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

SIM-03.01AC

Der Cloud-Anbieter simuliert das Identifizieren, Analysieren und Abwehren von Sicherheitsvorfällen und Angriffen mindestens jährlich durch geeignete Tests und Übungen (z. B. Red Team-Übungen).

SIM-03.02AC

Ein integriertes Team aus Forensik-/Incident-Responder-Personal, das speziell dafür qualifiziert ist, Nachweise zu sichern und eine Beweismittelkette zu verwalten, ist eingerichtet oder für seine Dienstleistungen beauftragt.

SIM-03.03AC

Der Cloud-Anbieter verifiziert die Anwendung von Richtlinien und Verfahren des Vorfallmanagements durch Überwachung der Prozesse zur Behandlung von Informationssicherheitsvorfällen. Zeitnahe und angemessene Abhilfemaßnahmen adressieren alle bei der Überwachung festgestellten Abweichungen.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: SIM-03.06B

Regulatorische Anforderungen können es erforderlich machen, eine Beweismittelkette aufrechtzuerhalten, um sicherzustellen, dass Dokumente in Gerichtsverfahren als Beweismittel herangezogen werden können.

Korrespondierende Kriterien für Kunden

–

SIM-04 Dokumentation und Berichterstattung über Sicherheitsvorfälle

Basiskriterien

SIM-04.01B

Nachdem ein Sicherheitsvorfall bearbeitet wurde, wird die Lösung in Übereinstimmung mit den vertraglichen Vereinbarungen dokumentiert und die Dokumentation wird den betroffenen Cloud-Kunden zur abschließenden Kenntnisnahme oder gegebenenfalls als Bestätigung zugesandt.

SIM-04.02B

Informationen zu Sicherheitsvorfällen oder bestätigten Sicherheitsverstößen werden allen betroffenen Cloud-Kunden zur Verfügung gestellt.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

SIM-04.01AC

Der Cloud-Kunde kann Lösungen entweder aktiv genehmigen oder die Lösung wird nach einer bestimmten Frist automatisch genehmigt.

SIM-04.02AC

Zwischen Cloud-Anbieter und Cloud-Kunden ist vertraglich geregelt, welche Daten dem Cloud-Kunden bei Sicherheitsvorfällen zur eigenen Analyse zur Verfügung gestellt werden.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: SIM-04.02B

Sicherheitsverletzungen im Sinne dieses Kriteriums sind Sicherheitsvorfälle, die durch unbefugten Zugriff und Kompromittierung von Cloud-Kundendaten oder der Diensterbringung infolge von Verstößen gegen Richtlinien und Verfahren oder gegen geltende gesetzliche und regulatorische Anforderungen verursacht werden (vgl. HR-04.02B).

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass sie Benachrichtigungen des Cloud-Anbieters bezüglich sie betreffender Sicherheitsvorfälle sowie deren Lösung erhalten, und dass diese Benachrichtigungen zeitnah an die für die Bearbeitung verantwortliche Stelle weitergeleitet werden, sodass eine angemessene Reaktion erfolgen kann.

SIM-05 Verpflichtung des Personals zur Meldung von Sicherheitsvorfällen an eine zentrale Stelle

Basiskriterien

SIM-05.01B

Der Cloud-Anbieter informiert das Personal und externe Geschäftspartner über ihre Verpflichtungen. Falls erforderlich, stimmen sie zu oder werden vertraglich verpflichtet, alle ihnen bekannt werdenden Sicherheitsereignisse, die in direktem Zusammenhang mit dem vom Cloud-Anbieter bereitgestellten Cloud-Dienst stehen, zeitnah an eine zuvor benannte zentrale Stelle des Cloud-Anbieters zu melden.

SIM-05.02B

Der Cloud-Anbieter kommuniziert, dass ‘Fehlmeldungen’ von Ereignissen, die sich im Nachhinein nicht als Vorfälle herausstellen, keine negativen Folgen nach sich ziehen.

SIM-05.03B

Die Meldemechanismen für Informationssicherheitsvorfälle werden dem Personal, den Cloud-Kunden und den Service-Organisationen des Cloud-Anbieters kommuniziert.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

–

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass identifizierte Sicherheitsereignisse, die vom Cloud-Anbieter bearbeitet werden müssen, zeitnah an zuvor benanntes, verantwortliches Personal kommuniziert werden.

Die Identifizierung solcher Sicherheitsereignisse wird durch geeignete Kontrollen unterstützt (vgl. korrespondierendes Kundenkriterium für OPS-10).

SIM-06 Auswertung und Lernprozess

Basiskriterien

SIM-06.01B

Mechanismen sind vorhanden, um Art und Umfang der Sicherheitsvorfälle messen und überwachen sowie wie an unterstützende Stellen melden zu können.

SIM-06.02B

Der Cloud-Anbieter definiert, implementiert und pflegt eine Wissensdatenbank, die Folgendes enthält:

- Sicherheitsvorfälle;
- Maßnahmen, die zur Lösung dieser Sicherheitsvorfälle ergriffen wurden; und
- Informationen über die Assets, die von diesen Sicherheitsvorfällen betroffen sind.

Diese Informationen werden verwendet, um den Klassifizierungskatalog für Vorfälle zu ergänzen (vgl. SIM-03).

SIM-06.03B

Die aus der Überwachung von Sicherheitsvorfällen gewonnenen Informationen und die in der Wissensdatenbank gesammelten Erkenntnisse werden verwendet, um wiederkehrende Sicherheitsereignisse oder Sicherheitsvorfälle oder potenziell erhebliche Sicherheitsvorfälle zu identifizieren, den Bedarf an weitergehenden Schutzmaßnahmen zu bestimmen und diese umzusetzen.

SIM-06.04B

Der Bewertungs- und Lernprozess umfasst die Ergebnisse von Ursachenanalysen, die in Übereinstimmung mit SIM-03 durchgeführt wurden.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: SIM-06.01B

Unterstützende Stellen können externe Service-Organisationen oder Regierungsbehörden wie das BSI sein.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass sie die Erkenntnisse aus vergangenen Sicherheitsvorfällen, die Ihnen mitgeteilt wurden, und die daraus resultierenden Maßnahmen des Cloud-Anbieters in Ihr ISMS aufnehmen und bewerten, ob und wenn ja welche Maßnahmen sie auf ihrer Seite unterstützend ergreifen können.

5.14 Kontinuität des Geschäftsbetriebs und Notfallmanagement (BCM)

Zielsetzung: Planen, Implementieren, Aufrechterhalten und Testen von Verfahren und Maßnahmen zur Kontinuität des Geschäftsbetriebs und für das Notfallmanagement

BCM-01 Business Continuity- und Notfallmanagementsystem

Basiskriterien

BCM-01.01B

Der Cloud-Anbieter betreibt ein Business Continuity- und Notfallmanagementsystem (BCM) gemäß ISO 22301 und/oder BSI 200-4.

BCM-01.02B

Richtlinien und Verfahren für das BCM des Cloud-Dienstes, einschließlich Strategie und Leitlinien, Business Impact Analysen und Plänen zur betrieblichen Kontinuität (engl. Business Continuity Plan (BCP)), sind in Bezug auf die folgenden Aspekte dokumentiert, kommuniziert und gemäß SP-01 verfügbar gemacht:

1. Ziele des BCM;
2. Rollen und Verantwortlichkeiten, Engagement des Managements;
3. Festlegung des Anwendungsbereichs des BCM, Identifizierung relevanter Geschäftsprozesse;
4. Schnittstellen, insbesondere zum Incident Management;
5. Kommunikation mit relevanten Stellen und zuständigen Behörden;
6. Methodik;
7. Berücksichtigung von Risiken;
8. Business Impact Analyse (BIA);
9. Pläne zur betrieblichen Kontinuität;
10. Ressourcenplanung (üblicherweise Teil des BCP);
11. Tests von Plänen zur betrieblichen Kontinuität und regelmäßige Aktualisierungen der BCM-Dokumentation; und
12. Kontinuierliche Verbesserung des BCM.

BCM-01.03B

Die oberste Leitung des Cloud-Anbieters (oder ein Mitglied der obersten Leitung) ist als Prozesseigentümer des Business Continuity- und Notfallmanagements benannt und trägt die Verantwortung für die Etablierung des Prozesses im Unternehmen und die Einhaltung der Richtlinien. Sie sorgt dafür, dass ausreichende Ressourcen für einen effektiven Prozess bereitgestellt werden.

BCM-01.04B

Personen in der Unternehmensleitung und anderen relevanten Führungspositionen demonstrieren Führung und Engagement in Bezug auf dieses Thema, indem sie beispielsweise das Personal dazu auffordern beziehungsweise ermutigen, zu der Effektivität des Business Continuity- und Notfallmanagements aktiv beizutragen.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: BCM-01.01B

Das Basiskriterium kann (muss aber nicht) durch eine Zertifizierung des BCM nach ISO/IEC 22301 erfüllt werden.

Anwendbar auf: BCM-01.02B

Ein BCM kann in das Enterprise Risk Management (ERM) integriert werden, um mehr Effizienz zu erzielen und Management-Silos zu überwinden.

Anwendbar auf: BCM-01.03B

Die Verantwortung der obersten Leitung kann von der obersten Leitung an eine andere Person delegiert werden, solange diese Person den Umfang, die Verantwortlichkeiten und die Fähigkeiten hat, die Cloud-dienst-weite Business-Continuity-Strategie und -Aktivitäten genauso zu steuern, wie die oberste Leitung dies könnte.

Korrespondierende Kriterien für Kunden

–

BCM-02 Business Impact Analyse

Basiskriterien

BCM-02.01B

Der Cloud-Anbieter führt eine Business Impact Analyse durch. In dieser BIA analysiert der Cloud-Anbieter die Auswirkungen der Unterbrechung von Aktivitäten auf seine Organisation in Bezug auf die Entwicklung und den Betrieb des Cloud-Dienstes gemäß den anwendbaren Richtlinien und Verfahren mit mindestens den folgenden Aspekten:

1. Mögliche Szenarien basierend auf einer Risikobeurteilung, die Cybersicherheitsrisiken einschließt;
2. Identifizierung kritischer Produkte und Dienstleistungen;
3. Identifizierung von Abhängigkeiten, einschließlich Prozessen (einschließlich erforderlicher Ressourcen), Anwendungen und Service-Organisationen;
4. Erfassung von Bedrohungen für kritische Produkte und Dienstleistungen;
5. Ermittlung von Auswirkungen resultierend aus geplanten und ungeplanten Ausfällen, Dienstverschlechterungen und die Veränderung im Laufe der Zeit;
6. Bestimmung des maximal tolerierbaren Zeitraums (MTA) von Ausfall und Dienstverschlechterung;
7. Feststellung der Prioritäten zur Wiederherstellung;
8. Festlegung von zeitlichen Zielvorgaben zur Wiederaufnahme kritischer Produkte und der Dienstleistung innerhalb des maximal tolerierbaren Zeitraums (d. h. RTO);
9. Festlegung zeitlicher Zielvorgaben zum maximal tolerierbaren Zeitraum, in dem abgeleitete Cloud-Dienstdaten, Cloud-Anbieterdaten, Kontodaten und, sofern deren Verarbeitung vertraglich vereinbart ist, Cloud-Kundendaten verloren gehen und nicht wiederhergestellt werden können (d.h. RPO); und
10. Abschätzung der zur Wiederaufnahme benötigten Ressourcen.

BCM-02.02B

Die Business Impact Analyse hält die anwendbaren Richtlinien und Verfahren ein und wird in regelmäßigen Abständen, mindestens einmal jährlich oder nach wesentlichen organisatorischen oder umgebungsbedingten Änderungen, überprüft.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: BCM-02.01B

Zu den gemäß dem Basiskriterium zu berücksichtigenden Szenarien gehören beispielsweise der Verlust von Personal, Gebäuden, Infrastruktur und Dienstleistern.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass die Szenarien für einen Ausfall des Cloud-Dienstes oder des Cloud-Anbieters im Rahmen ihrer Business Impact Analyse hinreichend berücksichtigt werden.

BCM-03 Pläne zur betrieblichen Kontinuität

Basiskriterien

BCM-03.01B

Auf der Grundlage der Ergebnisse der Business Impact Analyse werden Pläne zur betrieblichen Kontinuität in konsistenter Weise und gemäß den anwendbaren Richtlinien und Verfahren dokumentiert.

Pläne zur betrieblichen Kontinuität berücksichtigen die folgenden Aspekte:

1. Definierter Zweck und Umfang unter Berücksichtigung der relevanten Abhängigkeiten;
2. Zugänglichkeit und Verständlichkeit der Pläne für Personen, die diese Pläne ausführen sollen;
3. Eigentümerschaft durch mindestens eine benannte Person, die für die Überprüfung, Aktualisierung und Genehmigung zuständig ist;
4. Definierte Kommunikationskanäle, Rollen und Verantwortlichkeiten einschließlich Benachrichtigung des Cloud-Kunden;
5. Wiederherstellungsverfahren, manuelle Übergangslösungen und Referenzinformationen (unter Berücksichtigung der Priorisierung bei der Wiederherstellung von Cloud-Hardwareobjekten und Diensten sowie der Abstimmung mit Cloud-Kunden);
6. Methoden zur Inkraftsetzung der Pläne;
7. Kontinuierlicher Verbesserungsprozess der Pläne;
8. Konsistenz über alle Standorte, Zonen, Regionen und Partitionen hinweg; und
9. Schnittstellen zum Security Incident Management.

BCM-03.02B

Die Pläne zur betrieblichen Kontinuität werden in regelmäßigen Abständen, mindestens einmal jährlich oder nach wesentlichen organisatorischen oder umgebungsbedingten Veränderungen, überprüft.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: BCM-03.01B, BCM-03.02B

Obwohl unterschiedliche Partitionen kein gemeinsames IAM (und damit kein gemeinsames Personal für BCM) nutzen, können Pläne zur betrieblichen Kontinuität zwischen verschiedenen Partitionen geteilt werden, da dieselben Cloud-Dienste bereitgestellt werden.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass bei der Planung der betrieblichen Kontinuität und des Geschäftsplans die Ergebnisse ihrer Business Impact Analyse hinreichend berücksichtigt werden, um für die Auswirkungen eines Ausfalls des Cloud-Dienstes bzw. des Cloud-Anbieters vorzusorgen.

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass die Verfügbarkeit des Cloud-Dienstes, seine Wiederherstellungszeit gemäß den Plänen zur betrieblichen Kontinuität und der Datenverlust des Cloud-Dienstes mit ihren eigenen Verfügbarkeitsanforderungen und tolerierbarem Datenverlust vereinbar sind.

BCM-04 Testen der betrieblichen Kontinuität

Basiskriterien

BCM-04.01B

Pläne zur betrieblichen Kontinuität werden regelmäßig (mindestens jährlich) oder nach wesentlichen organisatorischen oder umgebungsbedingten Änderungen getestet. An den Tests sind betroffene Cloud-Kunden und relevante Dritte (z.B. Service-Organisationen) beteiligt.

BCM-04.02B

Die Tests werden dokumentiert, und die Ergebnisse werden zur Überprüfung der Pläne zur betrieblichen Kontinuität und für zukünftige Business-Continuity-Maßnahmen berücksichtigt.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

BCM-04.01AC

Zusätzlich zu den Tests werden auch Übungen durchgeführt, die u.a. Szenarien aus in der Vergangenheit bereits aufgetretenen Sicherheitsvorfällen hervorgegangen sind.

BCM-04.02AC

Der Cloud-Anbieter verfügt über Verfahren, um sicherzustellen, dass Cloud-Kunden rechtzeitig über geplante Aktivitäten im Zusammenhang mit Business-Continuity-Tests und -Übungen informiert werden, die die Informationssicherheit des Cloud-Dienstes beeinträchtigen könnten (z. B. hinsichtlich seiner Verfügbarkeit). Diese Informationen umfassen den geplanten Zeitrahmen für die Maßnahmen sowie eine Beschreibung der durchzuführenden Arbeiten.

BCM-04.03AC

Der Cloud-Anbieter stellt Cloud-Kunden eine Bewertung der potenziellen Auswirkungen dieser Tests und Übungen hinsichtlich der Informationssicherheit des Cloud-Dienstes sowie Angaben zur Kontaktaufnahme mit dem Cloud-Anbieter zur Verfügung.

BCM-04.04AC

Nach einer abgeschlossenen Übung wird der bestehende Alarm- und Benachrichtigungsplan überprüft und (falls erforderlich) angepasst.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: BCM-04.01B, BCM-04.01AC

Tests finden in erster Linie auf operativer Ebene statt und richten sich an operative Zielgruppen. Dazu gehören z. B.:

1. Test technischer vorsorglicher Schutzmaßnahmen;
2. Funktionstests; und
3. Plan-Review.

Übungen finden zusätzlich auf taktischer und strategischer Ebene statt. Dazu gehören z. B.:

1. Planbesprechung;
2. Personalübung;
3. Stabsrahmenübung;
4. Kommunikations- und Alarmierungsübung;
5. Simulation von Szenarien; und
6. Ernstfall- oder Vollübung.

Relevante Dritte sind insbesondere Service-Organisationen des Cloud-Anbieters, die zur Entwicklung oder zum Betrieb des Cloud-Dienstes beitragen (vgl. Basiskriterien SSO-02 und SSO-06). Ein Cloud-Kunde ist betroffen (im Sinne dieses Kriteriums), wenn der Test oder die Übung zu einer Dienstherabstufung außerhalb des im SLA definierten Niveaus führt oder wenn die Wirksamkeit der Pläne nur getestet werden kann, wenn der Cloud-Kunde Maßnahmen selbst handeln muss.

Anwendbar auf: BCM-04.04AC

Der Begriff ‘Alarm- und Benachrichtigungsplan’ bezieht sich auf das dokumentierte Verfahren zur Alarmierung und Benachrichtigung verantwortlicher Personen und Stakeholder im Falle von Vorfällen oder Störungen.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass die Maßnahmen zur Vorsorge der Auswirkungen eines Ausfalls des Cloud-Dienstes bzw. des Cloud-Anbieters regelmäßig überprüft, aktualisiert, getestet und geübt werden. Der Cloud-Anbieter wird gemäß den vertraglichen Vereinbarungen in die Tests und Übungen einbezogen.

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass die Ergebnisse der BCM-Tests und -Übungen des Cloud-Anbieters in das eigene BCM einfließen und hinsichtlich der Sicherstellung der betrieblichen Kontinuität des Cloud-Kunden umfassend gewürdigt werden.

Bei Tests und Übungen, die den Cloud-Kunden mit einbeziehen und daher eigene Maßnahmen auf Kundenseite bedingen, stellen Cloud-Kunden durch geeignete Kontrollen aus ihrem BCM sicher, dass die entsprechenden Maßnahmen zur Bewältigung gemäß Szenario geübt und getestet werden.

5.15 Compliance (COM)

Zielsetzung: Vermeiden von Verstößen gegen anwendbare gesetzliche, regulatorische, selbstauferlegte oder vertragliche Anforderungen zur Informationssicherheit und Überprüfen der Einhaltung.

COM-01 Identifizierung anwendbarer gesetzlicher, regulatorischer, selbst auferlegter oder vertraglicher Anforderungen

Basiskriterien

COM-01.01B

Die für die Informationssicherheit des Cloud-Dienstes relevanten gesetzlichen, regulatorischen, selbstauferlegten und vertraglichen Anforderungen sowie die Verfahren des Cloud-Anbieters zur Einhaltung dieser Anforderungen sind ausdrücklich definiert und dokumentiert.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

COM-01.01AC

Der Cloud-Anbieter stellt dem Cloud-Kunden auf Anfrage einen Überblick über die im Basiskriterium beschriebenen Verfahren zur Verfügung.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: COM-01.01B

Die Dokumentation des Cloud-Anbieters kann sich unter anderem auf die folgenden Anforderungen beziehen:

1. Anforderungen an den Schutz personenbezogener Daten (z. B. EU-Datenschutz-Grundverordnung);
2. Anforderungen hinsichtlich des Stands der Informationssicherheit des Cloud-Anbieters (z. B. NIS-2-Richtlinie, BSIG soweit auf KRITIS anwendbar);
3. Compliance-Anforderungen aufgrund vertraglicher Verpflichtungen mit Cloud-Kunden (z. B. ISO/IEC 27001, SOC 2, PCI-DSS); und
4. Anforderungen hinsichtlich des Austauschs und der Nutzung von Daten (z. B. EU Data Act).

Die Dokumentation der identifizierten Anforderungen und der Verfahren zur Einhaltung dieser Anforderungen kann sich auf mehrere Dokumente verteilen und muss nicht zwingend in einem einzigen Register oder Verzeichnis festgehalten sein.

Korrespondierende Kriterien für Kunden

–

COM-02 Richtlinie für die Planung und Durchführung von Audits

Basiskriterien

COM-02.01B

Der Cloud-Anbieter dokumentiert und implementiert ein mehrjähriges Auditprogramm, das den Umfang und die Häufigkeit der Audits festlegt. Das Auditprogramm berücksichtigt das Änderungsmanagement, Richtlinien und die Ergebnisse der Risikobeurteilung (vgl. OIS-07).

COM-02.02B

Risikobasierte Richtlinien und Verfahren mit Vorgaben für die Planung und Durchführung von Audits sind gemäß SP-01 dokumentiert, kommuniziert und bereitgestellt und adressieren folgende Aspekte, um nachteilige Auswirkungen des Audits auf den Betrieb des Cloud-Dienstes zu verhindern:

1. Beschränkung auf reinen Lesezugriff für Systemkomponenten gemäß der vereinbarten Auditplanung und wie es für die Durchführung der Aktivitäten notwendig ist;
2. Aktivitäten, die zu Ausfällen, Verschlechterungen des Cloud-Dienstes oder Verletzungen gegen vertragliche Anforderungen führen können, werden während der planmäßigen Wartungsfester oder außerhalb der Zeiten von Lastspitzen durchgeführt;
3. Protokollierung und Überwachung der Aktivitäten;
4. Überprüfung der Konfigurationen von Server- und Netzkomponenten, die in der Verantwortung des Cloud-Anbieters liegen;
5. Penetrationstests für externe Zugangspunkte; und
6. Quellcodeprüfungen intern entwickelter Sicherheitsfunktionen.

Zusatzkriterium (Verschärfend)

COM-02.01AS, verschärft COM-02.01B

Der Cloud-Anbieter dokumentiert und implementiert ein dreijähriges Auditprogramm, das den Umfang und die Häufigkeit der Audits festlegt. Das Auditprogramm berücksichtigt das Änderungsmanagement, Richtlinien und die Ergebnisse der Risikobeurteilung (vgl. OIS-07).

Zusatzkriterium (Erweiternd)

COM-02.01AC

Der Cloud-Anbieter gewährt seinen Cloud-Kunden vertraglich zugesicherte Informations- und Auditrechte. Diese Rechte können einzeln oder im Rahmen von Gruppenaudits ausgeübt werden.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: COM-02.01B, COM-02.01AS

Ein Audit ist ein systematischer, unabhängiger und dokumentierter Prozess zur Erlangung objektiver Nachweise und zu deren objektiver Bewertung, um festzustellen, inwieweit die Auditkriterien erfüllt sind. Audits können als interne Audits durchgeführt werden, manchmal auch als ‘First-Party Audits’, die von oder im Auftrag des Cloud-Anbieters selbst durchgeführt werden. Sie können auch als externe Audits durchgeführt werden, allgemein als ‘Second-Party-’ oder ‘Third-Party-Audits’ bezeichnet. Second-Party-Audits werden von Parteien durchgeführt, die ein Interesse an dem Cloud-Anbieter haben, wie z. B. Cloud-Kunden, oder von anderen Personen in deren Auftrag. Third-Party-Audits werden von unabhängigen Auditorganisationen durchgeführt.

Ein Auditprogramm umfasst Regelungen für eine Reihe von einem oder mehreren Audits, die für einen bestimmten Zeitraum geplant und auf einen bestimmten Zweck ausgerichtet sind. Das Auditprogramm kann beispielsweise einen Zeitraum von drei Jahren umfassen und interne und externe Audits beinhalten.

COM-02 ist vollständig auf virtuelle Infrastruktur und 'Infrastructure as Code' anwendbar. Auditaktivitäten können den Betrieb in einer virtuellen Umgebung dennoch beeinträchtigen. Überprüfungen von Konfigurationen könnten beispielsweise im Rahmen von Codeprüfungen durchgeführt werden.

Anwendbar auf: COM-02.02B

Siehe DEV-05 für weitere Erläuterungen zu Sicherheitsfunktionen.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass auf Ausfälle und Verschlechterungen des Cloud-Dienstes durch solche Audits angemessen reagiert wird.

Soweit vertraglich vereinbarte Informations- und Auditrechte vorliegen, stellen Cloud-Kunden mit geeigneten Kontrollen sicher, dass diese Rechte gemäß eigenen Anforderungen ausgestaltet und wahrgenommen werden.

COM-03 Interne Audits des Informationssicherheitsmanagementsystems

Basiskriterien

COM-03.01B

Sachverständiges Personal überprüft in regelmäßigen Abständen, mindestens jährlich, in internen Audits die Compliance des Informationssicherheitsmanagementsystems mit den relevanten und anwendbaren gesetzlichen, regulatorischen, selbstauferlegten oder vertraglichen Anforderungen (vgl. COM-01). Dies umfasst Prüfungen hinsichtlich:

1. Einhaltung der Richtlinien und Verfahren (vgl. SP-01) innerhalb ihres Verantwortungsbereichs (vgl. OIS-01); und
2. Wirksamkeit organisatorischer und betrieblicher Maßnahmen zur Steuerung der Risiken, die für die Sicherheit von Netz- und Informationssystemen bestehen (vgl. OIS-07).

COM-03.02B

Sachverständiges Personal, das interne Audits durchführt, stehen nicht in der Weisungslinie des Personals des überprüften Bereichs. Wenn die Größe des Cloud-Anbieters eine solche Trennung der Weisungslinie nicht zulässt, werden alternative Maßnahmen umgesetzt, um die Unparteilichkeit der Compliance-Prüfungen zu gewährleisten.

COM-03.03B

Identifizierte Schwachstellen und Abweichungen sowie Nichtkonformitäten mit den anwendbaren gesetzlichen, regulatorischen, selbst auferlegten und vertraglichen Anforderungen, die für die Informationssicherheit des Cloud-Dienstes relevant sind, werden gemäß dem Risikomanagementverfahren (vgl. OIS-07) einer Risikobeurteilung unterzogen. Folgemaßnahmen werden definiert und nachverfolgt (vgl. OPS-18).

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

COM-03.01AC

Auf Grundlage einer Risikobeurteilung (vgl. OIS-07) und der technischen Machbarkeit entscheidet der Cloud-Anbieter, in welchem Umfang interne Audits durch Verfahren ergänzt werden, um anwendbare Anforderungen von Richtlinien und Verfahren in Bezug auf die folgenden Aspekte automatisch zu überwachen:

1. Konfiguration von Systemkomponenten zur Bereitstellung des Cloud-Dienstes innerhalb des Verantwortungsbereichs des Cloud-Anbieters;
2. Leistung und Verfügbarkeit dieser Systemkomponenten;
3. Reaktionszeit auf Vorfälle und Sicherheitsvorfälle; und
4. Wiederherstellungszeit (Zeitraum bis zum Abschluss der Fehlerbehandlung).

COM-03.02AC

Identifizierte Schwachstellen und Abweichungen werden automatisch an das dafür zuständige Personal oder die dafür zuständigen Systemkomponenten des Cloud-Anbieters berichtet, um diese umgehend einer Beurteilung zu unterziehen und erforderliche Maßnahmen einzuleiten.

COM-03.03AC

Der Cloud-Anbieter stellt Cloud-Kunden Schnittstellen zur Verfügung, damit diese die Einhaltung ausgewählter vertraglicher Vereinbarungen in Echtzeit prüfen können.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: COM-03.01B

Sachverständiges Personal sind beispielsweise in der Internen Revision des Cloud-Anbieters tätig oder sind vom Cloud-Anbieter beauftragte fachkundige Dritte, wie etwa Prüfungsgesellschaften, und können über einschlägige Zertifizierungen wie 'Certified Internal Auditor (CIA)' verfügen.

Bezüglich Compliance des ISMS vgl. Abschnitt 9.2 der ISO/IEC 27001, der die Anforderungen an die Durchführung interner Audits eines Informationssicherheitsmanagementsystems (ISMS) und an die Einrichtung eines internen Auditprogramms darlegt. Bei der Einrichtung des/der internen Auditprogramme(s) sollte der Cloud-Anbieter den Umfang und die Kriterien unter Berücksichtigung der Bedeutung der betreffenden Prozesse und der Ergebnisse früherer Audits festlegen. Dieser Ansatz ermöglicht es Cloud-Anbietern, den Auditumfang auf Grundlage der Kritikalität der Einhaltung relevanter gesetzlicher, regulatorischer oder vertraglicher Anforderungen (vgl. COM-01) sowie interner Richtlinien und Verfahren (vgl. SP-01) festzulegen, ohne bei jedem Auditzyklus eine umfassende Überprüfung aller Anforderungen zu verlangen.

Korrespondierende Kriterien für Kunden

–

COM-04 Informationen über die Informationssicherheitsleistung und Managementbewertung des ISMS

Basiskriterien

COM-04.01B

Die oberste Leitung des Cloud-Anbieters wird regelmäßig über die Informationssicherheitsleistung im Anwendungsbereichs des ISMS informiert, um dessen fortdauernde Eignung, Angemessenheit und Wirksamkeit sicherzustellen. Die Informationen werden in die Managementbewertung des ISMS einbezogen. Diese Managementbewertung wird mindestens einmal jährlich durchgeführt.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

COM-04.01AC

Der Cloud-Anbieter definiert und implementiert technische und betriebliche Kennzahlen, die mit seinen Geschäftszielen, seinen Sicherheitsanforderungen und Compliance-Verpflichtungen im Einklang stehen. Diese Kennzahlen werden dokumentiert und in die Managementbewertung des ISMS einbezogen, um ihre fortdauernde Eignung, Angemessenheit und Wirksamkeit sicherzustellen.

COM-04.02AC

Die verantwortlichen Geschäftsbereiche des Cloud-Anbieters berichten der obersten Leitung mindestens jährlich über den Status und die Wirksamkeit der Richtlinien und Verfahren, die für die Managementbewertung des Informationssicherheitsmanagementsystems durch die oberste Leitung relevant sind. Diese Berichterstattung umfasst mindestens:

1. Umgesetzte Änderungen zur Behandlung von Cybersicherheitsrisiken für das in der Richtlinie oder im Verfahren behandelte Thema;
2. Informationssicherheitsvorfälle für das in der Richtlinie oder im Verfahren behandelte Thema und die Nachverfolgung;
3. Leistung der internen Kontrollen hinsichtlich der Informationssicherheit für das in der Richtlinie oder im Verfahren behandelte Thema; und
4. Geplante Änderungen für das in der Richtlinie oder im Verfahren behandelte Thema zur Behandlung von Cybersicherheitsrisiken sowie der Informationssicherheit und Cybersicherheit.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: COM-04.01B

Die oberste Geschäftsleitung ist eine natürliche Person oder Personengruppe, die die endgültige Entscheidung für die Organisation trifft und für diese Entscheidung verantwortlich ist.

Die in der Managementbewertung des ISMS zu behandelnden Aspekte sind in Abschnitt 9.3 der ISO / IEC 27001 aufgeführt.

Korrespondierende Kriterien für Kunden

–

5.16 Umgang mit behördlichen Auskunfts- und Herausgabeverlangen (INQ)

Zielsetzung: Gewährleisten eines angemessenen Umgangs mit behördlichen Auskunfts- und Herausgabeverlangen hinsichtlich juristischer Überprüfung, Information der Cloud-Kunden und Begrenzung des Zugriffs auf oder der Offenlegung von Cloud-Kundendaten oder abgeleiteten Cloud-Dienstdaten.

INQ-01 Juristische Bewertung von behördlichen Auskunfts- und Herausgabeverlangen

Basiskriterien

INQ-01.01B

Behördliche Auskunfts- und Herausgabeverlangen nach Cloud-Kundendaten, abgeleitete Cloud-Dienstdaten und Kontodaten unterliegen einer dokumentierten juristischen Bewertung durch

sachverständiges Personal des Cloud-Anbieters. Die Bewertung bestimmt, ob die Regierungsbehörde über eine anwendbare und rechtsgültige Rechtsgrundlage verfügt und welche weiteren Schritte für das vorliegende behördliche Auskunfts- und Herausgabeverlangen zu unternehmen sind.

INQ-01.02B

Der Zugriff auf oder die Offenlegung von Cloud-Kundendaten, abgeleitete Cloud-Dienstdaten oder Kontodaten als Reaktion auf behördliche Auskunfts- und Herausgabeverlangen ist nur zulässig, wenn der Cloud-Anbieter eine juristische Beurteilung durchgeführt hat. Diese Beurteilung muss bestätigen, dass eine anwendbare und gültige Rechtsgrundlage vorliegt und dass dem behördlichen Auskunfts- und Herausgabeverlangen auf Grundlage dieser stattgegeben werden muss.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: INQ-01.01B

Zu Nachweiszwecken bilden alle behördlichen Auskunfts- und Herausgabeverlangen, die im festgelegten Zeitraum vollständig bearbeitet wurden, die Grundgesamtheit für die Prüfung der Wirksamkeit der Kontrollen im Betrieb zur Erfüllung der Kriterien in dieser Domäne. Alle behördlichen Auskunfts- und Herausgabeverlangen sind in die Grundgesamtheit einzubeziehen, unabhängig davon, ob sie zur Offenlegung von Cloud-Kundendaten oder abgeleiteten Cloud-Dienstdaten geführt haben.

Anwendbar auf: INQ-01.02B

Die Offenlegung von Cloud-Kundendaten an Regierungsbehörden kann die Herausgabe von Verschlüsselungsschlüsseln einschließen. In diesem Fall gilt auch das Verfahren gemäß der INQ-Kriterien. Insbesondere ist mit Verweis auf INQ-03 darauf zu achten, dass durch die Herausgabe eines Schlüssels keine anderen Cloud-Kundendaten beeinträchtigt werden.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass Art und Umfang der behördlichen Auskunfts- und Herausgabeverlangen sowie die damit verbundene Offenlegung ihrer eigenen Daten in ihrem eigenen Risikomanagement behandelt wurden und dass die Nutzung des Cloud-Dienstes nur aufgenommen oder fortgeführt wird, wenn dieses Risiko als akzeptabel eingestuft wurde.

INQ-02 Information der Cloud-Kunden über behördliche Auskunfts- und Herausgabeverlangen

Basiskriterien

INQ-02.01B

Der Cloud-Anbieter informiert die betroffenen Cloud-Kunden unverzüglich, es sei denn, die anwendbare Rechtsgrundlage, auf der das behördliche Auskunfts- und Herausgabeverlangen beruht, verbietet dies oder es liegen klare Anhaltspunkte für rechtswidrige Handlungen im Zusammenhang mit der Nutzung des Cloud-Dienstes vor.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: INQ-02.01B

Dies berührt keine anderen gesetzlichen oder regulatorischen Anforderungen, die eine frühere Information der Cloud-Kunden erfordern.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen durch geeigneten Kontrollen sicher, dass derartige Meldungen entgegengenommen und gemäß eigenen Vorgaben und Möglichkeiten juristisch geprüft werden.

INQ-03 Begrenzung des Zugriffs auf oder der Offenlegung von Daten bei behördlichen Auskunfts- und Herausgabeverlangen

Basiskriterien

INQ-03.01B

Die Verfahren des Cloud-Anbieters zur Gewährung des Zugriffs auf oder zur Offenlegung von Cloud-Kundendaten und abgeleitete Cloud-Dienstdaten im Zusammenhang mit behördlichen Auskunfts- und Herausgabeverlangen stellen sicher, dass die Behörden nur Zugang zu den Daten erhalten oder Einsicht in die Daten nehmen, die Gegenstand des behördlichen Auskunfts- und Herausgabeverlangens sind.

INQ-03.02B

Wenn keine eindeutige Begrenzung der Cloud-Kundendaten und der abgeleiteten Cloud-Dienstdaten möglich ist, anonymisiert oder pseudonymisiert der Cloud-Anbieter diese Daten so, dass Regierungsbehörden sie nur denjenigen Cloud-Kunden zuordnen können, die Gegenstand des behördlichen Auskunfts- und Herausgabeverlangens sind.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

INQ-03.01AC

Der Zugriff und die Tätigkeiten, die von oder im Namen von Ermittlern (im Rahmen des behördlichen Auskunfts- und Herausgabeverlangens) durchgeführt werden, werden vom Cloud-Anbieter überwacht, wie durch den in INQ-01 beschriebenen Prozess festgelegt.

INQ-03.02AC

Rechtzeitige und angemessene Abhilfemaßnahmen behandeln alle Abweichungen, die während der Überwachung der von oder im Namen von Ermittlern (im Rahmen des behördlichen Auskunfts- und Herausgabeverlangens) durchgeführten Tätigkeiten festgestellt werden.

Ergänzende Informationen

Zum Kriterium

–

Korrespondierende Kriterien für Kunden

–

INQ-04 Kommunikation technischer Verfahren zur Datenoffenlegung bei behördlichen Auskunfts- und Herausgabeverlangen

Basiskriterien

INQ-04.01B

Der Cloud-Anbieter dokumentiert die technischen Verfahren je Dienst und sonstige technische Informationen bezüglich der Bereitstellung oder Offenlegung von Cloud-Kundendaten als Reaktion auf gültige behördliche Auskunfts- und Herausgabeverlangen und stellt sie den Cloud-Kunden zur Verfügung.

INQ-04.02B

Art und Umfang der den Cloud-Kunden bereitgestellten Informationen richten sich nach den Bedürfnissen ihres sachverständigen Personals zur Bewertung von Risiken für die Vertraulichkeit der Cloud-Kundendaten. Mindestens werden die folgenden Aspekte behandelt:

1. Der Prozess für die Bereitstellung und Offenlegung von Cloud-Kundendaten als Reaktion auf berechtigte behördliche Auskunfts- und Herausgabeverlangen;
2. Die technischen Fähigkeiten und Beschränkungen des Cloud-Anbieters hinsichtlich der Offenlegung von Cloud-Kundendaten;
3. Protokollierungsmechanismen, die implementiert wurden, um Zugriffe für die Offenlegung von Cloud-Kundendaten aufzuzeichnen;
4. Zugriffsmöglichkeiten für Cloud-Kunden zur Einsicht in solche Protokolle;
5. Methoden und technische Verfahren je Dienst für den Zugriff auf und die Offenlegung von Cloud-Kundendaten; und
6. Gesetze, Vorschriften oder andere rechtliche Mittel und ihre Anwendbarkeit in Bezug auf die Fähigkeit des Cloud-Anbieters, seine Cloud-Kunden über die Bereitstellung und Offenlegung von Cloud-Kundendaten zu informieren.

INQ-04.03B

Das vorgenannte Dokument wird in Übereinstimmung mit SP-01 gepflegt und an den Leitlinien des Cloud-Anbieters zur Minimierung des Zugriffs auf Cloud-Kundendaten (vgl. DEV-01) ausgerichtet, um seine Relevanz und Genauigkeit für Cloud-Kunden sicherzustellen.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: INQ-04.01B, INQ-04.02B, INQ-04.03B

Das Kriterium ist auf Cloud-Kundendaten beschränkt. Der Cloud-Anbieter hat typischerweise Zugriff auf andere Datentypen wie abgeleitete Cloud-Dienstdaten und Kontodaten, sodass eine Ausweitung des Kriteriums auf diese anderen Datentypen möglicherweise nicht zu nützlichen Informationen für das Risikomanagement der Cloud-Kunden führt. Technische Fähigkeiten und Beschränkungen beim Zugriff auf Cloud-Kundendaten umfassen Aspekte wie:

1. Ob die Cloud-Kunden ihre Cloud-Kundendaten unverschlüsselt speichern;
2. Ob der Cloud-Anbieter Cloud-Kundendaten bei der Speicherung und Übertragung verschlüsselt;

3. Ob der Cloud-Anbieter die Fähigkeit hat, Cloud-Kundendaten im Falle solcher behördlichen Auskunfts- und Herausgabeverlangen zu entschlüsseln, und wie diese Fähigkeit zum Zugriff oder zur Offenlegung genutzt wird;
4. Aufbewahrungsfristen für abgeleitete Cloud-Dienstdaten in Bezug zum Cloud-Kunden und ob solche Daten in verschlüsselter Form gespeichert werden;
5. Möglichkeiten zur Entschlüsselung von Cloud-Kundendaten oder zur Extraktion von Cloud-Kundendaten während des Entschlüsselungsprozesses;
6. Offenlegung von Benutzeridentitäten und Anmeldedaten; und
7. Weitere Maßnahmen, die geschaffen wurden oder genutzt werden können, um Cloud-Kundendaten offenzulegen.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass sie eine potenzielle Offenlegung ihrer Cloud-Kundendaten minimieren. Entsprechend dem Schutzbedarf der Cloud-Kundendaten treffen die Cloud-Kunden die Entscheidung, ob der jeweilige Cloud-Dienst genutzt werden kann oder ob das Risiko einer Offenlegung zu hoch ist.

5.17 Produktsicherheit (PSS)

Zielsetzung: bereitstellen aktueller Informationen zur sicheren Konfiguration und über bekannte Schwachstellen des Cloud-Dienstes für Cloud-Kunden, geeigneter Mechanismen zur Fehlerbehandlung und Protokollierung sowie zur Authentisierung und Autorisierung von Cloud-Nutzern der Cloud-Kunden.

PSS-01 Leitlinien und Empfehlungen für Cloud-Kunden

Basiskriterien

PSS-01.01B

Der Cloud-Anbieter veröffentlicht Leitlinien und Empfehlungen für Cloud-Kunden hinsichtlich der sicheren Nutzung des bereitgestellten Cloud-Dienstes. Die darin enthaltenen Informationen sollen den Cloud-Kunden bei der sicheren Konfiguration und Nutzung des Cloud-Dienstes sowie, soweit auf den Cloud-Dienst und den Verantwortungsbereich des Cloud-Kunden anwendbar, bei der Umsetzung korrespondierender Kontrollen des Cloud-Kunden unterstützen.

PSS-01.02B

Die Art und der Umfang der Informationen in den Leitlinien und Empfehlungen für die sichere Nutzung des bereitgestellten Cloud-Dienstes richten sich nach den Bedürfnissen des sachverständigen Personals der Cloud-Kunden, die Informationssicherheitsanforderungen festlegen, umsetzen oder deren Umsetzung überprüfen (z. B. IT, Compliance, Interne Revision). Die Informationen in den Leitlinien und Empfehlungen für die sichere Nutzung des Cloud-Dienstes behandeln, soweit auf den Cloud-Dienst anwendbar, die folgenden Aspekte:

1. Verfahren für eine sichere Konfiguration;
2. Informationsquellen zu bekannten Schwachstellen und Aktualisierungsmechanismen;
3. Malware-Schutz für Container oder virtuelle Maschinen;
4. Mechanismen zur Fehlerbehandlung und Protokollierung;
5. Authentisierungsmechanismen;
6. Rahmenwerk für Rollen und Berechtigungen einschließlich Kombinationen, die zu einem erhöhten Risiko führen;

7. Dienste und Funktionen für die Administration des Cloud-Dienstes durch privilegierte Cloud-Nutzer;
8. Korrespondierende Kontrollen der Cloud-Kunden;
9. Verschlüsselungsmechanismen und -dienste;
10. Verhinderung von Datenabfluss;
11. Sichere Anwendungsentwicklung und sicherer Betrieb auf dem Cloud-Dienst;
12. Anweisungen zur Nutzung und Konfiguration defensiver Mechanismen;
13. Anweisungen zur Nutzung und Konfiguration von Mechanismen verteilter Weitverkehrsarchitekturen;
14. Methoden, die zur Trennung von Kundendaten verwendet werden (vgl. OPS-30 und OPS-31);
15. Wie Cybersicherheitsrisiken im Zusammenhang mit der Nutzung des Cloud-Dienstes durch geeignete Protokollierungs- und Überwachungsmechanismen adressiert werden können; und
16. Eingabe und Ausgabeschnittstellen, über die auf den Cloud-Dienst durch andere Cloud-Dienste oder IT-Systeme von Cloud-Kunden zugegriffen werden kann (vgl. PI-01).

PSS-01.03B

Der Cloud-Anbieter beschreibt in der Cloud-Nutzerdokumentation alle erforderlichen korrespondierenden Kontrollen der Cloud-Kunden und entsprechende Erläuterungen dazu, sodass der Cloud-Kunde über ausreichende Informationen für ein angemessenes Risikomanagement auf seiner Seite verfügt.

PSS-01.04B

Die oben genannten Informationen werden so gepflegt, dass sie auf den bereitgestellten Cloud-Dienst, in der für den produktiven Einsatz vorgesehenen Version, anwendbar sind.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

PSS-01.01AC

Der Cloud-Anbieter informiert Cloud-Kunden zeitnah über geplante Änderungen am Cloud-Dienst, damit die betroffenen Cloud-Kunden mit organisatorischen und technischen Maßnahmen angemessen reagieren können, bevor die Änderungen wirksam werden.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: PSS-01.01B

In einer Cloud-Umgebung werden Sicherheitsverantwortlichkeiten zwischen dem Cloud-Anbieter und dem Cloud-Kunden geteilt, wobei sie je nach Servicemodel — Infrastructure as a Service (IaaS), Platform as a Service (PaaS) oder Software as a Service (SaaS) — variieren. Leitlinien zu den korrespondierenden Kontrollen helfen Cloud-Kunden, ihre Rollen und Verantwortlichkeiten innerhalb des Shared Responsibility Model auch im Hinblick auf Sicherheits- und Betriebsmanagement zu verstehen (vgl. OIS-03). Durch das Angebot detaillierter Leitlinien werden Cloud-Kunden in die Lage versetzt, die erforderlichen Kontrollen zu verstehen und umzusetzen, die in ihren Verantwortungsbereich fallen. Der Detaillierungsgrad und der Umfang können je nach Art des bereitgestellten Cloud-Dienstes variieren.

Beispiele für defensive Mechanismen sind Payload-Filterung, Traffic Shaping, Load Balancing, Load Shedding und DDoS-Abwehr.

Beispiele für Mechanismen verteilter Weitverkehrsarchitekturen sind Fehlertoleranz durch Replikation, die Vermeidung lokalisierter Ausfälle und Katastrophen durch die Nutzung mehrerer Cloud-Regionen sowie die Verringerung der aufseiten der Cloud-Nutzer wahrgenommenen Latenz durch die geografische Verteilung von Dienstendpunkten.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass die Informationen des Cloud-Anbieters verwendet werden, um Richtlinien, Rahmenwerke und Maßnahmen für die sichere Konfiguration und Nutzung (gemäß ihrer eigenen Risikobeurteilung) des Cloud-Dienstes abzuleiten. Die Einhaltung dieser Richtlinien, Rahmenwerke und Maßnahmen wird überprüft. Änderungen an den Informationen werden zeitnah hinsichtlich ihrer Auswirkungen auf diese Dokumente bewertet und erforderliche Änderungen werden umgesetzt.

PSS-02 Identifikation von Schwachstellen des Cloud-Dienstes

Basiskriterien

PSS-02.01B

Der Cloud-Anbieter überprüft den Cloud-Dienst durch geeignete Verfahren auf Schwachstellen, die durch den Softwareentwicklungsprozess in den Cloud-Dienst einfließen können.

PSS-02.02B

Die Verfahren zur Identifkation solcher Schwachstellen sind Teil des Softwareentwicklungsprozesses und umfassen in Abhängigkeit von einer Risikobeurteilung die folgenden Aktivitäten:

1. Statische Code-Analysen;
2. Dynamische Code-Analysen;
3. Code-Reviews durch sachverständiges Personal des Cloud-Anbieters;
4. Durchführung von Sicherheitsprüfungen auf Grundlage einer Liste von Softwarekomponenten oder einer Software Bill of Materials; und
5. Einholen von Information über bestätigte Schwachstellen in Software-Bibliotheken, die von Dritten bereitgestellt und im eigenen Cloud-Dienst genutzten werden.

PSS-02.03B

Der Schweregrad identifizierter Schwachstellen wird nach definierten Kriterien beurteilt und Maßnahmen zur zeitnahen Behebung oder Mitigation eingeleitet.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

PSS-02.01AC

Die Verfahren zur Indentifikation solcher Schwachstellen umfassen außerdem jährliche Code-Reviews oder Sicherheits-Penetrationstests durch qualifizierte externe Dritte.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: PSS-02.01B, PSS-02.02B, PSS-02.03B, PSS-02.01AC

Bekannte Schwachstellen in extern bezogenen Systemkomponenten (z. B. Betriebssystemen), die für die Entwicklung und Bereitstellung des Cloud-Dienstes verwendet werden, aber nicht den

Softwareentwicklungsprozess des Cloud-Anbieters durchlaufen, sind Gegenstand des Kriteriums OPS-25 (Management von Schwachstellen, Vorfällen und Fehlern - Schwachstellenscans).

Korrespondierende Kriterien für Kunden

–

PSS-03 Information der Cloud-Kunden über bekannte Schwachstellen

Basiskriterien

PSS-03.01B

Der Cloud-Anbieter stellt durch einen koordinierten Prozess sicher, dass Cloud-Kunden Zugang zu regelmäßig aktualisierten Informationen über bekannte Schwachstellen im Zusammenhang mit dem Cloud-Dienst haben, die die Informationssicherheit des Cloud-Kunden beeinträchtigen können. Dies umfasst:

1. Bekannte ausgenutzte Schwachstellen;
2. Bekannte Schwachstellen, für die ein Patch und/oder Maßnahmen zur Risikomitigation vom Cloud-Anbieter bereitgestellt werden (N-Day-Schwachstellen), mit geeigneten Verweisen auf den Patch/die Maßnahme; und
3. Bekannte Schwachstellen, für die ein Patch und/oder Maßnahmen zur Risikomitigation vom Cloud-Anbieter voraussichtlich nicht bereitgestellt werden (Forever-Day-Schwachstellen), zusammen mit einer Begründung, warum sie nicht bereitgestellt werden.

Diese betreffen den bereitgestellten Cloud-Dienst und vom Cloud-Anbieter bereitgestellte Assets, die die Cloud-Kunden innerhalb ihres eigenen Verantwortungsbereichs installieren, bereitstellen oder betreiben müssen.

PSS-03.02B

Die den Cloud-Kunden bereitgestellten Informationen umfassen, soweit verfügbar, eine Beschreibung anwendbarer und geplanter Abhilfemaßnahmen oder mitigierender Maßnahmen für die identifizierten Schwachstellen.

PSS-03.03B

Diese Schwachstellen werden auch auf Grundlage von Daten aus einer Liste von Softwarekomponenten oder von Daten einer Software Bill of Materials identifiziert.

PSS-03.04B

Die Schwachstellen werden mit Verweisen auf die Common Vulnerabilities and Exposures (CVE) dargestellt, und die Bewertungen basieren auf:

1. dem Common Vulnerability Scoring System (CVSS); und
2. dem Exploit Prediction Scoring System (EPSS), der Stakeholder-Specific Vulnerability Categorization (SSVC) oder anderen ähnlichen Bewertungsmetriken

in der zum Zeitpunkt der Bewertung gültigen neuesten Version.

Diese Informationen sind für alle Cloud-Kunden zugänglich und unterstützen deren Risikobeurteilung und Folgemaßnahmen, gegebenenfalls mit Verweisen auf schwachstellenspezifische Maßnahmen.

PSS-03.05B

Der Cloud-Anbieter konsultiert mindestens täglich die Schwachstelleninformationen seiner Lieferanten und Service-Organisationen. Die veröffentlichten Schwachstellen werden hinsichtlich ihrer potenziellen Auswirkungen auf den Cloud-Dienst analysiert und gemäß dem Prozess zur Behandlung von

Schwachstellen behandelt (vgl. OPS-18). Falls der Lieferant oder die Service-Organisation keine täglichen Informationen bereitstellt, wird das damit verbundene Risiko gemäß OIS-07 gesteuert.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

PSS-03.01AC

Vom Cloud-Anbieter bereitgestellte Assets, die Cloud-Kunden in ihrem Verantwortungsbereichs selbst installieren, bereitstellen oder betreiben müssen, sind mit automatischen Aktualisierungsmechanismen ausgestattet. Nach einer Freigabe durch den jeweiligen Cloud-Kunden können Softwareaktualisierungen darüber durch den Cloud-Anbieter ausgerollt werden.

PSS-03.02AC

Schwachstellen werden in Übereinstimmung mit dem Common Security Advisory Framework Version 2.0 oder höher und, wie in der Technischen Richtlinie TR-03191 des BSI festgelegt, offengelegt.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: PSS-03.01B

Dieses Kriterium unterstützt Transparenz im Management von Schwachstellen. Es verlangt vom Cloud-Anbieter, Cloud-Kunden proaktiv über Schwachstellen zu informieren, die aufgrund des Fehlens von Abhilfeoptionen ein Restrisiko darstellen können. Solche Offenlegungen helfen Cloud-Kunden, ihre Exponierung zu bewerten und bei Bedarf kompensierende Kontrollen umzusetzen.

Informationen über bekannte ausgenutzte Schwachstellen und bekannte Schwachstellen können beispielsweise Informationen über Schwachstellen in Autorisierungsmechanismen umfassen, die aus dem im Rahmen von PSS-09 durchgeführten Validierungsprozess gewonnen wurden.

Anwendbar auf: PSS-03.03B

Obwohl der Cloud-Anbieter die Schwachstellen auf Grundlage von einer Liste von Softwarekomponenten oder SBOM-Daten identifizieren muss, um dieses Kriterium zu erfüllen, müssen diese Liste von Softwarekomponenten oder SBOM-Daten zur Erfüllung des Kriteriums nicht an den Cloud-Kunden übergeben werden.

Anwendbar auf: PSS-03.04B

Schwachstellenspezifische Maßnahmen können beispielsweise im ‘Vulnerability, Exploitability eXchange’ (VEX) oder in den ‘Common Security Advisory Frameworks’ (CSAF) gefunden werden.

Das Common Vulnerability Scoring System (CVSS) bewertet den Schweregrad identifizierter Schwachstellen (vgl. OPS-18). Das Exploit Prediction Scoring System (EPSS), die Stakeholder-Specific Vulnerability Categorization (SSVC) und andere ähnliche Bewertungsmetriken priorisieren Maßnahmen, die zur Behebung oder Risikomitigation identifizierter Schwachstellen umzusetzen sind. Beide Arten von Systemen sollten im Zusammenspiel verwendet werden.

Anwendbar auf: PSS-03.05B

Es kann verschiedene Wege geben, Informationen über Schwachstellen von Lieferanten und Service-Organisationen zu erhalten. Das Kriterium verlangt keinen bestimmten Weg zur Beschaffung dieser Informationen, sondern dass die Informationen mindestens täglich eingeholt werden.

Anwendbar auf: PSS-03.01AC, PSS-03.02AC

Vom Cloud-Anbieter bereitgestellte Assets, welche die Cloud-Kunden in ihrem Verantwortungsbereich selbst installieren, bereitstellen oder betreiben müssen, sind beispielsweise lokale Software-Clients und Apps sowie Werkzeuge zur Integration des Cloud-Dienstes.

Falls der Cloud-Dienst auf andere Cloud-Dienste angewiesen ist, sollten diese Informationen die Schwachstellen dieser anderen Cloud-Dienste einbeziehen oder auf sie verweisen, damit dieses Kriterium erfüllt ist.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass die erhaltenen Schwachstelleninformationen zeitnah in ihr eigenes Risikomanagement einfließen, bewertet und, falls erforderlich, im eigenen Verantwortungsbereich berücksichtigt werden.

PSS-04 Fehlerbehandlungs- und Protokollierungsmechanismen

Basiskriterien

PSS-04.01B

Der bereitgestellte Cloud-Dienst ist mit Fehlerbehandlungs- und Protokollierungsmechanismen für Systemkomponenten ausgestattet, die in den Verantwortungsbereich des Cloud-Kunden fallen. Diese ermöglichen es Cloud-Kunden, sicherheitsrelevante Informationen über den Sicherheitsstatus des Cloud-Dienstes sowie die von ihm bereitgestellten Daten, Dienste oder Funktionen zu erhalten.

PSS-04.02B

Diese Mechanismen sind so gestaltet, dass sie identifizierte Sicherheitsrisiken im Zusammenhang mit der Nutzung des Cloud-Dienstes adressieren. Der Cloud-Anbieter identifiziert und dokumentiert diese Risiken im Voraus und stellt sicher, dass die implementierten Protokollierungsmechanismen relevante Ereignisse und Aktivitäten erfassen.

PSS-04.03B

Die Informationen sind so detailliert, dass Cloud-Kunden damit die folgenden Aspekte prüfen können, soweit sie auf den Cloud-Dienst anwendbar sind:

1. Auf welche Cloud-Kundendaten und abgeleitete Cloud-Dienstdaten, Dienste oder Funktionen, die dem Cloud-Kunden innerhalb des Cloud-Dienstes zur Verfügung stehen, von wem, wann und von wo zugegriffen wurde (Audit Logs);
2. Störungen beim Verarbeiten von automatischen oder manuellen Aktionen; und
3. Änderungen an sicherheitsrelevanten Konfigurationsparametern, Fehlerbehandlungs- und Protokollierungsmechanismen, Cloud-Nutzerauthentisierung, Aktionsautorisierung, Kryptographie und Kommunikationssicherheit.

PSS-04.04B

Die protokollierten Informationen sind vor unautorisierten Zugriffen und unautorisierten Änderungen geschützt und können vom Cloud-Kunden gelöscht werden.

PSS-04.05B

Soweit anwendbar, kann der Cloud-Kunde die Protokollierung aktivieren oder deaktivieren und den Umfang sowie den Detaillierungsgrad der Protokollierung steuern, die der Cloud-Dienst bereitstellt.

PSS-04.06B

Die Protokollierung von Aktionen der Management-Ebene durch die Cloud-Kunden deckt alle relevanten Systeme und Systemkomponenten ab.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

PSS-04.01AC

Cloud-Kunden können sicherheitsrelevante Informationen über dokumentierte Schnittstellen abrufen, die für die Weiterverarbeitung dieser Informationen im Rahmen ihres Security Information and Event Management (SIEM) geeignet sind.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: PSS-04.01B, PSS-04.02B, PSS-04.03B, PSS-04.04B, PSS-04.05B, PSS-04.06B, PSS-04.01AC

Im Gegensatz zum Zusatz-Kriterium von OPS-15, das sowohl Systemkomponenten unter der Verantwortung des Cloud-Anbieters als auch Systemkomponenten unter der Verantwortung des Cloud-Kunden abdeckt, ist der Geltungsbereich dieses Kriteriums strikt auf Systemkomponenten beschränkt, die nur unter der Verantwortung des Cloud-Kunden stehen.

Der Umfang der Protokollierung hängt vom Cloud-Dienst ab. Daher kann es Cloud-Dienste geben, wie SaaS-Dienste, bei denen die Anzahl der Systemkomponenten unter der Verantwortung des Cloud-Kunden sehr begrenzt ist und auf die dieses Kriterium nicht anwendbar ist.

Anwendbar auf: PSS-04.04B

Die Löschung der protokollierten Informationen durch den Cloud-Kunden kann beispielsweise dadurch umgesetzt werden, dass dem Cloud-Kunden ein Prozess zur Beantragung dieser Löschung bereitgestellt wird.

Korrespondierende Kriterien für Kunden

Falls der Cloud-Dienst mit Fehlerbehandlungs- und Protokollierungsmechanismen ausgestattet ist, müssen Cloud-Kunden diese aktivieren und entsprechend festgelegten Anforderungen konfigurieren. Der Cloud-Kunde muss hierfür sein eigenes Informationssicherheitsmanagement einbeziehen.

PSS-05 Authentisierungsmechanismen

Basiskriterien

PSS-05.01B

Der bereitgestellte Cloud-Dienst ist mit Authentisierungsmechanismen ausgestattet, die für Cloud-Nutzer, IT-Komponenten oder Anwendungen innerhalb des Verantwortungsbereichs der Cloud-Kunden Multi-Faktor-Authentisierung erzwingen können. Diese Authentisierungsmechanismen sind an allen Zugangspunkten eingerichtet, die es Cloud-Nutzern, IT-Komponenten oder Anwendungen ermöglichen, mit dem Cloud-Dienst zu interagieren.

PSS-05.02B

Für privilegierte Cloud-Nutzer, IT-Komponenten oder Anwendungen unter der Verantwortung des Cloud-Kunden können diese Authentisierungsmechanismen vom Cloud-Kunden erzwungen werden.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

PSS-05.01AC

Der Cloud-Dienst bietet Out-of-Band-Authentisierung (OOB-Authentisierung), bei der die Faktoren über unterschiedliche Kanäle übertragen werden (z. B. Internet und Mobilfunknetz).

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: PSS-05.01B, PSS-05.02B, PSS-05.01AC

IT-Komponenten im Sinne dieses Kriteriums sind eigenständig nutzbare Objekte mit externen Schnittstellen, die mit anderen IT-Komponenten verbunden werden können.

Zugangspunkte im Sinne dieses Kriteriums sind solche, die von Cloud-Nutzern, IT-Komponenten oder Anwendungen über Netze erreicht werden können (für Cloud-Nutzer beispielsweise der Anmeldebildschirm auf der öffentlich zugänglichen Website des Cloud-Anbieters).

Multi-Faktor-Authentisierung sollte erzwungen werden und kann z. B. mit kryptographischen Zertifikaten, Smartcards oder Token durchgeführt werden.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass die vom Cloud-Dienst angebotenen Authentisierungsmechanismen gemäß den Vorgaben des Identitäts- und Berechtigungsmanagement des Cloud-Kunden genutzt werden. Falls Cloud-Kunden virtuelle Maschinen oder Container mit dem Cloud-Dienst betreiben, stellen sie mit geeigneten Kontrollen sicher, dass die Authentisierungsmechanismen container-spezifische Szenarien abdecken, wie etwa Multi-Faktor-Authentisierung für Container-Hosts und den Zugriff auf Registries.

PSS-06 Session Management

Basiskriterien

PSS-06.01B

Zum Schutz von Vertraulichkeit, Verfügbarkeit, Integrität und Authentizität während der Interaktionen mit dem Cloud-Dienst wird ein geeignetes Session Management verwendet, das dem Stand der Technik entspricht und gegen bekannte Angriffe geschützt ist.

PSS-06.02B

Es werden Mechanismen implementiert, die eine Session ungültig machen, nachdem erkannt wurde, dass sie inaktiv ist. Die Inaktivität kann durch Zeitmessung erkannt werden. In diesem Fall kann das Zeitintervall vom Cloud-Anbieter oder - soweit technisch möglich - vom Cloud-Kunden konfiguriert werden.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: PSS-06.01B

Bekannte Angriffe umfassen Manipulation, Fälschung, Sessionübernahme, Denial-of-Service-Angriffe, Enveloping-, Replay- und Null-Cipher-Angriffe.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass sie die Schutzfunktionen des Session Managements des Cloud-Dienstes gemäß den Vorgaben aus ihrem eigenen ISMS nutzen. Außerdem legen sie die Zeitspanne, nach der eine Session ungültig wird, nach den Vorgaben aus ihrem eigenen ISMS fest.

PSS-07 Vertraulichkeit von Authentisierungsinformationen

Basiskriterien

PSS-07.01B

Falls Passwörter als Authentisierungsinformationen für den Cloud-Dienst verwendet werden, stellt der Cloud-Anbieter den Cloud-Kunden die folgenden Verfahren zum Schutz der Vertraulichkeit der Passwörter zur Verfügung:

1. Cloud-Nutzer können das Passwort zunächst selbst erstellen oder müssen ein Initialpasswort bei der ersten Anmeldung am Cloud-Dienst ändern. Ein Initialpasswort verliert nach maximal 14 Tagen seine Gültigkeit;
2. Bei der Erstellung von Passwörtern wird die Einhaltung der Längen- und Komplexitätsanforderungen des Cloud-Anbieters (vgl. IAM-08) oder des Cloud-Kunden technisch erzwungen;
3. Der Cloud-Nutzer wird über die Änderung oder Zurücksetzung des Passworts informiert. Verfahren zum Zurücksetzen von Passwörtern sind höchstens 48 Stunden gültig. Nachdem das Zurücksetzungsverfahren verwendet wurde, ist das Passwort vom Cloud-Nutzer zu ändern; und
4. Die serverseitige Speicherung verwendet Hashfunktionen in Kombination mit Salt-Werten, die beide dem Stand der Technik entsprechen.

PSS-07.02B

Regeln und Empfehlungen werden den Cloud-Kunden so mitgeteilt, wie sie für die Cloud-Nutzer unter ihrer Verantwortung anwendbar sind. Der Cloud-Anbieter bietet den Cloud-Kunden Werkzeuge für die Verwaltung und Erzwingung dieser Regeln an.

PSS-07.03B

Bei der Verteilung von Zugangsdaten überprüft der Cloud-Anbieter die Identität des Empfängers, validiert die Anfrage und schützt die Zugangsdaten durch den Einsatz zusätzlicher Sicherheitsmechanismen wie Multi-Faktor-Authentisierung.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: PSS-07.01B

Der Stand der Technik in Bezug auf kryptographische Hashfunktionen wird in der aktuellen Version der Technischen Richtlinie TR-02102-1 ‘Kryptographische Verfahren: Empfehlungen und Schlüssellängen’ des BSI beschrieben.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass sie hinreichend sichere Passwörter verwenden (vgl. IAM-08) und die vom Cloud-Anbieter bereitgestellten Verfahren zum Schutz der Vertraulichkeit der Passwörter entsprechend ihrer eigenen Einschätzung einsetzen und dass die mit ihrer eigenen Wahl verbundenen Risiken unautorisierter Zugriffe getragen werden. Falls Cloud-Kunden virtuelle Maschinen oder Container mit dem Cloud-Dienst betreiben, stellen sie mit geeigneten Kontrollen sicher, dass die Vertraulichkeit der Informationen auch bei der Zuweisung von Authentisierungsinformationen für die virtuellen Maschinen oder Container gewährleistet ist.

PSS-08 Rahmenwerk für Rollen und Berechtigungen

Basiskriterien

PSS-08.01B

Der bereitgestellte Cloud-Dienst umfasst ein Rahmenwerk für Rollen und Berechtigungen für Cloud-Nutzer des Cloud-Kunden. Dieses Rahmenwerk ermöglicht es Cloud-Nutzern, ihre eigenen Zugriffsrechte zu verwalten. Es beschreibt Zugriffsrechte und Rollen für die vom Cloud-Dienst bereitgestellten Funktionen. Cloud-Kunden können relevante Parameter der Zugriffskontrolle selbst konfigurieren.

PSS-08.02B

Die Zugriffsrechte und Rollen sind geeignet, Cloud-Nutzern des Cloud-Kunden die Verwaltung von Zugriffsrechten und Zugangsberechtigungen in Übereinstimmung mit dem Prinzip der geringsten Berechtigung (‘Least-Privilege-Prinzip’) und soweit dies für die Erfüllung von Aufgaben erforderlich ist (‘Need-to-know-Prinzip’) zu ermöglichen und das Prinzip der funktionalen Trennung zwischen ausführenden und kontrollierenden Funktionen (‘Separation of Duties’) umzusetzen.

PSS-08.03B

Der bereitgestellte Cloud-Dienst ist mit einer Funktionalität ausgestattet, die Cloud-Kunden dabei unterstützt, Cloud-Nutzerzugriffsrechte unter ihrer Verantwortung zu überprüfen.

PSS-08.04B

Falls der Cloud-Dienst die Verwaltung von Kundenidentitäten umfasst, ist der bereitgestellte Cloud-Dienst für eine bestimmte Kundenidentität mit einer Funktionalität ausgestattet, eine Liste der dieser Identität derzeit gewährten Zugriffsrechte gemäß den vertraglichen Bedingungen bereitzustellen.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: PSS-08.01B

Bei IaaS würde ein Rahmenwerk für Rollen und Berechtigungen unter anderem die Zugriffsrechte und Rollen für die folgenden Funktionen des Cloud-Dienstes beschreiben:

1. Verwaltung der Zustände virtueller Maschinen (Start, Pause, Stopp) sowie ihrer Migration oder Überwachung;
2. Verwaltung verfügbarer Images, die zur Erstellung virtueller Maschinen verwendet werden können; und
3. Verwaltung virtueller Netze (z. B. Konfiguration virtueller Router und Switches).

Anwendbar auf: PSS-08.03B

Diese Funktionalität kann z. B. das Abrufen einer Liste aller Rollen und Zugriffe umfassen, die der Cloud-Kunde aktiviert hat, und wann sie zuletzt geändert wurden.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass:

1. Sie das vom Cloud-Anbieter angebotene Rahmenwerk für Rollen und Berechtigungen sowie die begleitenden Funktionalitäten aktiv nutzen;
2. Die Erteilung von Berechtigungen an Cloud-Nutzer in ihrem Verantwortungsbereich einer Autorisierung unterliegt; und
3. Die Angemessenheit der zugewiesenen Berechtigungen regelmäßig überprüft wird und Berechtigungen bei erforderlichen Änderungen (z. B. Ausscheiden von Personal) zeitnah angepasst oder entzogen werden.

PSS-09 Autorisierungsmechanismen

Basiskriterien

PSS-09.01B

Der Zugriff auf die vom Cloud-Dienst bereitgestellten Funktionen ist durch Zugriffskontrollen (Autorisierungsmechanismen) beschränkt, die überprüfen, ob Cloud-Nutzer, IT-Komponenten oder Anwendungen berechtigt sind, bestimmte Aktionen auszuführen.

PSS-09.02B

Der Cloud-Anbieter validiert die Funktionalität der Autorisierungsmechanismen, bevor neue Funktionen für Cloud-Kunden verfügbar gemacht werden, sowie bei Änderungen an den Autorisierungsmechanismen bestehender Funktionen (vgl. DEV-07).

PSS-09.03B

Falls Validierungsaktivitäten Schwachstellen offenlegen, werden die Verfahren zur Indentifikation von Schwachstellen (vgl. PSS-02) angewendet und Maßnahmen zur zeitnahen Behebung oder Risikomitigation eingeleitet.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

PSS-09.01AC

Zugriffskontrollen sind attributbasiert, um granulare und kontextbezogene Prüfungen gegen mehrere Attribute eines Cloud-Nutzers, einer IT-Komponente oder einer Anwendung zu ermöglichen (z. B. Rolle, Standort, Authentisierungsmethode).

Ergänzende Informationen

Zum Kriterium

–

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass Systemkomponenten unter ihrer Verantwortung regelmäßig auf Schwachstellen überprüft und diese durch geeignete Maßnahmen mitigiert werden.

PSS-10 Software-defined Networking

Basiskriterien

PSS-10.01B

Falls der Cloud-Dienst Funktionen für softwaredefinierte Netze (SDN) anbietet, wird die Vertraulichkeit der Cloud-Kundendaten durch geeignete SDN-Verfahren sichergestellt.

PSS-10.02B

Der Cloud-Anbieter validiert die Funktionalität der SDN-Funktionen, bevor neue SDN-Merkmale für Cloud-Kunden bereitgestellt oder bestehende SDN-Merkmale geändert werden. Identifizierte Mängel werden risikoorientiert beurteilt und korrigiert.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

–

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: PSS-10.01B, PSS-10.02B

Dieses Kriterium ist für das Servicemodell SaaS typischerweise nicht anwendbar.

Geeignete SDN-Methoden zur Erhöhung der Vertraulichkeit sind beispielsweise L2-Overlay-Netze (Tagging) oder Tunneling/Kapselung.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass sie die Funktionalität von SDN-Merkmalen für ihre individuellen Anwendungsfälle validieren, bevor sie neu eingeführte Fähigkeiten oder geänderte bestehende nutzen.

PSS-11 Images für virtuelle Maschinen und Container

Basiskriterien

PSS-11.01B

Falls Cloud-Kunden virtuelle Maschinen oder Container mit dem Cloud-Dienst betreiben, ist der bereitgestellte Cloud-Dienst mit Funktionalitäten ausgestattet, die die folgenden Aspekte sicherstellen:

1. Cloud-Kunden können die Auswahl von Images virtueller Maschinen oder Containern nach ihren Vorgaben einschränken, sodass Cloud-Nutzer des Cloud-Kunden nur die gemäß diesen Einschränkungen freigegebenen Images oder Container starten können;
2. Falls der Cloud-Anbieter dem Cloud-Kunden Images virtueller Maschinen oder Container bereitstellt, informiert der Cloud-Anbieter den Cloud-Kunden in angemessener Weise über die gegenüber der vorherigen Version vorgenommenen Änderungen;
3. Vom Cloud-Anbieter bereitgestellte Images sind mit Informationen zu ihrer Herkunft gekennzeichnet; und
4. Die vom Cloud-Anbieter bereitgestellten Images sind nach allgemein akzeptierten Branchenstandards gehärtet.

Zusatzkriterium (Verschärfend)

–

Zusatzkriterium (Erweiternd)

PSS-11.01AC

Der Cloud-Anbieter prüft beim Start die Integrität und Authentizität von virtuellen Maschinen oder Container-Images und informiert den Cloud-Kunden entsprechend über die Ergebnisse dieser Prüfungen.

PSS-11.02AC

Während der Laufzeit schützt der Cloud-Anbieter die virtuellen Maschinen oder Container-Images vor Manipulation und informiert den Cloud-Kunden entsprechend über den Status während der Laufzeit.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: PSS-11.01B

Dieses Kriterium ist für das Servicemodell SaaS typischerweise nicht anwendbar.

Allgemein akzeptierte Branchenstandards sind z. B. der Security Configuration Benchmark des Center for Internet Security (CIS) oder die entsprechenden Bausteine im BSI IT-Grundschutz-Kompendium.

Anwendbar auf: PSS-11.01AC

Typische Maßnahmen zur Prüfung von virtuellen Maschinen oder Container-Images hinsichtlich Integrität und Authentizität umfassen den Einsatz kryptographischer Signaturen.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass die Images virtueller Maschinen oder Container, die sie mit dem Cloud-Dienst betreiben, ihren Anforderungen an das Informationssicherheitsmanagement entsprechen und dass die Ergebnisse der Integritätsprüfungen beim Start und während der Laufzeit gemäß diesen Anforderungen verarbeitet werden.

PSS-12 Region der Datenverarbeitung und -speicherung

Basiskriterien

PSS-12.01B

Die Architektur des Cloud-Dienstes, einschließlich der technischen Ausgestaltung seiner Infrastruktur, stellt sicher, dass Cloud-Kundendaten und etwaige Datensicherungen davon nur in der in den vertraglichen Vereinbarungen mit dem Cloud-Anbieter festgelegten Region verarbeitet und gespeichert werden. Falls der Cloud-Kunde aus mehreren Regionen auswählen kann, ist die Verarbeitung und Speicherung der vorgenannten Daten auf die ausgewählten Regionen beschränkt.

PSS-12.02B

Die Verarbeitung und Speicherung von Cloud-Kundendaten innerhalb der Service-Organisationen des Cloud-Anbieters hält sich ebenfalls an die vom Cloud-Kunden ausgewählten Regionen.

PSS-12.03B

Die vertraglichen Vereinbarungen legen die Regionen fest, in denen die Verarbeitung und Speicherung von Cloud-Kundendaten, abgeleiteten Cloud-Dienstdaten und Kontodaten erfolgt, sowie die Umstände, unter denen Änderungen vorgenommen werden können.

PSS-12.04B

Cloud-Kunden werden im Voraus über Änderungen der Regionen informiert, in denen die vorgenannten Daten verarbeitet oder gespeichert werden. Falls dem Cloud-Anbieter hierfür keine vorherige allgemeine Autorisierung durch den Cloud-Kunden erteilt wurde, werden solche Berechtigungen gemäß den in den

vertraglichen Vereinbarungen festgelegten Anforderungen eingeholt oder dem Cloud-Kunden die Ausübung von Kündigungsrechten ermöglicht.

Zusatzkriterium (Verschärfend)

PSS-12.01AS, verschärft PSS-12.01B

Die Architektur des Cloud-Dienstes, einschließlich der technischen Ausgestaltung seiner Infrastruktur, stellt sicher, dass die Cloud-Kundendaten, abgeleiteten Cloud-Dienstdaten und etwaige Datensicherungen davon nur in der in den vertraglichen Vereinbarungen mit dem Cloud-Anbieter festgelegten Region verarbeitet und gespeichert werden. Falls der Cloud-Kunde aus mehreren Regionen auswählen kann, ist die Verarbeitung und Speicherung der vorgenannten Daten auf die ausgewählten Regionen beschränkt.

PSS-12.02AS, verschärft PSS-12.02B

Die Verarbeitung und Speicherung von Cloud-Kundendaten und abgeleiteten Cloud-Dienstdaten innerhalb der Service-Organisationen des Cloud-Anbieters hält sich ebenfalls an die vom Cloud-Kunden ausgewählten Regionen.

Zusatzkriterium (Erweiternd)

PSS-12.01AC

Der Cloud-Anbieter bietet vom Cloud-Kunden auswählbare Partitionen an, in denen partitionsspezifisches Identitätsmanagement sowohl für Cloud-Kunden als auch für sämtliches Personal des Cloud-Anbieters erzwungen wird. Identitätsprüfung und Identitätsspeicherung sind auf die geografischen Grenzen der ausgewählten Partition beschränkt.

PSS-12.02AC

Innerhalb dieser Partitionen sind die folgenden Operationen des Cloud-Anbieters darauf beschränkt, nur innerhalb der geografischen Grenzen der vom Cloud-Kunden ausgewählten Partitionen stattzufinden:

1. Privilegierter Zugang zur Produktionsumgebung durch den Cloud-Anbieter, einschließlich potenziellen Zugriffs auf Cloud-Kundendaten und abgeleitete Cloud-Dienstdaten;
2. Systemprotokollierung und Ereignisüberwachung durch den Cloud-Anbieter, ausgenommen die Verarbeitung von Ereignisprotokollen speziell für Threat Intelligence und die Verarbeitung von IP-Adressen zu Routing-Zwecken; und
3. Verfahren zur Verwaltung und Speicherung kryptographischer Schlüssel, um sicherzustellen, dass Schlüssel innerhalb der Grenzen der Partition gehandhabt und gespeichert werden.

Diese Beschränkungen unter Berücksichtigung von Partitionen gelten auch für alle Service-Organisationen, die am Betrieb des Cloud-Dienstes beteiligt sind.

Ergänzende Informationen

Zum Kriterium

Anwendbar auf: PSS-12.03B

Dieses Kriterium bezieht sich auf die Architektur des Cloud-Dienstes und legt der vom Cloud-Kunden entworfenen Architektur keine Beschränkungen auf.

Wenn ein Cloud-Anbieter mehrere Regionen anbietet, die denselben Dienst bereitstellen, steht es dem Cloud-Kunden frei, den Dienst in unterschiedlichen Regionen zu nutzen (z. B. für mehr Resilienz).

Dieses Unterkriterium bezieht sich auf vertragliche Vereinbarungen, die die Zusage einschließen, dass Cloud-Kundendaten, abgeleitete Cloud-Dienstdaten, Cloud-Anbieterdaten und Kontodaten in der gewählten Region verbleiben. Es behandelt auch, wie vertragliche Vereinbarungen aktualisiert werden, und stellt eine transparente Kommunikation sowie den fortgesetzten Verbleib aller vier Datentypen in der/den vereinbarten Region(en) sicher.

Anwendbar auf: PSS-12.01B, PSS-12.02B, PSS-12.03B, PSS-12.04B, PSS-12.01AS, PSS-12.01AC, PSS-12.02AC

Dieses Kriterium ergänzt die Allgemeine Bedingung GC-01. Es verlangt nicht, dass der Cloud-Anbieter mehrere Regionen oder Partitionen anbietet. Falls der Cloud-Anbieter nur eine Partition für den/die im Geltungsbereich befindlichen Cloud-Dienst(e) anbietet, stellt dies keine Abweichung vom Kriterium dar.

Falls das Zusatz-Unterkriterium nur für ausgewählte Partitionen im Geltungsbereich eines Attestierungsauftrags gemäß diesem Katalog anwendbar ist, sollte dies in der Beschreibung seines internen Kontrollsystems für den Cloud-Dienst durch den Cloud-Anbieter dargestellt werden.

Dieses Kriterium ist eine Voraussetzung für technische Dienst-Souveränität.

Die Überwachung von Threat Intelligence Daten, die keine Cloud-Kundendaten und keine Kontodaten umfassen, sowie die Protokollierung erforderlicher Routing-Informationen wie IP-Adressen müssen nicht geografisch auf eine einzelne Partition beschränkt sein.

Korrespondierende Kriterien für Kunden

Cloud-Kunden stellen mit geeigneten Kontrollen sicher, dass sie bei der Auswahl von Cloud-Anbietern und der Konfiguration des Cloud-Dienstes über die verfügbaren Partitionen für Datenverarbeitung und -speicherung informiert sind und, falls eine Wahl zwischen verschiedenen Partitionen besteht, diejenigen auswählen, die ihren eigenen Anforderungen entsprechen.

Je nach Anwendungsfall und insbesondere bei der Nutzung von Diensten eines Cloud-Anbieters, der in einem anderen Land ansässig ist, berücksichtigen Cloud-Kunden bei ihrer Auswahl die für sie geltenden Gesetze ihrer eigenen Jurisdiktion (z. B. bei der Verarbeitung personenbezogener Daten; Einhaltung gesetzlicher Aufbewahrungspflichten für Geschäftsunterlagen usw.).